

Ciberseguridad

Repaso y estudio con conceptos mapas y casos

Este libro desarrolla 60 indicadores de la especialidad mediante conceptos, mapas y 300 casos explicados. Su propósito es relacionar decisiones, comprender situaciones y aplicar el conocimiento al resolver preguntas de práctica.

Cómo trabajar el libro

Lea las explicaciones, explique las relaciones del mapa con sus propias palabras y resuelva cada caso antes de consultar su respuesta. Utilice las variantes para comprobar cuándo cambia la decisión. Vuelva a los conceptos que necesite reforzar después de cada práctica.

Los casos son material didáctico original. Conserve como referencia la tabla oficial correspondiente y las orientaciones de su docente.

Contenido del libro

01 Uso ético y legal de los datos	5
02 Internet de las cosas e internet de todo	8
03 Impacto de una violación de seguridad	11
04 Mantenimiento seguro de los datos	14
05 Tipos de malware y código malicioso	17
06 Identidad y control de acceso	20
07 Estructuras funciones clases y objetos	23
08 Sistema de gestión de seguridad de la información	26
09 Lectura de código y flujo de datos	29
10 Errores excepciones y ejecución controlada	32
11 Automatización robotizada	35
12 Sistemas operativos y entornos de trabajo	38
13 Compatibilidad y virtualización de sistemas	41
14 Riesgos en el ciclo de vida del software	44

15 Capas de protección del software	47
16 Características y modelos de implementación de nube	50
17 Servicios IaaS PaaS y SaaS	53
18 Ciclo de vida y cifrado de datos en nube	56
19 Diseño seguro de aplicaciones web y móviles	59
20 Ley de Murphy y vulnerabilidades web	62
21 Riesgos de red móviles datos y servidores	65
22 Inteligencia de negocios minería de datos y data mart	68
23 Integridad y vulnerabilidades de bases de datos	71
24 Contraseñas defensa activa y contingencia	74
25 Criptografía y protección de equipos	77
26 Administración segura de sistemas de código abierto	80
27 Acceso y registros en un SIEM	83
28 Automatización auditoría y análisis forense	86
29 Recursos virtuales portátiles y nube	88
30 Características y calidad de una red	91
31 Componentes de redes LAN y WAN	94
32 Protocolos estándares y comunicación	97
33 Modelos OSI y TCP IP	100
34 Capa física y enlace de datos	103
35 Tablas MAC y resolución de direcciones	106
36 Direcciones IPv4 e IPv6	109
37 Transporte con TCP y UDP	112

38 Hackeo ético y evaluación autorizada	115
39 Energía sostenibilidad y disposiciones nacionales	118
40 Configuración básica de dispositivos de red	121
41 Conceptos de conmutación	124
42 VLAN y diagnóstico de switches de capa 3	127
43 Protocolo de árboles de expansión	130
44 DHCPv4	133
45 DHCPv6 SLAAC y anuncios de router	136
46 Controles de seguridad en LAN	139
47 Redes inalámbricas	142
48 Protocolos y servicios de red	144
49 Vulnerabilidades de servicios y bases de datos	148
50 Cifrado y monitoreo de seguridad	151
51 Hardware y firmware de dispositivos IoT	153
52 Funciones del analista y operación del SOC	156
53 Arquitecturas y marcos de seguridad	159
54 Herramientas para construir modelos de negocio	163
55 Atención y servicio al cliente	166
56 Formalización del emprendimiento en Costa Rica	169
57 Herramientas y preservación en peritajes forenses	172
58 Clasificación funcional del software malicioso	175
59 Infección prevención y herramientas antimalware	178
60 Gobernanza clasificación y protección de datos	181

Este libro desarrolla los temas de la tabla de especificaciones de la prueba nacional de especialidades técnicas 2026. Su propósito es ayudar a comprender cómo funcionan los conceptos, por qué se relacionan y cómo utilizarlos para analizar situaciones.

Cada recorrido comienza por los fundamentos, amplía la explicación mediante ejemplos comentados y se acompaña de un mapa conceptual y cinco casos o preguntas con explicación razonada. Las relaciones entre temas permiten pasar de reconocer una palabra a explicar una decisión técnica.

Subárea	Ítems	Distribución
Tecnologías de la información	6	10 %
Programación y pruebas de la seguridad del software	17	28,33 %
Operaciones ciberseguras	30	50 %
Emprendimiento e innovación aplicada a la ciberseguridad	3	5 %
Seguridad de la información y gestión administrativa en ciberseguridad	4	6,67 %
Total	60	100 %

Organización curricular. Los 60 recorridos corresponden a los 60 indicadores de la tabla. El nivel y código se conservan para facilitar su localización. Los conceptos se desarrollan con distinta extensión según lo que requiere su comprensión; el número de páginas no representa un peso adicional en la prueba.

Material didáctico de estudio · Edición ampliada con 300 casos explicados 2026

Cómo aprender con este manual

Estudiar ciberseguridad exige conectar decisiones. Una contraseña puede autenticar a una persona sin autorizarla a leer un expediente; una copia puede existir sin ser recuperable; una conexión puede estar cifrada y transportar actividad maliciosa. El dominio del tema aparece cuando se explica la diferencia utilizando los datos del caso.

Un recorrido de lectura con propósito

Primera lectura. Ubique el indicador y lea los fundamentos. Explique cada término con una frase propia y un ejemplo. Si una definición utiliza otra palabra desconocida, consulte el índice de conceptos y vuelva al apartado.

Explicación guiada. Siga las relaciones de causa y consecuencia. En los ejemplos, deténgase antes de la conclusión e identifique qué detalle cambia la decisión. Compruebe después si su explicación atiende el mecanismo y el objetivo del caso.

Mapa conceptual. Lea cada ruta como una oración completa: concepto central, palabra de enlace y concepto relacionado. Explique por qué existe cada conexión. Los mapas representan relaciones seleccionadas; el desarrollo escrito aporta condiciones, excepciones y ejemplos.

Recuperación y transferencia. Resuelva los cinco casos de cada indicador antes de leer sus explicaciones y justifique con los conceptos estudiados. Después cambie una condición del escenario: otra cuenta, otra VLAN, un archivo cifrado o una conexión interrumpida. Explique si la respuesta se mantiene o debe cambiar.

Distribuir el esfuerzo y revisar errores

Operaciones ciberseguras reúne 30 de los 60 ítems. Programación y pruebas reúne 17; las otras tres subáreas suman 13. Distribuya el tiempo con esa referencia y añada práctica donde haya confusiones. No abandone una subárea por tener menos ítems: cada indicador conserva un lugar en la tabla.

Un error debe convertirse en una pregunta concreta: ¿confundí función, capa, alcance, secuencia o evidencia? Releer todo sin identificar la confusión suele ser menos útil que comparar dos conceptos y resolver un caso distinto. Mantenga un registro de esos pares y vuelva a explicarlos unos días después.

En selección única, evalúe cada alternativa completa. Una afirmación puede ser verdadera y no responder a lo solicitado. Distinga lo observado de lo supuesto, y no añada características de un ataque o de una herramienta que el caso no proporciona.

Alcance educativo. La tabla y los saberes del programa oficial orientan la evaluación. Este material desarrolla explicaciones para el estudio y debe utilizarse junto con el trabajo de aula y los programas correspondientes. Los ejemplos son didácticos y no constituyen un examen oficial aplicado ni una garantía de aprobación.

01 Uso ético y legal de los datos

Tecnologías de la información · Nivel 10 · Indicador 1.1 · Tabla página 3

Indicador de logro. Determina las implicaciones legales del uso incorrecto de los datos según la legislación vigente.

Propósito de aprendizaje. Relacionar una actuación sobre datos personales con su finalidad, autorización y consecuencias.

Conceptos fundamentales

Un dato personal permite identificar a una persona directa o indirectamente: nombre, teléfono o un registro asociado a su identidad. Los datos sensibles, como información de salud, requieren especial protección. Una base con códigos sigue conteniendo datos personales si existe una forma razonable de volver a vincularlos con las personas.

Tratar datos incluye recopilarlos, consultarlos, analizarlos, conservarlos, compartirlos y eliminarlos. El acceso técnico no equivale a autorización para cualquier uso. Debe existir una finalidad determinada y una base que permita el tratamiento; cuando corresponde consentimiento, este debe ser informado. También pueden existir excepciones legales, por lo que no se resuelve un caso afirmando que siempre basta o siempre falta el consentimiento.

La Ley 8968 protege a la persona frente al tratamiento de sus datos. Distinga el deber de seguridad, que exige medidas de protección, del deber de confidencialidad, que limita la

revelación o uso indebido. La transferencia a terceros necesita cumplir las condiciones aplicables. La persona titular tiene derechos respecto de sus datos, como acceso y rectificación. La PRODHAB es la autoridad especializada en esta materia. [F2]

Anonimizar busca impedir la identificación de forma efectiva; seudonimizar sustituye identificadores, pero conserva una posibilidad de vinculación. Cifrar protege la lectura, aunque no transforma automáticamente datos personales en datos anónimos ni autoriza una finalidad nueva.

Caso resuelto. Una tienda recibe teléfonos para coordinar entregas y un empleado los vende a un anunciante, sin autorización ni excepción aplicable. El problema es usar y transferir datos para otra finalidad. La existencia de una cuenta válida y un archivo cifrado no legitima la venta. Pueden existir responsabilidades administrativas u otras, según los hechos y la norma aplicable; no se presume una sanción concreta sin analizar el caso.

Por qué un dato aislado puede revelar más de lo que parece

Imagine que un registro no incluye nombres, pero indica edad, distrito, puesto y una fecha de atención. Si en ese lugar solo existe una persona con esa combinación, puede ser identificable. Por eso, al analizar privacidad no basta con buscar una columna llamada nombre. Debe considerarse qué puede deducirse al combinar registros. En grandes volúmenes de datos, esta capacidad de vincular fuentes aumenta tanto la utilidad del análisis como la posibilidad de exposición.

El valor de los datos tampoco justifica cualquier recopilación. Si una biblioteca necesita un contacto para avisar sobre un préstamo, debe explicar ese propósito y evitar solicitar información que no necesita. El principio de minimización reduce lo que se recopila; la limitación de finalidad restringe para qué se usa. Son decisiones diferentes: un formulario puede pedir pocos datos y aun así utilizarlos después de forma indebida.

Tres responsabilidades que no deben confundirse

La responsabilidad administrativa se relaciona con incumplimientos frente a una autoridad competente; la civil, con la reparación de daños cuando se cumplen los presupuestos correspondientes; la penal, con conductas definidas como delito y determinadas mediante el proceso aplicable. Un incidente no permite afirmar automáticamente que concurren las tres. Primero se identifican hechos, actuación de cada persona, obligaciones y norma aplicable. La ética profesional añade preguntas sobre necesidad, justicia y consecuencias aunque una herramienta permita técnicamente realizar la acción.

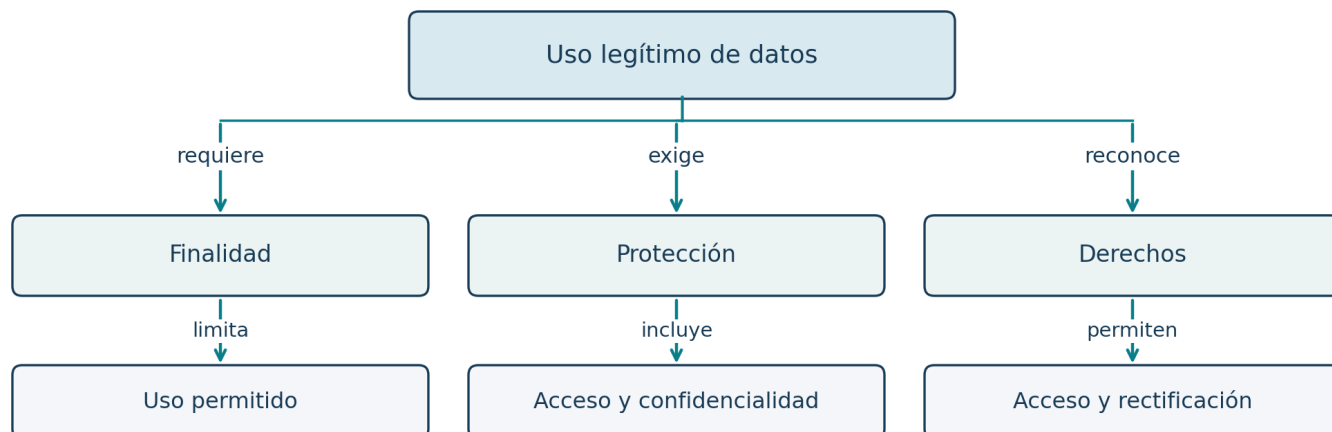
Un análisis explicado como en clase

Una clínica desea publicar estadísticas de atención. Primero separa el objetivo estadístico del expediente asistencial: publicar tendencias no exige publicar identidades. Después revisa qué combinaciones podrían identificar pacientes. Agrupa categorías cuando corresponde, limita los datos y comprueba el riesgo de vinculación. Finalmente define quién autoriza la publicación y conserva evidencia del procedimiento. El cifrado durante la transferencia protege el envío, pero no corrige una tabla pública que identifica a una persona.

Para razonar un caso nuevo. Pregunte qué dato se usa, quién lo utiliza, para qué, con qué habilitación y durante cuánto tiempo. Si la respuesta propone únicamente comprar un

antivirus, no ha atendido todavía la legitimidad del tratamiento. Una solución completa conecta decisiones organizativas con controles técnicos y derechos de las personas.

Mapa de relaciones para explicar el tema



Mapa conceptual 1 Uso legítimo de datos

Preguntas y casos del indicador 01

Aplicación del aprendizaje. Relacionar una actuación sobre datos personales con su finalidad, autorización y consecuencias.

1 Finalidad del tratamiento

Una clínica recopila teléfonos para confirmar citas y luego los utiliza en publicidad de terceros. ¿Qué debe analizarse aunque el acceso a la base estuviera autorizado?

Explicación. Deben analizarse la finalidad nueva y la habilitación para ese uso o transferencia. Poder consultar un dato por razones laborales no autoriza cualquier tratamiento. El caso se resuelve examinando propósito, información al titular y base aplicable, no únicamente la contraseña utilizada.

2 Identificación indirecta

Una publicación elimina nombres, pero conserva edad exacta, distrito y una enfermedad infrecuente. ¿Puede seguir conteniendo datos personales?

Explicación. Sí, si la combinación permite identificar razonablemente a alguien. Quitar el nombre no demuestra anonimización. Hay que valorar el conjunto y su posible vinculación con otras fuentes; sustituir nombres por códigos tampoco elimina necesariamente esa posibilidad.

3 Consentimiento informado

Un formulario solicita aceptar «cualquier uso futuro» de los datos sin explicar destinatarios ni finalidad. ¿Qué debilidad presenta?

Explicación. La aceptación no permite asumir un consentimiento informado para cualquier actividad. Deben examinarse claridad, finalidad y condiciones aplicables. Un botón marcado no reemplaza la información necesaria para comprender el tratamiento ni corrige un uso incompatible con la ley.

4 Derechos de la persona titular

Un expediente conserva una dirección equivocada y su titular solicita corregirla. ¿Qué derecho se relaciona con la petición y qué procedimiento requiere?

Explicación. Se relaciona con rectificación. La organización debe verificar identidad y gestionar la solicitud mediante el procedimiento aplicable, conservando trazabilidad. No corresponde entregar el expediente a cualquiera que afirme ser su titular ni concluir que corregir un dato autoriza borrar todos los registros.

5 Responsabilidades diferentes

Un empleado divulga expedientes sin autorización. ¿Puede afirmarse, solo con ese dato, que existe una condena penal y una indemnización determinada?

Explicación. No. Deben distinguirse responsabilidades administrativas, civiles y penales y analizar sus respectivos presupuestos. La conducta amerita investigación, pero la sanción o reparación exige hechos, norma y procedimiento. La gravedad aparente no sustituye esa determinación.

02 Internet de las cosas e internet de todo

Tecnologías de la información · Nivel 10 · Indicador 2.1 · Tabla página 3

Indicador de logro. Describe la implementación de solución de internet de todo en el entorno de trabajo.

Propósito de aprendizaje. Explicar cómo objetos, datos, personas y procesos producen una solución útil y segura.

Conceptos fundamentales

El internet de las cosas, IoT, conecta objetos físicos capaces de captar datos, comunicarse o actuar: cámaras, medidores, sensores y cerraduras. El internet de todo, IoE, integra además personas, datos y procesos para convertir esa conectividad en decisiones y servicios.

Un sensor mide una variable, como temperatura. Un actuador produce una acción, como abrir una válvula. Una pasarela o gateway conecta dispositivos o traduce comunicaciones. La plataforma recibe y procesa datos; una persona interpreta o supervisa el resultado y un proceso establece qué hacer. La conectividad puede ser cableada o inalámbrica, según distancia, energía, capacidad y entorno.

Datos son mediciones; se convierten en información útil al contextualizarlos. Registrar «8» sin indicar unidad, momento o ubicación no permite decidir si existe un riesgo. El procesamiento en el borde, edge, ocurre cerca del dispositivo y puede reducir demora y dependencia de la nube; el procesamiento central facilita agregación y análisis global.

Caso resuelto. En una cámara de refrigeración, un sensor detecta una temperatura fuera del rango permitido. La plataforma relaciona el dato con la cámara afectada; una encargada recibe la alerta y aplica el procedimiento de traslado y revisión. Los cuatro componentes de IoE están presentes. Añadir sensores sin responsables ni reglas de respuesta no completa la solución.

Protección de la solución. Inventariar equipos, cambiar credenciales predeterminadas, actualizar firmware, limitar comunicaciones y recopilar únicamente los datos necesarios. Debe contemplarse qué ocurre si la red falla o una lectura es incorrecta: una medición aislada no siempre justifica una acción irreversible.



IoT integra los cuatro componentes para producir una decisión útil

Esquema aplicado Del sensor a la actuación en una solución IoT

Del número medido a una actuación útil

Un sensor entrega una medición, pero no conoce necesariamente su significado para la organización. Un valor de temperatura requiere unidad, fecha, ubicación y rango de referencia. A ese conjunto se le agrega una regla: si una cámara supera el límite durante cierto tiempo, se genera una alerta. La regla evita tratar un dato como una decisión automática sin contexto. El sistema debe distinguir también una temperatura peligrosa de un sensor averiado.

El controlador recibe entradas y ejecuta reglas. El actuador convierte una orden en acción física. El microcontrolador integra capacidad de procesamiento, memoria e interfaces para tareas específicas; una computadora de placa única puede ejecutar un sistema operativo y aplicaciones más generales. Ninguna de estas características convierte por sí sola al dispositivo en inteligente o seguro. La capacidad debe corresponder a la tarea y sus restricciones de energía y comunicación.

Diseñar desde la necesidad del trabajo

En un invernadero, la necesidad es conservar humedad adecuada, no simplemente conectar objetos. Se eligen sensores, se comprueba dónde medir, se define cómo enviar datos y quién supervisa. El riego es la acción; la reducción de desperdicio y el bienestar del cultivo son resultados que deben medirse. Si la válvula puede quedar abierta ante una falla, se necesita una condición de cierre o supervisión apropiada. La seguridad incluye consecuencias físicas, además de confidencialidad.

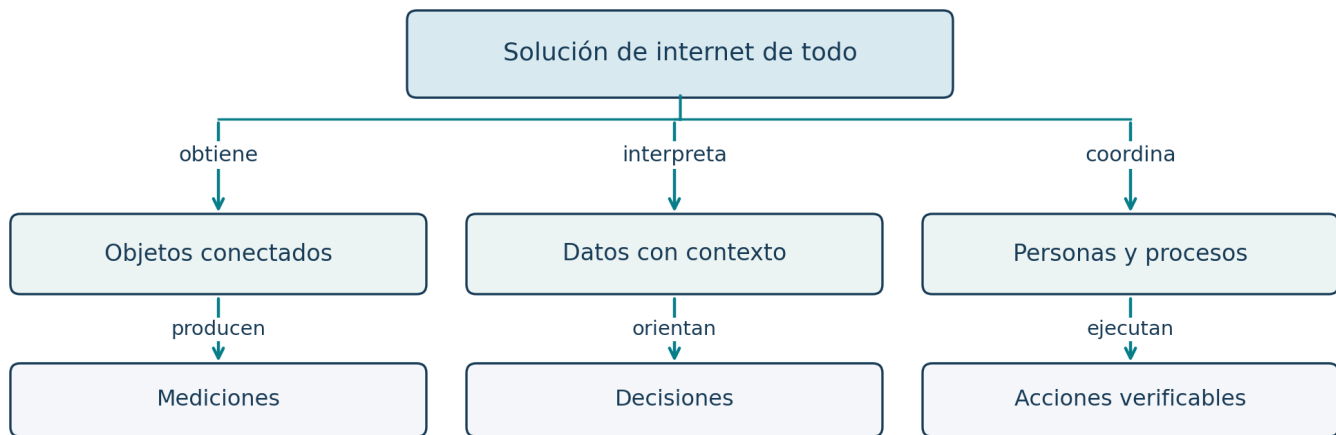
El procesamiento en el borde puede decidir localmente y seguir funcionando cuando se interrumpe Internet. La nube puede reunir históricos de varios sitios y apoyar comparaciones. Ambas ubicaciones pueden coexistir. Procesar cerca no elimina la necesidad de actualizar; procesar en nube no elimina los riesgos del sensor ni de la válvula.

Comprobar una propuesta

Una buena propuesta describe recorrido del dato, acción esperada, responsable y respuesta ante fallas. También limita permisos: el sensor no necesita acceso a los expedientes administrativos. Las credenciales deben ser propias del dispositivo o servicio y poder revocarse. Al retirar un equipo, se eliminan secretos y accesos. Esta última etapa suele olvidarse: un objeto desconectado físicamente puede dejar una cuenta activa en la plataforma.

Cambio de escenario. Si el mismo sistema se instala en una cadena de frío de medicamentos, cambian impacto, tolerancia al error y procedimientos de atención. Los componentes loE permanecen, pero el diseño debe adaptarse a la criticidad del proceso.

Mapa de relaciones para explicar el tema



Mapa conceptual 2 Solución de internet de todo

Preguntas y casos del indicador 02

Aplicación del aprendizaje. Explicar cómo objetos, datos, personas y procesos producen una solución útil y segura.

1 Identificar los componentes

En una finca, un sensor mide humedad, una plataforma interpreta el valor y una persona autoriza el riego. ¿Qué integra esta solución de internet de todo?

Explicación. Objetos conectados, datos, personas y procesos. El sensor aporta la medición; el contexto la vuelve útil; la persona y el procedimiento determinan la actuación. Contar únicamente dispositivos dejaría fuera parte de la solución que se pretende implementar.

2 Diferenciar sensor y actuador

Un invernadero registra temperatura y abre una ventana automáticamente. ¿Cuál componente observa y cuál modifica el entorno?

Explicación. El sensor mide temperatura; el actuador mueve la ventana. El controlador decide según reglas. Confundirlos impide explicar la secuencia: una medición no abre físicamente la ventana y un motor no determina por sí solo cuándo debe abrirse.

3 Convertir datos en información

Una pantalla muestra «38» sin unidad, hora ni ubicación. ¿Por qué resulta insuficiente para decidir si existe una emergencia?

Explicación. El número carece de contexto. Puede representar temperatura, porcentaje u otra variable. La unidad, el momento, el origen y el rango esperado permiten interpretarlo. Acumular más valores sin esos datos no resuelve la ambigüedad.

4 Procesamiento en el borde

Un sistema de refrigeración debe actuar aunque se interrumpa Internet. ¿Qué ventaja puede aportar procesar una regla cerca del sensor?

Explicación. El procesamiento en el borde puede mantener la decisión local y reducir dependencia de la conexión externa. La nube puede seguir sirviendo para análisis histórico. La elección depende de latencia, continuidad y capacidad; procesar localmente no elimina mantenimiento ni controles de seguridad.

5 Diseñar una respuesta segura

Una válvula queda abierta cuando falla la comunicación. ¿Qué aspecto debe revisarse además de la conectividad?

Explicación. Debe definirse el comportamiento ante fallas: estado seguro apropiado, límites de operación, alarma y supervisión. Recuperar la red no explica cómo evitar daño durante la interrupción. El diseño debe considerar consecuencias físicas y no solo entrega de mensajes.

03 Impacto de una violación de seguridad

Tecnologías de la información · Nivel 10 · Indicador 3.1 · Tabla página 3

Indicador de logro. Describe el impacto de la violación de seguridad.

Propósito de aprendizaje. Identificar qué activo y propiedad resultan afectados y explicar las consecuencias del incidente.

Conceptos fundamentales

La seguridad de la información protege datos en cualquier soporte. La ciberseguridad se centra en sistemas, redes y actividades del entorno digital. Un activo tiene valor: datos, servicios, equipos, credenciales o reputación. Una amenaza puede causar daño; una vulnerabilidad es una debilidad que puede aprovecharse. El riesgo combina posibilidad e impacto en un contexto concreto.

La tríada CIA comprende confidencialidad, integridad y disponibilidad. La confidencialidad evita divulgación no autorizada; la integridad protege frente a alteraciones indebidas; la disponibilidad permite acceso oportuno a usuarios autorizados. Autenticidad se refiere a que una identidad u origen sea genuino; trazabilidad permite reconstruir acciones.

Un evento es algo observado. Un incidente compromete o amenaza la seguridad y requiere tratamiento. No toda alerta confirma un incidente: puede existir un falso positivo. Una violación o brecha puede implicar exposición, alteración o pérdida de acceso a información.

Distinga motivaciones y métodos. El cibercrimen persigue beneficios ilícitos; el espionaje obtiene información estratégica; el hacktivismo utiliza medios digitales para una causa; el ciberterrorismo busca intimidar o coaccionar mediante ataques graves. El DoS agota recursos para impedir un servicio; DDoS lo hace desde múltiples fuentes. Una amenaza interna puede ser intencional o accidental.



Esquema aplicado Propiedades de seguridad y consecuencias diferentes

Caso resuelto. Se extraen expedientes, se cambian diagnósticos y se bloquea la aplicación. Hay afectación de las tres propiedades. Las consecuencias incluyen interrupción del trabajo, decisiones equivocadas, costos de recuperación y daño a personas y confianza. No debe elegirse una sola propiedad si el caso describe varias.

Construir la relación entre amenaza y consecuencia

Piense en una computadora con expedientes sin respaldo. La computadora es un activo, pero también lo son los expedientes y el servicio que depende de ellos. Un incendio es una amenaza; conservar la única copia en ese lugar es una debilidad del diseño de protección. La pérdida del archivo es un efecto inmediato; suspender atención o repetir procedimientos son consecuencias para las personas y la organización.

Una amenaza no siempre es una persona atacante. Fallos eléctricos, errores humanos y fenómenos naturales también pueden comprometer la información. Cuando existe una persona adversaria, sus motivos pueden ser económicos, políticos, ideológicos o de espionaje. Identificar un motivo no demuestra quién actuó: atribuir exige evidencia. La gravedad tampoco depende únicamente de cuántos dispositivos resultaron afectados; un solo servidor puede sostener un servicio esencial.

Analizar sin mezclar propiedades

Si alguien consulta una nota sin permiso, se afecta confidencialidad aunque no cambie nada. Si sustituye la nota por otra, se afecta integridad. Si el sistema impide consultarla cuando se necesita, se afecta disponibilidad. Puede haber las tres afectaciones en un mismo incidente. Un respaldo ayuda a reconstruir información, pero no hace que las copias robadas desaparezcan; por eso no resuelve por sí mismo una filtración.

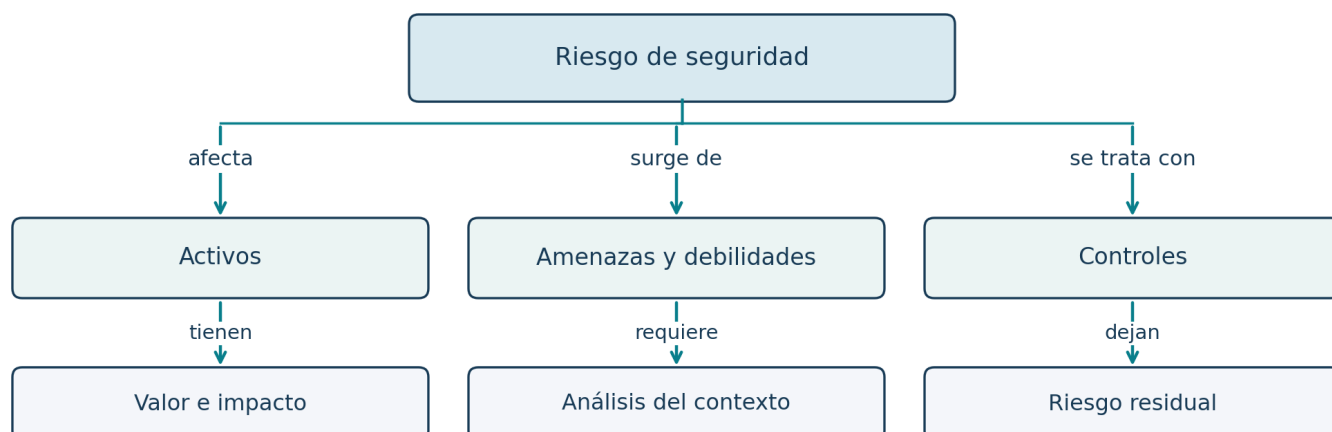
La autenticidad permite valorar si la identidad u origen declarado corresponde al esperado. La trazabilidad registra el recorrido de acciones. La responsabilidad exige asociar decisiones con funciones y obligaciones. Un registro de actividad útil necesita identidades individuales; una cuenta compartida dificulta determinar quién ejecutó una operación.

Un ejemplo de priorización

Una escuela detecta dos problemas: una impresora sin actualizar y acceso público a expedientes. No basta comparar el nombre de las fallas. Debe revisar exposición, datos afectados, posibilidad de abuso y consecuencias. Restringir la publicación indebida puede ser una prioridad inmediata, mientras se organiza el parcheo. Esto no convierte la impresora en irrelevante: podría ofrecer otra vía de acceso.

Cómo justificar. Explique la cadena completa: existe una debilidad, una amenaza puede aprovecharla, cierto activo queda afectado y una consecuencia concreta justifica el control. Evite respuestas que solo enumeran nombres de ataques sin describir qué cambia en el escenario.

Mapa de relaciones para explicar el tema



Mapa conceptual 3 Riesgo de seguridad

Preguntas y casos del indicador 03

Aplicación del aprendizaje. Identificar qué activo y propiedad resultan afectados y explicar las consecuencias del incidente.

1 Confidencialidad sin modificación

Una persona lee salarios sin permiso, pero no cambia archivos. ¿Qué propiedad se compromete principalmente?

Explicación. La confidencialidad, porque ocurrió divulgación o acceso indebido. La integridad no requiere suponerse afectada si no hay cambios. Una respuesta debe utilizar la evidencia del caso: que los datos sigan iguales no significa que no haya incidente.

2 Integridad de una decisión

Se cambia una cuenta bancaria en una factura antes de que tesorería la procese. ¿Por qué el impacto supera la modificación de un campo?

Explicación. Se altera la integridad de la información y puede inducirse un pago incorrecto. El impacto incluye consecuencias del uso del dato. Una copia previa puede ayudar a reconstruirlo, pero no revierte automáticamente un pago ya efectuado.

3 Disponibilidad y servicio

Un portal de matrícula queda inaccesible por saturación. No hay evidencia de extracción de datos. ¿Qué efecto está demostrado?

Explicación. La pérdida de disponibilidad del servicio. La saturación no demuestra por sí sola robo de información. Si el enunciado indica fuentes coordinadas múltiples, puede distinguirse DDoS; sin esa evidencia no corresponde inventar la distribución del ataque.

4 Amenaza vulnerabilidad y riesgo

Un servidor está en una sala con filtraciones y sin protección frente al agua. ¿Cómo se distinguen los elementos del riesgo?

Explicación. El agua que puede ingresar constituye una amenaza; la exposición sin protección es una vulnerabilidad; el servidor y su información son activos. El riesgo relaciona posibilidad y consecuencias. Enumerar estos elementos sin conectarlos no explica por qué se prioriza el problema.

5 Alerta frente a incidente confirmado

Un sistema avisa de acceso inusual, pero el usuario confirma un viaje autorizado. ¿Qué debe concluir el analista?

Explicación. La alerta necesita contexto y verificación adicional según el caso; no constituye automáticamente un incidente. Puede ser un falso positivo. Descartar todas las alertas similares sería igualmente incorrecto: debe ajustarse la interpretación con evidencia, no eliminar la observación indiscriminadamente.

04 Mantenimiento seguro de los datos

Tecnologías de la información · Nivel 10 · Indicador 4.1 · Tabla página 3

Indicador de logro. Describir los procedimientos seguros para el mantenimiento de datos.

Propósito de aprendizaje. Seleccionar procedimientos que preserven datos antes, durante y después de cambios o fallos.

Conceptos fundamentales

El mantenimiento seguro comprende organización, actualización, validación, respaldo, restauración, conservación y eliminación. Antes de un cambio deben identificarse los datos afectados, responsables, dependencias y permisos; luego se realiza una copia adecuada y se prepara un procedimiento de reversión.

Un respaldo es una copia recuperable. La restauración devuelve datos o servicios desde esa copia. Una tarea que informa «completada» no demuestra que los archivos puedan abrirse ni que la aplicación funcione. La verificación debe comprobar integridad, consistencia, claves disponibles y capacidad real de recuperación.

Tipo de copia	Qué contiene	Qué se necesita para restaurar
Completa	Todos los datos incluidos en el alcance.	La copia completa correspondiente.
Incremental	Cambios desde la copia anterior de la cadena.	La completa y todos los incrementales necesarios.
Diferencial	Cambios desde la última copia completa.	La completa y el diferencial elegido.

Una copia sincronizada puede replicar también un borrado o cifrado malicioso. RAID aporta tolerancia a ciertos fallos de discos, pero no sustituye respaldos separados. Una instantánea captura un estado y puede ayudar a revertir, aunque puede depender del mismo almacenamiento.

Retención es el tiempo durante el cual se conservan datos; no significa guardar todo indefinidamente. Antes de reutilizar un medio se aplica sanitización, mediante un procedimiento apropiado que haga inviable recuperar la información protegida. Borrar un archivo o formatear rápidamente no garantiza ese resultado. La elección depende del medio y sensibilidad.

Caso resuelto. Una actualización daña una base de datos. El equipo dispone de una copia restaurada en prueba y de un plan de reversión. Puede recuperar un estado conocido y verificar operaciones. Tener diez copias que nadie puede descifrar no ofrece la misma capacidad.

Comprender las dependencias de los respaldos

Suponga que el domingo se realiza una copia completa. El lunes cambia el archivo A y el martes cambia B. Una copia incremental del lunes guarda A; la del martes guarda B si ese es el cambio desde el respaldo anterior. Para reconstruir el martes se necesita la completa y la cadena de incrementales correspondiente. Una copia diferencial del martes reúne los cambios desde la completa: A y B. Por eso necesita la completa y ese diferencial, no todos los diferenciales anteriores.

La elección depende de ventanas de copia, almacenamiento y tiempo de restauración. Ahorrar espacio durante la copia puede aumentar trabajo durante la recuperación. Además, una cadena depende de que sus componentes sean utilizables. No se trata de memorizar cuál respaldo es mejor, sino de explicar la dependencia que crea cada método.

Diferenciar recuperación y reversión

Una restauración recupera información de una copia. Una reversión devuelve un cambio a un estado anterior mediante el procedimiento disponible. Una migración de base de datos puede necesitar ambos: restaurar datos y reinstalar la versión de aplicación compatible. Recuperar solo los archivos no garantiza que el servicio funcione si faltan configuración, claves o dependencias.

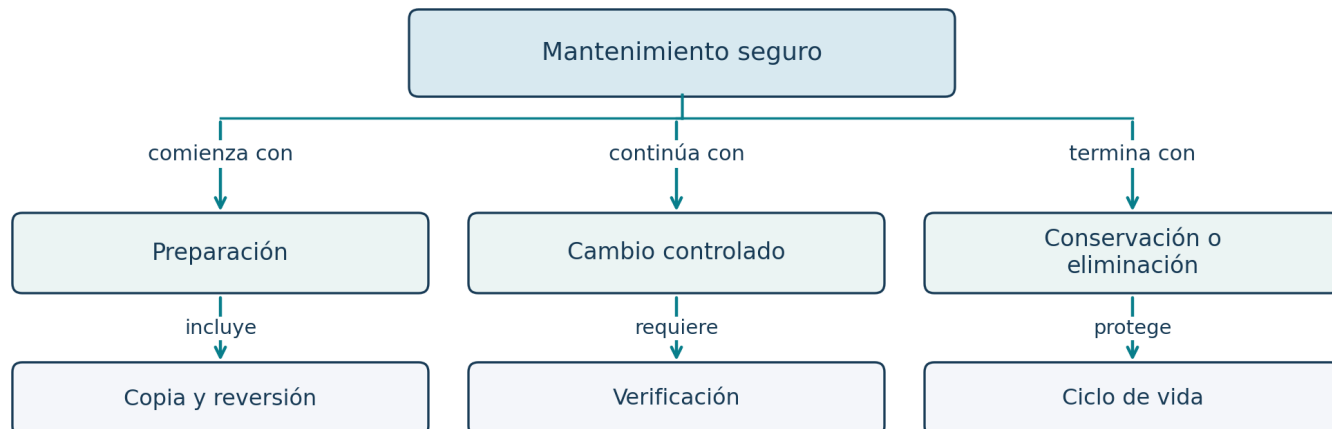
La prueba debe incluir una tarea real del servicio. En una aplicación de ventas, abrir la base sin errores es insuficiente: compruebe consulta, registro y consistencia de una operación de prueba. Esa verificación debe realizarse en un entorno que no duplique cobros ni mensajes reales.

El final del ciclo también protege

Borrar una entrada del sistema de archivos puede dejar contenido recuperable. La sanitización selecciona un método según soporte y sensibilidad: borrado lógico validado, funciones seguras del dispositivo, borrado criptográfico bajo condiciones adecuadas o destrucción física cuando corresponde. En unidades con gestión interna de bloques, sobrescribir archivos visibles no demuestra que todos los datos anteriores desaparecieron.

Caso de transferencia. Una empresa dona computadoras y solo elimina accesos directos del escritorio. Esos accesos no son los datos. Debe inventariar soportes, conservar lo requerido, aplicar sanitización y verificarla. El retiro incluye también certificados, cuentas de servicio y permisos remotos asociados al equipo. El mantenimiento seguro protege antes, durante y después del uso.

Mapa de relaciones para explicar el tema



Mapa conceptual 4 Mantenimiento seguro

Preguntas y casos del indicador 04

Aplicación del aprendizaje. Seleccionar procedimientos que preserven datos antes, durante y después de cambios o fallos.

1 Elegir una cadena de restauración

Hay copia completa del domingo e incrementales del lunes y martes. ¿Qué se necesita normalmente para reconstruir el estado del martes?

Explicación. La completa y las incrementales de la cadena hasta el martes. Cada incremental contiene cambios respecto del respaldo anterior correspondiente. Si falta la del lunes, la del martes no sustituye sus datos. Esta dependencia distingue el esquema de uno diferencial.

2 Entender el diferencial

Después de una copia completa se realizan diferenciales cada noche. ¿Se necesitan todos para recuperar el último estado respaldado?

Explicación. Normalmente se necesita la completa y el diferencial elegido, porque este reúne cambios desde la completa. No debe aplicarse la lógica de encadenar todas las incrementales. La respuesta depende del tipo de respaldo declarado, no del nombre que tenga el archivo.

3 Verificar recuperación

El programa informa que el respaldo terminó, pero nadie ha abierto una copia restaurada. ¿Qué capacidad todavía no se ha demostrado?

Explicación. No se ha demostrado recuperación utilizable. Deben comprobarse lectura, integridad, claves y funcionamiento pertinente de la aplicación. Un mensaje de ejecución exitosa acredita parte del proceso; la evidencia de restauración exige probar el resultado.

4 Reversión de un cambio

Una actualización modifica estructura de base de datos y ejecutables. ¿Basta reinstalar la versión anterior del programa si el cambio falla?

Explicación. Puede ser insuficiente porque los datos ya tienen otra estructura. El plan de reversión debe contemplar componentes y dependencias compatibles. Restaurar solo una parte puede crear nuevas inconsistencias; por eso se prepara y prueba la recuperación antes de intervenir.

5 Retiro de un medio

Se elimina una carpeta y se entrega el disco a otra organización. ¿Por qué no puede darse por demostrada la eliminación segura?

Explicación. El borrado ordinario puede dejar contenido recuperable. Se requiere sanitización apropiada al medio y sensibilidad, con verificación. Sobrescribir archivos visibles tampoco garantiza cubrir todas las áreas de dispositivos que administran internamente sus bloques.

05 Tipos de malware y código malicioso

Tecnologías de la información · Nivel 10 · Indicador 5.1 · Tabla página 3

Indicador de logro. Diferencia los tipos de malware y código malicioso.

Propósito de aprendizaje. Clasificar una amenaza a partir de su propagación, comportamiento y propósito.

Conceptos fundamentales

Malware es software o código destinado a realizar acciones maliciosas. Una categoría puede describir cómo entra, cómo se propaga o qué hace. Por eso un mismo incidente puede involucrar un troyano que instala ransomware; no son descripciones necesariamente excluyentes.

Tipo	Rasgo que lo distingue	Señal que orienta la clasificación
Virus	Infecta archivos o componentes anfitriones.	Se activa al ejecutar o abrir el contenido infectado.
Gusano	Se propaga entre sistemas por sí mismo.	Aprovecha conectividad o vulnerabilidades para extenderse.
Troyano	Se presenta como algo legítimo para engañar.	La persona ejecuta una utilidad aparentemente confiable.
Ransomware	Bloquea o cifra y exige un rescate.	Extorsión asociada a la pérdida de acceso o divulgación.
Spyware	Recopila información de forma encubierta.	Vigilancia y extracción de datos del usuario.
Adware malicioso	Muestra publicidad abusiva o no consentida.	Cambios y anuncios impuestos por el programa.

Un keylogger registra pulsaciones; un RAT permite control remoto malicioso; un rootkit oculta actividad o mantiene acceso mediante componentes del sistema; una bomba lógica se activa al cumplirse una condición. Una botnet es un conjunto de dispositivos comprometidos controlados de manera coordinada. El cryptojacking utiliza recursos ajenos para minería sin autorización.

Caso resuelto. Un supuesto visor de documentos instala código que cifra archivos. Si se pregunta por el engaño de distribución, corresponde troyano; si se pregunta por el efecto extorsivo, ransomware. Lea qué característica solicita clasificar el enunciado.

Error frecuente. La extensión o el icono no prueban que un archivo sea seguro. Tampoco la ausencia de una firma conocida en el antivirus garantiza inocuidad. Una herramienta de administración legítima puede ser abusada sin cambiar de nombre.

Clasificar observaciones y no apariencias

Imagine un programa que se ofrece como visor de documentos, instala una puerta trasera y cifra archivos. Su presentación engañosa permite hablar de troyano; el cifrado con exigencia de pago corresponde a ransomware; la puerta trasera describe otra función. No hay contradicción: las etiquetas responden a preguntas distintas. En una selección única, el enunciado debe indicar qué comportamiento desea identificar.

Un virus necesita un elemento anfitrión que infecta; puede activarse cuando se ejecuta o abre contenido compatible. Un gusano tiene capacidad de propagarse entre sistemas sin esa asociación con un archivo anfitrión. Esto no significa que todo gusano use el mismo servicio o que todo virus llegue por correo. El medio por el que llega y la forma en que se replica son dimensiones diferentes.

Reconocer amenazas que no cifran

El spyware recopila información de forma indebida. Un keylogger se concentra en pulsaciones, pero no es la única forma de obtener credenciales: también pueden robarse cookies o tokens. El adware muestra publicidad; se considera malicioso cuando su instalación o comportamiento es abusivo, engañoso o no autorizado. El rogueware simula ser una herramienta de seguridad y presiona para pagar o instalar componentes mediante alertas falsas.

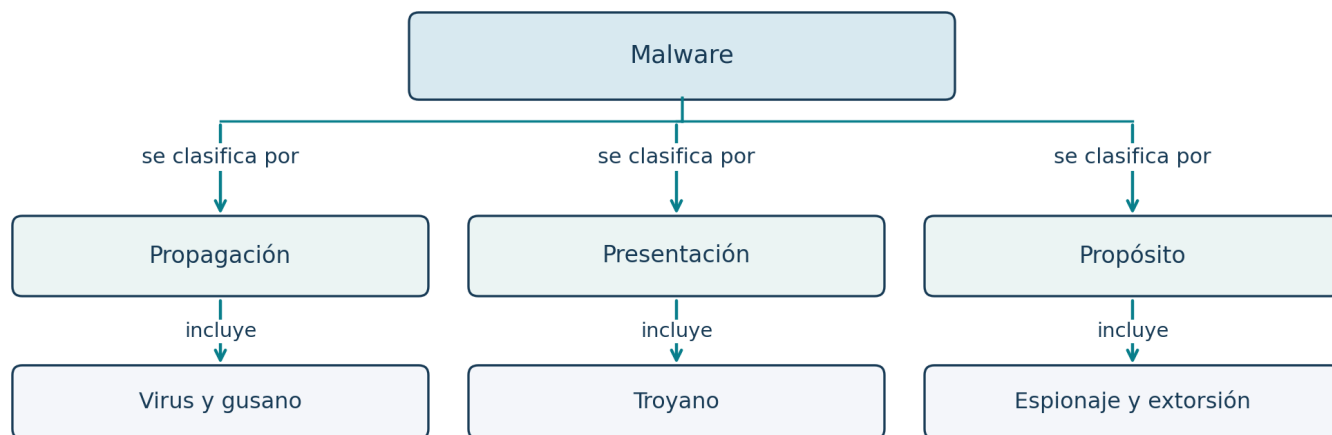
El crimeware agrupa software orientado a facilitar actividades delictivas; es una categoría por finalidad, no un único mecanismo. El malware de arranque afecta componentes que intervienen al iniciar el sistema. Un dialer malicioso altera o utiliza marcación telefónica para generar conexiones o cargos no autorizados, asociado especialmente con entornos de módem. Reconocer un término histórico no obliga a considerarlo la amenaza más frecuente hoy.

Por qué una defensa necesita varias capas

La formación reduce ciertos engaños; las actualizaciones corrigen fallas conocidas; el control de aplicaciones limita ejecuciones; la segmentación reduce desplazamientos; el monitoreo aporta detección. Los respaldos permiten recuperar ciertos daños. Cada medida corta una parte diferente del recorrido. Un antivirus puede no reconocer una variante nueva, y una firma válida tampoco garantiza que un programa sea invulnerable.

Ejercicio mental. Si solo se sabe que un archivo cifra datos, no puede inferirse que se propaga como gusano. La respuesta debe respetar la evidencia disponible. Añadir características que el caso no presenta puede llevar a una clasificación incorrecta.

Mapa de relaciones para explicar el tema



Mapa conceptual 5 Malware

Preguntas y casos del indicador 05

Aplicación del aprendizaje. Clasificar una amenaza a partir de su propagación, comportamiento y propósito.

1 Propagación autónoma

Un código se replica entre equipos sin adherirse a un archivo anfitrión. ¿Qué categoría describe principalmente ese rasgo?

Explicación. Un gusano. El criterio es la propagación autónoma entre sistemas. No basta llamarlo troyano porque llegó por Internet; troyano describe presentación engañosa. Las categorías deben elegirse según la característica preguntada, aunque puedan coexistir en una infección.

2 Apariencia de programa legítimo

Una supuesta herramienta de edición instala actividad maliciosa cuando se ejecuta. ¿Qué permite clasificar su presentación como troyano?

Explicación. El engaño al presentarse como una utilidad legítima. La descripción no prueba que se replique como virus ni que cifre archivos. Para clasificar efectos adicionales se necesitan datos sobre su comportamiento posterior.

3 Extorsión y acceso

Un programa cifra documentos y exige dinero para recuperar acceso. ¿Cuál es la categoría y qué propiedad se afecta directamente?

Explicación. Corresponde a ransomware y afecta disponibilidad de esos documentos. Si además se acredita extracción, también hay afectación de confidencialidad. No debe inferirse automáticamente esa extracción solo porque existe una exigencia de pago.

4 Espionaje de entradas

Una aplicación registra las teclas pulsadas y envía el contenido a un tercero. ¿Qué función específica se identifica?

Explicación. La función de keylogger, asociada al espionaje de entradas. Puede capturar credenciales y otros datos. No es sinónimo de todo spyware: este abarca formas más amplias de recopilación encubierta, como seguimiento de actividad o extracción de información.

5 Publicidad frente a falsa protección

Un programa inventa infecciones y exige comprar una reparación. ¿Qué lo distingue de una aplicación que solo muestra anuncios?

Explicación. El engaño mediante falsa protección corresponde a rogware. El adware se relaciona con publicidad, que puede ser abusiva. Aquí la señal decisiva es simular un diagnóstico para presionar el pago, no simplemente mostrar una ventana emergente.

06 Identidad y control de acceso

Tecnologías de la información · Nivel 10 · Indicador 6.1 · Tabla página 3

Indicador de logro. Describe las técnicas de control de acceso a la confidencialidad.

Propósito de aprendizaje. Distinguir identificación, autenticación, autorización y auditoría al proteger información confidencial.

Conceptos fundamentales

La identificación declara quién se pretende ser, por ejemplo mediante un usuario. La autenticación comprueba esa identidad con una prueba. La autorización determina qué acciones puede realizar sobre cada recurso. La auditoría registra lo ocurrido para revisión y atribución. AAA reúne autenticación, autorización y contabilidad o registro de actividad.

Los factores de autenticación pueden ser conocimiento, posesión o inherencia: una contraseña, un dispositivo y una característica biométrica, respectivamente. MFA combina categorías diferentes. Dos contraseñas o contraseña más pregunta secreta siguen siendo conocimiento. La biometría no es infalible y requiere tratamiento apropiado de sus datos.

Modelo	Cómo decide el permiso	Ejemplo
DAC	El propietario administra permisos.	Comparte un archivo con usuarios determinados.
MAC	Una política central usa etiquetas y autorizaciones.	Información clasificada y nivel de habilitación.
RBAC	Los permisos se asocian a funciones o roles.	Contabilidad consulta documentos financieros.
ABAC	Evalúa atributos del sujeto, recurso y contexto.	Rol, sensibilidad, horario y dispositivo autorizado.

Una ACL enumera permisos o restricciones; no constituye por sí sola un modelo único. El mínimo privilegio concede únicamente lo necesario. La separación de funciones distribuye tareas incompatibles; por ejemplo, quien crea un pago no necesariamente lo aprueba. El ciclo de cuentas incluye alta, cambio de funciones y baja.

Caso resuelto. Un usuario ingresa con su clave y cambia el identificador de una URL para leer un expediente ajeno. La autenticación funcionó, pero falta autorización sobre ese recurso. Ocultar el enlace no corrige la comprobación que debe realizar el servidor.

Seguir una solicitud desde la identidad hasta el recurso

Una persona escribe su usuario: todavía solo declara quién es. Después demuestra control de una credencial. El sistema crea una sesión y la persona solicita abrir un expediente. En ese punto aparece otra pregunta: ¿esa identidad puede realizar esa acción sobre ese expediente? Comprobar una contraseña no responde la segunda pregunta. La autorización debe aplicarse sobre el recurso y la operación, incluso si el botón no aparece en pantalla.

Una sesión puede representarse mediante un identificador que el navegador conserva. Si una tercera persona obtiene un token válido, podría utilizarlo sin volver a escribir la contraseña, según el sistema. De ahí la importancia de vencimiento, revocación, protección del transporte y almacenamiento adecuado. Cerrar una pestaña no equivale necesariamente a invalidar la sesión del servidor.

Elegir un modelo de permisos

En DAC, el propietario dispone de facultades para conceder acceso según la política. En MAC, una política central relaciona etiquetas y autorizaciones; aquí MAC significa control de acceso obligatorio, no dirección de red. RBAC agrupa permisos por roles: docente, auxiliar o administrador. ABAC evalúa atributos, por ejemplo rol, sede, horario, recurso y dispositivo. Los modelos pueden combinarse en una implementación.

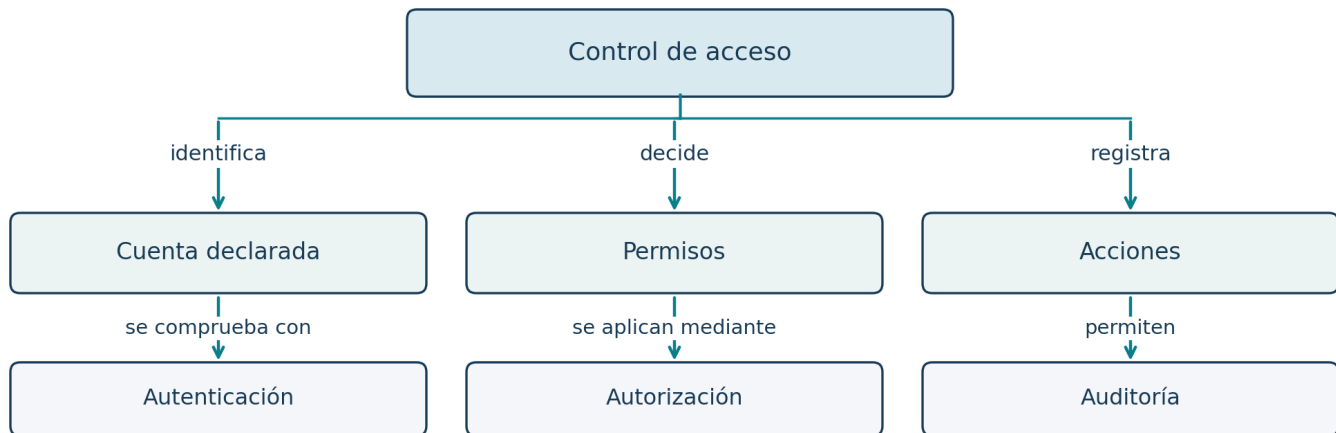
Una lista de control de acceso, ACL, expresa reglas sobre sujetos y acciones o comunicaciones. No es necesariamente un modelo completo de gobierno de identidades. Por su parte, el mínimo privilegio indica cuánto acceso conceder; la separación de funciones indica qué combinaciones deben evitarse. Una persona puede necesitar registrar un pago sin tener permiso para aprobar su propia devolución.

Aplicar el ciclo de vida de una cuenta

El alta requiere autorización y rol inicial. Un cambio de puesto exige revisar permisos anteriores y nuevos. La baja requiere desactivar acceso y tratar sesiones, tokens y otros mecanismos vinculados. Las cuentas de aplicaciones también necesitan responsables y revisión. Dejar una cuenta técnica activa porque nadie recuerda quién la usa crea una dependencia peligrosa.

Caso comentado. Un auxiliar pasa a otra sede y conserva acceso a todos los expedientes. Cambiar su contraseña no ajusta el alcance. Deben revisarse atributos o roles y comprobar solicitudes reales permitidas y denegadas. La prueba del control debe verificar ambas: poder trabajar y no acceder a lo que queda fuera de sus funciones.

Mapa de relaciones para explicar el tema



Mapa conceptual 6 Control de acceso

Preguntas y casos del indicador 06

Aplicación del aprendizaje. Distinguir identificación, autenticación, autorización y auditoría al proteger información confidencial.

1 Autenticar no autoriza todo

Una estudiante inicia sesión correctamente y cambia un identificador para leer la nota ajena. ¿Qué verificación falta?

Explicación. Falta autorización sobre el recurso solicitado. La identidad ya se comprobó, pero debe validarse permiso en cada acceso. Ocultar el enlace en la interfaz no resuelve la falla si el servidor sigue atendiendo solicitudes indebidas.

2 Reconocer factores distintos

Un sistema solicita contraseña y pregunta secreta. ¿Constituye necesariamente autenticación multifactor?

Explicación. No: ambos mecanismos son del factor conocimiento. MFA combina categorías diferentes, como conocimiento y posesión. Tener dos pasos no demuestra dos factores. Además, el diseño debe proteger recuperación y sesiones para no debilitar la verificación.

3 Seleccionar un modelo de acceso

Los permisos de consulta se asignan a «docente», «orientación» y «administración». ¿Qué modelo predomina y qué cambiaría con restricciones por horario y dispositivo?

Explicación. Predomina RBAC, basado en roles. Si la decisión evalúa atributos de usuario, recurso y contexto, se incorpora una lógica ABAC. Los modelos pueden combinarse; una lista de nombres de usuarios no demuestra por sí sola gestión por atributos.

4 Separar funciones

La misma persona crea un pago y lo aprueba sin revisión. ¿Qué principio busca reducir ese riesgo?

Explicación. La separación de funciones distribuye tareas incompatibles entre responsables. El mínimo privilegio limita lo que cada uno necesita. Cambiar contraseñas fortalece otro aspecto, pero no elimina la concentración de facultades descrita.

5 Dar de baja una identidad

Se elimina una contraseña, pero quedan sesiones y tokens activos de la cuenta. ¿Terminó necesariamente el acceso?

Explicación. No. La baja debe considerar sesiones, tokens, credenciales vinculadas y permisos según el sistema. El punto evaluado es el ciclo de vida completo de la identidad. Borrar una entrada del formulario no demuestra revocación de todos los medios de acceso.

07 Estructuras funciones clases y objetos

Programación y pruebas de la seguridad del software · Nivel 10 · Indicador 1.1 · Tabla página 4

Indicador de logro. Distingue estructuras de programación para el uso de funciones, clases y objetos.

Propósito de aprendizaje. Seleccionar estructuras que expresen decisiones, repeticiones y comportamiento de objetos.

Conceptos fundamentales

Un programa organiza instrucciones para transformar entradas en resultados. La secuencia ejecuta pasos en orden; la selección decide entre caminos; la repetición vuelve a ejecutar un bloque mientras se cumpla una condición o queden elementos. Estas estructuras también se utilizan dentro de funciones y métodos.

if, elif y else permiten seleccionar ramas. Con and deben cumplirse ambas condiciones; con or basta una; not niega el valor lógico. Para autorizar un retiro, «monto positivo y saldo suficiente» exige and: usar or permitiría operaciones que incumplen uno de los requisitos.

Un for recorre elementos de una secuencia o iterable. Un while repite según una condición y necesita una forma de finalizar. break termina el ciclo; continue omite el resto de la iteración actual. Un ciclo anidado está dentro de otro: su cantidad de repeticiones debe analizarse considerando ambos.

Una función agrupa una tarea y puede recibir parámetros y devolver un resultado mediante return. Los argumentos son los valores concretos suministrados al llamarla. Una variable local pertenece a su ámbito de ejecución; no se convierte automáticamente en un dato compartido por todo el programa.

La clase define estructura y comportamiento; el objeto es una instancia. Los atributos representan estado y los métodos, operaciones. En Python, self refiere a la instancia. Encapsulación organiza y controla acceso al estado; herencia permite especializar una clase; polimorfismo permite usar una interfaz común con comportamientos distintos.

Caso resuelto. La clase Cuenta tiene el método retirar. Primero valida monto y saldo mediante una condición; después actualiza el saldo. Si debe revisar veinte movimientos, puede recorrerlos con un ciclo. No debe descontar antes de comprobar las reglas.

De una regla verbal a una condición lógica

Para autorizar un retiro se exige monto positivo y saldo suficiente. La palabra *y* significa que ambas condiciones deben cumplirse. Usar *o* permitiría continuar cuando se cumple solo una. Antes de escribir código, traduzca la regla a casos: monto válido con saldo suficiente, monto válido sin saldo, monto negativo y saldo disponible. Esta tabla mental descubre errores que no aparecen al probar únicamente el caso exitoso.

Una condición simple produce verdadero o falso; una compuesta combina resultados. Los paréntesis aclaran agrupación y evitan depender de una lectura informal de precedencia. Una comparación como `saldo >= monto` pregunta por una relación; una asignación como `saldo = monto` cambia un valor. Cumplen funciones distintas aunque visualmente se parezcan.

Entender qué pertenece a una función y qué pertenece al objeto

Una función recibe parámetros, ejecuta una tarea y puede devolver un valor. En una llamada, los valores concretos se llaman argumentos. Devolver con `return` entrega el resultado a quien llamó; imprimir muestra información. Imprimir un número no equivale a devolverlo para que otra expresión lo utilice. Además, `return` termina esa ejecución de la función.

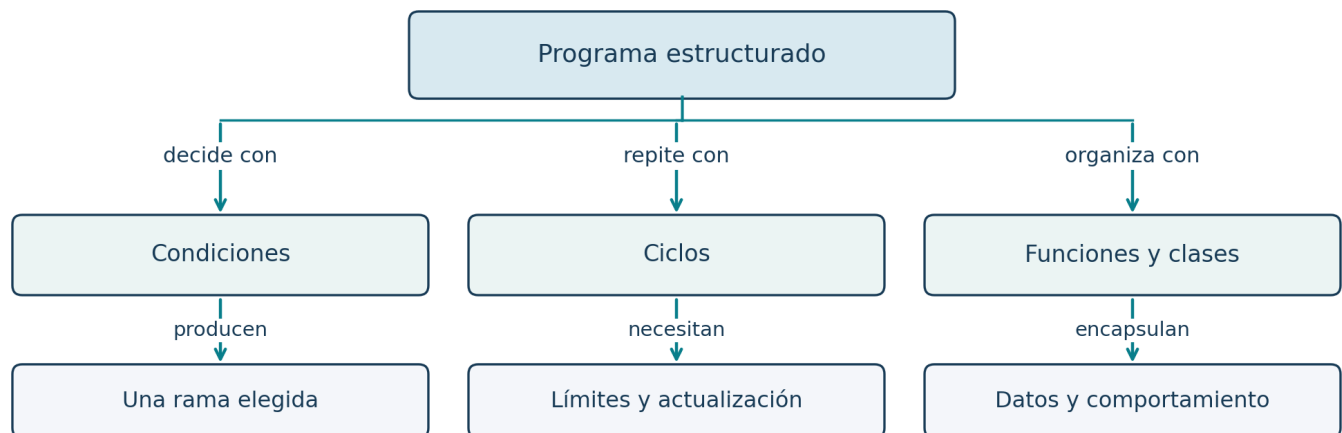
Una clase describe atributos y operaciones. Dos objetos de la clase `Cuenta` pueden tener saldos distintos. El método actúa sobre la instancia que recibe; en Python se usa habitualmente el nombre `self` para esa referencia. El método `__init__` inicializa el estado de la instancia. Una variable de clase compartida requiere especial cuidado cuando se utiliza una estructura mutable, porque no representa automáticamente un estado independiente para cada objeto.

Relacionar los principios de objetos con un problema

La encapsulación reúne estado y comportamiento y establece una interfaz para usarlos. Una cuenta ofrece retirar en lugar de exigir que cualquier parte del programa cambie libremente el saldo. La herencia permite especializar una clase; el polimorfismo permite que una misma operación tenga comportamientos apropiados en objetos distintos. Ningún principio elimina automáticamente errores de autorización o de lógica.

Ejemplo guiado. Una función revisa tres intentos con un ciclo. Si encuentra una credencial válida, termina la búsqueda. Si se usa `break`, sale del ciclo; si se usa `return` dentro de la función, termina también la función. Para interpretar el resultado, señale exactamente qué bloque abandona cada instrucción. Esa diferencia explica muchos ítems de lectura de código.

Mapa de relaciones para explicar el tema



Mapa conceptual 7 Programa estructurado

Preguntas y casos del indicador 07

Aplicación del aprendizaje. Seleccionar estructuras que expresen decisiones, repeticiones y comportamiento de objetos.

1 Traducir una condición

Un retiro requiere monto positivo y saldo suficiente. ¿Por qué utilizar OR entre ambas condiciones permitiría operaciones incorrectas?

Explicación. OR acepta que se cumpla solo una condición. Podría admitir un monto positivo sin saldo suficiente. AND exige ambas. Traducir el requisito a casos válidos e inválidos permite comprobar la lógica antes de ejecutar el programa.

2 Elegir una repetición

Se debe revisar cada elemento de una lista de diez registros. ¿Qué diferencia hay entre recorrerla con for y repetir con while?

Explicación. For recorre el iterable de forma directa; while repite mientras una condición sea verdadera y exige actualizar el estado pertinente. Ambos pueden resolver el problema. Debe explicarse cómo termina el ciclo, no elegir únicamente por la cantidad diez.

3 Parámetros y argumentos

La función calcular recibe un parámetro llamado precio y se invoca con el valor 2500. ¿Qué representa cada elemento?

Explicación. Precio es el nombre del parámetro dentro de la definición; 2500 es el argumento suministrado en esa llamada. Distinguirlos ayuda a seguir los datos. Imprimir el cálculo y devolverlo con return también son operaciones diferentes.

4 Estado de los objetos

Dos objetos Cuenta tienen saldos distintos. ¿Por qué una clase común no obliga a compartir el mismo saldo?

Explicación. Cada instancia puede mantener sus propios atributos. La clase define estructura y comportamiento, no un único estado obligatorio. Una variable de clase compartida es distinta

de un atributo de instancia; confundirlas puede introducir cambios que afecten a varios objetos.

5 Herencia y polimorfismo

CuentaAhorro y CuentaCorriente especializan Cuenta y calculan cargos de manera diferente. ¿Qué conceptos aparecen?

Explicación. La especialización expresa herencia. Usar una operación común cuyo comportamiento cambia según el objeto expresa polimorfismo. Encapsulación, por su parte, organiza estado y operaciones mediante una interfaz; no debe confundirse con esas otras relaciones.

08 Sistema de gestión de seguridad de la información

Programación y pruebas de la seguridad del software · Nivel 10 · Indicador 2.1 · Tabla página 4

Indicador de logro. Reconoce conceptos relacionados con SGSI.

Propósito de aprendizaje. Explicar cómo un SGSI organiza responsabilidades, riesgos, controles y mejora continua.

Conceptos fundamentales

Un SGSI es un sistema de gestión de seguridad de la información. Integra políticas, procesos, personas, recursos y controles para tratar riesgos dentro de un alcance definido. No equivale a comprar un antivirus ni a instalar un firewall. ISO/IEC 27001 establece requisitos para un SGSI; ISO/IEC 27002 ofrece orientación sobre controles. [F3]

El alcance indica qué procesos, sedes, información y sistemas se incluyen. Una política expresa directrices aprobadas; un procedimiento explica cómo actuar; un registro aporta evidencia de lo realizado. La dirección asigna responsabilidades y recursos, y los propietarios de riesgos participan en decisiones de tratamiento.

El análisis reconoce activos, amenazas y vulnerabilidades; estima probabilidad e impacto y prioriza. El riesgo inherente se considera antes del efecto de los controles y el residual es el que permanece después del tratamiento. Se puede evitar, reducir, compartir o aceptar un riesgo según criterios y autorización. Contratar un seguro no elimina todas las responsabilidades.

Los controles pueden ser preventivos, detectivos o correctivos; también administrativos, técnicos o físicos. Una capacitación es administrativa; MFA es técnica; una cerradura es física. La clasificación depende del criterio usado y un control puede cumplir más de una función.



La revisión alimenta un nuevo ciclo de gestión

Esquema aplicado La revisión alimenta el ciclo de mejora del SGSI

Caso resuelto. La institución detecta copias públicas de expedientes. Define permisos, capacita, revisa accesos y mide incidentes. Si el problema persiste, investiga causas y ajusta controles. Esa revisión distingue una gestión sostenida de una acción aislada.

Conceptos de evaluación. Una auditoría contrasta evidencia con criterios; una no conformidad señala un requisito incumplido; una acción correctiva busca eliminar su causa. La certificación, cuando existe, tiene alcance y no garantiza ausencia de incidentes.

Por qué un SGSI es una forma de trabajar

Suponga que una institución compra una herramienta de respaldo, pero nadie revisa los errores. Existe un producto, aunque falta gestión. Un SGSI define qué información se protege, quién responde, qué riesgos importan, cómo se actúa y con qué evidencia se verifica. La política expresa una directriz; el procedimiento explica cómo cumplirla; el registro demuestra lo realizado. Confundir estos documentos impide comprobar la operación real.

El alcance delimita procesos, servicios, sedes y dependencias. Si incluye una plataforma educativa, deben considerarse identidades, aplicaciones, datos y terceros que intervienen. No basta decir «todos los equipos» sin reconocer para qué se utilizan. La dirección aporta decisiones y recursos; el personal técnico implementa controles y produce evidencia. La gestión no puede recaer únicamente en quien instala programas.

Valorar el riesgo sin fingir precisión

Una matriz puede usar categorías de probabilidad e impacto. Primero deben definirse los criterios: qué significa impacto alto, qué interrupción se tolera y qué datos están involucrados. Si dos personas usan escalas diferentes, sus colores no son comparables. Una puntuación orienta una decisión; no sustituye el análisis ni convierte una estimación en certeza matemática.

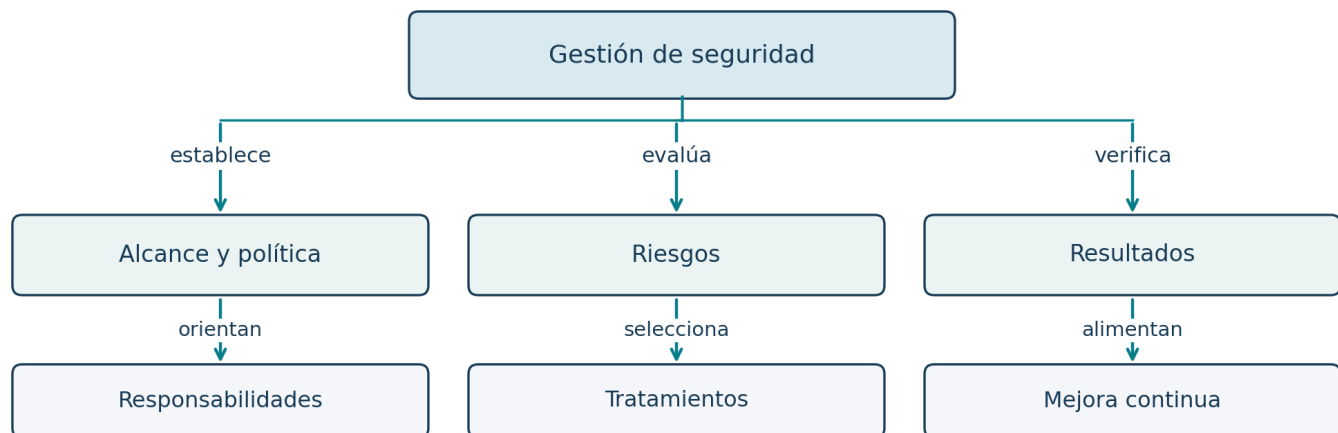
Tratar el riesgo puede implicar evitar una actividad, reducir exposición, compartir determinadas consecuencias o aceptar un riesgo documentado. Contratar un seguro no elimina la vulnerabilidad ni todas las responsabilidades. El riesgo residual permanece después de controles y debe ser conocido por quien tiene autoridad para aceptarlo.

Verificar eficacia en una situación concreta

La política exige recuperar expedientes. El procedimiento establece copia y prueba periódica. El registro muestra que la tarea de copia terminó. Todavía falta demostrar recuperación: restaurar una muestra o servicio en condiciones controladas y comprobar su uso. Si falla, se registra una no conformidad respecto del requisito aplicable y se analiza la causa. Repetir la tarea sin averiguar por qué falla puede no corregir el problema.

Transferencia. Al aparecer una nueva sede o un servicio externo, deben revisarse alcance y riesgos. La mejora continua responde a cambios y resultados, no solo a una fecha de auditoría. ISO/IEC 27001 establece requisitos de gestión; ISO/IEC 27002 orienta sobre controles. Una certificación tiene un alcance específico y no demuestra ausencia absoluta de incidentes.

Mapa de relaciones para explicar el tema



Mapa conceptual 8 Gestión de seguridad

Preguntas y casos del indicador 08

Aplicación del aprendizaje. Explicar cómo un SGSI organiza responsabilidades, riesgos, controles y mejora continua.

1 Definir el alcance

Una institución declara que su SGSI cubre el sistema de matrícula. ¿Debe considerar al proveedor que almacena sus respaldos?

Explicación. Debe analizar la dependencia y los requisitos pertinentes dentro del alcance y sus interfaces. El proveedor participa en la protección del servicio aunque sea externo. Definir alcance no consiste únicamente en enumerar computadoras propias.

2 Distinguir documentos

«Se harán respaldos» aparece en una política, hay un instructivo y existe una bitácora de ejecución. ¿Qué aporta cada documento?

Explicación. La política establece la directriz; el instructivo explica cómo actuar; la bitácora registra evidencia. Son funciones diferentes. Disponer de una política no demuestra ejecución, y un registro de ejecución tampoco prueba por sí solo recuperación satisfactoria.

3 Tratar y aceptar riesgo

Se cifra un portátil, pero persiste riesgo de pérdida del equipo. ¿Cómo se denomina lo que permanece después del tratamiento?

Explicación. Riesgo residual. Debe evaluarse y aceptarse por quien tenga autoridad según los criterios definidos. El control reduce determinados efectos, pero no elimina necesariamente todos. Riesgo inherente corresponde a la valoración anterior al efecto de los controles considerados.

4 Interpretar una auditoría

La política exige probar restauraciones y no hay evidencia de ninguna prueba. ¿Qué debe registrar una auditoría?

Explicación. Un incumplimiento respecto del criterio aplicable, sustentado en evidencia. No basta recomendar comprar otra herramienta. La acción correctiva debe investigar y tratar la causa de la falta de pruebas y comprobar que no se repita.

5 Diferenciar normas

Se necesita una norma de requisitos para un SGSI y una guía de controles. ¿Cómo se distinguen ISO IEC 27001 y 27002?

Explicación. ISO IEC 27001 establece requisitos del sistema de gestión; ISO IEC 27002 ofrece orientación sobre controles. No son dos marcas de antivirus. La selección responde a la necesidad de gestión o de orientación, y debe utilizarse la edición aplicable.

09 Lectura de código y flujo de datos

Programación y pruebas de la seguridad del software · Nivel 10 · Indicador 3.1 · Tabla página 4

Indicador de logro. Identifica la codificación de programas que utilicen herramientas de control.

Propósito de aprendizaje. Seguir el estado de variables y estructuras para determinar qué realiza un programa.

Conceptos fundamentales

Para comprender código, identifique entradas, variables iniciales, condiciones, cambios de estado y salidas. No adivine el resultado por el nombre de una variable. En Python la indentación delimita bloques; cambiarla puede modificar el comportamiento o producir un error.

Los tipos básicos incluyen enteros, decimales, booleanos y cadenas. Una lista es ordenada y modificable; una tupla es ordenada e inmutable; un diccionario asocia claves con valores; un conjunto reúne elementos únicos sin indexación posicional como la de una lista. Un módulo agrupa código reutilizable que puede importarse.

En índices de listas, la primera posición es 0. `range(1, 5)` genera 1, 2, 3 y 4: el límite final no se incluye. `=` asigna; `==` compara igualdad; `%` obtiene el residuo. `n % 2 == 0` comprueba si un entero es par.

```
total = 0
for n in [2, 5, 4, -1, 8]:
    if n < 0:
        break
    if n % 2 == 0:
        total += n
print(total)
```

Valor revisado	Decisión	Total después del paso
2	Es par y se suma.	2
5	No es par.	2

Valor revisado	Decisión	Total después del paso
4	Es par y se suma.	6
-1	Se termina el ciclo.	6
8	No se ejecuta esta iteración.	6

Resultado explicado. Se imprime 6. break impide llegar a 8. Si la instrucción fuera continue, se omitiría el negativo y el ciclo podría seguir, cambiando el resultado.

Seguir el estado línea por línea

Un programa no entiende la intención del nombre de una variable: ejecuta instrucciones. Para analizarlo, escriba el valor inicial y actualícelo después de cada operación. Si una suma está dentro de un if, solo ocurre cuando su condición es verdadera. Si está fuera, puede ocurrir en todas las iteraciones. La indentación en Python establece esa diferencia y forma parte de la sintaxis.

En el ejemplo anterior, el ciclo encuentra 2, después 5, luego 4 y finalmente -1. El total pasa de 0 a 2 y después a 6. El valor negativo activa break; 8 no se procesa. Cambiar break por continue omitiría el resto de esa iteración, pero permitiría llegar a 8: el resultado sería 14. No es suficiente identificar la palabra ciclo; hay que observar qué interrumpe y qué continúa.

Comprender las estructuras de datos por su uso

Una lista mantiene una secuencia y admite cambios. Una tupla mantiene una secuencia cuya estructura no se modifica del mismo modo; eso no implica que cualquier objeto contenido sea inmutable. Un diccionario relaciona claves con valores, por ejemplo un usuario con su rol. Un conjunto representa elementos únicos y resulta útil para comprobar pertenencia o eliminar duplicados, aunque no se utiliza como una lista por posiciones.

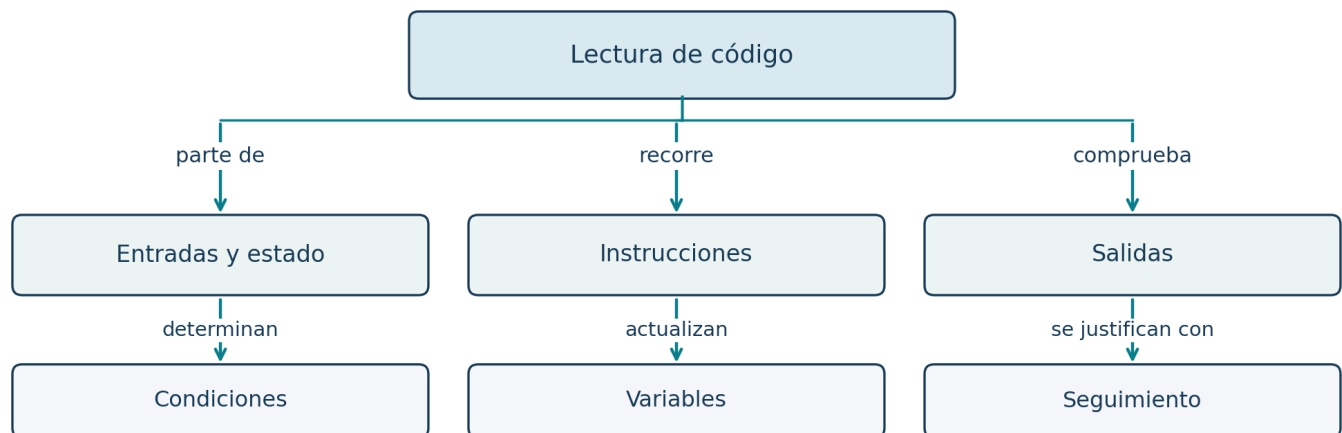
El índice inicial habitual de una lista en Python es 0. Para cuatro elementos, los índices no negativos válidos son 0, 1, 2 y 3. Pedir el índice 4 produce un error. En range(2, 6), se obtienen 2, 3, 4 y 5; el límite final queda excluido. Estos límites explican errores de una repetición adicional o de omitir el último elemento.

Modularizar sin perder el flujo

Un módulo reúne definiciones reutilizables. Importarlo permite acceder a sus funciones o nombres según la forma utilizada. Una función llamada desde un ciclo ejecuta su propio bloque y devuelve el control al llamador cuando termina normalmente. Si cambia una estructura mutable compartida, el cambio puede ser visible fuera de la función; por eso deben seguirse referencias y efectos, no solo valores impresos.

Práctica explicada. Una lista de edades contiene 17, 18 y 20. Contar edades mayores que 18 produce 1; contar edades mayores o iguales a 18 produce 2. El caso de frontera es 18. Diseñar ese ejemplo permite verificar exactamente el operador que exige la regla.

Mapa de relaciones para explicar el tema



Mapa conceptual 9 Lectura de código

Preguntas y casos del indicador 09

Aplicación del aprendizaje. Seguir el estado de variables y estructuras para determinar qué realiza un programa.

1 Seguir una suma condicional

En una lista [3, 4, 6], un programa suma únicamente los números pares desde total cero. ¿Cuál es el resultado y por qué?

Explicación. El resultado es 10. El 3 no cumple la condición; 4 y 6 sí se agregan. Es necesario seguir tanto el valor revisado como el acumulador: sumar todos los elementos produciría 13 y desconocería la condición.

2 Interpretar range

Un ciclo usa `range(1, 4)`. ¿Qué valores recorre y cuántas iteraciones tiene?

Explicación. Recorre 1, 2 y 3: tres iteraciones. El límite final queda excluido. Si fuera `range(1, 5)`, incluiría 4 y tendría cuatro iteraciones. Confundir límite con último valor altera cálculos y posiciones de acceso.

3 Break y continue

Al recorrer [2, -1, 5], se omiten negativos con `continue`. ¿Se llega a procesar 5? ¿Qué ocurriría con `break`?

Explicación. Con `continue` se omite el resto de la iteración del -1 y se sigue con 5. Con `break` se termina el ciclo y no se llega a 5. Debe identificar qué bloque interrumpe cada instrucción, no tratarlas como sinónimos.

4 Índices y posiciones

Una lista contiene cuatro nombres. ¿Por qué consultar la posición 4 mediante su índice produce error en Python?

Explicación. Sus índices no negativos válidos son 0, 1, 2 y 3. El índice 4 intenta acceder a un quinto elemento inexistente. El tamaño de la lista no equivale al último índice; esa diferencia es una causa frecuente de errores de frontera.

5 Elegir una estructura

Se necesitan asociar códigos únicos de productos con sus precios. ¿Qué aporta un diccionario frente a una lista de precios sin códigos?

Explicación. El diccionario relaciona claves con valores y permite consultar por código. La lista conserva posiciones, pero por sí sola no expresa esa asociación. La elección depende de la operación necesaria, no de que una estructura sea siempre mejor.

10 Errores excepciones y ejecución controlada

Programación y pruebas de la seguridad del software · Nivel 10 · Indicador 4.1 · Tabla página 4

Indicador de logro. Distingue las sintaxis de codificación de programas mediante el uso de flujo de datos y manejo de errores y excepciones.

Propósito de aprendizaje. Interpretar qué bloques se ejecutan cuando una operación falla o finaliza correctamente.

Conceptos fundamentales

Un error de sintaxis impide interpretar correctamente el programa, por ejemplo omitir un signo requerido. Una excepción de ejecución aparece al realizar una operación no válida en esas condiciones. Un error lógico produce un resultado equivocado aunque el programa se ejecute sin excepción.

En Python, try contiene operaciones que pueden fallar; except atiende excepciones compatibles; else se ejecuta cuando el bloque try termina sin excepción; finally sirve para acciones de cierre que se ejecutan al salir de la estructura en el flujo normal del lenguaje. No se debe utilizar un manejador vacío para ocultar todos los problemas.

Excepción	Situación típica
ValueError	Convertir "ocho" a entero con int.
TypeError	Aplicar una operación a tipos incompatibles.
ZeroDivisionError	Dividir un número entre cero.
IndexError	Acceder a una posición inexistente de una lista.
KeyError	Consultar una clave que no existe en un diccionario.
FileNotFoundError	Abrir una ruta de archivo inexistente.


```
try:
    cantidad = int("8")
except ValueError:
    print("Entrada inválida")
else:
    print(cantidad + 2)
finally:
    print("Fin")
```

Caso resuelto. La conversión es válida: se imprime 10 y luego Fin. Si el texto fuera "ocho", se imprimiría Entrada inválida y después Fin; no se ejecutaría else. En aplicaciones web, el mensaje para la persona debe ser comprensible y los detalles técnicos deben registrarse de manera protegida.

Datos y validación. Convertir un texto a número no garantiza que cumpla la regla del negocio. Una edad de -5 puede convertirse a entero y seguir siendo inválida. Deben comprobarse tipo, rango y contexto.

Qué sucede cuando falla una operación

Dentro de un bloque try, las instrucciones se ejecutan en orden. Si una conversión genera una excepción, las instrucciones posteriores de ese bloque no continúan normalmente: se busca un manejador compatible. El bloque except ValueError atiende ese tipo, pero no equivale a capturar cualquier falla. Si no se encuentra un manejador adecuado, la excepción se propaga hacia el contexto que llamó o termina la ejecución correspondiente.

El bloque else se ejecuta cuando el bloque try termina sin excepción. finally se utiliza para acciones de cierre que se ejecutan al abandonar la estructura bajo el funcionamiento normal del lenguaje, incluso cuando hay una excepción o un retorno. No debe interpretarse como protección frente a cualquier interrupción física del equipo. La estructura organiza el flujo del programa, no controla un corte eléctrico.

Validar antes y después de convertir

Convertir el texto «18» a entero produce el número 18. Convertir «dieciocho» con int no produce ese resultado y genera una excepción. Sin embargo, convertir «-5» sí puede funcionar y dejar un valor inválido para una edad. La primera comprobación atiende formato; la segunda, rango y regla de negocio. Son necesarias por razones distintas.

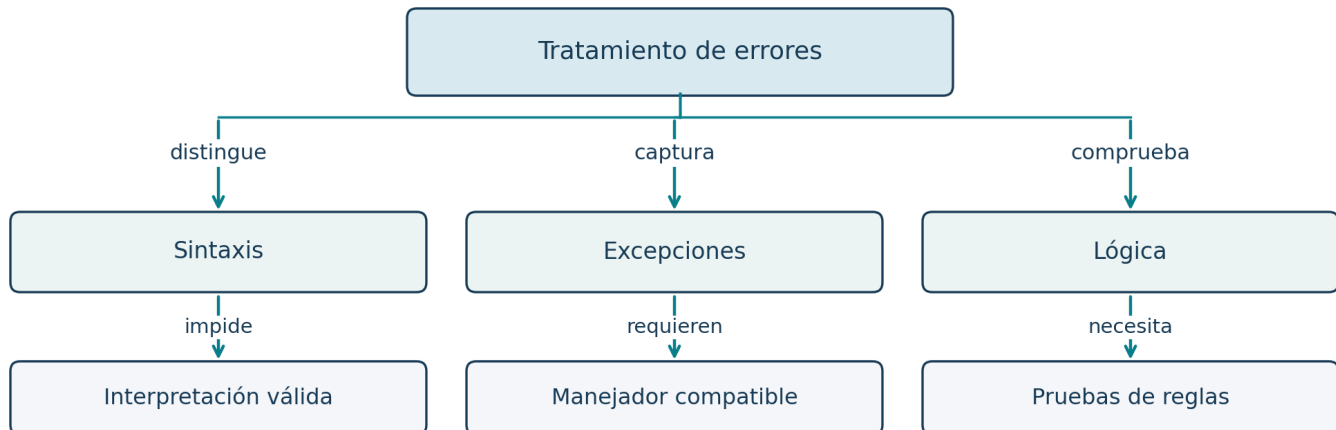
La validación en el navegador ayuda a la persona usuaria, pero puede eludirse. El servidor debe verificar de nuevo lo necesario antes de procesar. Un mensaje de error puede indicar que el dato no cumple el formato sin revelar rutas internas, consultas SQL o credenciales. Los detalles técnicos pertinentes se conservan en registros protegidos.

Analizar una recuperación correcta

Si falla un registro de pago a mitad del proceso, mostrar «intente de nuevo» no demuestra que nada haya sido guardado. Debe conocerse el estado de la transacción y evitar duplicados. Una excepción controlada puede dejar una operación incompleta si no se diseñó reversión o atomicidad. Por eso el manejo de errores se relaciona con integridad y con el ciclo de vida del software.

Comparación razonada. Un programa cobra el doble por usar una fórmula incorrecta, pero todos sus tipos son válidos. Puede no generar ninguna excepción. Agregar más except no corrige esa fórmula. Se necesitan ejemplos con resultados esperados, pruebas de frontera y revisión de la regla que se implementó.

Mapa de relaciones para explicar el tema



Mapa conceptual 10 Tratamiento de errores

Preguntas y casos del indicador 10

Aplicación del aprendizaje. Interpretar qué bloques se ejecutan cuando una operación falla o finaliza correctamente.

1 Error de sintaxis

Una instrucción if omite los dos puntos que requiere Python. ¿Se trata de una decisión lógica incorrecta o de un error de sintaxis?

Explicación. Es un error de sintaxis: el código no cumple la estructura del lenguaje. Un error lógico puede ejecutarse sin excepción y producir un resultado incorrecto. Primero debe distinguirse si el programa puede interpretarse antes de analizar su decisión.

2 Conversión inválida

El programa intenta convertir el texto «ocho» mediante int. ¿Qué excepción es esperable y qué puede hacer el manejador?

Explicación. Es esperable ValueError. El manejador puede informar el formato requerido y permitir una entrada nueva. No convierte automáticamente cualquier palabra en número. Capturar la excepción organiza la recuperación, pero debe programarse una respuesta apropiada.

3 Else y finally

Una conversión dentro de try termina correctamente. ¿Cuándo se ejecutan else y finally en el flujo normal de esa estructura?

Explicación. Else se ejecuta si el bloque try termina sin excepción; finally realiza las acciones de cierre al salir de la estructura según el flujo del lenguaje. Finally no equivale a «solo cuando hay error» ni protege contra cualquier interrupción física.

4 Tipo válido y valor inválido

Una aplicación acepta -3 como edad porque puede convertirlo a entero. ¿Qué comprobación falta?

Explicación. Falta validar el rango y la regla del negocio. La conversión comprueba que el texto puede representarse como entero, pero no que sea una edad admisible. El control debe distinguir formato, tipo y significado del valor.

5 Resultado equivocado sin excepción

El programa calcula un descuento de 10 por ciento como precio menos 10. No genera excepciones. ¿Cómo se detecta el problema?

Explicación. Mediante pruebas con resultados esperados y revisión de la fórmula. Para precio 200, restar 10 produce 190 y el descuento proporcional debería dar 180. Un bloque except no corrige una regla matemática mal implementada.

11 Automatización robotizada

Programación y pruebas de la seguridad del software · Nivel 10 · Indicador 5.1 · Tabla página 5

Indicador de logro. Reconoce conceptos básicos de la automatización robotizada.

Propósito de aprendizaje. Distinguir automatización de procesos y robótica física, y reconocer sus componentes y límites.

Conceptos fundamentales

La automatización ejecuta tareas con intervención humana reducida. Conviene cuando existen reglas identificables, entradas suficientes y resultados verificables. No elimina la necesidad de supervisar errores, cambios del entorno o decisiones de alto impacto.

La RPA, automatización robótica de procesos, utiliza software para realizar tareas repetitivas en aplicaciones: leer campos estructurados, copiar registros y generar reportes. Un bot no necesita poseer inteligencia artificial; puede seguir reglas deterministas. Un proceso atendido requiere participación humana y uno desatendido puede ejecutarse con supervisión programada.

La robótica física integra sensores, controlador y actuadores. El sensor capta el estado; el controlador compara información con reglas u objetivos; el actuador mueve o modifica el entorno. En un sistema de lazo abierto no se corrige la acción a partir del resultado medido; en uno de lazo cerrado existe retroalimentación.

Situación	Aplicación apropiada
Transcribir formularios estandarizados.	RPA con validación y registro de excepciones.
Clasificar piezas en una línea.	Robot físico con sensor y actuador.
Atender un caso con información insuficiente.	Derivación a una persona según el procedimiento.

Caso resuelto. Un bot registra una orden, pero pierde la conexión antes de recibir confirmación. Repetir sin verificar puede duplicarla. Un identificador único permite comprobar si la operación ya ocurrió y hacer un reintento controlado. Esta propiedad se relaciona con la idempotencia: repetir la misma solicitud no debe producir un efecto adicional indebido.

Seguridad de la automatización. Las cuentas del bot requieren mínimos privilegios; los secretos no deben incrustarse en archivos públicos. Se necesita bitácora, control de cambios, mecanismo de detención y manejo de entradas faltantes. En robots físicos también importan límites de operación y seguridad de las personas.

Distinguir automatización digital y acción física

Una tarea automatizada puede copiar datos entre aplicaciones sin mover ningún objeto. Esa es una aplicación típica de automatización robótica de procesos, RPA. Un robot físico, en cambio, puede medir, desplazarse o manipular materiales mediante actuadores. Ambos ejecutan instrucciones, pero sus fallas producen consecuencias distintas. Una duplicación en un formulario afecta información; una orden incorrecta a un brazo puede afectar también equipos o personas.

Un sensor convierte una variable física en una señal utilizable. Un controlador interpreta entradas y decide según un programa. Un actuador, como motor o válvula, ejecuta la acción. La alimentación sostiene el funcionamiento y las interfaces comunican componentes. El firmware contiene instrucciones cercanas al hardware. Cada componente introduce dependencias: un programa correcto no compensa una medición fuera de calibración.

Comprender la realimentación

En un sistema de lazo abierto, la acción no se corrige usando una medición del resultado. Un temporizador que enciende riego durante cinco minutos puede hacerlo aunque el terreno ya esté húmedo. En un lazo cerrado, la medición se compara con una referencia y ajusta la actuación. Eso mejora capacidad de respuesta, pero exige sensores, límites y tratamiento de lecturas erróneas.

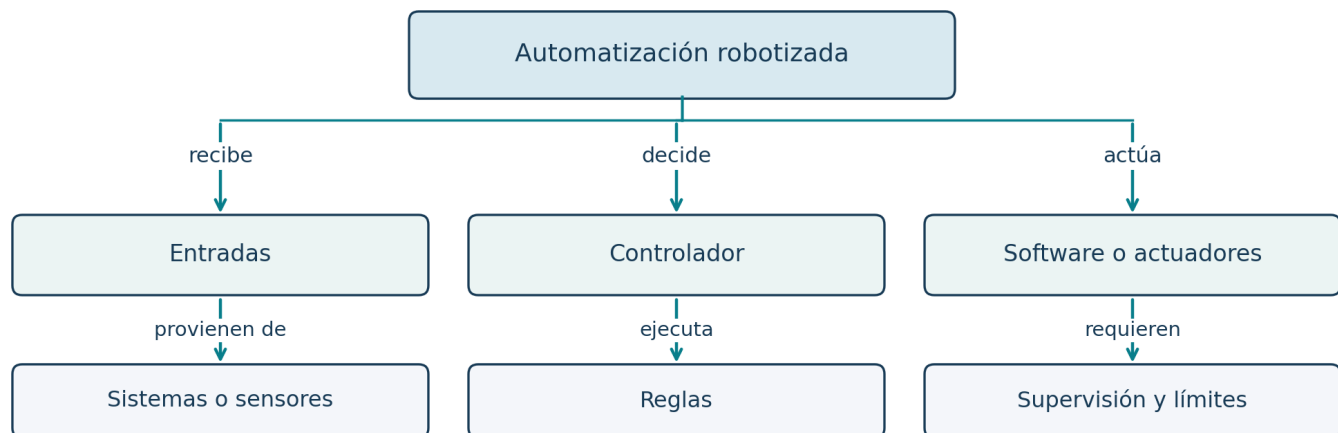
Una alarma y una acción automática tampoco son idénticas. La alarma solicita atención; el control automático modifica el proceso. La decisión debe considerar criticidad, tiempo disponible y posibilidad de supervisión humana. No toda tarea debe automatizarse solo porque sea técnicamente posible.

Hacer una automatización verificable

Un bot de facturas debe reconocer qué documento procesó, registrar resultados y distinguir fallos de datos faltantes. Si se interrumpe la conexión después de guardar, repetir a ciegas puede duplicar. Una operación idempotente está diseñada para que repetir la misma solicitud no produzca un efecto adicional indebido. Un identificador único y una consulta del estado ayudan a controlar ese problema.

Ejemplo de bienestar social. Un dispensador programado puede recordar un horario, pero su diseño debe contemplar carga incorrecta, energía y confirmación de la acción. Estudiar el caso exige separar utilidad de garantía. La automatización reduce ciertas tareas y errores, mientras introduce nuevas necesidades de mantenimiento, supervisión y seguridad.

Mapa de relaciones para explicar el tema



Mapa conceptual 11 Automatización robotizada

Preguntas y casos del indicador 11

Aplicación del aprendizaje. Distinguir automatización de procesos y robótica física, y reconocer sus componentes y límites.

1 Automatización de tareas digitales

Una herramienta copia datos de facturas entre dos aplicaciones mediante reglas. ¿Por qué puede ser RPA aunque no exista un brazo mecánico?

Explicación. RPA automatiza tareas de software y no requiere movimiento físico. Aquí procesa información entre aplicaciones. La robótica física incorpora sensores y actuadores sobre el entorno; ambas automatizan, pero sus componentes y consecuencias son distintos.

2 Realimentación

Un riego opera diez minutos por reloj; otro se detiene cuando alcanza la humedad prevista. ¿Cuál utiliza realimentación?

Explicación. El segundo utiliza la medición del resultado para ajustar la acción: es un lazo cerrado. El primero actúa por duración sin comprobar humedad. El temporizador puede ser adecuado en ciertos casos, pero no demuestra corrección basada en el resultado.

3 Reintentos sin duplicación

Un bot envía una orden y pierde la conexión antes de recibir confirmación. ¿Por qué no debe repetirla sin verificar su estado?

Explicación. La orden pudo quedar registrada. Repetirla puede duplicar efectos. Un identificador de operación y un diseño idempotente permiten reconocer reintentos. El fallo de comunicación no implica necesariamente que el servidor no haya ejecutado la primera solicitud.

4 Manejo de excepciones

Una factura carece del identificador obligatorio y el bot no puede determinarlo. ¿Qué actuación conserva integridad?

Explicación. Registrar la excepción y derivarla al procedimiento de revisión. Inventar un valor para terminar introduce información falsa. La automatización debe distinguir casos procesados, rechazados y pendientes para que el resultado pueda verificarse.

5 Límites de una acción física

Un robot sigue una orden válida, pero una persona entra en su zona de movimiento. ¿Qué necesidad de diseño aparece?

Explicación. Se requieren medidas de seguridad física, límites e interbloqueos adecuados al riesgo. Que el software ejecute correctamente su orden no demuestra que la operación sea segura para personas. La supervisión y las condiciones del entorno forman parte del diseño.

12 Sistemas operativos y entornos de trabajo

Programación y pruebas de la seguridad del software · Nivel 11 · Indicador 6.1 · Tabla página 5

Indicador de logro. Menciona tipos de sistemas operativos, entornos de trabajo, funciones y procesos de compatibilidad.

Propósito de aprendizaje. Reconocer las funciones del sistema operativo y diferenciar criterios de clasificación.

Conceptos fundamentales

El sistema operativo, SO, administra recursos y ofrece servicios a los programas. Su núcleo o kernel coordina funciones esenciales. Un proceso es un programa en ejecución con estado y recursos; un hilo es una unidad de ejecución dentro de un proceso. La planificación asigna tiempo de CPU; la memoria virtual organiza espacios de direcciones y puede utilizar almacenamiento como apoyo.

También administra archivos, dispositivos, usuarios, permisos, comunicación y errores. Un controlador o driver permite que el SO interactúe con un dispositivo. Un sistema de archivos organiza información y metadatos; no debe confundirse con la aplicación que abre los documentos.

Una interfaz gráfica, GUI, permite operar con ventanas y controles; una interfaz de línea de comandos, CLI, recibe órdenes textuales. Ambas pueden existir en el mismo sistema. Saber usar una terminal no implica tener privilegios administrativos.

Criterio	Distinción importante
Uso	Escritorio, servidor, móvil o integrado.
Tiempo	Un SO de tiempo real atiende restricciones temporales definidas.
Ejecución	Multitarea permite coordinar varios procesos.
Usuarios	Multiusuario gestiona acceso de varias identidades.
Licencia	Código abierto y software propietario tienen condiciones diferentes.

Código abierto significa que la licencia permite determinados usos, estudio y modificación del código; no significa ausencia de licencia ni necesariamente precio cero. El software propietario restringe acceso o modificación según sus términos. Ninguna categoría garantiza por sí sola seguridad.

Caso resuelto. Dos aplicaciones se ejecutan a la vez y cada una conserva un espacio de memoria protegido. El SO está planificando procesos y aislando memoria. La lentitud por falta de recursos debe distinguirse de una incompatibilidad de software.

Qué administra realmente el sistema operativo

Una aplicación no suele controlar directamente cada componente físico. Solicita servicios al sistema operativo para abrir archivos, reservar memoria o comunicarse. El kernel coordina funciones esenciales. Un controlador permite trabajar con un dispositivo específico; el sistema de archivos organiza nombres, ubicaciones lógicas y metadatos. La interfaz gráfica facilita interacción, pero no es todo el sistema operativo.

Un proceso es un programa en ejecución con estado y recursos. Un hilo es una unidad de ejecución dentro de un proceso y comparte determinados recursos de este. La planificación distribuye oportunidades de CPU. La ejecución concurrente puede dar la impresión de simultaneidad aunque existan menos núcleos que tareas. Tener múltiples procesos no significa que todos ejecuten una instrucción al mismo instante.

Relacionar memoria y almacenamiento

La RAM permite acceso rápido a datos de trabajo; el almacenamiento conserva información de forma persistente. La memoria virtual organiza espacios de direcciones y puede apoyarse en almacenamiento. Ese apoyo no convierte el disco en RAM con el mismo rendimiento. Cuando la presión de memoria aumenta, el intercambio de páginas puede degradar la experiencia. Debe medirse el recurso que limita, no comprar más almacenamiento por cualquier lentitud.

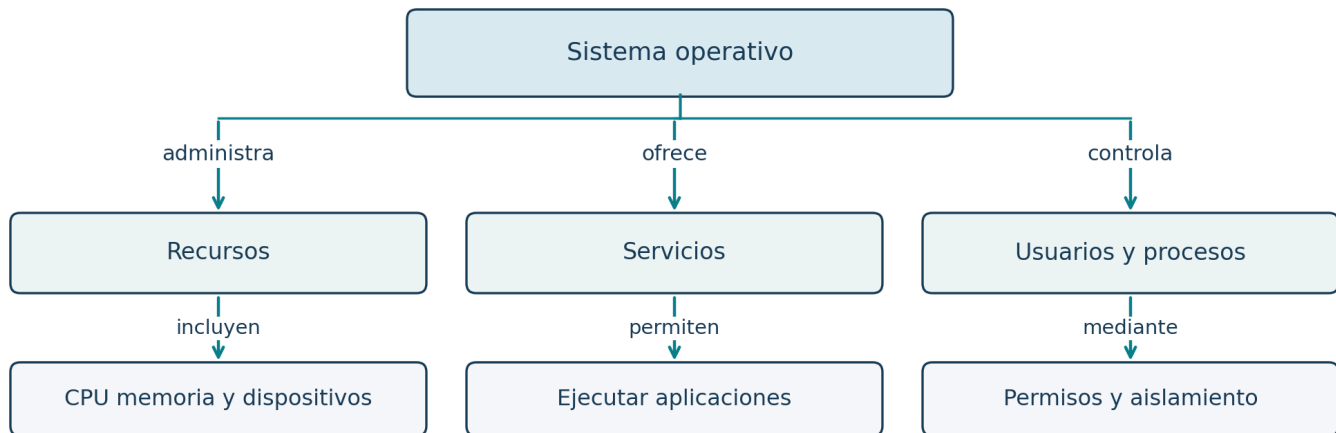
Los permisos de archivo y el aislamiento de procesos reducen accesos indebidos, pero dependen de configuración y del funcionamiento del sistema. Una cuenta con privilegios elevados puede superar muchos límites normales. Mantener identidades separadas permite también atribuir acciones mediante registros.

Clasificar sin mezclar criterios

Escritorio, servidor, móvil e integrado describen contextos de uso. Multitarea y multiusuario describen capacidades. Código abierto y propietario describen condiciones de licencia y acceso al código. Un mismo sistema puede pertenecer a varias categorías. Un sistema de tiempo real se diseña para cumplir restricciones temporales específicas; no significa simplemente que responde rápido en una prueba informal.

Caso comentado. Una impresora no funciona después de instalar el sistema. Si la aplicación abre y otros dispositivos operan, revise controlador, conexión, cola y compatibilidad antes de concluir que todo el sistema es defectuoso. La localización de la falla depende de qué servicio funciona y cuál no.

Mapa de relaciones para explicar el tema



Mapa conceptual 12 Sistema operativo

Preguntas y casos del indicador 12

Aplicación del aprendizaje. Reconocer las funciones del sistema operativo y diferenciar criterios de clasificación.

1 Programa proceso e hilo

Se abre dos veces una aplicación. ¿Por qué el archivo instalado no equivale a cada proceso en ejecución?

Explicación. El programa contiene instrucciones; cada proceso incorpora estado y recursos de ejecución. Un proceso puede tener varios hilos que comparten determinados recursos. El sistema operativo coordina su ejecución y aislamiento; no se deduce la cantidad de procesos solo por ventanas visibles.

2 Memoria y almacenamiento

El disco tiene mucho espacio, pero varias aplicaciones agotan la RAM. ¿Por qué liberar archivos puede no resolver la lentitud?

Explicación. RAM y almacenamiento cumplen funciones diferentes. La presión de memoria puede generar paginación y demoras aunque sobre capacidad de disco. Debe medirse el recurso limitante; espacio libre no equivale a memoria de trabajo rápida.

3 Controladores

Después de instalar un sistema operativo, funciona el teclado, pero no el adaptador de red. ¿Qué debe investigarse?

Explicación. Compatibilidad y disponibilidad del controlador del adaptador, además del dispositivo y su configuración. Un controlador permite la interacción del sistema con ese hardware. El funcionamiento de un periférico no prueba soporte correcto para todos los demás.

4 Interfaces de usuario

Dos personas administran el mismo sistema: una usa ventanas y otra comandos. ¿Están necesariamente utilizando sistemas operativos diferentes?

Explicación. No. Un mismo sistema puede ofrecer GUI y CLI. Son interfaces de interacción, no sistemas completos independientes. Utilizar terminal tampoco demuestra privilegios administrativos: estos dependen de la identidad y los permisos.

5 Clasificación por licencia y función

Un servidor utiliza software de código abierto. ¿Puede concluirse que es gratuito, monousuario o automáticamente seguro?

Explicación. No. Código abierto describe condiciones de acceso, uso y modificación del código según la licencia. Precio, capacidad multiusuario y seguridad son criterios diferentes. Un sistema puede pertenecer simultáneamente a varias clasificaciones sin que una determine las demás.

13 Compatibilidad y virtualización de sistemas

Programación y pruebas de la seguridad del software · Nivel 11 · Indicador 7.1 · Tabla página 5

Indicador de logro. Identifica el concepto de compatibilidad de los sistemas operativos.

Propósito de aprendizaje. Explicar qué requisitos deben coincidir para ejecutar un sistema operativo y sus aplicaciones.

Conceptos fundamentales

La compatibilidad es la capacidad de componentes para trabajar juntos bajo condiciones definidas. Deben revisarse arquitectura del procesador, memoria, almacenamiento, firmware, versión del sistema, controladores, bibliotecas y requisitos de la aplicación. Un equipo con suficiente RAM puede seguir siendo incompatible por arquitectura o controlador.

Una máquina virtual, VM, presenta hardware virtual a un sistema invitado. El anfitrión es el equipo que aporta recursos. El hipervisor administra las VM: de tipo 1 funciona directamente sobre el hardware; de tipo 2 se apoya en un sistema operativo anfitrión. La virtualización no crea CPU o RAM ilimitadas.

Una emulación reproduce el comportamiento de otra plataforma y puede permitir ejecutar instrucciones de arquitectura diferente, con costos o límites. Un contenedor comparte el kernel del entorno que lo ejecuta y aísla procesos y dependencias; no equivale a una VM con su propio kernel invitado.

Caso resuelto. Un programa requiere servicios de Windows y el equipo usa Linux. Una VM con una versión compatible de Windows puede ofrecer el entorno previsto si hardware, licencia y recursos lo permiten. Renombrar el ejecutable no lo hace compatible. Si falta una biblioteca dentro de la VM, iniciar Windows no resuelve esa dependencia de la aplicación.

Procedimiento de análisis. Primero lea requisitos; después verifique soporte de virtualización y recursos; seleccione el entorno invitado; instale desde una fuente confiable; actualice y pruebe dispositivos y aplicaciones. Use redes de laboratorio aisladas cuando se estudien vulnerabilidades.

Las instantáneas ayudan a regresar a un estado durante prácticas, pero su alcance depende de la plataforma. No reemplazan una estrategia independiente de respaldo ni garantizan que toda evidencia forense quede preservada.

Por qué una aplicación puede no ejecutarse

El archivo ejecutable espera ciertas instrucciones de procesador, bibliotecas, servicios y formatos. Una aplicación construida para otra arquitectura puede no ejecutarse directamente. Incluso dentro de una misma familia de sistemas, una versión puede carecer de una función requerida. Compatibilidad significa que se cumplen condiciones para trabajar conjuntamente; no basta que dos productos pertenezcan a la misma marca.

Una dependencia es un componente que la aplicación necesita. Un controlador permite acceso a un dispositivo. Una licencia autoriza determinados usos. Son cuestiones diferentes: un entorno puede ser técnicamente compatible y aun requerir una licencia apropiada. Asimismo, disponer de autorización no garantiza que el programa funcione en un hardware determinado.

Diferenciar tres formas de ejecutar entornos

La virtualización presenta recursos virtuales a un sistema invitado. El hipervisor administra las VM y comparte recursos físicos. La emulación reproduce el comportamiento de otra plataforma y puede permitir trabajar con instrucciones diferentes, con costos de rendimiento. Un contenedor aísla procesos y dependencias, pero comparte el kernel del entorno donde se ejecuta. No equivale por sí solo a una máquina con un kernel invitado independiente.

Un hipervisor de tipo 1 opera directamente sobre el hardware; uno de tipo 2 se apoya en un sistema anfitrión. La clasificación orienta arquitectura, no garantiza seguridad. Una VM puede estar expuesta si su red, credenciales o carpetas compartidas están mal configuradas.

Diagnosticar con pruebas que aíslen causas

Primero compare requisitos con recursos disponibles. Después verifique instalación y arranque. Luego pruebe el dispositivo o servicio específico. Si una aplicación abre pero no encuentra su base de datos, el problema puede estar en conexión o dependencia. Reinstalar el invitado sin analizar registros puede repetir la misma falla.

Ejemplo explicado. En un laboratorio, se ejecuta un programa de Windows dentro de una VM sobre Linux. La VM aporta el entorno requerido, pero una cámara USB necesita ser presentada al invitado y disponer de controlador compatible. El éxito al iniciar Windows no prueba funcionamiento de esa cámara. Una instantánea ayuda a regresar a un estado del laboratorio, pero no sustituye un respaldo independiente ni demuestra que todos los datos externos estén incluidos.

Mapa de relaciones para explicar el tema



Mapa conceptual 13 Compatibilidad de sistemas

Preguntas y casos del indicador 13

Aplicación del aprendizaje. Explicar qué requisitos deben coincidir para ejecutar un sistema operativo y sus aplicaciones.

1 Arquitectura del procesador

Una aplicación requiere una arquitectura distinta de la del equipo. ¿Basta aumentar RAM para que pueda ejecutarse directamente?

Explicación. No. La arquitectura determina instrucciones y compatibilidad del ejecutable. Puede requerirse una versión compatible o un entorno de emulación apropiado. La RAM atiende capacidad de memoria, pero no convierte instrucciones incompatibles en instrucciones nativas.

2 Hipervisores

Una plataforma de virtualización funciona directamente sobre el hardware; otra se ejecuta sobre un sistema anfitrión. ¿Cómo se clasifican habitualmente?

Explicación. La primera corresponde al tipo 1 y la segunda al tipo 2. La clasificación describe arquitectura. No demuestra por sí sola cuál instalación es segura o rápida: recursos, configuración y carga también determinan el resultado.

3 Contenedores y máquinas virtuales

Dos aplicaciones aisladas comparten el kernel del entorno. ¿Qué diferencia existe respecto de una VM con sistema invitado propio?

Explicación. Ese aislamiento corresponde a la idea de contenedores. Una VM presenta hardware virtual y puede ejecutar su propio kernel invitado. Compartir kernel cambia compatibilidad y aislamiento; no debe describirse un contenedor como una VM completa por defecto.

4 Dependencias de una aplicación

El sistema invitado arranca, pero el programa informa que falta una biblioteca. ¿Qué problema está demostrado?

Explicación. Falta una dependencia de la aplicación. El arranque acredita parte del entorno, pero no todos sus componentes. Debe instalarse o ajustar la dependencia compatible; reinstalar toda la VM sin interpretar el mensaje puede repetir el mismo problema.

5 Acceso a periféricos

Una cámara funciona en el anfitrión y no aparece en la VM. ¿Qué comprobaciones son pertinentes?

Explicación. Presentación o asignación del dispositivo a la VM, permisos y controlador del invitado. La VM no recibe automáticamente cualquier periférico conectado. Aumentar almacenamiento no atiende esa relación entre hardware, hipervisor y sistema invitado.

14 Riesgos en el ciclo de vida del software

Programación y pruebas de la seguridad del software · Nivel 11 · Indicador 8.1 · Tabla página 5

Indicador de logro. Identifica las valoraciones y riesgos del ciclo de vida de sistemas.

Propósito de aprendizaje. Relacionar cada etapa del sistema con los riesgos y controles que le corresponden.

Conceptos fundamentales

El ciclo de vida del desarrollo, SDLC, abarca concepción, requisitos, diseño, implementación, pruebas, despliegue, operación y retiro. Sus etapas pueden iterarse; seguridad no es una revisión que se añade únicamente al final.

Etapa	Riesgo representativo	Tratamiento coherente
Requisitos y diseño	Acceso a datos ajenos no contemplado.	Definir autorización y modelar amenazas.
Implementación	Entradas concatenadas en consultas.	Parametrización y revisión de código.
Pruebas	Falla que solo aparece con entradas límite.	Casos válidos, inválidos y de borde.
Despliegue	Secretos y configuración expuestos.	Revisión del entorno y gestión de secretos.
Mantenimiento	Dependencias vulnerables.	Inventario, evaluación, parches y pruebas.
Retiro	Cuentas o copias abandonadas.	Revocación y tratamiento de datos remanentes.

El modelado de amenazas identifica activos, límites de confianza, posibles abusos y controles. La superficie de ataque comprende puntos por los que se interactúa con el sistema. Un cambio puede reducir una vulnerabilidad y generar otro riesgo si afecta disponibilidad; requiere evaluación, pruebas y un plan de reversión.

Prueba unitaria revisa una parte pequeña; integración verifica componentes juntos; sistema evalúa el conjunto; aceptación verifica necesidades acordadas. Una prueba de regresión comprueba que un cambio no dañó funciones existentes. Las pruebas de rendimiento, carga y estrés estudian comportamiento ante condiciones de uso; no equivalen automáticamente a penetración.

Caso resuelto. Una biblioteca corrige una vulnerabilidad crítica, pero cambia una función. Corresponde evaluar exposición, probar la actualización y desplegar con seguimiento y reversión. Aplazar indefinidamente o instalar sin pruebas ignora una parte del riesgo.

Detectar riesgos antes de programar

Un requisito de seguridad debe expresar una condición comprobable. «La aplicación será segura» no indica qué probar. «Cada docente consultará únicamente los grupos asignados» permite diseñar casos autorizados y denegados. Si esta condición se omite al definir requisitos, puede faltar en diseño, implementación y pruebas. Corregirla al final suele exigir más cambios que incorporarla desde el inicio.

El modelado de amenazas observa activos, entradas, límites de confianza y posibles abusos. Un límite aparece cuando información pasa del navegador al servidor o de una aplicación a un servicio externo. El dato no debe considerarse confiable solo porque llega de una pantalla de la propia organización: el cliente puede modificarse.

Elegir pruebas por la pregunta que responden

Una prueba unitaria examina una unidad pequeña. Una prueba de integración revisa la interacción entre componentes. Una prueba de sistema evalúa el conjunto y una de aceptación contrasta necesidades acordadas. Las pruebas de regresión buscan que un cambio no dañe funciones existentes. Estas categorías no son equivalentes a nivel de seguridad: cada una puede incluir comprobaciones relacionadas con protección.

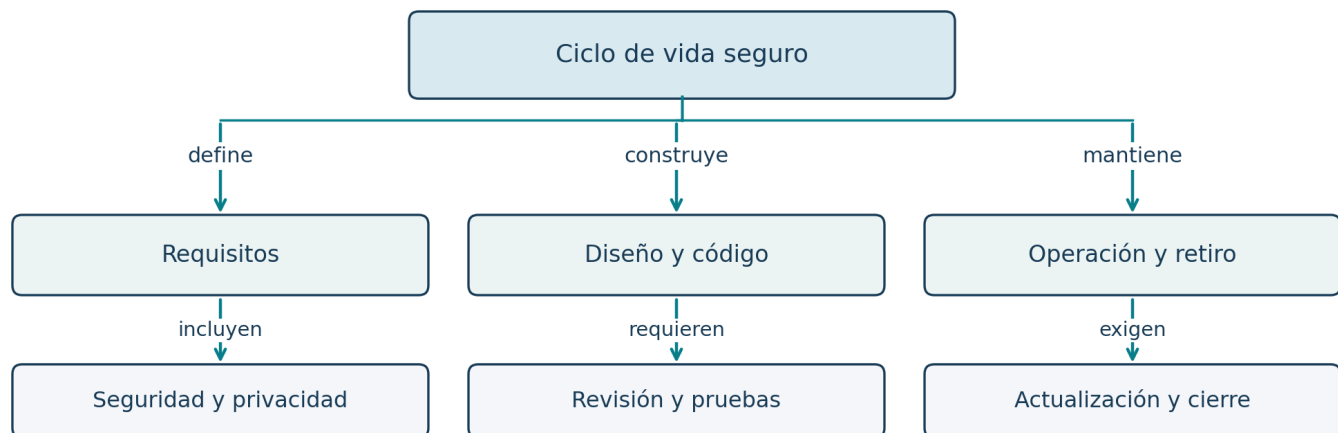
SAST analiza código sin ejecutar la aplicación; DAST observa un sistema en ejecución; SCA examina componentes y dependencias. Sus resultados requieren interpretación. Una herramienta puede señalar una posibilidad que no es explotable en el contexto o no detectar una regla de negocio mal definida. El criterio del analista sigue siendo necesario.

Entender el riesgo de un cambio

Una biblioteca actualizada puede corregir una vulnerabilidad y modificar un comportamiento utilizado por la aplicación. La respuesta adecuada combina revisión de exposición, pruebas y despliegue controlado. Un plan de reversión indica cómo recuperar operación si el cambio falla. Debe considerar si la estructura de datos también cambió, porque volver al ejecutable anterior puede no ser suficiente.

Caso comentado. Al retirar una aplicación, queda una cuenta con privilegios sobre la base de datos. Aunque ya no existan usuarios en su interfaz, continúa una vía de acceso. El retiro seguro debe tratar secretos, cuentas, datos, respaldos y obligaciones de conservación. El ciclo termina cuando se gestionan esas dependencias, no cuando se elimina el acceso directo.

Mapa de relaciones para explicar el tema



Mapa conceptual 14 Ciclo de vida seguro

Preguntas y casos del indicador 14

Aplicación del aprendizaje. Relacionar cada etapa del sistema con los riesgos y controles que le corresponden.

1 Requisitos verificables

Un requisito dice «la aplicación será segura». ¿Por qué debe precisarse antes de diseñar las pruebas?

Explicación. No indica una condición observable de aceptación. «Cada docente consultará solo sus grupos asignados» permite casos autorizados y denegados. La seguridad debe traducirse en comportamientos comprobables, no quedar como un adjetivo general.

2 Riesgo en implementación

El código construye consultas mezclando instrucciones SQL y texto recibido. ¿En qué etapa aparece la debilidad y qué tratamiento corresponde?

Explicación. La implementación introduce una posible inyección. La parametrización separa estructura de consulta y valores. Revisar requisitos y pruebas también ayuda, pero cambiar colores de la interfaz o cifrar el canal no corrige esa construcción insegura.

3 Pruebas de frontera

Una inscripción permite edades de 15 a 18 inclusive. ¿Qué datos de prueba distinguen mejor los límites?

Explicación. Conviene incluir 14, 15, 18 y 19, además de datos inválidos pertinentes. Así se comprueban rechazo exterior y aceptación de los extremos. Probar solo 16 confirma un caso interior, pero no detecta errores en los operadores del límite.

4 Regresión tras un parche

Una actualización corrige una vulnerabilidad y modifica la biblioteca usada para facturar. ¿Por qué se requieren pruebas de regresión?

Explicación. Para comprobar que el cambio no dañó funciones que antes operaban. Corregir una vulnerabilidad no garantiza compatibilidad funcional. Deben verificarse procesos afectados y preparar recuperación, considerando también cambios en datos y configuración.

5 Retiro del sistema

Se apaga una aplicación, pero permanecen su cuenta de servicio y una base accesible. ¿Terminó el tratamiento de riesgos del ciclo de vida?

Explicación. No. El retiro debe gestionar credenciales, permisos, datos, copias y dependencias remanentes. Que la pantalla ya no abra no elimina otros accesos. La conservación necesaria y la eliminación autorizada deben definirse de forma separada.

15 Capas de protección del software

Programación y pruebas de la seguridad del software · Nivel 11 · Indicador 9.1 · Tabla página 5

Indicador de logro. Reconoce las capas de protección de software.

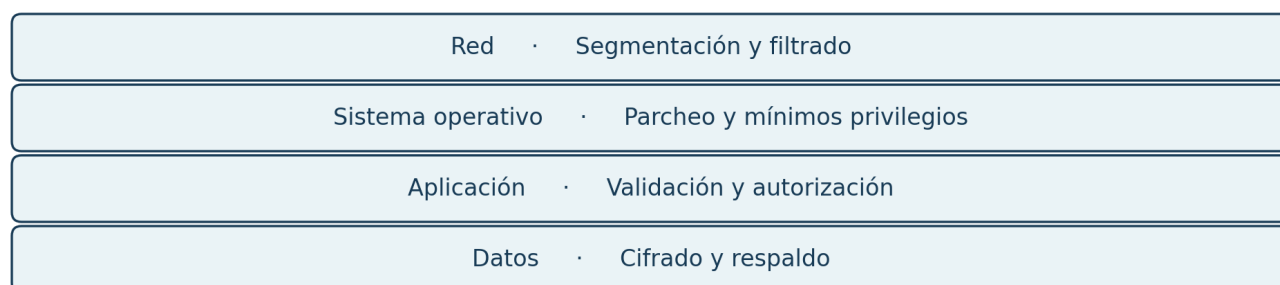
Propósito de aprendizaje. Explicar cómo controles complementarios limitan un ataque y su impacto.

Conceptos fundamentales

La defensa en profundidad utiliza controles en varias capas, de manera que una falla no exponga todo el sistema. Las capas pueden incluir dispositivo, sistema operativo, red, aplicación, identidad, datos y gestión. No consiste en instalar varias herramientas idénticas sin analizar qué protegen.

La red puede limitar puertos mediante firewall y separar zonas. El SO aplica actualizaciones y permisos. La aplicación valida entradas y autoriza operaciones. La base de datos restringe cuentas y mantiene integridad. Los registros y alertas permiten detectar actividad y responder.

La validación de entrada comprueba tipo, formato, rango y reglas. La codificación de salida adapta datos al contexto donde se mostrarán y ayuda a evitar interpretación como código, por ejemplo en HTML. Las consultas parametrizadas separan instrucciones SQL de valores. Son controles relacionados, pero no intercambiables.



Esquema aplicado Controles complementarios en capas distintas

Caso resuelto. El navegador oculta el botón Eliminar, pero el servidor acepta la petición de cualquier usuario autenticado. Falta autorización en el servidor. Un firewall no conoce necesariamente la regla de negocio sobre quién puede borrar cada documento. Reducir privilegios de la cuenta de base de datos añade otra barrera si falla la aplicación.

Gestión de sesiones. Después del acceso, una sesión identifica la interacción autenticada. Sus tokens deben protegerse, tener vigencia apropiada y poder revocarse. La aplicación no debe confiar en un rol enviado por el propio cliente sin verificarlo.

Un control preventivo intenta impedir el abuso; uno detectivo permite observarlo; uno correctivo limita consecuencias o restaura. Registrar un ataque no implica haberlo bloqueado. Del mismo modo, cifrar un archivo no decide quién tiene permiso para descifrarlo.

Seguir las barreras que encuentra una solicitud

Una solicitud llega por la red, alcanza un servicio del sistema operativo y es interpretada por una aplicación que consulta datos. Cada etapa puede aplicar controles. El firewall limita comunicaciones; los permisos del sistema restringen recursos; la aplicación comprueba identidad y reglas; la base de datos limita operaciones de su cuenta. Estas barreras no son copias idénticas: atienden fallas diferentes.

Si todas las capas comparten la misma credencial administrativa, aumenta la dependencia común. Si un fallo permite obtener esa credencial, podrían caer varias barreras. La defensa en profundidad necesita independencia razonable y revisión de relaciones. Agregar tres productos con una configuración igualmente abierta no multiplica automáticamente la protección.

Tres controles de aplicación que suelen confundirse

La validación de entrada revisa si un valor tiene tipo, formato y rango admisibles. La codificación de salida transforma caracteres según el contexto donde se mostrarán, para evitar interpretación no deseada. La parametrización separa la estructura de una consulta de los valores que recibe. Validar una longitud no reemplaza parametrizar SQL; parametrizar SQL no evita por sí solo mostrar contenido peligroso en HTML.

La autorización se pregunta quién puede ejecutar la operación sobre el recurso. Debe aplicarse después de identificar al usuario y cada vez que sea necesario. Un identificador difícil de adivinar puede reducir descubrimiento accidental, pero no sustituye comprobar el permiso.

Diseñar para limitar consecuencias

Suponga que un error en la aplicación permite una consulta indebida. Una cuenta de base de datos con permiso solo de lectura limita ciertas modificaciones; una cuenta administradora aumenta el alcance potencial. El registro puede ayudar a detectar la acción y el respaldo a recuperar daños. Sin embargo, un respaldo no evita la lectura indebida ni borra una copia extraída.

Razonamiento transferible. Para evaluar un control, formule dos preguntas: qué acción impide o detecta y qué ocurre si falla. Esa segunda pregunta permite identificar la siguiente barrera. La seguridad por capas resulta de esta relación entre funciones, no de una lista de herramientas compradas.

Mapa de relaciones para explicar el tema



Mapa conceptual 15 Defensa en profundidad

Preguntas y casos del indicador 15

Aplicación del aprendizaje. Explicar cómo controles complementarios limitan un ataque y su impacto.

1 Controles por capas

Un firewall permite HTTPS a un portal que no comprueba propiedad de expedientes. ¿Por qué el filtrado no basta?

Explicación. El firewall permite una comunicación, pero la aplicación debe autorizar cada recurso. Las capas atienden decisiones distintas. Un canal permitido puede transportar una solicitud indebida; la defensa necesita controles coherentes en red, identidad, aplicación y datos.

2 Validación de entrada

Un formulario recibe cantidad negativa cuando solo admite cantidades positivas. ¿Qué control responde directamente a ese caso?

Explicación. Validación de rango y reglas en el servidor. La comprobación del navegador ayuda al usuario, pero puede eludirse. Cifrar el envío protege el transporte de esa cantidad; no la convierte en un valor admisible.

3 Codificación de salida

Un comentario recibido se muestra en una página y el navegador lo interpreta como código. ¿Qué protección debe considerar el contexto de salida?

Explicación. La codificación de salida apropiada y el tratamiento seguro del contenido reducen interpretación ejecutable no deseada. El control depende del contexto HTML, atributo u otro. Parametrizar SQL atiende consultas y no sustituye automáticamente esa protección del navegador.

4 Cuenta de base de datos

Una aplicación de consulta se conecta como administrador de toda la base. ¿Cómo aumenta el impacto de una falla?

Explicación. Una solicitud abusiva puede disponer de facultades innecesarias para modificar o eliminar datos. Una cuenta con permisos mínimos limita consecuencias. No corrige toda falla del programa, pero añade una barrera distinta que reduce el alcance del abuso.

5 Clasificar por función

Un filtro bloquea una acción, una bitácora la registra y una restauración recupera datos. ¿Qué funciones representan?

Explicación. Preventiva, detectiva o de observación, y correctiva o recuperativa, respectivamente, según su uso. Son clasificaciones funcionales. Registrar no equivale a bloquear; disponer de respaldo no impide que se consulte información antes de una recuperación.

16 Características y modelos de implementación de nube

Programación y pruebas de la seguridad del software · Nivel 11 · Indicador 10.1 · Tabla página 5

Indicador de logro. Distingue características de los servicios en la nube según el modelo relación y el tipo de servicio nube.

Propósito de aprendizaje. Distinguir qué hace que un servicio sea nube y a quién está destinada su infraestructura.

Conceptos fundamentales

La computación en nube ofrece acceso a recursos compartidos que pueden aprovisionarse con rapidez. Entre sus características se encuentran autoservicio bajo demanda, acceso por red, agrupación de recursos, elasticidad y servicio medido. Elasticidad ajusta recursos a la demanda; escalabilidad es capacidad de crecer. Tener una página en Internet no demuestra por sí solo todas estas características. [F4]

Los modelos de implementación indican para quién se dispone la nube y cómo se relacionan infraestructuras. No deben confundirse con IaaS, PaaS y SaaS, que describen qué nivel de servicio se entrega.

Modelo	Característica decisiva	Ejemplo
Pública	Oferta para uso abierto de clientes.	Proveedor que comercializa recursos compartidos.
Privada	Uso exclusivo de una organización.	Nube institucional, incluso administrada por un tercero.
Comunitaria	Uso de una comunidad con intereses comunes.	Entidades con requisitos compartidos.
Híbrida	Composición de nubes distintas vinculadas.	Integración privada y pública para una carga.

La ubicación física no define por sí sola el modelo: una nube privada puede estar fuera de la institución. Multinube significa usar más de un proveedor o nube; no necesariamente implica una integración híbrida. La multitenencia permite compartir infraestructura manteniendo separación lógica entre clientes.

Caso resuelto. Una entidad mantiene expedientes en una nube exclusiva y utiliza una pública integrada para absorber aumentos de demanda. El modelo es híbrido. La respuesta no se determina por que exista acceso web, sino por la combinación de entornos.

Riesgos que deben analizarse. Dependencia del proveedor, conectividad, localización y transferencia de datos, permisos, visibilidad de incidentes y salida del servicio. Un SLA establece compromisos de servicio, pero no equivale a garantizar disponibilidad absoluta.

Qué significa consumir recursos como servicio

Cuando una organización solicita capacidad de cómputo en una plataforma, puede disponer de recursos sin comprar físicamente cada servidor. El autoservicio bajo demanda permite aprovisionar según los mecanismos ofrecidos; el acceso por red permite utilizar el servicio desde clientes compatibles; la agrupación de recursos sostiene múltiples consumidores. La medición registra uso para administrar y, según el contrato, cobrar. Estas características explican por qué no toda página alojada en Internet representa por sí sola todos los rasgos de nube.

La elasticidad ajusta recursos a variaciones de demanda. La escalabilidad describe capacidad de aumentar o reducir capacidad mediante el diseño. Una aplicación puede escalar agregando instancias o aumentando recursos de una instancia, pero necesitar ajustes en la base de datos y el balanceo. Encender más servidores no corrige cualquier cuello de botella.

Separar propiedad de ubicación

Una nube privada se destina al uso exclusivo de una organización y puede administrarse dentro o fuera de sus instalaciones. Una pública ofrece recursos a un conjunto abierto de clientes conforme al servicio. Una comunitaria atiende organizaciones con intereses comunes. Una híbrida combina infraestructuras distintas con una integración que permite determinadas operaciones. Usar dos proveedores sin integración no demuestra automáticamente una arquitectura híbrida.

La multitenencia permite compartir infraestructura manteniendo separación lógica entre consumidores. La separación requiere controles de plataforma y configuración; no debe suponerse que compartir hardware equivale a compartir permisos sobre datos.

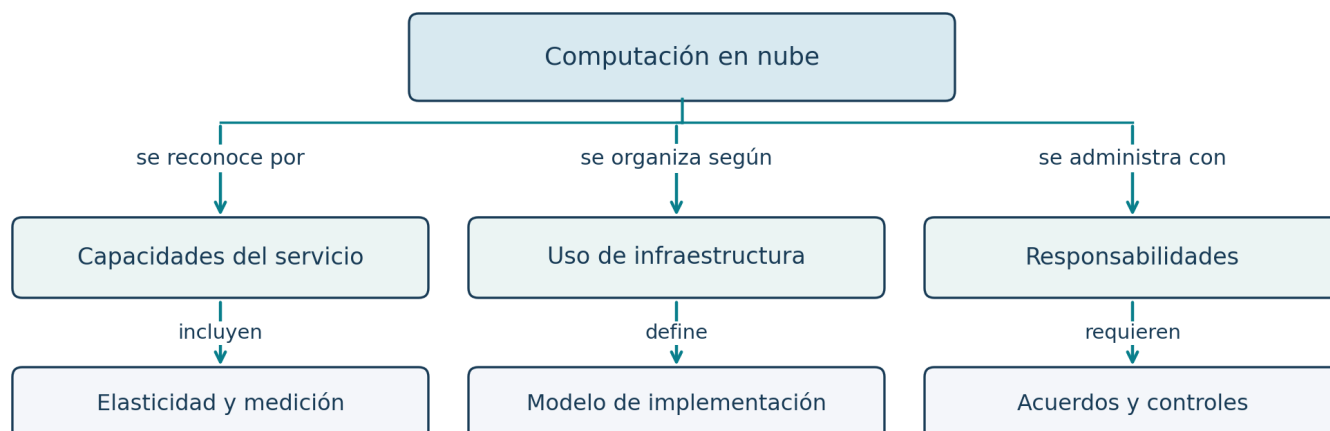
Analizar una decisión de migración

Una tienda tiene demanda elevada solo en temporadas. La nube puede facilitar ajustes de capacidad, pero deben valorarse costo total, dependencia del proveedor, conectividad, protección de datos y recuperación. Un SLA especifica compromisos y condiciones, no ausencia de toda interrupción. También importa la portabilidad: cómo recuperar datos o trasladar la aplicación si cambia el contrato.

Caso explicado. Un expediente se guarda en una nube privada, pero su enlace de acceso queda público. El modelo de implementación no corrige el permiso. El análisis debe mantener separadas arquitectura de infraestructura y autorización sobre cada recurso. Confundirlas

produce la falsa conclusión de que privado significa automáticamente inaccesible para terceros.

Mapa de relaciones para explicar el tema



Mapa conceptual 16 Computación en nube

Preguntas y casos del indicador 16

Aplicación del aprendizaje. Distinguir qué hace que un servicio sea nube y a quién está destinada su infraestructura.

1 Reconocer elasticidad

Un servicio agrega capacidad durante matrícula y la reduce al terminar la demanda. ¿Qué característica se ilustra?

Explicación. Elasticidad: ajuste de recursos a variaciones de demanda mediante el diseño del servicio. Escalabilidad expresa capacidad de crecer. Una instalación que solo permite ampliar manualmente no demuestra por ese hecho ajuste elástico en ambas direcciones.

2 Nube privada fuera de la institución

Una infraestructura se destina exclusivamente a una organización, pero está administrada por un proveedor externo. ¿Puede ser nube privada?

Explicación. Sí, si cumple las características correspondientes de nube y uso exclusivo. La ubicación fuera del edificio no la convierte necesariamente en pública. Deben distinguirse destinatarios, propiedad, administración y ubicación física.

3 Nube híbrida y multinube

Una organización contrata dos proveedores sin integrar sus entornos. ¿Demuestra eso una nube híbrida?

Explicación. Demuestra uso de varios proveedores, pero no necesariamente composición híbrida. Una nube híbrida relaciona infraestructuras de nube distintas mediante una integración apropiada. La cantidad de contratos no basta para clasificar la arquitectura.

4 Nube comunitaria

Varias instituciones con requisitos compartidos utilizan una infraestructura destinada a esa comunidad. ¿Qué modelo describe esa organización?

Explicación. Nube comunitaria, si se cumplen las características de servicio correspondientes. Su criterio es el uso por una comunidad con intereses comunes. No se define simplemente porque varias personas tengan cuentas ni porque el acceso se haga desde Internet.

5 Servicio medido

Un proveedor registra consumo de almacenamiento y procesamiento por cliente. ¿Qué característica aparece y qué no demuestra?

Explicación. Aparece medición del servicio. Puede facilitar administración y cobro, pero no demuestra automáticamente ahorro, seguridad ni disponibilidad absoluta. Para valorar una migración deben analizarse consumo esperado, contrato, dependencias y recuperación, además de esa característica.

17 Servicios IaaS PaaS y SaaS

Programación y pruebas de la seguridad del software · Nivel 11 · Indicador 11.1 · Tabla página 6

Indicador de logro. Identifica conceptos y formas de organización nube IaaS, PaaS y SaaS.

Propósito de aprendizaje. Identificar qué administra el proveedor y qué conserva bajo su responsabilidad el cliente.

Conceptos fundamentales

Los modelos de servicio describen cuánto de la solución entrega el proveedor. En IaaS, infraestructura como servicio, el cliente utiliza recursos de cómputo, red y almacenamiento y normalmente administra el sistema operativo invitado y sus aplicaciones. En PaaS, plataforma como servicio, despliega código sobre una plataforma administrada. En SaaS, software como servicio, utiliza una aplicación ya operativa.

Responsabilidad típica	IaaS	PaaS	SaaS
Hardware físico	Proveedor	Proveedor	Proveedor
SO de la plataforma o invitado	Cliente en su VM	Proveedor	Proveedor
Código de la aplicación ofrecida	Cliente	Cliente en su aplicación	Proveedor
Identidades y permisos de uso	Responsabilidad del cliente según servicio	Responsabilidad del cliente según servicio	Responsabilidad del cliente según servicio
Datos y configuración del cliente	Cliente y acuerdos del servicio	Cliente y acuerdos del servicio	Cliente y acuerdos del servicio

La tabla resume responsabilidades típicas; el contrato y la configuración concretan su reparto. El cliente no deja de ser responsable de decisiones sobre acceso o tratamiento de sus datos porque utilice SaaS. El proveedor puede administrar la aplicación sin conocer qué usuario de la organización debe tener permiso sobre cada recurso.

Tres casos resueltos. Una VM donde el equipo instala Linux corresponde a IaaS. Un entorno que recibe el código y administra el sistema y el runtime corresponde a PaaS. Un correo web terminado, donde se crean cuentas y se utiliza el servicio, corresponde a SaaS.

La palabra «servidor» o «suscripción» no basta para clasificar. Observe quién instala, actualiza y administra cada capa. Tampoco pública equivale a SaaS: pueden existir servicios IaaS en una nube pública y aplicaciones SaaS destinadas a distintos grupos.

Reconocer quién administra cada componente

En IaaS se contratan recursos como máquinas virtuales, redes y almacenamiento. El proveedor administra la infraestructura física; el cliente normalmente instala o configura el sistema invitado y sus aplicaciones. En PaaS, el proveedor opera una plataforma donde el cliente despliega su código. En SaaS, el cliente utiliza una aplicación ya operativa. La pregunta decisiva es qué capa recibe y qué tareas conserva, no si paga una suscripción.

Imagine tres decisiones para ofrecer un sistema de reservas. En la primera se alquila una VM y se instala el servidor completo: IaaS. En la segunda se carga el código en un servicio que administra el entorno de ejecución: PaaS. En la tercera se contrata una aplicación de reservas y se configuran usuarios: SaaS. El objetivo de negocio puede ser el mismo, mientras cambia el reparto del trabajo técnico.

Responsabilidad compartida no significa responsabilidad inexistente

En SaaS, el proveedor puede mantener la aplicación y aun así el cliente debe decidir qué personas reciben acceso. Si comparte una carpeta con todo Internet, no puede asumir que el proveedor conoce que los archivos son confidenciales. En IaaS, omitir parches del sistema invitado puede quedar bajo responsabilidad del cliente, según el servicio. El contrato y la documentación concretan la separación.

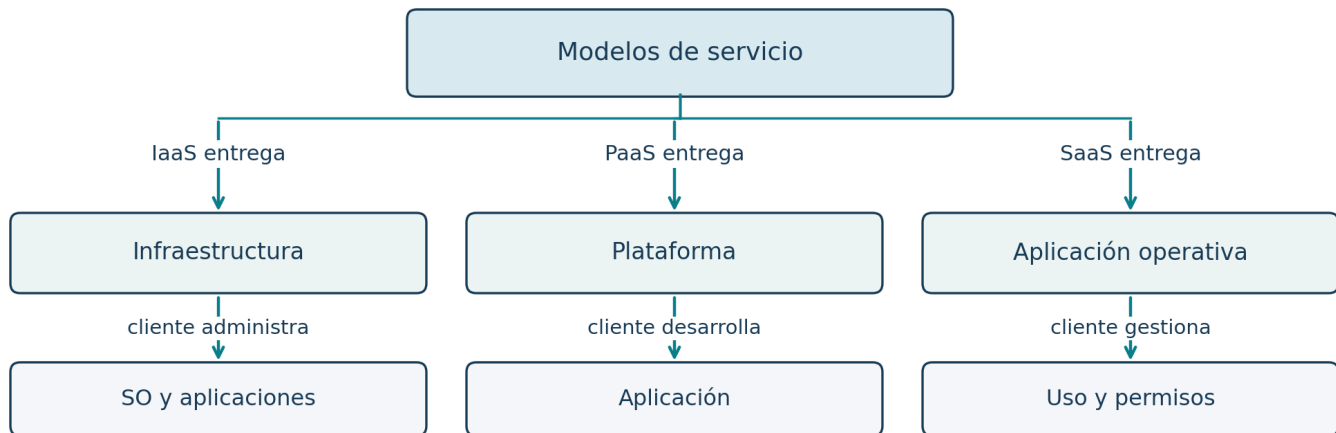
Los datos requieren decisiones de finalidad, clasificación, conservación y exportación. Los permisos, cuentas y dispositivos de acceso siguen siendo relevantes en los tres modelos. Una cuenta comprometida puede operar funciones legítimas de la aplicación, por lo que la infraestructura puede estar funcionando correctamente mientras ocurre abuso.

Interpretar un escenario de prueba

Si el caso menciona que el equipo instala Linux, configura servicios y aplica parches al invitado, existe evidencia de IaaS. Si solo desarrolla código sobre un entorno administrado, orienta a PaaS. Si administra usuarios dentro de una aplicación terminada, orienta a SaaS. Estas pistas son más útiles que memorizar marcas, porque un proveedor puede ofrecer varios modelos.

Comprensión ampliada. Mayor administración por parte del proveedor reduce ciertas tareas locales, pero puede disminuir control sobre versiones o configuración interna. La elección depende de capacidades del equipo, requisitos de la aplicación y obligaciones sobre los datos.

Mapa de relaciones para explicar el tema



Mapa conceptual 17 Modelos de servicio

Preguntas y casos del indicador 17

Aplicación del aprendizaje. Identificar qué administra el proveedor y qué conserva bajo su responsabilidad el cliente.

1 Infraestructura como servicio

Una empresa recibe VM y red virtual, instala su sistema operativo y aplica sus parches. ¿Qué modelo predomina?

Explicación. IaaS. El proveedor entrega infraestructura y el cliente administra normalmente el sistema invitado y las aplicaciones. La evidencia decisiva es qué capas gestiona cada parte. Que se acceda mediante navegador no convierte el servicio en SaaS.

2 Plataforma como servicio

Un equipo carga código en un entorno cuyo runtime y sistema operativo administra el proveedor. ¿Qué modelo corresponde?

Explicación. PaaS. El equipo desarrolla y configura su aplicación sobre una plataforma administrada. Sigue siendo responsable de aspectos de código, identidades y datos según el contrato. Delegar el sistema operativo no elimina errores de autorización de su aplicación.

3 Software como servicio

Una institución utiliza un correo ya operativo y administra cuentas y permisos. ¿Por qué corresponde a SaaS?

Explicación. Consume una aplicación ofrecida como servicio. No instala todo el entorno para construirla. La administración de cuentas y el uso correcto de datos siguen siendo necesarios; SaaS no significa que el proveedor conozca todas las decisiones internas de acceso.

4 Responsabilidad compartida

Un archivo queda público porque un administrador del cliente habilitó un enlace abierto. ¿Basta señalar que el almacenamiento es del proveedor?

Explicación. No. Debe analizarse quién controla esa configuración y las obligaciones del servicio. La infraestructura puede funcionar correctamente mientras existe una exposición

causada por permisos. El modelo ayuda a repartir tareas, pero el contrato concreta responsabilidades.

5 Elegir según la tarea

Un proyecto necesita controlar módulos del sistema operativo que una plataforma administrada no permite instalar. ¿Qué diferencia debe valorar?

Explicación. Necesita valorar el control disponible sobre la capa requerida. IaaS puede ofrecer mayor administración del invitado; PaaS reduce esas tareas y ciertas posibilidades. La elección debe responder a requisitos y capacidad de operación, no solo al precio anunciado.

18 Ciclo de vida y cifrado de datos en nube

Programación y pruebas de la seguridad del software · Nivel 11 · Indicador 11.2 · Tabla página 6

Indicador de logro. Describe el ciclo de vida en la seguridad en la nube por medio de la aplicación de modelos de entrega y cifrado de datos.

Propósito de aprendizaje. Seleccionar protecciones para los datos desde su creación hasta su eliminación.

Conceptos fundamentales

Los datos pueden crearse, almacenarse, utilizarse, compartirse, archivarse y eliminarse. Cada etapa genera riesgos distintos: recopilar información innecesaria, exponer un almacenamiento, conceder permisos excesivos, compartir copias sin control o conservar datos más tiempo del justificado.

El cifrado en tránsito protege información mientras se comunica, por ejemplo mediante TLS. El cifrado en reposo protege datos almacenados. Durante su uso, una aplicación autorizada puede necesitar datos legibles; existen tecnologías específicas para protección durante procesamiento, pero no debe asumirse que todo servicio las utiliza.

Una clave criptográfica controla una operación de cifrado o descifrado. Su gestión incluye generación segura, custodia, acceso, rotación cuando corresponde, recuperación y destrucción. Guardar la clave al lado del dato con los mismos permisos puede anular gran parte de la separación prevista.

Caso resuelto. Un almacenamiento cifra expedientes, pero una cuenta comprometida tiene permiso de descargarlos y solicitar descifrado. El cifrado no impide ese abuso. Deben tratarse identidad, MFA, privilegios, registros y acceso a claves; cambiar únicamente el nombre de los archivos no atiende la causa.

Configuración y continuidad. Revisar exposición pública, enlaces compartidos, cuentas de servicio, registros, copias y ubicación de datos. La responsabilidad compartida exige comprender tanto lo que protege el proveedor como lo que configura el cliente. Las copias necesitan recuperación probada y separación adecuada del entorno comprometido.

Al terminar el contrato, la organización debe poder recuperar lo que necesita, revocar accesos y verificar el tratamiento de datos, respaldos y claves. Cerrar una cuenta o perder acceso a la interfaz no demuestra que desaparecieron todas las copias.

Proteger información en estados distintos

Los datos en reposo están almacenados; los datos en tránsito se comunican; los datos en uso son procesados. Cifrar un disco protege ciertos accesos al soporte, pero una aplicación autorizada puede leer sus datos después de descifrarlos. TLS protege un canal, pero no decide si el usuario debe recibir el expediente. La protección debe seguir el recorrido completo.

Al crear un archivo se decide qué recopilar y con qué finalidad. Al usarlo se aplican permisos. Al compartirlo se comprueban destinatarios y alcance. Al archivarlo se define conservación. Al eliminarlo se tratan copias y obligaciones pendientes. Una clasificación puede cambiar si el contenido se combina con otra fuente o se publica una versión realmente anonimizada; el cambio requiere evaluación, no solo renombrar el archivo.

Las claves tienen su propio ciclo de vida

Una clave debe generarse de forma apropiada, almacenarse protegida, estar disponible para operaciones autorizadas y poder rotarse o retirarse según necesidad. Guardarla junto al archivo con idénticos permisos puede reducir la separación buscada. Un servicio de gestión de claves centraliza ciertas tareas, pero necesita roles, registros y mecanismos de recuperación.

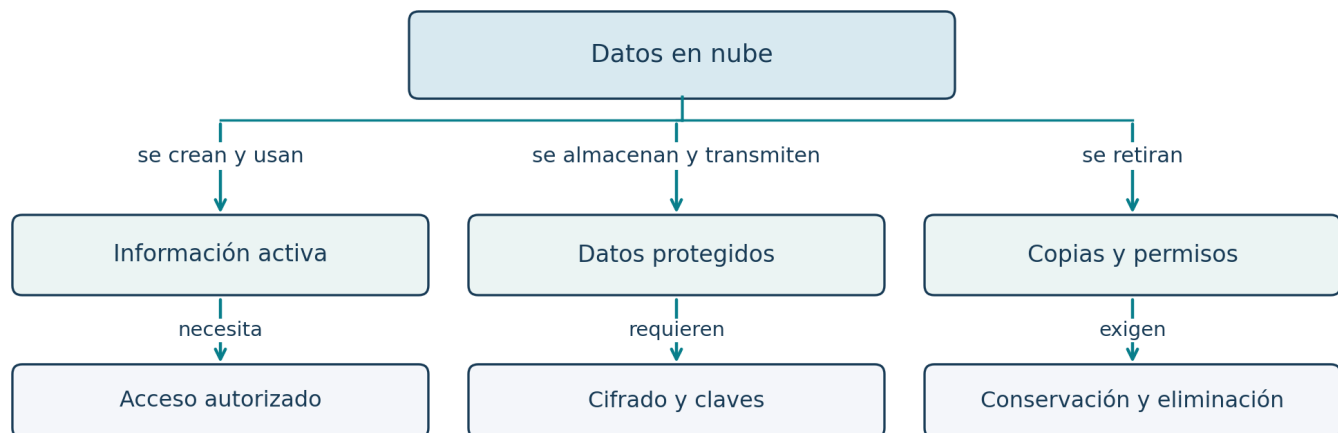
La rotación cambia material criptográfico conforme a un procedimiento. Debe considerar cómo seguir leyendo información anterior. Destruir una clave puede impedir acceso a datos cifrados, pero el borrado criptográfico solo funciona bajo condiciones adecuadas: no deben permanecer otras claves recuperables ni copias legibles que hagan inútil la medida.

Un retiro de servicio explicado

Antes de cerrar una suscripción, una empresa identifica qué información necesita conservar. Exporta los datos en un formato utilizable, verifica la integridad y prueba una restauración o lectura. Después revoca accesos y revisa condiciones de eliminación del proveedor, incluidos respaldos y retención. Cerrar sesión no ejecuta necesariamente todo ese proceso.

Situación para analizar. Un respaldo está cifrado, pero solo una persona conoce la clave y deja la organización. La confidencialidad pudo estar protegida, aunque la disponibilidad depende de una gestión deficiente de claves. La solución no es publicar la clave: consiste en un mecanismo de custodia y recuperación con autorización y trazabilidad.

Mapa de relaciones para explicar el tema



Mapa conceptual 18 Datos en nube

Preguntas y casos del indicador 18

Aplicación del aprendizaje. Seleccionar protecciones para los datos desde su creación hasta su eliminación.

1 Datos en tránsito

Un expediente viaja entre navegador y servidor mediante TLS. ¿Qué estado del dato se está protegiendo principalmente?

Explicación. El tránsito entre los extremos del canal. La protección no demuestra cifrado del archivo almacenado ni autorización para cada consulta. Es necesario separar comunicación, almacenamiento y uso para ubicar correctamente el control.

2 Datos en reposo

Se cifra un disco, pero una sesión autorizada puede abrir sus archivos. ¿Por qué no existe contradicción?

Explicación. El cifrado en reposo protege determinadas formas de acceso al soporte. Durante el uso autorizado el sistema puede descifrar los datos. Una cuenta comprometida con permiso de lectura exige controles adicionales; cifrar almacenamiento no elimina la necesidad de autorización.

3 Custodia de claves

El respaldo está cifrado y la única clave se pierde. ¿Qué propiedad puede quedar comprometida aunque nadie haya leído los archivos?

Explicación. La disponibilidad, porque podría ser imposible recuperar información. La gestión de claves debe contemplar custodia y recuperación autorizada. Guardarlas junto a todos los datos con idénticos permisos puede, en cambio, debilitar la separación de seguridad buscada.

4 Conservación y eliminación

Termina un contrato de nube y se cierra la cuenta. ¿Eso prueba que desaparecieron datos, réplicas y respaldos?

Explicación. No. Deben revisarse condiciones de exportación, conservación y eliminación del servicio. El cierre de acceso es una acción distinta del tratamiento de copias. La organización debe recuperar lo necesario y verificar el procedimiento acordado.

5 Compartir una copia

Un informe pasa de carpeta restringida a enlace público. ¿Cambió solo su ubicación?

Explicación. También cambió su exposición y posiblemente su finalidad o destinatarios. Debe revisarse clasificación y autorización para compartir. Que el archivo estuviera cifrado antes o que no se altere su contenido no legitima automáticamente la publicación.

19 Diseño seguro de aplicaciones web y móviles

Programación y pruebas de la seguridad del software · Nivel 11 · Indicador 12.1 · Tabla página 6

Indicador de logro. Reconoce las tendencias del diseño seguro en el desarrollo de diferentes tipos de aplicaciones.

Propósito de aprendizaje. Relacionar principios de diseño con controles verificables desde el desarrollo.

Referencia para ampliar los saberes Programa de duodécimo páginas 84

Conceptos fundamentales

La seguridad desde el diseño integra requisitos y controles desde el inicio. La seguridad por defecto ofrece una configuración inicial protectora. La privacidad desde el diseño reduce exposición mediante finalidad, minimización y control del uso de datos. No basta con añadir un aviso de privacidad a una aplicación que publica todo por defecto.

Los principios incluyen mínimo privilegio, separación de funciones, comprobación de permisos en cada acceso y fallo seguro. Fallar de forma segura significa que un error no concede permisos indebidos. Los límites de confianza indican dónde cambian supuestos: navegador y servidor, aplicación y base de datos, o dispositivo y nube.

SAST analiza código sin ejecutar la aplicación; DAST prueba un sistema en ejecución desde su comportamiento; SCA identifica componentes y dependencias y ayuda a revisar sus riesgos. Son complementarios y pueden producir falsos positivos o no detectar fallas. DevSecOps integra seguridad en colaboración y automatización del ciclo de entrega.

Caso resuelto. Un perfil se crea privado, solicita únicamente permisos necesarios y verifica en el servidor quién puede leer cada dato. Aplica privacidad y seguridad por defecto. Si el servicio de permisos falla, permitir todo para mantener comodidad sería una falla insegura.

Secretos y componentes. Contraseñas, tokens y claves no deben quedar en repositorios públicos. Si se exponen, retirarlos del archivo actual no invalida las copias: se deben revocar o rotar y revisar actividad. Las dependencias necesitan inventario, versiones mantenidas y verificación de procedencia.

En móviles, los permisos deben justificarse por función; el almacenamiento local, sesiones y comunicación requieren protección. Un certificado válido de un sitio demuestra aspectos del canal y su identidad, no que cada contenido o servicio sea honesto.

Diseñar la seguridad antes de elegir pantallas

Una aplicación web suele separar navegador, servidor y datos; una aplicación móvil añade almacenamiento y permisos del dispositivo. El navegador o teléfono presenta la interfaz, pero no debe ser el único lugar donde se decide autorización. Una petición puede construirse fuera de esa interfaz. Por eso el servidor debe comprobar identidad, permiso, formato y regla de negocio antes de realizar una acción.

La seguridad por defecto establece una configuración inicial protectora. La privacidad desde el diseño incorpora minimización, finalidad y control durante todo el ciclo. Si un perfil comienza público y exige que la persona descubra cómo ocultarlo, no ofrece la misma protección inicial que un perfil privado con una decisión informada para compartir.

Entender límites de confianza y sesiones

Un límite de confianza aparece cuando cambia quién controla los datos o las decisiones. El servidor no debe aceptar como prueba de privilegio un campo enviado por el cliente que dice administrador. Debe obtener esa autorización de información confiable. Las sesiones necesitan identificadores protegidos, vencimiento y revocación; los cambios sensibles pueden requerir nueva comprobación de identidad.

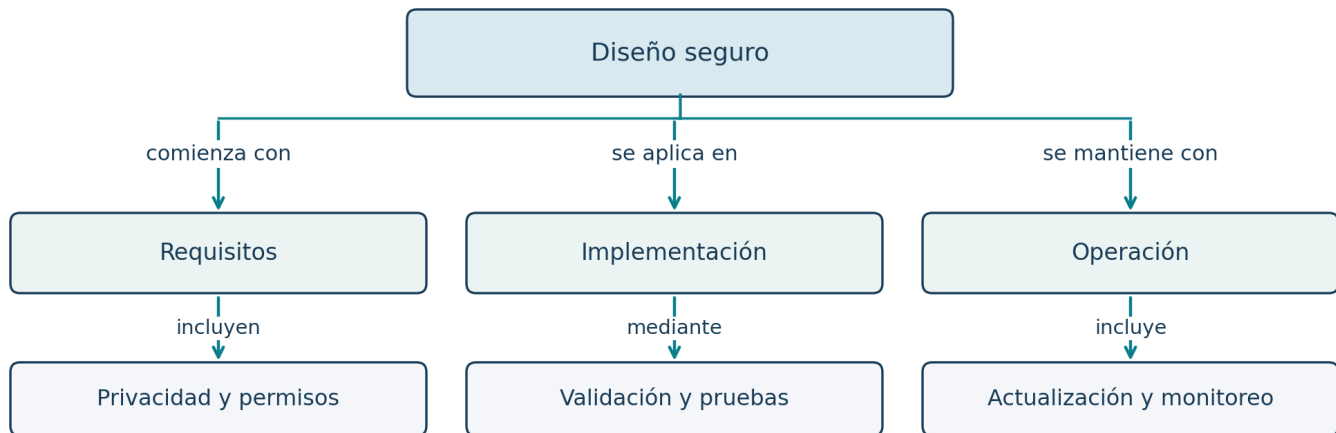
La fijación de sesión busca que una persona use un identificador conocido por un tercero. El secuestro de sesión consiste en apropiarse o abusar de una sesión válida. Renovar identificadores cuando corresponde, proteger cookies y transporte y controlar vencimiento reduce riesgos. Ningún atributo aislado resuelve todos los casos.

Verificar propiedades específicas

SAST revisa código; DAST prueba comportamiento en ejecución; SCA revisa componentes. A ello se añaden pruebas funcionales de autorización: un usuario A no debe consultar ni modificar recursos del usuario B sin permiso. Un resultado técnico sin hallazgos no reemplaza esa prueba si la herramienta desconoce la regla del negocio.

Ejemplo móvil. Una aplicación de notas solicita acceso permanente a contactos y ubicación sin justificarlo por sus funciones. Debe revisarse necesidad y limitar permisos. Instalarla desde una fuente conocida reduce ciertos riesgos de distribución, pero no decide por sí solo si la recopilación es necesaria. Una revisión de diseño conecta funcionalidad, datos pedidos y beneficio real para la persona usuaria.

Mapa de relaciones para explicar el tema



Mapa conceptual 19 Diseño seguro

Preguntas y casos del indicador 19

Aplicación del aprendizaje. Relacionar principios de diseño con controles verificables desde el desarrollo.

1 Privacidad por defecto

Una aplicación publica perfiles nuevos hasta que cada estudiante cambia la configuración. ¿Qué alternativa reduce exposición inicial?

Explicación. Crear perfiles con visibilidad restringida apropiada y decisiones informadas para compartir. Es privacidad por defecto. Un aviso legal no sustituye esa configuración, y ocultar perfiles tampoco resuelve por sí solo todas las reglas de tratamiento de datos.

2 Límites de confianza

El navegador envía un campo que dice rol igual a administrador. ¿Debe el servidor aceptarlo como prueba de privilegios?

Explicación. No. El cliente puede modificarse. El servidor debe obtener la autorización de información confiable y verificarla en la operación solicitada. El límite de confianza exige tratar datos recibidos como entradas por comprobar, no como decisiones ya válidas.

3 Sesiones

Después de autenticar a una persona, la aplicación conserva el mismo identificador de sesión que un tercero conocía previamente. ¿Qué riesgo se relaciona?

Explicación. Puede facilitar fijación de sesión según el diseño. Regenerar identificadores en transiciones pertinentes y proteger su uso reduce ese riesgo. La contraseña correcta no garantiza que el mecanismo de sesión esté bien diseñado.

4 Análisis complementarios

Se revisan código sin ejecutarlo, comportamiento del servicio activo y bibliotecas incluidas. ¿Qué enfoques corresponden?

Explicación. SAST, DAST y SCA, respectivamente. Examinan dimensiones diferentes. Un resultado sin hallazgos en uno no reemplaza los demás ni prueba todas las reglas del negocio; deben añadirse pruebas específicas de permisos y de datos pertinentes.

5 Permisos en móviles

Una calculadora solicita ubicación permanente y acceso a contactos. ¿Qué pregunta de diseño debe responder antes de concederlos?

Explicación. Debe justificarse la necesidad de cada permiso para la función ofrecida. El principio de minimización reduce datos y accesos innecesarios. Una aplicación de una tienda conocida puede seguir solicitando permisos excesivos; procedencia y necesidad son comprobaciones distintas.

20 Ley de Murphy y vulnerabilidades web

Programación y pruebas de la seguridad del software · Nivel 12 · Indicador 13.1 · Tabla página 6

Indicador de logro. Identifica usos de la ley de Murphy aplicada a la seguridad.

Propósito de aprendizaje. Utilizar la anticipación de fallos para analizar riesgos y probar controles de aplicaciones.

Referencia para ampliar los saberes Programa de duodécimo páginas 84 y 85

Conceptos fundamentales

La ley de Murphy es una idea práctica sobre anticipar que algo susceptible de fallar puede hacerlo en una situación desfavorable. No es una fórmula de probabilidad ni prueba de que todos los fallos ocurrirán. En seguridad se utiliza para evitar depender únicamente del camino exitoso.

Pregunte qué sucede si se pierde la conexión, llega una entrada inesperada, falla un proveedor o está ausente la persona responsable. Diseñe validaciones, transacciones, recuperación, registro y procedimientos alternativos. Un control debe comprobarse también cuando otra parte del sistema no funciona.

OWASP publica recursos sobre riesgos y desarrollo seguro de aplicaciones. Conviene comprender las causas de las vulnerabilidades, sin reducir el estudio a memorizar el número de una categoría que puede cambiar de versión.

Debilidad	Qué ocurre	Control relacionado
Inyección SQL	Datos se interpretan como parte de la consulta.	Consultas parametrizadas.
XSS	Contenido no confiable se interpreta como código en el navegador.	Codificación contextual y controles de entrada y contenido.
Acceso indebido a objetos	Un usuario opera sobre recursos ajenos.	Autorización por recurso en el servidor.

Debilidad	Qué ocurre	Control relacionado
CSRF	Se induce una operación aprovechando una sesión existente.	Verificación de origen y mecanismos anti CSRF.
Configuración insegura	Servicios, cuentas o detalles quedan expuestos.	Configuración mínima y revisión del entorno.

Caso resuelto. El sistema registra un pago, pero pierde la confirmación. Repetir la operación puede cobrar dos veces. Un identificador estable y una consulta de estado permiten reintentar sin duplicar el efecto. Prever esa combinación aplica el razonamiento preventivo asociado a Murphy.

No es necesario atacar sistemas reales para comprender estas fallas. Las comprobaciones se realizan con autorización y en entornos adecuados. Un escaneo automático no reemplaza comprender reglas de negocio ni verificar cada resultado.

Usar la ley de Murphy como una pregunta de diseño

La ley de Murphy no calcula probabilidades ni demuestra que toda falla ocurrirá. En seguridad sirve como invitación a revisar lo que el caso exitoso deja fuera: una conexión se corta, un dato llega vacío, un usuario repite una solicitud, un componente no responde o una cuenta conserva privilegios. La respuesta es diseñar y probar condiciones de falla concretas.

En una compra de boletos, el sistema puede guardar el pago y perder la conexión antes de mostrar confirmación. Repetir la operación sin consultar su estado puede cobrar dos veces. Un identificador de operación y una ejecución controlada permiten reconocer el intento anterior. La protección de integridad surge de cómo se administra el estado, no solo de cifrar el formulario.

Distintuir mecanismos de vulnerabilidad web

En inyección SQL, información no confiable altera la interpretación de una consulta cuando se construye de forma insegura. Las consultas parametrizadas mantienen separados valores y estructura. En inyección de comandos, una entrada puede alterar una operación enviada a un intérprete del sistema; conviene evitar construir comandos con texto recibido y usar interfaces seguras con argumentos y restricciones apropiados.

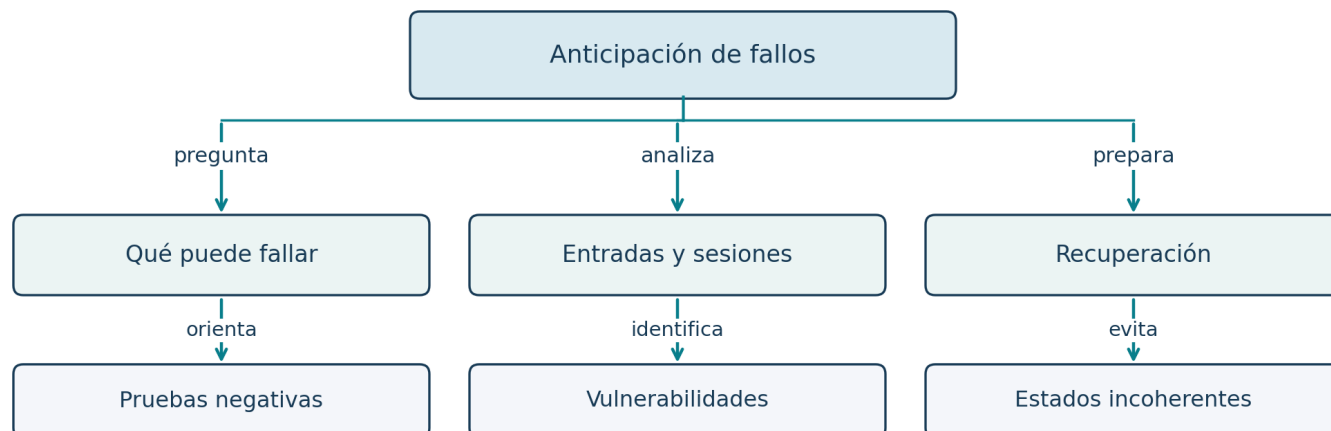
En XSS, contenido no confiable se interpreta como código en el navegador. La defensa depende del contexto de salida y del tratamiento del contenido. En CSRF, se intenta inducir una operación utilizando una sesión ya autenticada; se requieren mecanismos que validen el origen o intención conforme al diseño. Un control de SQL no resuelve automáticamente XSS ni CSRF.

Analizar acceso URL y redirecciones

Ocultar una dirección no constituye autorización. Cada solicitud a un recurso necesita control en el servidor. Una redirección que acepta cualquier destino puede conducir a un sitio engañoso aunque el enlace inicial pertenezca a una organización legítima. Deben limitarse destinos y verificarse parámetros según la función.

Decálogo explicado. Defina permisos; reduzca datos; valide entradas; codifique salidas; parametrize consultas; proteja sesiones; custodie secretos; mantenga dependencias; registre sin exponer datos; pruebe fallas y recuperación. Estas acciones deben convertirse en comprobaciones específicas. Una lista marcada sin evidencias no demuestra que la aplicación cumpla sus requisitos.

Mapa de relaciones para explicar el tema



Mapa conceptual 20 Anticipación de fallos

Preguntas y casos del indicador 20

Aplicación del aprendizaje. Utilizar la anticipación de fallos para analizar riesgos y probar controles de aplicaciones.

1 Anticipación de fallas

Una venta registra el pago y falla antes de mostrar confirmación. ¿Cómo ayuda aplicar el razonamiento asociado a Murphy?

Explicación. Obliga a prever ese estado incompleto, consultar el resultado y controlar reintentos para evitar doble cobro. No predice matemáticamente que todo fallará. Su utilidad es convertir posibilidades de falla en condiciones concretas de diseño y prueba.

2 Inyección SQL

El servidor concatena una entrada del usuario dentro de una consulta. ¿Por qué parametrizar atiende la causa mejor que esconder mensajes de error?

Explicación. Parametrizar separa valores de la estructura SQL. Ocultar errores reduce divulgación, pero puede conservar la construcción insegura. Los controles no son intercambiables: uno evita una interpretación indebida y el otro limita información expuesta.

3 XSS

Un comentario almacenado se interpreta como script al mostrarlo a otros usuarios. ¿Dónde ocurre la ejecución relevante y qué debe protegerse?

Explicación. En el navegador de quienes ven el contenido. Deben emplearse tratamiento seguro y codificación apropiada al contexto de salida. El hecho de que el comentario provenga de la propia base de datos no lo vuelve confiable para ejecutarlo.

4 CSRF

Se intenta inducir al navegador autenticado a enviar una operación que la persona no quiso realizar. ¿Qué diferencia hay respecto de adivinar su contraseña?

Explicación. Se aprovecha una sesión existente para inducir una solicitud, no necesariamente se obtiene la contraseña. Las defensas verifican origen e intención según el diseño, con mecanismos anti CSRF. Cambiar solo el texto del botón no valida la solicitud recibida.

5 Redirecciones y URL

Un enlace institucional acepta cualquier dirección de destino y lleva a una página de engaño. ¿Qué control y qué distinción son pertinentes?

Explicación. Deben limitarse y validarse destinos según la función. Que el enlace inicial sea legítimo no demuestra legitimidad del destino. También debe distinguirse ocultar una URL de autorizar un recurso: una ruta poco visible puede seguir accesible sin permiso.

21 Riesgos de red móviles datos y servidores

Programación y pruebas de la seguridad del software · Nivel 12 · Indicador 14.1 · Tabla página 6

Indicador de logro. Distingue las características de los riesgos de red, móvil, en los datos y el servidor.

Propósito de aprendizaje. Diferenciar el lugar del riesgo, su mecanismo y la medida que responde al caso.

Referencia para ampliar los saberes Programa de duodécimo páginas 85 y 86

Conceptos fundamentales

Un riesgo puede afectar varios componentes a la vez. La superficie de ataque incluye interfaces expuestas, credenciales, servicios y datos. Una debilidad del servidor puede facilitar robo de datos; un teléfono comprometido puede exponer sesiones que luego se utilizan en otros sistemas.

Ámbito	Riesgos frecuentes	Medidas relacionadas
Red	Intercepción, suplantación y servicios expuestos.	Cifrado, segmentación y control de comunicaciones.
Móvil	Permisos excesivos, aplicaciones falsas y pérdida del equipo.	Fuentes confiables, actualizaciones y protección del dispositivo.
Datos	Acceso excesivo, filtración y alteración.	Autorización, integridad, cifrado y respaldo.
Servidor	Parches faltantes, configuración débil y secretos expuestos.	Endurecimiento, mínimos privilegios y monitoreo.

El phishing utiliza suplantación para obtener datos o inducir acciones. Spear phishing se dirige a una persona o grupo; smishing utiliza mensajes SMS; vishing, voz. El engaño puede solicitar una clave, instalar un programa o aprobar una petición MFA. Una técnica de fatiga MFA insiste con solicitudes para obtener una aprobación indebida.

Compruebe dominio y contexto por un canal independiente. La urgencia, un logotipo o HTTPS no bastan para confiar. Un código QR también puede llevar a una página falsa. Nunca debe aprobarse una solicitud de acceso que no se inició o no se reconoce.

Caso resuelto. Un supuesto soporte solicita instalar una herramienta y compartir un código de acceso. El riesgo es ingeniería social con posible control remoto. Corresponde verificar la solicitud por los medios institucionales y reportar el intento; la apariencia profesional del mensaje no demuestra legitimidad.

Un mismo incidente puede recorrer varios componentes

Una persona se conecta a una red que imita el nombre de la institucional, abre una página falsa y entrega una credencial. El engaño puede comenzar en la red, continuar en el navegador y terminar en un servidor legítimo mediante una cuenta comprometida. Clasificar el riesgo exige reconocer el punto descrito por la pregunta. No siempre se trata de elegir una única capa para todo el incidente.

La conectividad inalámbrica añade exposición al medio compartido y posibilidad de puntos de acceso falsos. El dispositivo móvil conserva aplicaciones, tokens y datos locales. El servidor administra sesiones y permisos. La base de datos concentra registros y privilegios. Una medida debe atender el mecanismo concreto: cifrar el canal no legitima una página de phishing ni limita los permisos de una cuenta robada.

Reconocer ingeniería social sin depender de errores de ortografía

El phishing intenta inducir acciones mediante suplantación o engaño. Puede usar mensajes bien redactados, logotipos correctos e información real sobre la persona. El spear phishing personaliza el objetivo; el smishing utiliza SMS y el vishing, llamadas de voz. La verificación por un canal independiente rompe la dependencia del mensaje recibido.

La urgencia y la autoridad aparente pueden presionar para omitir procedimientos. Un supuesto técnico que solicita aprobar una notificación MFA está intentando utilizar una acción válida fuera de su finalidad. El código o aprobación no debe compartirse ni aceptarse si no corresponde a una operación iniciada y reconocida.

Del síntoma a la medida

Si el teléfono se pierde, importan bloqueo, cifrado, sesiones y administración remota autorizada. Si una aplicación conserva datos sensibles sin protección, importa almacenamiento local. Si el servidor permite intentos ilimitados, deben revisarse controles de autenticación y monitoreo. Si la base recibe consultas inseguras, se revisan parametrización y privilegios.

Ejemplo comentado. Un sitio falso captura credenciales y después abre el sitio verdadero. Esa segunda pantalla no valida la primera. La evidencia relevante es dónde se ingresó el secreto. La respuesta debe considerar cambio de credenciales, revocación de sesiones y revisión de accesos según el procedimiento institucional.

Mapa de relaciones para explicar el tema



Mapa conceptual 21 Riesgos de una aplicación

Preguntas y casos del indicador 21

Aplicación del aprendizaje. Diferenciar el lugar del riesgo, su mecanismo y la medida que responde al caso.

1 Riesgo de red

Una red inalámbrica imita el nombre de la institución y dirige a una página falsa. ¿Qué elementos debe analizar el usuario?

Explicación. Identidad de la red y del destino, además del contexto del acceso. Un nombre conocido no prueba legitimidad. El riesgo comienza en la conexión, pero puede terminar en robo de credenciales dentro de una página engañosa.

2 Pérdida de un móvil

Se pierde un teléfono que conserva sesiones abiertas y datos institucionales. ¿Por qué cambiar únicamente el nombre del dispositivo es insuficiente?

Explicación. Deben tratarse sesiones, credenciales, datos locales y controles de gestión disponibles conforme al procedimiento. Renombrar no revoca acceso. El impacto depende del bloqueo, cifrado, permisos y estado real del teléfono, no solo de su valor económico.

3 Exposición de datos

Una base permite consultar expedientes completos a una cuenta que solo necesita estadísticas. ¿Qué riesgo y medida se relacionan?

Explicación. Existe acceso excesivo respecto de la función. Debe limitarse alcance mediante permisos y datos adecuados al propósito. Cifrar la conexión no impide que esa cuenta utilice facultades ya concedidas; es un problema de autorización y minimización.

4 Servidor desactualizado

Un servicio de Internet conserva una vulnerabilidad conocida corregida por el fabricante. ¿Qué actuación debe planificarse?

Explicación. Evaluar exposición, aplicar tratamiento apropiado y comprobar el cambio, con recuperación prevista. El mantenimiento reduce la debilidad. Cambiar el nombre del servidor puede alterar una apariencia, pero no corrige el componente vulnerable.

5 Suplantación por voz

Una llamada de supuesto soporte exige el código temporal de acceso con urgencia. ¿Qué técnica se relaciona y cómo se verifica la solicitud?

Explicación. Se relaciona con vishing e ingeniería social. Debe verificarse mediante un canal institucional independiente y no compartirse el código. La urgencia y conocer datos de la institución no prueban identidad del interlocutor.

22 Inteligencia de negocios minería de datos y data mart

Programación y pruebas de la seguridad del software · Nivel 12 · Indicador 15.1 · Tabla página 6

Indicador de logro. Distingue las características de la inteligencia de negocios tomando como bases los data mart.

Propósito de aprendizaje. Explicar cómo se transforman datos en información útil para tomar decisiones.

Referencia para ampliar los saberes Programa de duodécimo páginas 89 y 90

Conceptos fundamentales

La inteligencia de negocios, BI, organiza y analiza datos para apoyar decisiones. Un indicador debe responder una pregunta: cuántos incidentes se repiten, dónde aumentan costos o qué productos requieren reposición. Un tablero atractivo no corrige datos incompletos o mal interpretados.

Un data warehouse integra datos históricos de varias áreas para análisis. Un data mart enfoca un área o necesidad, como ventas o seguridad. Puede alimentarse de un almacén corporativo o de otras fuentes. Una base transaccional, OLTP, prioriza operaciones cotidianas; el análisis OLAP permite explorar información agregada por distintas dimensiones.

ETL extrae, transforma y carga datos. La transformación limpia errores, homologa unidades y relaciona registros. En ELT, la carga precede a parte de la transformación. La calidad incluye exactitud, consistencia, completitud, actualidad y pertinencia.

La minería de datos busca patrones mediante técnicas como clasificación, agrupamiento, asociación y detección de anomalías. Clasificación asigna categorías conocidas; agrupamiento descubre similitudes; asociación encuentra relaciones de ocurrencia. Una correlación no demuestra por sí sola causalidad.



Esquema aplicado De los datos a una decisión de negocio

Caso resuelto. El data mart del SOC muestra menos alertas, pero dos sedes dejaron de enviar registros. Antes de concluir que mejoró la seguridad, debe comprobarse cobertura comparable. Menos datos observados pueden parecer menos incidentes sin que el riesgo haya disminuido.

Una medida es un valor cuantificable, como minutos; una dimensión permite analizarlo por fecha, sede o tipo. Un KPI mide progreso respecto de un objetivo. Debe definirse su fórmula, fuente y periodo; «tiempo de respuesta» y «tiempo de resolución» no representan lo mismo.

Construir una pregunta antes de construir un tablero

Una tabla de incidentes contiene fechas, sedes y tiempos. Para convertirla en información útil se formula una pregunta: ¿en qué sede tarda más la recuperación y por qué? La respuesta exige definir qué se entiende por recuperación, desde qué momento se cuenta y qué casos se comparan. Un gráfico atractivo con criterios distintos puede inducir una conclusión equivocada.

Una medida es un valor analizable, como cantidad o duración. Una dimensión ofrece contexto: sede, fecha, servicio o categoría. El nivel de detalle, o granularidad, indica qué representa cada registro. Si una fila representa un incidente y otra representa un día completo, mezclarlas sin transformación produce resultados difíciles de interpretar.

El término big data se relaciona con conjuntos y procesos cuyas características de volumen, velocidad o variedad exigen enfoques adecuados de almacenamiento y análisis. La veracidad y el valor recuerdan que muchos datos no equivalen a información confiable o útil. Un almacén de datos puede trabajar sin alcanzar esa escala, y una solución de big data puede utilizar nube o recursos locales. Son conceptos relacionados, pero no sinónimos.

Diferenciar almacenamiento operativo y analítico

Una base operativa, OLTP, prioriza transacciones cotidianas como registrar una compra. Un almacén de datos reúne información para análisis histórico. Un data mart se concentra en un área o necesidad particular, como ventas o seguridad. Puede alimentarse de un almacén corporativo o de otras fuentes; no se define únicamente por su tamaño.

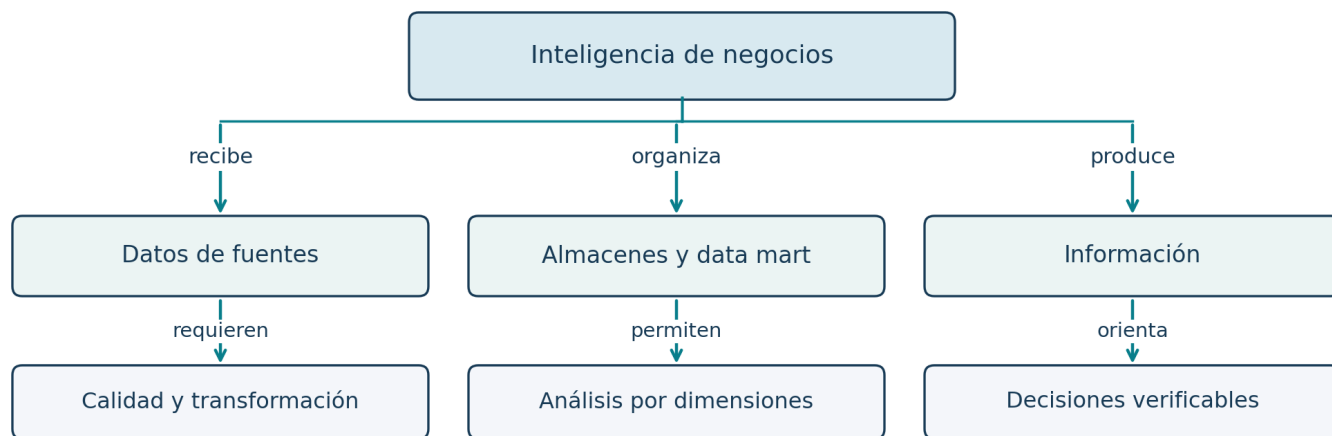
ETL significa extraer, transformar y cargar. La transformación puede depurar duplicados, normalizar fechas y convertir unidades. En ELT se carga antes de efectuar parte de la transformación. El orden depende del diseño, pero en ambos casos deben cuidarse procedencia y calidad. El linaje permite rastrear de dónde viene un resultado y qué transformaciones recibió.

Comprender minería de datos sin atribuirle certeza

La clasificación asigna categorías a partir de patrones; el agrupamiento reúne elementos semejantes sin exigir las mismas etiquetas previas; la asociación busca coocurrencias; la detección de anomalías destaca diferencias respecto de un patrón. Una anomalía no prueba automáticamente un ataque y una correlación no demuestra causalidad.

Caso resuelto adicional. Un tablero muestra menos alertas después de un cambio. Antes de concluir que mejoró la seguridad, compruebe que continúan llegando registros de todas las sedes. Si faltan fuentes, la disminución puede reflejar menor observación. Deben distinguirse datos ausentes, cero eventos y eventos no detectados. La calidad del análisis depende de esa separación.

Mapa de relaciones para explicar el tema



Mapa conceptual 22 Inteligencia de negocios

Preguntas y casos del indicador 22

Aplicación del aprendizaje. Explicar cómo se transforman datos en información útil para tomar decisiones.

1 Indicador de negocio

Un tablero muestra cantidad de alertas, pero la pregunta era cuánto tarda la recuperación. ¿Responde la medida al objetivo?

Explicación. No directamente. El número de alertas y el tiempo de recuperación describen aspectos distintos. Deben definirse medida, inicio, fin y población de casos. Un gráfico correcto puede ser irrelevante si no responde a la decisión que se necesita tomar.

2 Data mart y almacén corporativo

Un repositorio reúne información de toda la organización; otro se concentra en ventas. ¿Cómo se distinguen por su alcance?

Explicación. El primero corresponde al concepto de almacén corporativo; el segundo, a un data mart de área. La distinción principal es la orientación del contenido, no solo tamaño físico. Un data mart puede alimentarse del almacén o de otras fuentes.

3 Transformación de datos

Se combinan montos en colones y dólares en una suma sin conversión. ¿Qué parte del proceso necesita revisión?

Explicación. La transformación y calidad de datos. Deben unificarse unidades mediante reglas documentadas antes de compararlos o agregarlos. Extraer y cargar correctamente no garantiza interpretación válida; también deben conservarse procedencia, fecha y criterio de conversión.

4 Minería y causalidad

Se observa que aumentan simultáneamente visitas y ventas. ¿La asociación demuestra que cada visita causó una compra?

Explicación. No. Una asociación no prueba causalidad ni establece correspondencia individual. La minería descubre patrones que requieren interpretación y contraste. Otras variables pueden influir; el análisis debe distinguir descripción, predicción y explicación causal.

5 Datos faltantes

El tablero muestra menos incidentes después de que dos sedes dejaron de enviar registros. ¿Puede afirmarse una mejora de seguridad?

Explicación. No con esa evidencia. Se redujo la cobertura de observación. Hay que comprobar fuentes y periodos comparables antes de interpretar la tendencia. Ausencia de registros, cero incidentes observados y ausencia real de incidentes no son equivalentes.

23 Integridad y vulnerabilidades de bases de datos

Programación y pruebas de la seguridad del software · Nivel 12 · Indicador 16.1 · Tabla página 6

Indicador de logro. Identifica y evalúa las vulnerabilidades de las bases de datos.

Propósito de aprendizaje. Identificar debilidades de datos y seleccionar controles que atiendan su causa.

Referencia para ampliar los saberes Programa de duodécimo páginas 90 y 91

Conceptos fundamentales

Una base de datos organiza información y un SGBD administra almacenamiento, consultas, transacciones y permisos. La seguridad debe proteger acceso, datos, configuración, credenciales y disponibilidad; instalar un motor no configura automáticamente todas estas protecciones.

La integridad de entidad requiere identificar filas de forma válida, normalmente con una clave primaria. La integridad referencial mantiene relaciones coherentes mediante claves foráneas. La integridad de dominio limita tipos y valores; las reglas del negocio añaden condiciones específicas. No es igual que todos los campos sean texto a que los datos sean válidos.

Las transacciones se asocian a propiedades ACID: atomicidad, ejecutar todo o nada; consistencia, respetar reglas; aislamiento, controlar interacción concurrente; durabilidad, conservar cambios confirmados. Una condición de carrera aparece cuando operaciones simultáneas interactúan de forma no prevista.

Debilidad	Ejemplo	Control pertinente
Inyección	Concatenar texto recibido en SQL.	Usar consultas parametrizadas.
Permisos excesivos	Una cuenta de consulta puede borrar tablas.	Roles y mínimo privilegio.
Falta de integridad referencial	Pedido de un cliente inexistente.	Relaciones y restricciones apropiadas.
Exposición de credenciales	Clave en archivo legible por cualquiera.	Custodia de secretos y permisos.
Configuración o versión vulnerable	Motor expuesto sin mantenimiento.	Restricción de red, revisión y parches.

Caso resuelto. Dos retiros leen saldo 100 y cada uno acepta retirar 80 antes de coordinar cambios. El problema es concurrencia e integridad transaccional. El control debe garantizar que la decisión y actualización respeten el saldo real; cambiar el nombre de la tabla no resuelve la carrera.

La bitácora permite investigar accesos y modificaciones, pero debe protegerse de alteraciones. Un respaldo ayuda a recuperar; no impide por sí mismo que alguien consulte datos sin permiso. Revise cada medida según su función.

Por qué la base necesita reglas propias

Una tabla de estudiantes identifica personas mediante una clave primaria. Una tabla de matrículas contiene una clave foránea que apunta al estudiante. Si se permite registrar una matrícula con un estudiante inexistente, se rompe integridad referencial. Una restricción del motor puede impedir ese estado aunque la aplicación cometa un error. Esta defensa complementa la validación de la interfaz.

La integridad de dominio limita valores: tipo, rango o conjunto admitido. Un dato puede ser técnicamente entero y no ser válido como cantidad disponible si es negativo. Las restricciones deben expresar la regla correspondiente. Una clave primaria única evita duplicidad de identificadores, pero no garantiza por sí sola que todos los datos personales sean exactos.

Entender una transacción con un ejemplo

Transferir dinero requiere restar de una cuenta y sumar en otra. La atomicidad trata la operación como un conjunto que se confirma o se revierte según el diseño. La consistencia exige respetar reglas; el aislamiento controla interacción concurrente; la durabilidad conserva cambios confirmados. Estas propiedades se conocen como ACID.

Si dos operaciones leen saldo 100 y cada una acepta retirar 80 antes de coordinar, ambas pueden creer que hay fondos. El problema aparece por concurrencia. Deben diseñarse

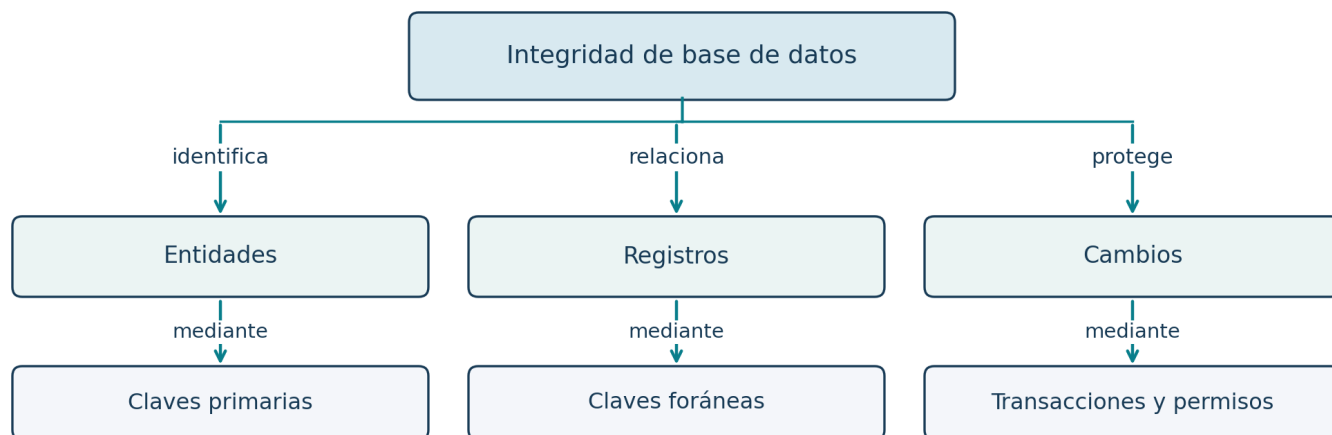
transacciones y mecanismos de control apropiados; cambiar nombres de campos o cifrar el archivo no resuelve esa carrera.

Relacionar acceso y protección

Una cuenta utilizada para consultas no necesita administrar usuarios ni borrar tablas. Los roles limitan operaciones y las vistas pueden restringir qué información se presenta. Un índice mejora ciertos accesos, pero no es una medida de autorización. Un respaldo recupera datos bajo determinadas condiciones, pero tampoco evita una consulta indebida.

Ejemplo de inyección explicado. Si el programa concatena directamente texto del usuario dentro de una consulta, mezcla valores con instrucciones. Parametrizar mantiene la estructura de la consulta separada. Debe combinarse con mínimos privilegios y registros protegidos. El motor sigue necesitando actualización, configuración y control de red aunque se utilicen parámetros correctamente.

Mapa de relaciones para explicar el tema



Mapa conceptual 23 Integridad de base de datos

Preguntas y casos del indicador 23

Aplicación del aprendizaje. Identificar debilidades de datos y seleccionar controles que atiendan su causa.

1 Integridad de entidad

Dos estudiantes reciben el mismo identificador que debería ser único. ¿Qué regla de base de datos debe impedirlo?

Explicación. La unicidad de la clave primaria protege la identificación de filas. No garantiza que todos los datos sean verdaderos, pero evita esa duplicación estructural. Una validación solo en pantalla puede ser eludida por otras rutas de escritura.

2 Integridad referencial

Se intenta registrar una matrícula vinculada a un estudiante inexistente. ¿Qué restricción relaciona ambas tablas?

Explicación. Una clave foránea puede exigir que exista la referencia válida, conforme al diseño. Es integridad referencial. No se resuelve cifrando el nombre del estudiante: el problema es la relación inconsistente entre registros.

3 Integridad de dominio

Un inventario permite guardar cantidades negativas aunque el negocio las prohíbe. ¿Qué regla falta?

Explicación. Una restricción de dominio o regla pertinente que limite los valores admitidos. El tipo entero acepta negativos, por lo que el tipo por sí solo no basta. La base y la aplicación deben sostener reglas coherentes.

4 Atomicidad y concurrencia

Una transferencia descuenta una cuenta y falla antes de acreditar la otra. ¿Qué propiedad exige tratar ambos cambios como una unidad?

Explicación. Atomicidad. La operación debe confirmarse completa o revertirse según el diseño transaccional. El aislamiento atiende interacciones concurrentes y la durabilidad conserva cambios confirmados. No deben confundirse todas las propiedades ACID bajo el nombre de respaldo.

5 Privilegios y consultas

Una aplicación usa consultas parametrizadas, pero su cuenta puede borrar todas las tablas. ¿Desaparece el riesgo de permisos excesivos?

Explicación. No. Parametrización y mínimo privilegio atienden riesgos distintos. Deben limitarse las facultades a las operaciones necesarias. Una técnica correcta de consulta no justifica permisos administrativos ni elimina fallas de lógica, exposición o mantenimiento.

24 Contraseñas defensa activa y contingencia

Operaciones ciberseguras · Nivel 10 · Indicador 1.1 · Tabla página 7

Indicador de logro. Reconoce los conceptos básicos relacionados con la gestión de contraseñas y defensa activa.

Propósito de aprendizaje. Seleccionar controles de acceso y respuesta según la forma de ataque observada.

Conceptos fundamentales

Una contraseña debe ser difícil de adivinar y diferente entre servicios. La longitud y la imprevisibilidad importan; sustituir letras de una palabra conocida con números no garantiza fortaleza. Un gestor de contraseñas ayuda a generar y custodiar claves únicas. MFA añade una barrera, aunque no elimina phishing ni compromiso de sesiones.

La fuerza bruta prueba combinaciones; un ataque de diccionario utiliza candidatos probables; password spraying prueba pocas claves frecuentes contra muchas cuentas; credential stuffing utiliza pares de usuario y contraseña obtenidos de otras filtraciones. La reutilización facilita este último ataque.

Los sistemas no deben almacenar contraseñas en texto claro. Se emplean funciones de derivación apropiadas para contraseñas, con una sal aleatoria por registro y un costo de

cálculo adecuado. La sal no es una contraseña adicional: evita que claves iguales produzcan necesariamente registros iguales y dificulta reutilizar tablas precalculadas.

Defensa activa implica observar, detectar, investigar y responder dentro del ámbito autorizado. Un honeypot es un recurso señuelo que ayuda a detectar o estudiar actividad; una honeynet agrupa señuelos. Deben aislarse y administrarse para no convertirse en un riesgo. Defensa activa no concede permiso para atacar equipos de terceros.

Continuidad y contingencia. Un plan de continuidad mantiene procesos esenciales; la recuperación ante desastres restablece tecnología; la respuesta a incidentes trata eventos de seguridad. Deben definirse responsables, prioridades, comunicaciones y medios alternativos.

Caso resuelto. Tras una filtración de una tienda, aparecen accesos al correo con las mismas credenciales. Usar claves únicas, MFA y límites de intentos reduce el riesgo. Cambiar solo el nombre de usuario en pantalla no invalida una contraseña comprometida ni revoca sus sesiones.

Distinguir los ataques por su patrón

La fuerza bruta recorre combinaciones. El diccionario utiliza candidatos probables. El password spraying prueba pocas contraseñas frecuentes contra muchas cuentas para buscar un patrón de éxito. El credential stuffing reutiliza pares de usuario y contraseña filtrados de otro servicio. Una contraseña compleja reutilizada puede ser vulnerable al último caso aunque no sea fácil de adivinar.

Un gestor permite conservar claves diferentes sin depender de recordarlas todas. Debe protegerse el acceso al propio gestor y considerar recuperación. MFA combina factores de categorías distintas. Dos preguntas de conocimiento no equivalen a dos factores diferentes; una contraseña y un dispositivo de posesión sí pueden aportar categorías distintas, según el mecanismo.

Por qué las contraseñas se verifican y no se recuperan

El sistema debe usar una función de derivación adecuada para contraseñas, con sal y costo apropiados. Cuando se ingresa una candidata, se procesa con los parámetros del registro y se compara el resultado. La sal puede almacenarse junto al registro: no necesita ser secreta para cumplir su función. Evita que contraseñas iguales tengan necesariamente el mismo resultado y dificulta reutilizar cálculos precalculados.

Un hash rápido de propósito general no equivale automáticamente a una función adecuada para almacenar contraseñas. Tampoco debe confundirse hash con cifrado reversible. Si una aplicación ofrece mostrar la contraseña original, requiere revisar cómo la conserva o recupera.

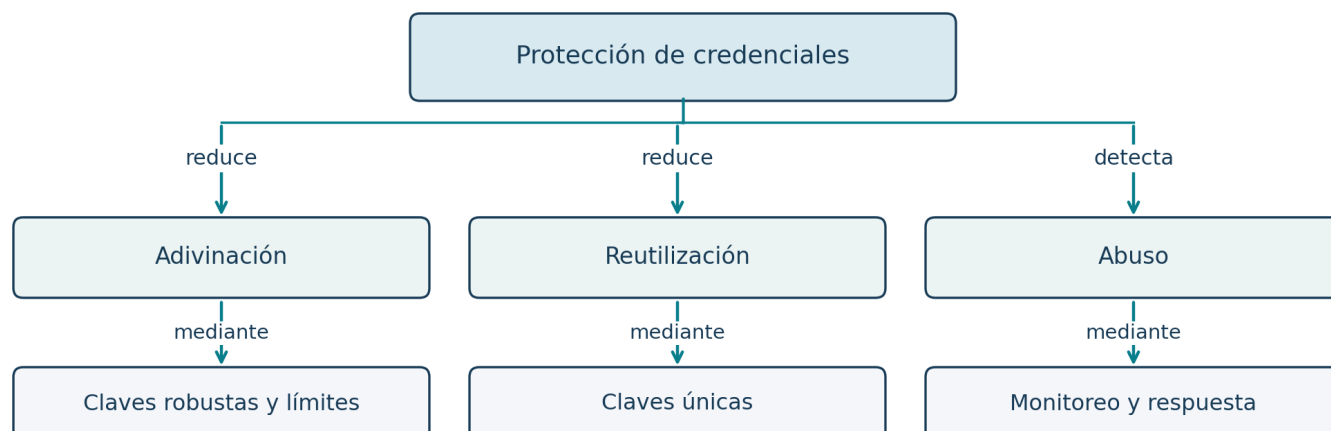
Contener no es contraatacar

Una defensa activa autorizada observa, detecta y responde en el entorno permitido. Los señuelos pueden revelar actividad, pero necesitan aislamiento y administración. Encontrar una conexión maliciosa no concede autorización para intervenir equipos externos. La continuidad busca mantener procesos esenciales; la respuesta a incidentes investiga y controla el evento; la recuperación restablece servicios.

Caso ampliado. Se detecta acceso con una contraseña filtrada. Cambiarla es una medida, pero deben revisarse sesiones activas, tokens, recuperación de cuenta y acciones realizadas. La

cuenta puede seguir comprometida por un mecanismo adicional. La solución debe seguir todas las formas de acceso, no solo la pantalla inicial.

Mapa de relaciones para explicar el tema



Mapa conceptual 24 Protección de credenciales

Preguntas y casos del indicador 24

Aplicación del aprendizaje. Seleccionar controles de acceso y respuesta según la forma de ataque observada.

1 Ataque de diccionario

Se prueban contraseñas de una lista de palabras frecuentes contra una cuenta. ¿Qué patrón lo diferencia de recorrer todas las combinaciones posibles?

Explicación. Es un ataque de diccionario: usa candidatos probables. La fuerza bruta exhaustiva recorre un espacio de combinaciones. Ambos buscan adivinar secretos, pero el patrón de prueba y la resistencia dependen de longitud, imprevisibilidad y controles de acceso.

2 Password spraying

Se prueban unas pocas claves habituales contra muchas cuentas. ¿Qué técnica describe esa distribución?

Explicación. Password spraying. Distribuir pocos intentos entre muchas identidades lo distingue de concentrarlos en una sola cuenta. Deben analizarse patrones agregados y políticas de autenticación; observar cada usuario aisladamente puede ocultar la actividad coordinada.

3 Reutilización de credenciales

Una clave filtrada en una tienda permite entrar al correo porque se reutilizó. ¿Qué técnica aprovecha esa condición?

Explicación. Credential stuffing utiliza pares de usuario y contraseña obtenidos de filtraciones. No necesita adivinar de nuevo la misma clave. Contraseñas únicas reducen reutilización y MFA puede añadir protección, aunque deben tratarse también recuperación y sesiones.

4 Sal y verificación

Dos usuarios eligen la misma contraseña y sus registros almacenados son diferentes. ¿Por qué una sal distinta puede explicar ese resultado?

Explicación. La sal interviene en la derivación de cada registro, de modo que entradas iguales no producen necesariamente registros iguales. No es una segunda contraseña secreta. Se necesita además una función adecuada y costo de cálculo; un hash rápido no basta por ese solo rasgo.

5 Defensa activa y continuidad

Un señuelo detecta actividad y una sede mantiene atención mediante un procedimiento alternativo. ¿Qué capacidades diferentes representan?

Explicación. El señuelo apoya detección e investigación dentro del ámbito autorizado; el procedimiento alternativo sostiene continuidad. Ninguno autoriza contraatacar. Recuperar tecnología, contener un incidente y mantener procesos son objetivos relacionados, pero requieren acciones diferentes.

25 Criptografía y protección de equipos

Operaciones ciberseguras · Nivel 10 · Indicador 2.1 · Tabla página 7

Indicador de logro. Selecciona estrategias para la implementación de procesos de seguridad efectiva en los equipos.

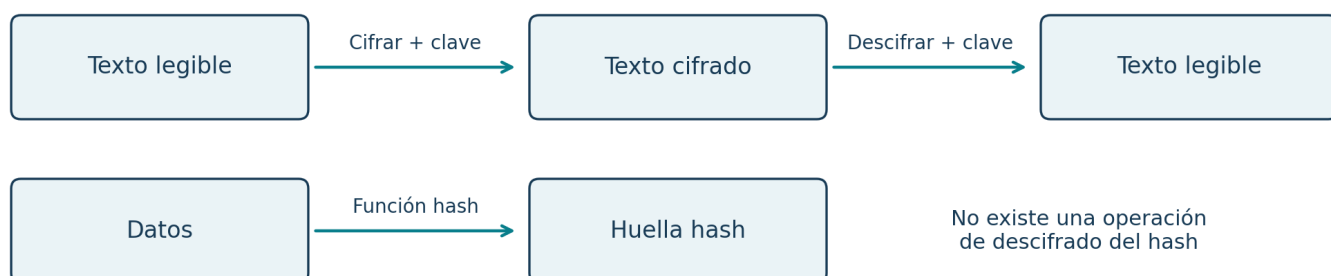
Propósito de aprendizaje. Distinguir los mecanismos que protegen confidencialidad, integridad, identidad y comunicaciones.

Conceptos fundamentales

El cifrado transforma datos legibles usando una clave y permite recuperarlos mediante el procedimiento de descifrado. En cifrado simétrico, las partes utilizan una clave secreta compartida; es apropiado para grandes volúmenes. En criptografía asimétrica, se trabaja con un par de claves relacionado, pública y privada, para funciones como intercambio seguro o firma.

Un hash calcula una huella de longitud definida. No se descifra para obtener el original. Ayuda a comparar integridad, pero un hash aislado no autentica quién lo publicó. Un MAC criptográfico, como HMAC, utiliza una clave compartida para verificar integridad y autenticidad entre quienes la conocen; no es la dirección MAC de una tarjeta de red.

Una firma digital se genera con una clave privada y se verifica con la pública correspondiente. Permite comprobar el firmante y la integridad cuando la confianza en la clave es adecuada. No oculta necesariamente el contenido. Un certificado relaciona una identidad con una clave pública mediante una autoridad o mecanismo de confianza.



Esquema aplicado Cifrado reversible y huella hash

TLS protege comunicaciones; VPN crea un túnel entre extremos mediante protocolos y configuración apropiados. El cifrado completo de disco protege información almacenada, especialmente ante pérdida de un equipo apagado. Las claves de recuperación deben custodiarse separadamente.

Caso resuelto. Un instalador tiene una firma válida del proveedor esperado. Eso permite verificar procedencia e integridad del archivo firmado, pero no demuestra que carezca de errores o vulnerabilidades. Un respaldo cifrado tampoco será útil si se pierde definitivamente la clave.

Entender qué problema resuelve cada mecanismo

El cifrado busca impedir lectura no autorizada. La integridad busca detectar modificaciones indebidas. La autenticidad permite valorar el origen. Una firma digital puede apoyar integridad y autenticidad, pero no necesariamente oculta el contenido. Un archivo firmado puede ser legible para cualquiera que lo reciba. Si el objetivo es confidencialidad, debe añadirse el mecanismo de cifrado apropiado.

En cifrado simétrico, una clave secreta compartida permite operaciones eficientes sobre grandes volúmenes. En criptografía asimétrica se usa un par de claves relacionado. No debe afirmarse que todo algoritmo asimétrico sirve para cualquier operación: existen esquemas específicos de firma, intercambio o cifrado. En comunicaciones modernas suelen combinarse mecanismos para establecer claves y proteger datos.

Distinguir una huella de una prueba de origen

Calcular un hash sobre un archivo permite comparar bytes con una referencia. Si el archivo y el hash se descargan de una fuente comprometida, ambos podrían haber sido sustituidos. Un HMAC utiliza una clave compartida para comprobar integridad y autenticidad entre quienes conocen esa clave. Una firma utiliza una clave privada y permite verificación con la pública correspondiente, bajo un esquema y confianza adecuados.

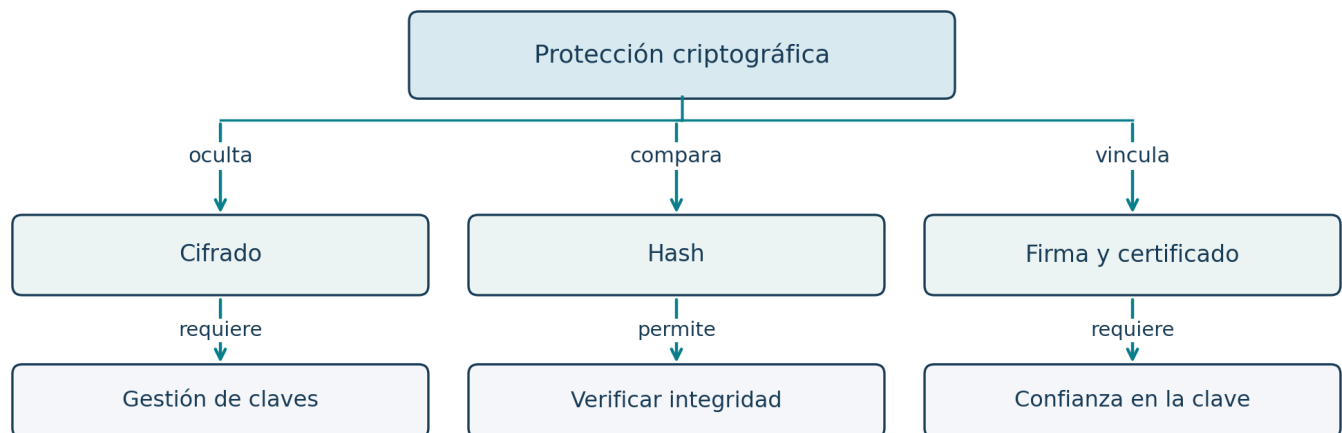
El certificado relaciona una identidad con una clave pública. Su comprobación puede incluir cadena de confianza, vigencia, nombre esperado y condiciones de revocación. Una cadena válida no significa que toda decisión del sitio sea honesta ni que el software no tenga vulnerabilidades.

Seguir una comunicación protegida

Cuando se establece un canal TLS, se negocian parámetros y se autentica el extremo según el modo utilizado. Los datos de aplicación quedan protegidos por el canal entre sus extremos. Si el usuario entrega su contraseña a un sitio falso que también usa TLS, el cifrado protege el envío hacia ese sitio falso; no corrige la elección del destinatario.

Caso ampliado. Se pierde un portátil apagado con disco cifrado y claves bien custodiadas. El cifrado puede reducir exposición del soporte. Si el portátil estaba desbloqueado y una sesión seguía activa, el escenario es diferente. La protección depende del estado del equipo y del acceso a las claves, además del nombre del algoritmo.

Mapa de relaciones para explicar el tema



Mapa conceptual 25 Protección criptográfica

Preguntas y casos del indicador 25

Aplicación del aprendizaje. Distinguir los mecanismos que protegen confidencialidad, integridad, identidad y comunicaciones.

1 Cifrado simétrico

Dos extremos protegen un volumen grande de datos con una clave secreta compartida. ¿Qué familia criptográfica describe ese uso?

Explicación. Cifrado simétrico. La seguridad depende del algoritmo, implementación y gestión de la clave. Compartir una clave requiere un mecanismo seguro; que el cifrado sea eficiente no resuelve cómo se entrega ni quién tiene autorización para utilizarla.

2 Firma y confidencialidad

Un documento firmado digitalmente sigue siendo legible. ¿Significa que la firma falló?

Explicación. No. La firma permite verificar integridad y origen bajo condiciones de confianza, pero no busca necesariamente ocultar contenido. Si también se requiere confidencialidad, debe incorporarse cifrado apropiado. Firmar y cifrar cumplen funciones diferentes.

3 Hash y fuente confiable

Se descarga un archivo y su hash desde el mismo sitio comprometido. ¿Coincidir ambos demuestra una procedencia segura?

Explicación. No. Un atacante pudo sustituir ambos. La comparación demuestra coincidencia respecto de esa referencia, pero su valor depende de confiar en ella. Un hash aislado no autentica automáticamente al publicador ni garantiza que el programa sea inocuo.

4 Certificado digital

Un navegador valida un certificado de un sitio de engaño. ¿La validación garantiza honestidad de la oferta comercial?

Explicación. No. El certificado y TLS respaldan aspectos de identidad del extremo y canal, según su validación. No certifican todas las afirmaciones del sitio. Es necesario distinguir conexión protegida, dominio esperado y legitimidad del contenido.

5 Estado de un equipo cifrado

Se roba un portátil apagado con disco cifrado; en otro caso se roba desbloqueado con una sesión activa. ¿Por qué cambia la valoración?

Explicación. El acceso a datos y claves puede ser distinto según el estado. El cifrado de disco protege especialmente determinadas formas de acceso al soporte, pero una sesión abierta puede permitir lectura. El control debe analizarse junto con bloqueo, identidad y configuración.

26 Administración segura de sistemas de código abierto

Operaciones ciberseguras · Nivel 10 · Indicador 3.1 · Tabla página 7

Indicador de logro. Aplica protocolos para la seguridad en sistemas operativos de código abierto.

Propósito de aprendizaje. Aplicar acceso remoto protegido, permisos y mantenimiento con privilegios limitados.

Conceptos fundamentales

El endurecimiento reduce exposición mediante configuración segura: eliminar servicios innecesarios, mantener actualizaciones, limitar cuentas, configurar red y registrar eventos. Debe aplicarse según la función del equipo, sin desactivar a ciegas servicios que el proceso necesita.

SSH protege una sesión remota; SFTP transfiere archivos mediante SSH. Telnet y FTP tradicional transmiten información sin el mismo resguardo criptográfico. Un cambio de puerto no sustituye autenticación, actualización ni restricción de acceso. La clave del servidor ayuda a comprobar que se está conectando al destino esperado.

En Linux, permisos básicos son lectura r, escritura w y ejecución x, para propietario, grupo y otros. Sus valores son 4, 2 y 1. En directorios, ejecución permite atravesarlos y acceder a entradas según permisos; no significa ejecutar el directorio como programa.

Permiso	Propietario	Grupo	Otros
600	Lectura y escritura.	Sin acceso.	Sin acceso.
640	Lectura y escritura.	Lectura.	Sin acceso.
750	Lectura escritura y ejecución.	Lectura y ejecución.	Sin acceso.

Una cuenta root tiene privilegios amplios. Es preferible usar identidades individuales y elevar permisos con sudo para tareas autorizadas. chmod modifica permisos; chown cambia propiedad. Las ACL de archivos permiten permisos más específicos que el esquema básico.

Caso resuelto. Un archivo con una clave pertenece al servicio y solo este debe leerlo y modificarlo. Un permiso 600 responde a ese requisito básico. Usar 666 permite escritura a otros y amplía exposición.

Aplicación segura. Antes de restringir SSH, pruebe una sesión nueva y conserve una vía autorizada de recuperación. Revise usuarios, registros y servicios después de cambios. Las instrucciones se practican en equipos propios o autorizados.

Interpretar permisos con su significado

En un archivo, lectura permite consultar contenido; escritura permite modificarlo; ejecución permite intentar ejecutarlo como programa. En un directorio, lectura permite enumerar nombres; ejecución permite recorrerlo y acceder a entradas según los permisos; escritura permite modificar entradas, con las condiciones adicionales aplicables. Por eso no se interpreta x igual en un archivo y en un directorio.

La notación numérica suma 4 para lectura, 2 para escritura y 1 para ejecución. En 640, el propietario tiene 6, el grupo 4 y otros 0. No expresa número de usuarios, sino permisos por categoría. La pertenencia a grupos y ACL adicionales también puede afectar el acceso real.

Usar privilegios sin perder identidad

Trabajar siempre como root amplía el impacto de errores y dificulta separar tareas. Una cuenta individual con elevación autorizada mediante sudo permite realizar operaciones concretas conservando atribución. Esto exige revisar la política de elevación: permitir ejecutar cualquier comando equivale a un privilegio muy amplio. Tener una contraseña de usuario no limita una cuenta que posee permisos administrativos excesivos.

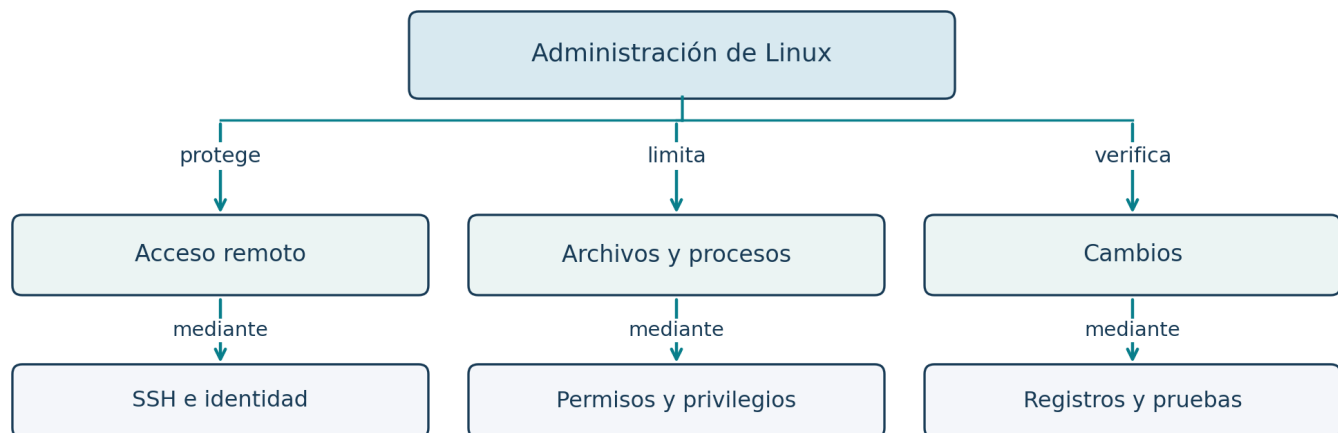
SSH cifra la sesión y permite verificar identidad del servidor mediante su clave. Ignorar un cambio inesperado de clave sin comprobarlo puede ocultar un problema. SFTP utiliza SSH para transferencia; FTP tradicional y Telnet no ofrecen el mismo resguardo criptográfico. Cambiar el puerto reduce ciertos intentos triviales, pero no reemplaza los controles principales.

Aplicar un cambio sin perder acceso

Antes de restringir el servicio remoto, revise la configuración y disponga de un acceso de recuperación autorizado. Conserve una sesión funcional y pruebe una nueva bajo las condiciones previstas. Verifique quién puede entrar y quién debe quedar excluido. Después revise registros y documente el cambio. El orden evita confundir una regla correcta con una interrupción accidental del trabajo.

Diagnóstico comentado. Un archivo tiene permiso 600, pero pertenece a una cuenta distinta de la que ejecuta el servicio. La restricción puede impedir el acceso legítimo. Deben revisarse propietario, identidad del proceso y necesidad real, sin resolverlo automáticamente con permisos para todo el mundo. Un control debe permitir la función autorizada y limitar las demás.

Mapa de relaciones para explicar el tema



Mapa conceptual 26 Administración de Linux

Preguntas y casos del indicador 26

Aplicación del aprendizaje. Aplicar acceso remoto protegido, permisos y mantenimiento con privilegios limitados.

1 Permisos numéricos

Un archivo tiene permiso 640. ¿Qué pueden hacer propietario, grupo y otros mediante ese esquema básico?

Explicación. El propietario puede leer y escribir; el grupo puede leer; otros no reciben permisos. Los valores se obtienen sumando lectura 4, escritura 2 y ejecución 1. No representan cantidad de usuarios ni nivel general de seguridad.

2 Ejecución en directorios

Un directorio tiene permiso de ejecución para un usuario. ¿Significa que se ejecuta como programa?

Explicación. No. En directorios, ejecución permite atravesarlos o buscar entradas según los permisos pertinentes. Lectura permite enumerar nombres y escritura modificar entradas bajo condiciones adicionales. El significado de cada bit depende de si se trata de archivo o directorio.

3 Propiedad y permisos

Un servicio no puede leer un archivo 600 que pertenece a otra cuenta. ¿Por qué abrirlo a todos no es la primera solución?

Explicación. Deben revisarse propietario, identidad del proceso y necesidad de acceso. El permiso restringe al propietario bajo el esquema básico. Puede requerirse corregir propiedad o una autorización limitada; permisos globales amplían exposición sin atender de forma precisa el requisito.

4 Administración remota

Se propone usar Telnet para administrar un servidor a través de una red no confiable. ¿Qué diferencia aporta SSH?

Explicación. SSH protege la comunicación y permite comprobar el extremo mediante claves y mecanismos de autenticación. Telnet tradicional no ofrece ese resguardo criptográfico. Usar un puerto diferente no convierte Telnet en un canal cifrado.

5 Elevación de privilegios

Todos usan directamente una cuenta root compartida. ¿Qué mejora aporta una identidad individual con elevación autorizada?

Explicación. Permite limitar funciones y atribuir acciones a cada persona. Debe configurarse cuidadosamente la política de elevación. Dar permiso de ejecutar cualquier comando como root conserva facultades muy amplias; tener cuentas separadas no reemplaza revisar qué pueden hacer.

27 Acceso y registros en un SIEM

Operaciones ciberseguras · Nivel 10 · Indicador 4.1 · Tabla página 8

Indicador de logro. Describe el proceso de configuración de inicio de sesión en el administrador de registros de SIEM.

Propósito de aprendizaje. Explicar cómo configurar accesos trazables y convertir registros en información analizable.

Conceptos fundamentales

Un SIEM recopila y relaciona eventos de distintas fuentes para apoyar detección e investigación. Un log o registro conserva datos de actividad. Un agente o colector los recibe; un analizador interpreta campos; la normalización los organiza en un formato común; la correlación relaciona eventos según condiciones.

Para configurar acceso al SIEM se definen identidades individuales, autenticación, MFA cuando corresponde y roles de consulta o administración. No todos los analistas necesitan modificar reglas. Las acciones sobre el propio SIEM también deben quedar auditadas.

Los eventos de inicio de sesión deberían permitir reconocer usuario, fecha y hora, origen, servicio y resultado. Los relojes y zonas horarias deben interpretarse correctamente. Un campo de fecha mal analizado puede ubicar sucesos fuera del periodo correcto y romper una secuencia de investigación.

Procedimiento de comprobación. Crear o vincular usuarios autorizados; asignar roles; habilitar auditoría; configurar recepción y análisis de logs; producir un acceso válido y uno fallido controlados; comprobar los registros y la regla esperada. Los datos deben conservarse con integridad, acceso limitado y retención definida.

Caso resuelto. Cinco fallos seguidos de un éxito pueden indicar adivinación de credenciales, pero también un usuario que olvidó su clave. Se revisan origen, horario, identidad, criticidad y otras evidencias. La alerta necesita contexto antes de declararse incidente.

Un falso positivo alerta sobre actividad legítima; un falso negativo deja pasar una actividad relevante sin detectarla. Aumentar sensibilidad puede aumentar alertas y carga de revisión. Afinar reglas requiere evidencia y validación, no desactivar todo lo que produce ruido.

Del registro individual a la alerta

Un servidor registra un inicio fallido; un firewall registra una conexión; una aplicación registra una consulta. El SIEM recibe esas fuentes y extrae campos. La normalización permite comparar formatos diferentes, como nombres distintos para usuario u origen. La correlación relaciona eventos mediante condiciones. Sin campos bien interpretados, una regla puede relacionar acciones que no pertenecen al mismo caso o perder una secuencia relevante.

La zona horaria importa: dos registros pueden mostrar horas distintas para un mismo instante. La sincronización y la interpretación temporal permiten ordenar. No se deben modificar los originales para hacerlos coincidir; se conserva el dato recibido y se documenta la transformación utilizada para analizarlo. También debe distinguirse fecha del evento de fecha de recepción, porque puede haber retrasos.

Configurar el acceso al administrador de registros

El analista necesita identidad individual y un rol acorde a sus funciones. Consultar eventos, modificar reglas y administrar usuarios son permisos distintos. La autenticación puede integrarse con un proveedor de identidad y requerir MFA. La autorización determina qué índices, fuentes o funciones puede utilizar. Las acciones dentro del SIEM deben registrarse para poder revisar quién cambió una regla o exportó información.

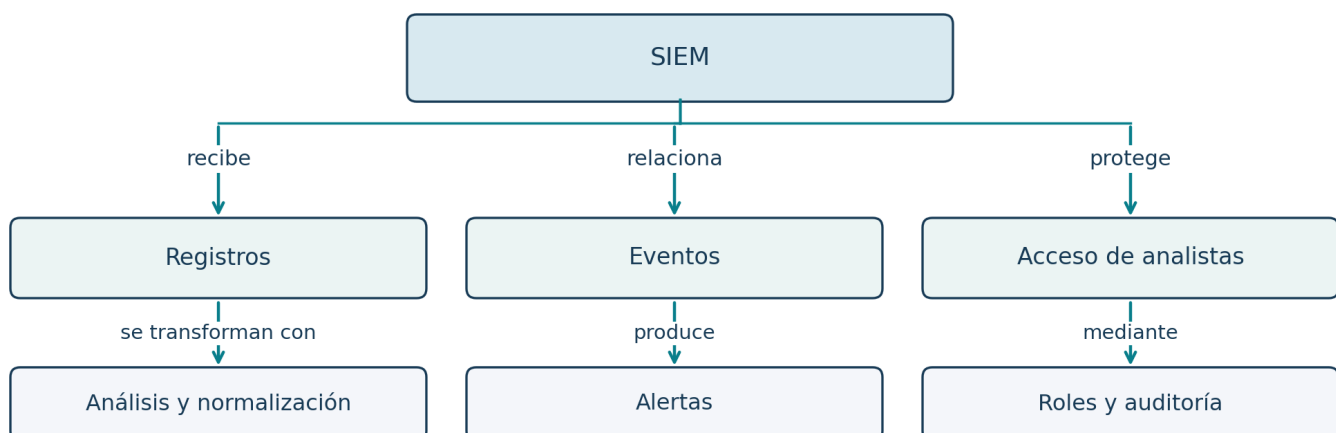
Una prueba funcional incluye acceso permitido, intento denegado y verificación del registro correspondiente. Si todos utilizan una misma cuenta, se reduce atribución. Si cualquier analista puede borrar registros, se compromete la evidencia necesaria para revisar el propio sistema.

Interpretar una alerta con contexto

Una regla detecta cinco fallos seguidos de éxito. Puede existir adivinación, pero también una persona que recordó su contraseña. Revise dispositivo, horario, origen, actividad posterior y sensibilidad de la cuenta. Un falso positivo alerta sobre actividad legítima; un falso negativo no detecta una actividad relevante. Desactivar reglas por producir alertas elimina observación, no necesariamente el problema.

Ejemplo ampliado. El SIEM muestra cero eventos de una sede. Antes de concluir que no hubo actividad, revise conectividad del agente, filtros y recepción. Cero actividad y ausencia de registros son estados diferentes. Una supervisión del flujo de fuentes debe acompañar las reglas de seguridad.

Mapa de relaciones para explicar el tema



Preguntas y casos del indicador 27

Aplicación del aprendizaje. Explicar cómo configurar accesos trazables y convertir registros en información analizable.

1 Recopilar y normalizar

Un servidor usa el campo user y otro usuario para el mismo dato. ¿Qué necesita el SIEM para compararlos correctamente?

Explicación. Normalizar e interpretar los campos en un esquema coherente. Recibir registros no garantiza que sus datos sean comparables. Una regla que usa un campo mal interpretado puede generar alertas erróneas o dejar de relacionar eventos relevantes.

2 Correlacionar

Se relacionan fallos de acceso, un ingreso exitoso y una descarga masiva. ¿Qué añade la correlación frente a contar cada evento separado?

Explicación. Permite evaluar una secuencia y contexto comunes. La combinación puede justificar investigación aunque cada evento aislado parezca ordinario. Aun así, la correlación no prueba automáticamente autoría o malicia; requiere identidades, tiempos y otras evidencias fiables.

3 Tiempo de los registros

Dos equipos registran horas distintas para una misma conexión. ¿Por qué no deben cambiarse los originales para hacerlos coincidir?

Explicación. Se deben conservar originales y documentar zona horaria, desfase y transformaciones de análisis. Modificarlos destruye parte de la evidencia. La sincronización facilita futuras comparaciones, pero no autoriza reescribir retrospectivamente lo observado.

4 Roles de analistas

Un usuario necesita consultar alertas, pero recibe permiso para borrar registros y cambiar reglas. ¿Qué principio se incumple?

Explicación. Mínimo privilegio: tiene facultades superiores a las necesarias. Deben separarse consulta, administración y cambios de configuración. Además, las acciones dentro del SIEM deben auditarse; proteger solo los registros que llegan deja sin control el uso de la herramienta.

5 Ausencia de datos

El SIEM muestra cero accesos desde una sede cuyo agente dejó de enviar información. ¿Qué debe concluirse?

Explicación. Existe una falta de cobertura que impide afirmar ausencia de actividad. Hay que revisar agente, conexión, recepción y análisis. Cero eventos registrados no equivale a cero eventos reales cuando el mecanismo de observación falla.

28 Automatización auditoría y análisis forense

Operaciones ciberseguras · Nivel 10 · Indicador 5.1 · Tabla página 8

Indicador de logro. Aplica técnicas para la automatización, auditoría y análisis forense, en materia de seguridad en los sistemas.

Propósito de aprendizaje. Elegir técnicas que produzcan resultados verificables y preserven el estado investigado.

Conceptos fundamentales

Una auditoría contrasta configuraciones o procesos con criterios. Una revisión de vulnerabilidades identifica posibles debilidades. El análisis forense recolecta, preserva y examina evidencia para responder preguntas sobre hechos. No son la misma actividad ni autorizan las mismas modificaciones.

La automatización mediante scripts permite revisar muchos equipos de forma consistente. Debe registrar alcance, equipo, fecha, versión de la comprobación, resultados y errores. «No fue posible revisar» no equivale a «cumple». Los permisos de lectura reducen alteraciones cuando la tarea es observar.

Una sandbox es un entorno controlado para analizar comportamiento. La virtualización puede aislar sistemas y facilitar estados restaurables, pero compartir carpetas, portapapeles o una red abierta puede debilitar ese aislamiento. También existen riesgos de escape o de software que detecta el laboratorio y cambia su comportamiento.

Evidencia volátil puede perderse al apagar, como memoria y ciertas conexiones. La no volátil incluye información persistente en discos. La decisión de mantener o apagar un equipo depende del procedimiento, riesgos y autorización; apagar automáticamente todo puede destruir información relevante.

Caso resuelto. Un script inspecciona 40 servidores, pero falla en 5. El informe debe señalar 35 evaluados y 5 pendientes, no afirmar que los 40 cumplen. Debe conservar resultados y errores para repetir comprobaciones concretas.

Para examinar un disco puede obtenerse una imagen forense, utilizar bloqueo de escritura cuando corresponde y calcular hashes. Una instantánea operativa no equivale automáticamente a una adquisición forense completa. El alcance y limitaciones del método deben documentarse.

Elegir el tipo de trabajo antes de elegir herramienta

Una auditoría compara con un criterio: por ejemplo, que todas las cuentas administrativas tengan autorización vigente. Un análisis de vulnerabilidades identifica debilidades posibles. Un peritaje examina evidencia para responder preguntas sobre hechos bajo procedimientos aplicables. Utilizar la misma computadora no convierte estas actividades en equivalentes. Sus permisos, efectos y productos pueden ser distintos.

Un script puede repetir una comprobación, pero necesita alcance y manejo de errores. Si un servidor no responde, el resultado es no evaluado; no cumple y cumple requieren evidencia

diferente. La salida debe distinguir cada estado e identificar fecha, destino y versión de la comprobación. Sin esa información, repetir el trabajo o explicar una discrepancia resulta difícil.

Preservar antes de alterar

La memoria, procesos y conexiones pueden desaparecer al apagar. Los discos conservan información persistente, aunque también cambian durante uso normal. La decisión de intervenir depende de riesgo operativo, autorización y procedimiento. No existe una regla universal de apagar siempre o mantener siempre encendido. Lo esencial es justificar la decisión y documentar lo que se modifica.

Una sandbox limita un análisis a un entorno controlado. Una VM ofrece recursos y estados virtuales, pero sus carpetas compartidas, red y dispositivos pueden conectar el laboratorio con otros sistemas. El aislamiento debe comprobarse. Un archivo malicioso también puede cambiar de comportamiento al detectar ciertas condiciones del entorno, por lo que no observar actividad no prueba inocuidad.

Convertir observaciones en un informe

El informe debe separar qué se observó, cómo se obtuvo, qué interpretación se propone y qué limitaciones permanecen. «No se encontraron archivos con ese nombre en el alcance adquirido» es más preciso que «ese archivo nunca existió». La adquisición puede ser parcial y los registros pueden haber caducado.

Caso explicado. Se comparan configuraciones de 40 equipos y cinco fallan por falta de permiso. El informe debe mostrar 35 revisados y cinco pendientes. Elevar privilegios sin autorización para completar la cifra no es una solución válida. La cobertura real es una propiedad del trabajo que debe comunicarse, no ocultarse.

Mapa de relaciones para explicar el tema



Mapa conceptual 28 Investigación automatizada

Preguntas y casos del indicador 28

Aplicación del aprendizaje. Elegir técnicas que produzcan resultados verificables y preserven el estado investigado.

1 Auditoría frente a análisis forense

Se compara configuración con una política y, en otro trabajo, se reconstruye una eliminación de archivos. ¿Cuál es la finalidad de cada actividad?

Explicación. La primera es auditoría respecto de criterios; la segunda, análisis forense de hechos a partir de evidencia. Pueden compartir herramientas, pero no objetivos ni efectos permitidos. Debe elegirse procedimiento según la pregunta y la autorización.

2 Automatización con errores

Un script consulta 50 equipos, pero no obtiene acceso a ocho. ¿Cómo deben presentarse los resultados?

Explicación. Como 42 equipos evaluados y ocho no evaluados, con los motivos disponibles. No obtener datos no significa cumplir ni incumplir. La automatización debe conservar errores y alcance para que otra persona pueda interpretar y repetir la comprobación.

3 Evidencia volátil

Se investiga actividad de memoria y conexiones activas. ¿Por qué apagar inmediatamente puede afectar el análisis?

Explicación. Esa información puede perderse al cesar la ejecución. La decisión de mantener o apagar debe coordinar riesgo operativo, autorización y procedimiento. No existe una regla universal de conservar siempre encendido: lo relevante es justificar la preservación y las consecuencias.

4 Aislamiento de laboratorio

Una VM de análisis comparte carpetas y portapapeles con el equipo de trabajo. ¿Qué límite debe revisarse?

Explicación. Esas conexiones pueden debilitar el aislamiento y exponer al anfitrión o información. Deben ajustarse según el laboratorio autorizado. Llamar sandbox a un entorno no demuestra que sus fronteras estén correctamente configuradas.

5 Informe reproducible

Un reporte dice «todo está seguro», pero omite versiones, alcance y resultados de las comprobaciones. ¿Qué falta para valorar su conclusión?

Explicación. Evidencia verificable de qué se examinó, cómo, cuándo y con qué limitaciones. La conclusión debe corresponder al alcance real. Un nombre de herramienta o una captura aislada no permite reproducir ni justificar una afirmación tan amplia.

29 Recursos virtuales portátiles y nube

Operaciones ciberseguras · Nivel 10 · Indicador 6.1 · Tabla página 8

Indicador de logro. Discrimina la relación existente entre la operacionalización de los conceptos de computación en la nube, y la virtualización con los equipos portátiles y otros dispositivos.

Propósito de aprendizaje. Analizar dónde se ejecuta una tarea y de qué recursos y conexiones depende.

Conceptos fundamentales

Un portátil puede ejecutar aplicaciones locales, máquinas virtuales locales o acceder a servicios remotos. En un escritorio virtual remoto, gran parte del procesamiento ocurre en el servidor; el dispositivo presenta la interfaz y envía entradas. Un cliente ligero requiere menos recursos locales para esa tarea, pero sigue necesitando capacidad básica y conectividad.

CPU, RAM, almacenamiento y red son recursos finitos. Las VM comparten los del anfitrión; asignar memoria virtual no crea memoria física ilimitada. La sobreasignación puede ser administrada por la plataforma, pero bajo demanda real puede causar presión de memoria, paginación y lentitud.

Los problemas deben ubicarse por capa: dispositivo local, red, servicio remoto o aplicación. Una batería degradada afecta movilidad; un almacenamiento lleno puede impedir actualizaciones; una mala conexión puede congelar la experiencia remota sin que la VM haya fallado.

Síntoma	Comprobación inicial pertinente
Lentitud al iniciar otra VM.	RAM disponible, CPU y actividad de almacenamiento.
Sesión remota se corta.	Conectividad, latencia, pérdidas y servicio remoto.
Aplicación no inicia en la VM.	Compatibilidad, dependencias y registros del invitado.
No aparece un dispositivo.	Controlador, conexión y asignación a la VM.

Caso resuelto. Un equipo tiene 16 GB de RAM y dos VM demandan 12 GB cada una, además del anfitrión. Puede existir degradación por falta de memoria. El diagnóstico debe medir consumo; ampliar disco no equivale a disponer de más RAM con el mismo rendimiento.

La nube permite ampliar capacidad remota, pero exige analizar costo, privacidad, conexión y recuperación. Un equipo personal no debe conservar credenciales o copias sensibles sin controles institucionales.

Ubicar dónde ocurre el trabajo

En una aplicación local, el portátil realiza gran parte del procesamiento. En una VM local, el anfitrión aporta recursos a un invitado. En un escritorio remoto, la ejecución principal ocurre en otro sistema y el cliente intercambia imagen y entradas. La misma pantalla puede ocultar arquitecturas distintas. Para diagnosticar debe identificarse dónde están proceso, archivo y servicio.

Un cliente ligero necesita menos recursos para ejecutar ciertas tareas remotas, pero aún requiere capacidad para presentar la sesión y conectarse. Si falla Internet, puede perder acceso sin que los datos guardados en el servidor hayan desaparecido. Si una aplicación guardaba cambios solo en memoria, debe revisarse ese estado por separado. Acceso, ejecución y persistencia no son lo mismo.

Relacionar síntomas con recursos

La CPU procesa instrucciones; la RAM conserva trabajo activo; el almacenamiento guarda información persistente y puede convertirse en un límite por capacidad o velocidad. La red aporta comunicación. Un equipo con varias VM puede sufrir presión de memoria aunque tenga mucho espacio libre en disco. La sobreasignación debe gestionarse y medirse según demanda real.

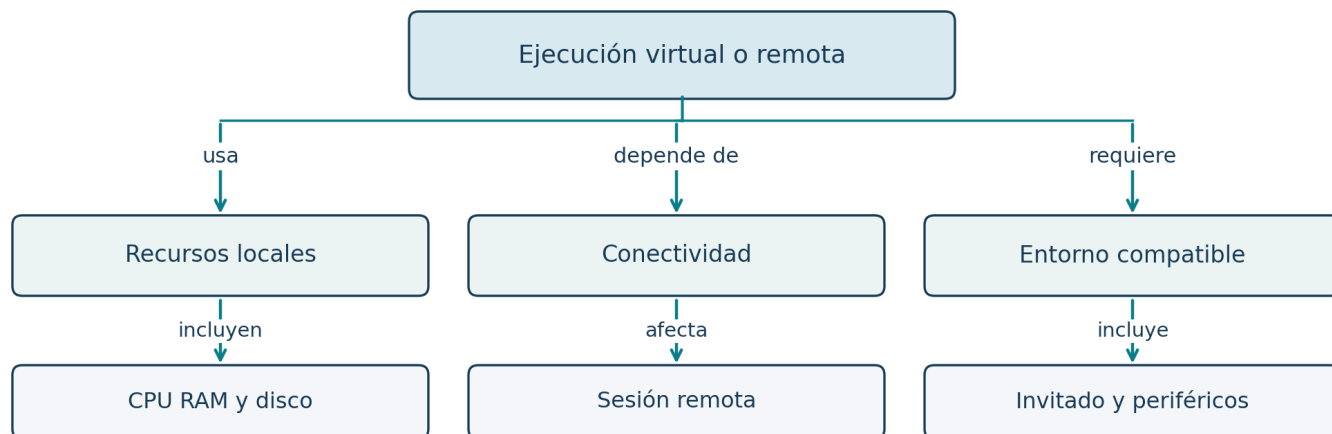
Una sesión remota con retardo puede deberse a latencia o pérdidas, mientras el servidor tiene recursos disponibles. Una aplicación lenta al consultar datos puede depender de la base y no del escritorio. Diagnosticar por capas evita sustituir hardware que no atiende la causa.

Una secuencia de comprobación

Primero describa qué acción falla y desde cuándo. Después compare con otra tarea: ¿el anfitrión responde?, ¿la VM arranca?, ¿la red llega al servicio?, ¿solo una aplicación falla? Revise registros y consumo. Cambie una variable justificada y compruebe el efecto. Modificar memoria, red y aplicación a la vez puede impedir saber qué resolvió el problema.

Caso comentado. Una cámara USB funciona en el anfitrión, pero no en la VM. La evidencia orienta a presentación del dispositivo al invitado, controlador y permisos. No demuestra falta de ancho de banda de Internet. El diagnóstico correcto utiliza lo que ya funciona para reducir hipótesis.

Mapa de relaciones para explicar el tema



Mapa conceptual 29 Ejecución virtual o remota

Preguntas y casos del indicador 29

Aplicación del aprendizaje. Analizar dónde se ejecuta una tarea y de qué recursos y conexiones depende.

1 Ubicación del procesamiento

Un portátil presenta un escritorio remoto, mientras las aplicaciones se ejecutan en un servidor. ¿Dónde ocurre la mayor parte del trabajo de esas aplicaciones?

Explicación. En el servidor remoto, según el diseño. El portátil presenta la interfaz y envía entradas, pero sigue necesitando recursos y conectividad. La apariencia de escritorio local no identifica por sí sola dónde se ejecuta cada proceso.

2 Sobreasignación de memoria

Un equipo con 16 GB sostiene dos VM que demandan 12 GB cada una, además del anfitrión. ¿Qué problema puede aparecer?

Explicación. Presión de memoria, paginación y degradación según plataforma y carga. Asignar memoria virtual no crea RAM física ilimitada. Debe medirse demanda efectiva y reservar recursos pertinentes; ampliar espacio de disco no ofrece automáticamente el mismo rendimiento.

3 Latencia de una sesión

El escritorio remoto responde tarde, pero el servidor tiene CPU y RAM disponibles. ¿Qué debe examinarse antes de ampliar el servidor?

Explicación. Latencia, pérdida de paquetes, congestión y condiciones de la conexión, además del cliente. La demora puede estar en la comunicación. Un diagnóstico por capas evita sustituir un recurso que no constituye el límite observado.

4 Desconexión y persistencia

Se corta Internet mientras un usuario trabaja en una aplicación remota. ¿Se perdieron necesariamente los archivos del servidor?

Explicación. No. Se perdió acceso a la sesión; debe comprobarse por separado el estado persistido. Cambios que no se guardaron pueden tener otro resultado. Acceso, ejecución y almacenamiento son dimensiones distintas y no se deducen todas de una desconexión.

5 Cliente ligero

Se elige un equipo sencillo para acceder a aplicaciones remotas. ¿Por qué todavía requiere dimensionamiento?

Explicación. Debe sostener interfaz, red, periféricos y seguridad local. Cliente ligero no significa ausencia de requisitos. Si la tarea exige video, múltiples pantallas o funcionamiento sin conexión, esas necesidades pueden cambiar la elección.

30 Características y calidad de una red

Operaciones ciberseguras · Nivel 10 · Indicador 7.1 · Tabla página 8

Indicador de logro. Reconoce las características de las redes que afectan el uso en pequeñas y medianas empresas.

Propósito de aprendizaje. Relacionar capacidad, rendimiento, disponibilidad y crecimiento con necesidades de una organización.

Conceptos fundamentales

El ancho de banda expresa capacidad de transmisión; el rendimiento efectivo, throughput, es la tasa realmente lograda. La latencia mide demora; el jitter es variación de esa demora; la pérdida de paquetes puede afectar continuidad o exigir retransmisión. No deben confundirse megabits por segundo con megabytes por segundo.

La QoS, calidad de servicio, clasifica y prioriza tráfico según políticas para atender necesidades como voz o video. Puede gestionar congestión, pero no crea capacidad ilimitada ni corrige todo defecto físico. Un archivo grande puede tolerar demoras que una conversación en vivo percibe inmediatamente.

La disponibilidad es la posibilidad de utilizar un servicio cuando se requiere. La tolerancia a fallos mantiene operación ante ciertos fallos mediante diseño y redundancia. La escalabilidad permite crecer en usuarios o carga sin rediseñar todo. La seguridad controla acceso, exposición y uso aceptable.

Caso resuelto. La voz se entrecorta cuando se descargan archivos. Deben medirse congestión, latencia y pérdida, y revisar priorización. Concluir únicamente que «falta velocidad» puede omitir interferencia, un enlace defectuoso o políticas inadecuadas.

La redundancia debe considerar fallos de causa común. Dos enlaces en el mismo ducto vulnerable pueden fallar simultáneamente. También deben probarse la conmutación y capacidad del enlace alternativo: tenerlo contratado no demuestra recuperación efectiva.

Comparación de diseño. Para ampliar de 20 a 80 puestos, revise puertos, direccionamiento, capacidad, puntos de acceso y servicios. Para mantener atención al público durante una falla, revise caminos alternos y continuidad. Para evitar filtración, revise segmentación y permisos. Son necesidades distintas que deben equilibrarse.

Entender por qué velocidad no es una sola medida

El ancho de banda expresa capacidad; el throughput, lo que realmente se transmite bajo condiciones concretas. La latencia es demora, el jitter es variación de esa demora y la pérdida indica unidades que no llegan. Una videollamada puede sufrir aunque una descarga logre buena tasa promedio. La aplicación necesita continuidad temporal, no solo completar muchos datos al final.

También deben distinguirse bits y bytes. Un byte contiene ocho bits. Un enlace anunciado en megabits por segundo no entrega ese mismo número de megabytes por segundo de archivo. Además existen cabeceras, competencia por recursos y otras condiciones que reducen la tasa útil. Una conversión de unidades es un primer paso, no una garantía de rendimiento.

Aplicar calidad de servicio con propósito

QoS clasifica y prioriza tráfico según una política. Durante congestión, puede favorecer comunicaciones sensibles a demora. No crea ancho de banda ilimitado. Si una red está permanentemente sobrecargada o tiene un enlace defectuoso, la priorización no sustituye revisar capacidad y medio. Debe existir un criterio sobre qué servicio se protege y por qué.

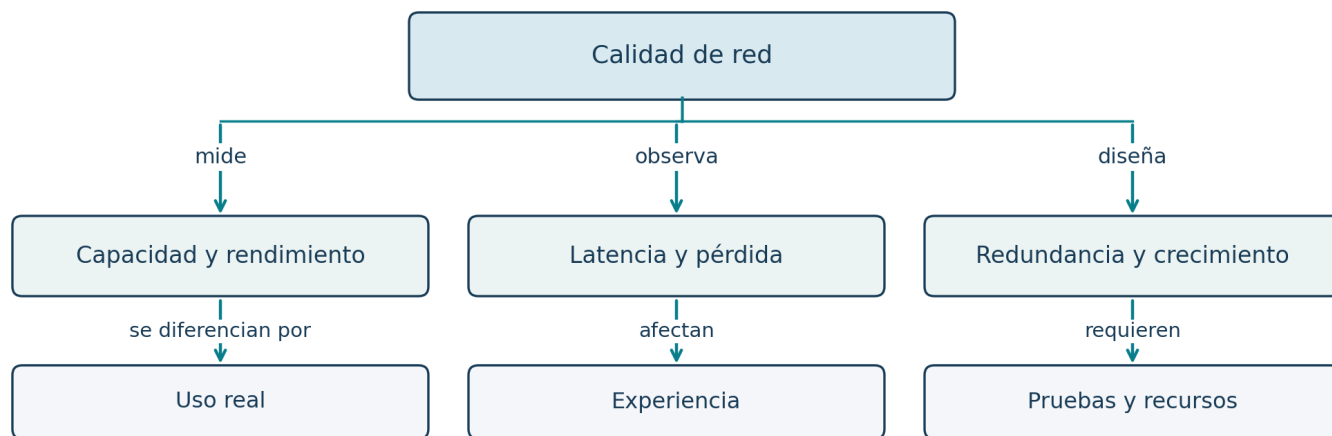
La disponibilidad requiere considerar energía, equipos, enlaces y servicios. Dos enlaces que pasan por el mismo punto vulnerable pueden compartir una causa de fallo. La redundancia debe comprobar su independencia y la capacidad del camino alterno. Un enlace de respaldo muy pequeño puede mantener conectividad sin sostener todas las tareas habituales.

Diseñar para crecer

La escalabilidad considera puertos, direcciones, capacidad, administración y servicios. Agregar usuarios puede aumentar demanda de autenticación, DNS o almacenamiento, además del tráfico. La tolerancia a fallos busca mantener operación ante fallas previstas; no equivale a crecer ni a proteger confidencialidad.

Ejemplo explicado. Una empresa pasa de 20 a 80 puestos. Necesita dimensionar switches, enlaces y WiFi, pero también segmentación y permisos. Si el objetivo del caso es continuidad durante una falla, debe justificar redundancia. Si es crecimiento, debe justificar capacidad y organización. Reconocer el objetivo evita elegir una propiedad verdadera que no responde a la necesidad planteada.

Mapa de relaciones para explicar el tema



Mapa conceptual 30 Calidad de red

Preguntas y casos del indicador 30

Aplicación del aprendizaje. Relacionar capacidad, rendimiento, disponibilidad y crecimiento con necesidades de una organización.

1 Ancho de banda y tasa obtenida

Un enlace anuncia 100 megabits por segundo. ¿Es correcto esperar 100 megabytes de archivo por segundo?

Explicación. No. Un byte contiene ocho bits; 100 megabits equivalen a 12,5 megabytes por segundo antes de considerar sobrecarga y límites reales. Además, el rendimiento efectivo depende de extremos, protocolos, congestión y condiciones del medio.

2 Jitter

Una llamada presenta demoras muy variables entre paquetes. ¿Qué métrica describe esa variación?

Explicación. Jitter. La latencia describe demora y la pérdida describe paquetes que no llegan. Distinguir las métricas permite seleccionar medidas pertinentes. Un promedio aceptable de transferencia no demuestra una conversación fluida si los tiempos varían mucho.

3 Calidad de servicio

La voz se entrecorta durante descargas masivas. ¿Qué puede aportar QoS y qué no puede crear?

Explicación. Puede clasificar y priorizar tráfico conforme a políticas durante competencia por recursos. No crea capacidad ilimitada ni corrige un cable defectuoso. Deben analizarse ancho de banda, medio y configuración junto con la priorización.

4 Redundancia con causa común

Dos enlaces de respaldo pasan por el mismo ducto que puede romperse. ¿Qué limitación existe?

Explicación. Comparten una causa de falla, por lo que una sola rotura puede afectar ambos. La redundancia útil requiere analizar independencia y recuperación. Tener dos contratos o dos cables no demuestra disponibilidad ante todos los eventos.

5 Escalabilidad

Una red debe pasar de 20 a 80 puestos. ¿Qué debe valorar el diseño además del número de conectores?

Explicación. Direccionamiento, capacidad de enlaces y equipos, servicios, administración y seguridad. La escalabilidad busca crecimiento sostenible. Agregar puertos puede resolver conexión física y dejar saturados autenticación, red inalámbrica o enlace principal.

31 Componentes de redes LAN y WAN

Operaciones ciberseguras · Nivel 10 · Indicador 7.2 · Tabla página 8

Indicador de logro. Distingue los componentes de redes LAN y WAN en pequeñas y medianas empresas.

Propósito de aprendizaje. Identificar qué dispositivo comunica equipos locales y cuál permite llegar a otras redes.

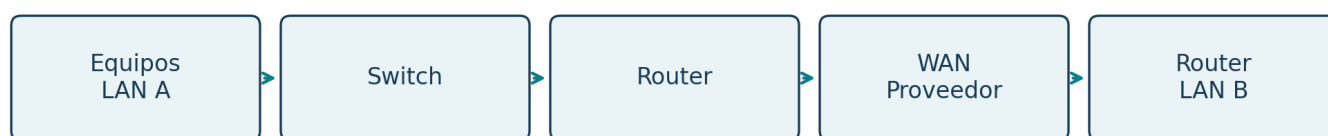
Conceptos fundamentales

Una LAN conecta equipos en un entorno local. Una WAN comunica redes en áreas más extensas, normalmente mediante servicios de telecomunicaciones. Una WLAN es una LAN inalámbrica. La clasificación depende del alcance y arquitectura, no solo de la marca de equipos.

Los dispositivos finales originan o reciben datos: computadoras, teléfonos y servidores. Los intermediarios facilitan su transporte: switches, routers y puntos de acceso. Los medios pueden ser cobre, fibra o radio. Una topología física muestra conexiones; una lógica expresa cómo se organiza el flujo.

Componente	Función principal en el escenario habitual
Switch de capa 2	Conmuta tramas dentro de VLAN usando MAC.

Componente	Función principal en el escenario habitual
Router	Interconecta redes mediante decisiones sobre paquetes IP.
Punto de acceso	Integra clientes inalámbricos con la red local.
Firewall	Permite o restringe comunicaciones según políticas.
Módem u ONT	Adapta o termina el acceso del operador según tecnología.
Servidor	Ofrece servicios como archivos, autenticación o aplicaciones.



El switch conecta la LAN; el router comunica redes diferentes

Esquema aplicado Una LAN se comunica con otras redes mediante un router

Caso resuelto. Dos sedes tienen LAN propias y se conectan por un enlace del proveedor. Si falla ese enlace, los equipos de una sede pueden seguir comunicándose localmente si no dependen de un servicio remoto. La falla WAN no prueba que el switch local dejó de funcionar.

Un equipo doméstico puede integrar router, switch, AP y firewall en una carcasa. Debe identificarse la función que realiza en el caso, no asumir que una sola caja representa siempre una sola función.

Seguir un envío local y uno remoto

Cuando un host envía a otro de su misma subred, busca la dirección de enlace correspondiente y entrega mediante la LAN. Si el destino está en otra red, utiliza el siguiente salto previsto por su tabla de rutas, normalmente la puerta de enlace. El switch de capa 2 conmuta tramas dentro de la VLAN; el router decide cómo alcanzar redes diferentes. Estas funciones pueden estar integradas en un mismo equipo, pero siguen siendo distintas.

Una LAN se define por su ámbito y organización local; una WAN interconecta redes más extensas mediante infraestructura de comunicación. Una WLAN es una LAN inalámbrica. Internet es una interconexión de redes, no el nombre de cualquier red local. Dos computadoras pueden compartir archivos localmente aunque falle el acceso a Internet si sus servicios no dependen de recursos externos.

Reconocer funciones sin depender de la carcasa

Un punto de acceso integra clientes inalámbricos. Un firewall aplica políticas de comunicación. Una ONT termina un acceso óptico según la tecnología del proveedor; un módem adapta el acceso en otras tecnologías. Un servidor ofrece una función, como nombres, archivos o autenticación. Un equipo doméstico puede reunir varias de estas funciones y no debe clasificarse solo por su apariencia.

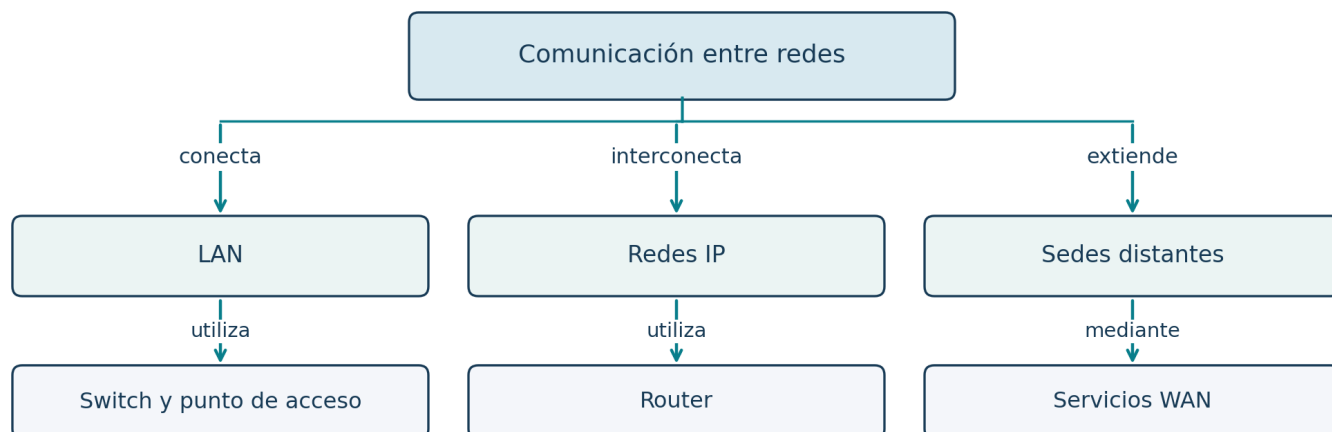
Una topología física muestra conexiones reales; la lógica muestra organización del flujo. Dos VLAN pueden compartir el mismo switch físico y mantener dominios lógicos separados. Una representación correcta debe indicar qué relación está mostrando.

Localizar una falla por alcance

Si dos hosts de una misma VLAN se comunican, pero ninguno llega a otra red, existe evidencia para revisar puerta de enlace, enrutamiento y políticas. Si solo un host falla localmente, revise su enlace, dirección y pertenencia a VLAN. Una conclusión precisa necesita varias comprobaciones, porque un firewall puede bloquear pruebas de diagnóstico sin que toda comunicación esté caída.

Caso comentado. Se pierde el enlace entre dos sedes y siguen funcionando impresoras locales. Esto es compatible con una falla WAN. Cambiar la configuración de todos los switches locales sin evidencia puede agregar problemas. Primero ubique qué trayectos fallan y cuáles permanecen operativos.

Mapa de relaciones para explicar el tema



Mapa conceptual 31 Comunicación entre redes

Preguntas y casos del indicador 31

Aplicación del aprendizaje. Identificar qué dispositivo comunica equipos locales y cuál permite llegar a otras redes.

1 Comunicación dentro de una LAN

Se interrumpe el enlace hacia Internet, pero dos equipos de la misma red local siguen compartiendo archivos. ¿Por qué es posible?

Explicación. La comunicación local puede utilizar switches y servicios internos sin atravesar la WAN. La falla externa no implica avería de toda la LAN. Deben distinguirse recursos locales de aquellos que dependen de servicios remotos.

2 Función del router

Un equipo necesita enviar datos a otra subred. ¿Qué función cumple normalmente su puerta de enlace?

Explicación. Proporciona el siguiente salto hacia otras redes según el diseño. El router o switch de capa 3 toma decisiones de enrutamiento. Un switch de capa 2 puede entregar la trama localmente al gateway, pero no reemplaza esa función de capa 3.

3 Punto de acceso

Se incorpora conectividad WiFi a una red cableada. ¿Qué función cumple el punto de acceso?

Explicación. Integra clientes inalámbricos con la red local según su configuración. No debe asumirse que por sí solo ofrece enrutamiento, Internet y todas las políticas de seguridad. Un dispositivo comercial puede reunir varias funciones, pero estas deben analizarse por separado.

4 Topología física y lógica

Dos grupos comparten el mismo switch, pero pertenecen a VLAN diferentes. ¿Son necesariamente un único dominio lógico de broadcast?

Explicación. No. La topología física común puede sostener separaciones lógicas. La VLAN organiza qué tramas se difunden dentro de cada dominio. Dibujar un solo equipo físico no demuestra que todos los hosts estén en la misma red lógica.

5 Identificar el alcance de una falla

Una sede pierde contacto con otra, mientras sus impresoras y servidores locales funcionan. ¿Qué trayecto debe investigarse?

Explicación. La comunicación entre sedes: enlace WAN, equipos de borde, rutas y políticas pertinentes. La evidencia acota el problema. Cambiar todos los switches locales sin revisar el trayecto afectado puede introducir errores y no atender la causa.

32 Protocolos estándares y comunicación

Operaciones ciberseguras · Nivel 10 · Indicador 8.1 · Tabla página 8

Indicador de logro. Identifica las características de los protocolos y comunicación de red.

Propósito de aprendizaje. Explicar cómo las reglas comunes permiten intercambiar e interpretar mensajes.

Conceptos fundamentales

Un protocolo define reglas de comunicación: formato, significado, orden, temporización y acciones ante eventos. La sintaxis describe estructura; la semántica, significado; la temporización coordina cuándo y a qué ritmo se intercambia información. Dos equipos conectados físicamente no necesariamente interpretan los mismos mensajes.

Los estándares favorecen interoperabilidad. IEEE desarrolla estándares como Ethernet y WLAN; IETF publica RFC sobre protocolos de Internet; ISO desarrolla marcos y estándares de diversas

áreas. IANA coordina registros de parámetros, como asignaciones de puertos. Un nombre de organización no reemplaza conocer su función.

La comunicación puede ser unicast, hacia un destino; multicast, hacia miembros de un grupo; o broadcast, hacia todos en un dominio que lo admite. En simplex hay un sentido; en semidúplex se alternan sentidos; en dúplex completo ambos sentidos pueden operar simultáneamente.

La encapsulación agrega información de protocolo al dato recibido de una capa superior; la desencapsulación la interpreta y retira en el extremo correspondiente. Un equipo puede manejar varios protocolos a la vez porque atienden funciones diferentes.

Caso resuelto. Ethernet transporta un paquete IP que contiene datos TCP de una aplicación. No hay contradicción: enlace, red y transporte aportan funciones complementarias. El receptor debe reconocer cada estructura para entregar los datos a la aplicación adecuada.

Una solicitud puede necesitar respuesta, confirmación o temporizador según su protocolo. El tamaño de mensajes, control de flujo y tolerancia a pérdidas dependen del diseño; no debe atribuirse fiabilidad a todo protocolo únicamente porque utiliza una red.

Comprender un protocolo mediante una conversación

Para intercambiar información, los participantes necesitan acordar cómo comienza el mensaje, qué significan sus campos y qué respuesta corresponde. Una cadena de bits no explica por sí sola si representa longitud, dirección o contenido. La sintaxis define estructura; la semántica define significado; la temporización establece condiciones de tiempo y secuencia. Cambiar el cable no corrige una interpretación incompatible.

Un estándar favorece interoperabilidad, pero debe existir implementación compatible. IEEE desarrolla familias como Ethernet y WLAN; IETF produce especificaciones de Internet mediante RFC; IANA coordina registros de parámetros. Un RFC puede tener distintas categorías y no toda publicación representa por sí sola un estándar de Internet. La función de la organización ayuda a identificar el contexto de una especificación.

Diferenciar destinatarios y dirección del intercambio

Unicast se dirige a un destino; multicast a un grupo; broadcast a todos dentro del dominio que lo admite. Estas categorías describen distribución. Simplex, semidúplex y dúplex completo describen sentidos de comunicación. Un enlace puede ser dúplex completo y transportar un mensaje unicast; las clasificaciones no se excluyen porque responden a preguntas distintas.

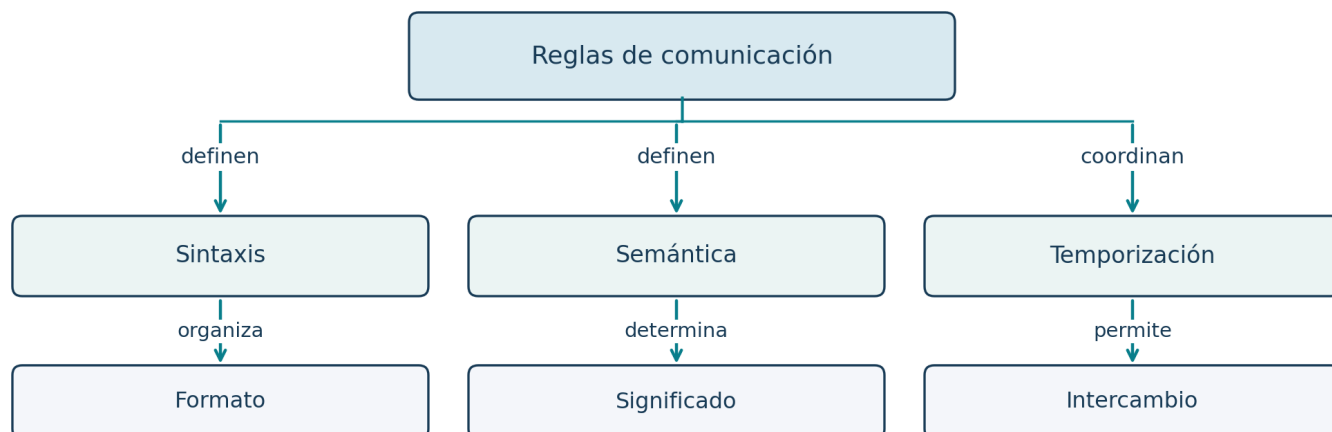
La encapsulación agrega información de una capa al dato recibido de otra. Esa información permite transportar, entregar o interpretar. En el receptor, cada capa utiliza los campos que le corresponden y entrega el contenido a la siguiente. No significa que cada dispositivo de la ruta lea toda la aplicación.

Relacionar varios protocolos sin confundirlos

Una aplicación utiliza TCP para transportar un flujo; TCP utiliza IP; IP se transporta en una trama del enlace. DNS puede intervenir antes para resolver un nombre, pero no reemplaza esos protocolos. Una red utiliza muchos acuerdos simultáneamente porque resuelven funciones diferentes.

Ejemplo explicado. Un equipo interpreta un campo de longitud en bytes y otro en bits. Aunque las señales lleguen, la interpretación será incorrecta. La solución está en compartir especificación y formato. Si el problema fuera pérdida de señal, el análisis sería físico. Identificar la función que falla permite elegir la capa y el control correspondientes.

Mapa de relaciones para explicar el tema



Mapa conceptual 32 Reglas de comunicación

Preguntas y casos del indicador 32

Aplicación del aprendizaje. Explicar cómo las reglas comunes permiten intercambiar e interpretar mensajes.

1 Sintaxis

Dos equipos esperan estructuras distintas para el mismo mensaje. ¿Qué aspecto del protocolo impide interpretar sus campos?

Explicación. La sintaxis define la estructura y disposición de los campos. Aunque el medio transmita señales, el receptor necesita reconocer esa organización. Una conexión física operativa no demuestra compatibilidad de los mensajes intercambiados.

2 Semántica

Un sistema interpreta una longitud en bytes y otro en bits. ¿Qué desacuerdo existe aunque ambos lean el mismo número?

Explicación. Un desacuerdo semántico: asignan significados o unidades diferentes al campo. Cambiar velocidad de enlace no lo corrige. Deben compartir la especificación que define qué representa cada valor y cómo se utiliza.

3 Temporización

Un emisor considera fallida una operación antes de que termine el tiempo normal de respuesta del receptor. ¿Qué aspecto requiere coordinación?

Explicación. Temporización y reglas de espera o reintento. El protocolo debe establecer secuencia y tiempos compatibles. Reintentar demasiado pronto puede generar duplicados si la aplicación no los controla; esperar indefinidamente tampoco demuestra funcionamiento correcto.

4 Formas de entrega

Un mensaje se dirige a un equipo, otro a un grupo y otro a todo el dominio que admite difusión. ¿Qué categorías corresponden?

Explicación. Unicast, multicast y broadcast. Describen destinatarios, no sentidos de comunicación. Dúplex completo, semidúplex y símplex responden a otra pregunta; una comunicación unicast puede funcionar sobre un enlace dúplex completo.

5 Organismos y estándares

Se estudian Ethernet, protocolos de Internet y asignaciones de parámetros. ¿Cómo se relacionan IEEE, IETF e IANA con esos ámbitos?

Explicación. IEEE desarrolla familias de estándares como Ethernet; IETF desarrolla especificaciones de Internet; IANA coordina registros de parámetros. No son fabricantes equivalentes. Además, no todo documento RFC tiene por sí solo la condición de estándar de Internet.

33 Modelos OSI y TCP IP

Operaciones ciberseguras · Nivel 10 · Indicador 8.2 · Tabla página 8

Indicador de logro. Diferencia los modelos de referencia de red (TCP/IP y OSI).

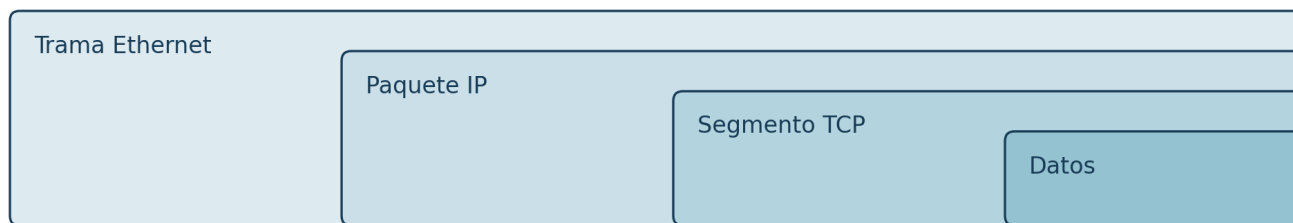
Propósito de aprendizaje. Relacionar funciones y unidades de datos con las capas de ambos modelos.

Conceptos fundamentales

Un modelo de referencia organiza funciones para explicar comunicación y diagnosticar fallas. OSI utiliza siete capas. El modelo TCP/IP suele presentarse con cuatro; algunas propuestas didácticas separan física y enlace y utilizan cinco. Debe leerse qué versión utiliza el ejercicio.

OSI	Función que debe reconocer	TCP IP de cuatro capas
7 Aplicación	Servicios de red utilizados por aplicaciones.	Aplicación
6 Presentación	Representación y transformación de datos.	Aplicación
5 Sesión	Gestión del diálogo entre sistemas.	Aplicación
4 Transporte	Comunicación entre procesos, puertos y transporte.	Transporte
3 Red	Direccionamiento lógico y enrutamiento.	Internet
2 Enlace de datos	Tramas y entrega dentro del enlace.	Acceso a la red

OSI	Función que debe reconocer	TCP IP de cuatro capas
1 Física	Señales, conectores y transmisión por el medio.	Acceso a la red



En el medio físico se transmiten bits mediante señales

Esquema aplicado Encapsulación sobre TCP e IP en Ethernet

La unidad de transporte de TCP se denomina segmento; UDP utiliza datagrama. En la capa de red se habla de paquete IP; en enlace, trama; en física, bits representados mediante señales. Una dirección IP identifica una interfaz lógicamente; una MAC se utiliza en el enlace; un puerto identifica un extremo de transporte asociado a un proceso.

Caso resuelto. Una trama Ethernet contiene un paquete IP y un segmento TCP. El orden de encapsulación corresponde a enlace, red y transporte, visto desde afuera. Visto desde los datos hacia el medio, el orden se invierte.

Uso en diagnóstico. Un cable desconectado orienta a física; una VLAN incorrecta, a enlace; una ruta faltante, a red; un puerto de servicio bloqueado exige revisar transporte y política; una respuesta incorrecta del programa requiere analizar aplicación y sus dependencias.

Leer las capas como responsabilidades

Aplicación reúne servicios utilizados por programas. Presentación representa y transforma datos. Sesión organiza el diálogo. Transporte comunica procesos. Red dirige paquetes entre redes. Enlace organiza entrega dentro de un enlace. Física transmite señales. El modelo OSI divide estas responsabilidades en siete capas; una implementación concreta puede combinar funciones y no debe forzarse cada programa a una única casilla.

El modelo TCP/IP de cuatro capas agrupa aplicación, transporte, Internet y acceso a la red. Las funciones OSI de aplicación, presentación y sesión se reúnen en su capa de aplicación. Física y enlace se agrupan en acceso. Algunos materiales separan estas últimas y presentan cinco capas. La diferencia de representación no implica que desaparezcan funciones.

Seguir una encapsulación completa

Un mensaje de aplicación se entrega a TCP. TCP añade información de puertos, secuencias y control, formando segmentos. IP añade direcciones lógicas y otra información para producir paquetes. Ethernet los incluye en tramas con direcciones MAC y comprobación de errores. Finalmente, la interfaz transmite señales. UDP usa datagramas y no aporta los mismos mecanismos de TCP.

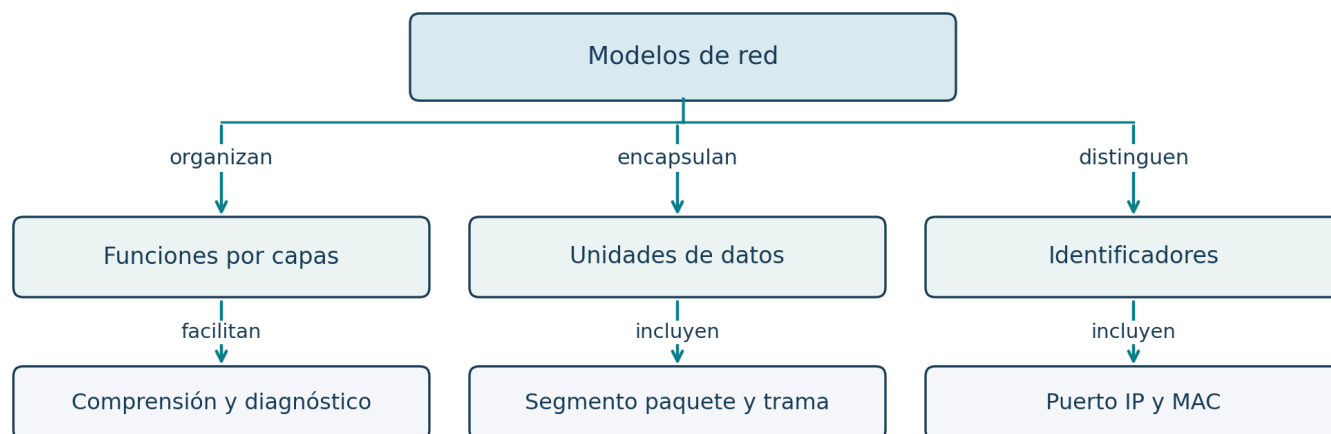
Un puerto identifica un extremo de transporte; una IP identifica una interfaz lógicamente; una MAC se utiliza en el enlace. Son identificadores con propósitos distintos. Para alcanzar un servidor remoto, la trama local puede dirigirse a la MAC del gateway mientras el paquete IP mantiene como destino al servidor.

Entender qué cambia durante el recorrido

Al atravesar un router, la trama del enlace de entrada no se reenvía intacta por todos los enlaces. El router examina el paquete y lo encapsula según el enlace de salida. Ciertos campos IP cambian durante el recorrido, como TTL en IPv4; NAT puede modificar direcciones o puertos donde se aplica. Por eso debe especificarse si el caso considera traducción o simplemente enrutamiento.

Diagnóstico explicado. Una IP válida no compensa un cable desconectado. Una señal correcta no crea una ruta faltante. Una ruta correcta no garantiza que la aplicación autorice al usuario. El modelo ayuda a construir comprobaciones desde la evidencia, evitando saltar de un síntoma a una conclusión sin revisar dependencias.

Mapa de relaciones para explicar el tema



Mapa conceptual 33 Modelos de red

Preguntas y casos del indicador 33

Aplicación del aprendizaje. Relacionar funciones y unidades de datos con las capas de ambos modelos.

1 Orden de encapsulación

En Ethernet sobre IPv4 con TCP, ¿qué contiene normalmente la trama: un paquete IP o directamente solo datos de aplicación?

Explicación. La trama contiene el paquete IP, que transporta el segmento TCP y sus datos. Cada capa añade información para su función. El orden permite reconocer unidades y evitar confundir direcciones MAC, direcciones IP y puertos.

2 Relacionar OSI y TCP IP

Se utiliza el modelo TCP IP de cuatro capas. ¿Dónde se agrupan funciones de aplicación, presentación y sesión del modelo OSI?

Explicación. Se agrupan en la capa de aplicación del modelo TCP IP. La correspondencia es didáctica entre modelos y no una igualdad exacta de implementación. Si un ejercicio utiliza cinco capas, debe atenderse a esa representación explícita.

3 Diagnóstico físico

Un puerto no detecta enlace después de retirar el cable. ¿Qué capa orienta la primera comprobación?

Explicación. La física, porque falta el medio o la señal de enlace. No corresponde comenzar cambiando permisos de una base de datos. El modelo ayuda a ordenar hipótesis, aunque un diagnóstico completo pueda involucrar varias capas.

4 Identificadores por función

Para una conexión se observan una MAC, una IP y un puerto TCP. ¿Qué distingue cada identificador?

Explicación. La MAC se utiliza en el enlace local; la IP identifica una interfaz lógicamente y participa en enrutamiento; el puerto identifica un extremo de transporte asociado a procesos. Ninguno sustituye automáticamente la identidad humana de quien usa el servicio.

5 Cambio al atravesar un router

Un paquete IP pasa de una LAN a otra por un router. ¿Debe conservar intacta la misma trama Ethernet durante todo el recorrido?

Explicación. No. El router retira la encapsulación de enlace de entrada y genera la apropiada para la salida. El paquete IP se procesa y ciertos campos cambian, como TTL. NAT, si existe, puede añadir otras transformaciones y debe indicarse aparte.

34 Capa física y enlace de datos

Operaciones ciberseguras · Nivel 10 · Indicador 9.1 · Tabla página 9

Indicador de logro. Identifica los protocolos de la capa física y la capa de enlace de datos.

Propósito de aprendizaje. Distinguir transmisión de señales, organización de tramas y acceso al medio.

Conceptos fundamentales

La capa física convierte bits en señales y define aspectos del medio: eléctricos, ópticos o de radio. Incluye conectores, sincronización y características de transmisión. El cobre puede sufrir interferencias; la fibra transmite luz y no presenta las mismas susceptibilidades electromagnéticas; el medio inalámbrico comparte el espacio radioeléctrico.

La capa de enlace organiza tramas para el enlace, direccionamiento local y detección de errores según tecnología. En Ethernet, una trama contiene MAC de destino y origen, información de protocolo, datos y FCS. La FCS permite detectar ciertos errores con una comprobación; no cifra la trama ni garantiza autenticidad del remitente.

Ethernet pertenece a la familia IEEE 802.3 y WiFi a IEEE 802.11. Ambas incluyen funciones físicas y de enlace. No debe asignarse todo un estándar complejo a una única operación sin leer qué función se pregunta.

En Ethernet compartido semidúplex se utiliza CSMA/CD, relacionado con detectar colisiones. En enlaces conmutados dúplex completo no se utiliza ese mecanismo de colisiones. En WiFi se emplean mecanismos de CSMA/CA, que buscan reducir colisiones en un medio compartido.

Situación	Función identificada
Convertir bits en pulsos luminosos.	Física.
Agregar MAC a una trama.	Enlace de datos.
Verificar FCS al recibir.	Detección de errores de trama.
Elegir una ruta hacia otra subred.	Red, no física ni enlace.

Caso resuelto. La señal llega, pero las tramas acumulan errores. Deben revisarse medio, conectores, interferencia y configuración del enlace antes de concluir que existe una falla de autenticación de usuarios.

Del bit a la señal

Un bit es una unidad de información; para viajar necesita una representación física. En cobre se utilizan señales eléctricas; en fibra, luz; en radio, ondas electromagnéticas. El medio introduce límites de distancia, atenuación e interferencia. Un enlace nominalmente rápido puede funcionar mal por conectores o condiciones del medio. El análisis físico examina esas condiciones antes de atribuir el síntoma a una aplicación.

El ancho de banda disponible, la codificación y la calidad de señal influyen en transmisión. La fibra evita ciertas interferencias electromagnéticas del cobre, pero sigue expuesta a cortes, curvaturas y problemas de conexión. Elegir un medio requiere considerar entorno y necesidad, no declararlo invulnerable.

La trama añade organización local

Ethernet utiliza direcciones MAC de origen y destino y una FCS para detectar ciertos errores. La FCS no constituye una firma de la persona remitente. Un atacante que construye una trama puede calcular su comprobación correspondiente. Detección de errores y autenticación son propiedades diferentes.

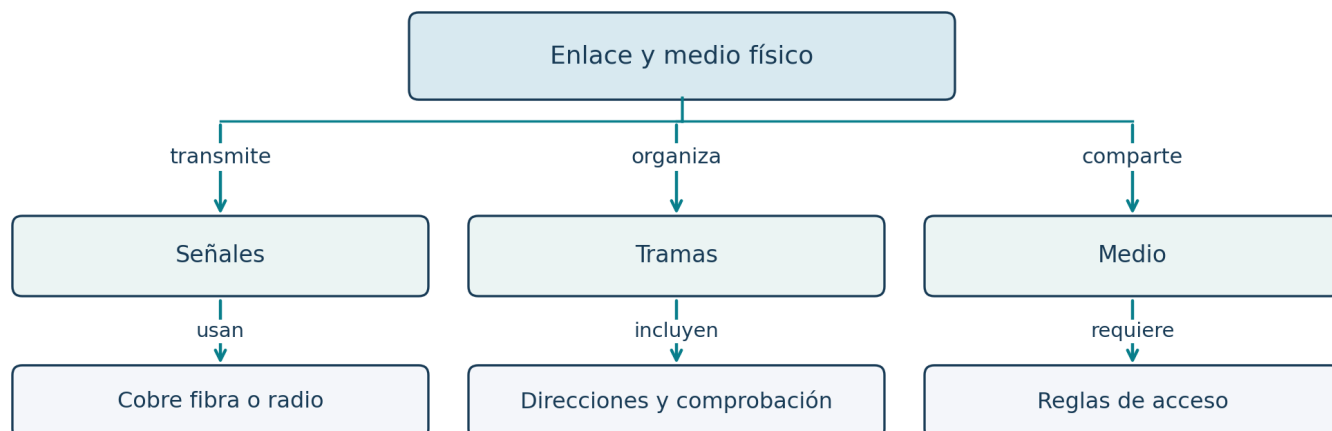
Ethernet y WiFi abarcan especificaciones de física y enlace. Ethernet conmutado en dúplex completo no utiliza el mecanismo de colisiones de Ethernet compartido semidúplex. CSMA/CD corresponde a detectar colisiones en ese entorno compartido; CSMA/CA en WiFi intenta reducir colisiones mediante mecanismos de acceso al medio. No significa que en radio nunca ocurran interferencias o pérdidas.

Usar el síntoma para decidir qué comprobar

Si la interfaz no detecta enlace, revise conexión, energía y condiciones físicas. Si hay errores de trama, revise medio, conectores y parámetros. Si el enlace funciona pero los equipos pertenecen a VLAN distintas, corresponde analizar organización lógica y enrutamiento. Cada evidencia reduce posibilidades, aunque no resuelve todo por sí sola.

Caso comentado. Un equipo recibe tramas con FCS válida, pero de una fuente que suplanta una dirección. La comprobación no demuestra legitimidad. Se requieren controles de acceso y otras validaciones. Una pregunta que menciona FCS pide reconocer integridad de transmisión, no confidencialidad ni autorización humana.

Mapa de relaciones para explicar el tema



Mapa conceptual 34 Enlace y medio físico

Preguntas y casos del indicador 34

Aplicación del aprendizaje. Distinguir transmisión de señales, organización de tramas y acceso al medio.

1 Medios de transmisión

Un cable de cobre presenta interferencia electromagnética. ¿Por qué la fibra puede ser una alternativa pertinente sin ser invulnerable?

Explicación. La fibra transmite luz y no tiene la misma susceptibilidad electromagnética del cobre. Sin embargo, puede sufrir cortes, curvaturas y problemas de conectores. Deben compararse propiedades del medio y condiciones reales, no afirmar inmunidad a toda falla.

2 Tramas y FCS

Una trama llega con error de comprobación FCS. ¿Qué indica esa verificación y qué no intenta proporcionar?

Explicación. Indica una inconsistencia detectada en la trama recibida. FCS ayuda a detectar errores, pero no cifra contenido ni autentica a una persona. Una trama con comprobación válida también puede transportar actividad maliciosa.

3 Ethernet compartido

Varios equipos comparten un medio Ethernet semidúplex. ¿Con qué mecanismo se relaciona la detección de colisiones?

Explicación. Con CSMA CD en ese entorno. No debe trasladarse sin cambios al Ethernet conmutado dúplex completo, donde no se utiliza el mismo mecanismo de colisiones. El modo de operación es un dato decisivo del escenario.

4 Acceso inalámbrico

En WiFi, estaciones compiten por un medio compartido. ¿Por qué se habla de mecanismos para evitar colisiones?

Explicación. Se emplean mecanismos asociados a CSMA CA para organizar acceso y reducir conflictos. Esto no garantiza que nunca existan interferencias o pérdidas. La radio compartida requiere coordinación y no funciona como todos los enlaces cableados independientes.

5 Medio frente a organización lógica

El enlace físico está activo, pero dos hosts quedaron en VLAN distintas sin enrutamiento. ¿Por qué cambiar el cable puede no resolverlo?

Explicación. La señal puede ser correcta mientras la separación lógica impide ese intercambio. Deben revisarse VLAN y la función de capa 3 si se requiere comunicación entre redes. Un síntoma de conectividad no demuestra automáticamente falla física.

35 Tablas MAC y resolución de direcciones

Operaciones ciberseguras · Nivel 10 · Indicador 10.1 · Tabla página 9

Indicador de logro. Diferencia las tablas de direccionamiento MAC.

Propósito de aprendizaje. Seguir cómo un switch aprende y reenvía tramas y distinguir su tabla de otras tablas de red.

Conceptos fundamentales

Un switch de capa 2 aprende la MAC de origen, el puerto de entrada y la VLAN de una trama. Usa la MAC de destino para decidir el reenvío. Las entradas dinámicas pueden caducar y actualizarse si un dispositivo cambia de puerto. También pueden existir entradas estáticas según configuración.

Si conoce el destino y está en otro puerto habilitado, reenvía hacia él. Si el destino unicast es desconocido, normalmente inunda por otros puertos de la misma VLAN en estado de reenvío. Si destino y origen están en el mismo puerto de entrada, filtra la trama. Los broadcasts también se limitan al dominio correspondiente.

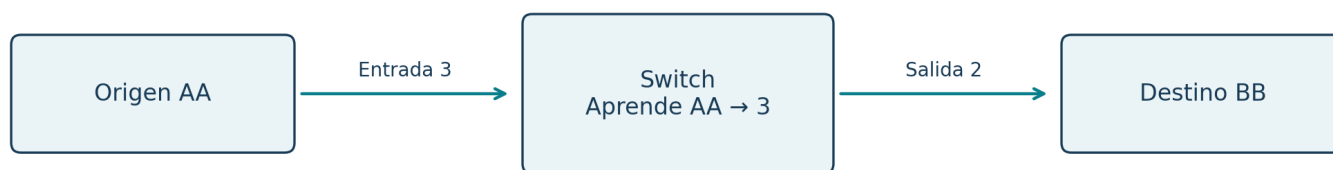


Tabla existente: BB → puerto 2 | La decisión de envío usa la MAC de destino

Esquema aplicado El origen permite aprender y el destino permite decidir

Tabla	Relaciona principalmente	Uso
MAC del switch	MAC, puerto y VLAN.	Conmutación local.
ARP de IPv4	Dirección IPv4 y MAC de un vecino.	Resolver destino o siguiente salto en el enlace.
Rutas IP	Prefijos y siguientes saltos o interfaces.	Elegir cómo llegar a otras redes.

ARP resuelve una IPv4 a una MAC dentro del enlace. Para enviar a una red remota, el host resuelve la MAC de su puerta de enlace, no la MAC del servidor remoto a través de Internet. IPv6 emplea descubrimiento de vecinos mediante ICMPv6, no ARP.

Caso resuelto. La tabla de VLAN 10 tiene BB en puerto 2. Una trama de AA entra por puerto 3 destinada a BB. El switch aprende AA en puerto 3 y reenvía por 2, si está operativo. No aprende BB por el puerto 3 solo porque la trama mencione ese destino.

Aprender y reenviar son dos operaciones diferentes

Cuando llega una trama, el switch observa la MAC de origen y la relaciona con el puerto y la VLAN. Después busca la MAC de destino para decidir dónde enviarla. No aprende la ubicación del destino por el hecho de que aparezca escrito en una trama que llega desde otro equipo. La dirección de origen aporta evidencia de dónde se encuentra quien emitió esa trama.

Si el destino es conocido y está en otro puerto habilitado para reenvío, se utiliza ese puerto. Si está asociado al mismo puerto de entrada, no se devuelve innecesariamente por ese camino. Si es unicast desconocido, suele inundarse por otros puertos pertinentes de esa VLAN. La inundación no significa enviar a todas las VLAN del equipo.

Separar tabla MAC tabla ARP y tabla de rutas

La tabla MAC relaciona direcciones de enlace con puertos y VLAN. ARP relaciona IPv4 con MAC de vecinos del enlace. La tabla de rutas relaciona prefijos IP con siguientes saltos o interfaces. Un host puede necesitar ARP para construir una trama; el switch utiliza su tabla MAC para reenviarla; el router usa rutas para llegar a otra red. Se complementan, pero no almacenan lo mismo.

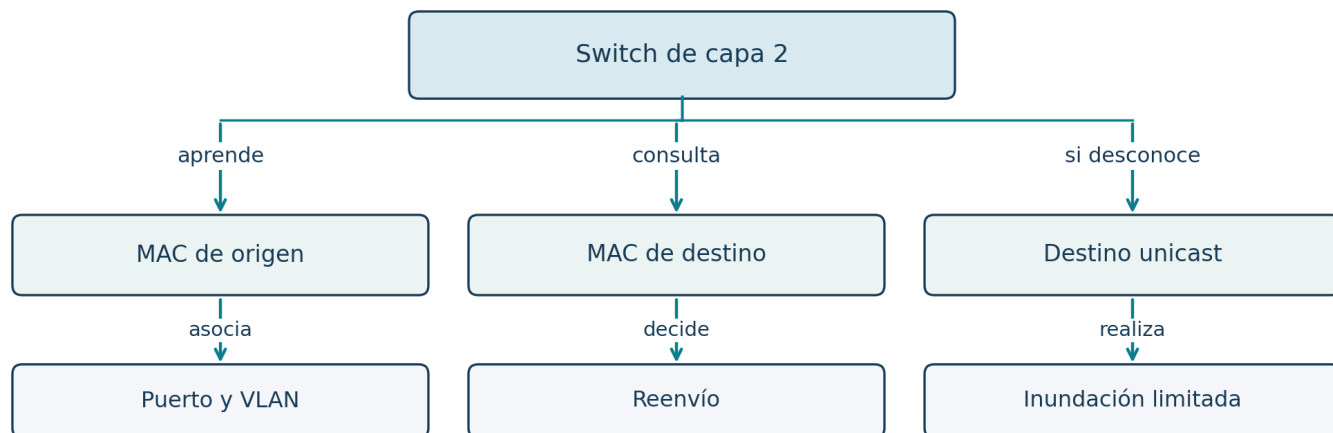
Las entradas dinámicas pueden caducar. Un destino desconocido no prueba necesariamente un ataque: puede ser un equipo recién conectado o una entrada expirada. Los cambios frecuentes e incoherentes pueden requerir investigar bucles, movilidad o suplantación según el contexto.

Un envío remoto explicado

El host 192.168.10.20 necesita llegar a un servidor de otra red. Determina que el destino es remoto y utiliza su gateway. Resuelve la MAC del gateway en su enlace, no la MAC remota a través de Internet. La trama se dirige al siguiente salto; el paquete IP se dirige al servidor, salvo transformaciones aplicables como NAT.

Compruebe la lógica. Si AA entra por puerto 3 destinada a BB, el aprendizaje nuevo corresponde a AA en 3. Que BB figure en el destino no la ubica en 3. La respuesta correcta necesita mantener separadas ambas acciones del switch.

Mapa de relaciones para explicar el tema



Mapa conceptual 35 Switch de capa 2

Preguntas y casos del indicador 35

Aplicación del aprendizaje. Seguir cómo un switch aprende y reenvía tramas y distinguir su tabla de otras tablas de red.

1 Aprendizaje de origen

Llega una trama desde MAC AA por puerto 3 y destinada a BB. ¿Qué asociación nueva aprende el switch?

Explicación. Aprende AA en puerto 3 y en la VLAN correspondiente. El aprendizaje usa el origen. El destino BB se consulta para decidir reenvío; no se aprende que BB está en puerto 3 solo por aparecer como destino.

2 Destino conocido

La tabla indica BB por puerto 2 y llega por puerto 3 una trama hacia BB. ¿Cómo se reenvía en condiciones operativas normales?

Explicación. Se envía por el puerto 2 correspondiente, si está habilitado para ese reenvío y VLAN. No se inunda innecesariamente como un destino desconocido. La tabla debe interpretarse con estado de puertos y configuración, no de manera aislada.

3 Destino desconocido

No existe entrada para una MAC unicast de destino. ¿Por qué el switch puede enviar por varios puertos?

Explicación. La inundación limitada a los puertos pertinentes de la VLAN permite intentar alcanzar el destino. No implica difusión a todas las VLAN. El aprendizaje posterior de tramas de origen puede permitir un reenvío más específico.

4 Tabla MAC frente a ARP

Un host consulta una asociación IP a MAC y un switch consulta MAC a puerto. ¿Están usando la misma tabla?

Explicación. No. ARP relaciona IPv4 con una dirección de enlace de un vecino; la tabla del switch relaciona MAC con puerto y VLAN. Ambas ayudan a entregar datos localmente, pero almacenan relaciones y cumplen operaciones diferentes.

5 Destino remoto

El host necesita llegar a un servidor de otra subred. ¿Resuelve normalmente la MAC del servidor remoto mediante ARP a través de Internet?

Explicación. No. Resuelve la dirección de enlace del siguiente salto local, normalmente el gateway. La trama va a ese vecino mientras el paquete IP se dirige al servidor, salvo transformaciones aplicables. ARP no es un sistema global de resolución de MAC remotas.

36 Direcciones IPv4 e IPv6

Operaciones ciberseguras · Nivel 10 · Indicador 11.1 · Tabla página 9

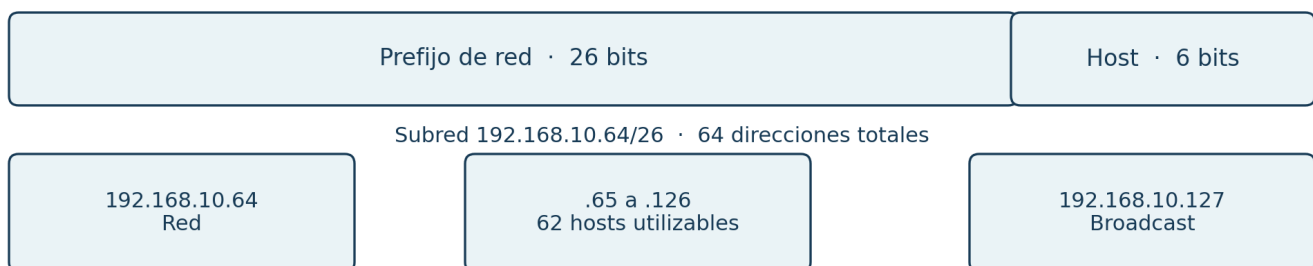
Indicador de logro. Diferencia las direcciones IPv4 (unicast, broadcast y multicast) e IPv6 (unicast, anycast, multicast).

Propósito de aprendizaje. Diferenciar unicast, broadcast, multicast y anycast y reconocer límites de una subred.

Conceptos fundamentales

IPv4 utiliza 32 bits, representados habitualmente en cuatro octetos. Un prefijo indica cuántos bits identifican la red. En una /24 quedan 8 bits para direcciones dentro de ese bloque. Las direcciones privadas son 10.0.0.0/8, 172.16.0.0/12 y 192.168.0.0/16; una dirección que no sea privada no es necesariamente pública utilizable, pues existen rangos especiales.

Unicast se dirige a una interfaz. Broadcast en IPv4 alcanza el dominio de difusión correspondiente; una dirección de broadcast de subred tiene todos los bits de host en 1. Multicast se dirige a miembros de un grupo; en IPv4 se utiliza el bloque 224.0.0.0/4 para ese tipo.



Esquema aplicado Subred 192.168.10.64 con prefijo 26

Ejemplo resuelto. 192.168.10.64/26 tiene 64 direcciones, desde .64 hasta .127. En una subred ordinaria, .64 identifica la red, .127 es broadcast y .65-.126 son direcciones de host. El tamaño proviene de los 6 bits restantes: 2 elevado a 6 = 64. No aplique restar dos a todos los casos especiales, como enlaces /31.

IPv6 utiliza 128 bits y escritura hexadecimal. Pueden omitirse ceros iniciales de grupos; :: comprime una secuencia de grupos cero una sola vez. Unicast identifica una interfaz;

multicast, un grupo; anycast utiliza una dirección compartida y entrega a una de sus interfaces según la ruta. IPv6 no define broadcast.

IPv6	Significado
::1	Loopback.
::	Dirección no especificada.
fe80::/10	Direcciones link local.
ff00::/8	Multicast.
fc00::/7	Direcciones locales únicas ULA.

Calcular una subred a partir del prefijo

En IPv4 hay 32 bits. Un prefijo /26 reserva 26 para la red y deja 6 para el bloque. Se obtienen 2 elevado a 6, es decir, 64 direcciones. En el último octeto, los bloques comienzan en 0, 64, 128 y 192 cuando los otros octetos permanecen en ese contexto. El bloque que comienza en .64 termina en .127.

En una subred convencional, todos los bits de host en 0 identifican la red y todos en 1 el broadcast. Por eso los hosts habituales de ese bloque van de .65 a .126. La máscara /26 es 255.255.255.192. No se debe aplicar la resta de dos de forma ciega a casos especiales como /31 en enlaces punto a punto.

Diferenciar dirección privada y alcance

Los rangos privados IPv4 se usan dentro de redes y no se enrutan globalmente como direcciones públicas. NAT puede traducir direcciones en un borde, pero no es sinónimo de firewall ni cifra tráfico. Una dirección no privada puede pertenecer a un rango especial; por eso no debe deducirse que toda dirección fuera de los tres bloques privados es pública utilizable.

Unicast llega a una interfaz; multicast se dirige a un grupo; broadcast existe en IPv4 dentro del dominio correspondiente. IPv6 no define broadcast. Anycast comparte una dirección entre interfaces y entrega a una según el enrutamiento, no a todas simultáneamente.

Leer y comprimir IPv6

Una IPv6 tiene ocho grupos de 16 bits escritos en hexadecimal. Se pueden omitir ceros iniciales de un grupo. Una única aparición de :: puede representar una secuencia de grupos cero. Por ejemplo, 2001:db8:0:0:0:0:25 se representa como 2001:db8::25. El prefijo 2001:db8::/32 se reserva para documentación y ejemplos.

Caso comentado. Dos servidores comparten una dirección y el enrutamiento selecciona uno. El rasgo decisivo es entrega a uno de los miembros, propia de anycast. Si el objetivo fuera entregar a los integrantes de un grupo multicast, sería una relación distinta. El número de equipos configurados no basta para decidir; importa la forma de entrega.

Mapa de relaciones para explicar el tema



Mapa conceptual 36 Direccionamiento IP

Preguntas y casos del indicador 36

Aplicación del aprendizaje. Diferenciar unicast, broadcast, multicast y anycast y reconocer límites de una subred.

1 Tamaño de una subred

En IPv4, ¿cuántas direcciones contiene un bloque /26 y cuántas se reservan habitualmente para red y broadcast en una subred convencional?

Explicación. Quedan seis bits: dos elevado a seis produce 64 direcciones. Habitualmente se reservan dos y quedan 62 para hosts. No debe aplicarse automáticamente esa resta a todos los casos especiales, como determinados enlaces /31.

2 Límites de un bloque

Para 192.168.10.64/26, ¿cuáles son red, broadcast y rango habitual de hosts?

Explicación. Red .64, broadcast .127 y hosts .65 a .126. Los bloques del último octeto avanzan de 64 en 64 en este caso. El límite .128 inicia el bloque siguiente, por lo que no pertenece a esta subred.

3 Direcciones privadas

Se comparan 172.20.1.8 y 172.40.1.8. ¿Pertenece ambas al bloque privado 172.16.0.0/12?

Explicación. No. Ese bloque comprende segundos octetos del 16 al 31. La primera pertenece y la segunda no. No basta observar que empieza con 172. También existen otros rangos especiales; fuera de un rango privado no significa automáticamente utilizable como dirección pública.

4 Notación IPv6

¿Cómo puede comprimirse 2001:0db8:0000:0000:0000:0000:0025 sin alterar su valor?

Explicación. Como 2001:db8::25. Se omiten ceros iniciales de grupos y una secuencia continua de grupos cero mediante una sola aparición de doble dos puntos. Usar esa compresión dos veces haría ambigua la cantidad de grupos omitidos.

5 Unicast multicast y anycast

Varios servidores IPv6 comparten una dirección y el enrutamiento entrega a uno de ellos. ¿Por qué no corresponde a multicast?

Explicación. Es anycast: se entrega a uno de los destinos según el enrutamiento. Multicast busca entrega a miembros de un grupo. Unicast identifica una interfaz y IPv6 no define broadcast; las categorías deben distinguirse por la forma de entrega.

37 Transporte con TCP y UDP

Operaciones ciberseguras · Nivel 10 · Indicador 12.1 · Tabla página 9

Indicador de logro. Compara el proceso de transporte de datos utilizando TCP y UDP.

Propósito de aprendizaje. Comparar fiabilidad, orden, control y uso de puertos según la necesidad de la aplicación.

Conceptos fundamentales

La capa de transporte comunica procesos. Los puertos identifican extremos asociados a servicios y aplicaciones; una dirección IP sola no indica qué proceso debe recibir los datos. Una conexión se distingue por información como direcciones, puertos y protocolo.

TCP establece una conexión y proporciona un flujo de bytes ordenado y fiable mediante secuencias, confirmaciones y retransmisiones. Su establecimiento habitual utiliza SYN, SYN ACK y ACK. Tiene control de flujo para no desbordar al receptor y control de congestión para adaptar transmisión a la red.

UDP envía datagramas sin establecer una conexión fiable de transporte. No ofrece por sí mismo orden, retransmisión o entrega garantizada. Una aplicación puede implementar sus propios controles sobre UDP; no debe concluirse que usar UDP impide toda fiabilidad en capas superiores.

Característica	TCP	UDP
Unidad habitual	Segmento y flujo de bytes.	Datagrama.
Establecimiento fiable	Sí.	No por el propio protocolo.
Orden y retransmisión	Los proporciona el transporte.	Debe resolverlos otra capa si los necesita.
Sobrecarga	Mayor por sus mecanismos.	Cabecera más simple.
Criterio de elección	Entrega completa y ordenada.	Requisitos de la aplicación y tolerancia a pérdidas.

Caso resuelto. Descargar un archivo exige que la aplicación reciba todos los datos correctos. Una llamada en vivo puede preferir perder una muestra tardía a esperar una retransmisión. Esto no significa que TCP sea siempre lento ni UDP siempre apropiado para toda comunicación de video.

Un checksum ayuda a detectar errores en un segmento o datagrama; no reemplaza cifrado ni autentica a una persona. Los números de secuencia TCP permiten ordenar el flujo; no deben confundirse con las direcciones MAC.

Comprender la fiabilidad de TCP

TCP entrega un flujo de bytes ordenado entre extremos mediante números de secuencia, confirmaciones y retransmisiones. Si faltan bytes, sus mecanismos intentan recuperarlos dentro de las condiciones de la conexión. Esto no garantiza que una aplicación complete cualquier negocio: una conexión puede fallar y una transacción puede requerir tratamiento propio. Fiabilidad de transporte y éxito de una compra son niveles diferentes.

El establecimiento habitual utiliza SYN, SYN ACK y ACK. El control de flujo evita exceder lo que puede recibir el extremo; el control de congestión adapta la transmisión a condiciones de red. El primero se centra en el receptor y el segundo en la red. Confundirlos oculta por qué una transmisión puede reducir su ritmo.

Qué deja UDP a la aplicación

UDP envía datagramas sin establecer la misma conexión fiable. No incorpora por sí solo confirmación y retransmisión de cada mensaje ni orden garantizado. Una aplicación puede añadir seguimiento, temporizadores y recuperación. Por eso una aplicación sobre UDP puede ofrecer funciones fiables en otra capa, y no debe suponerse que todo uso de UDP admite perder cualquier dato.

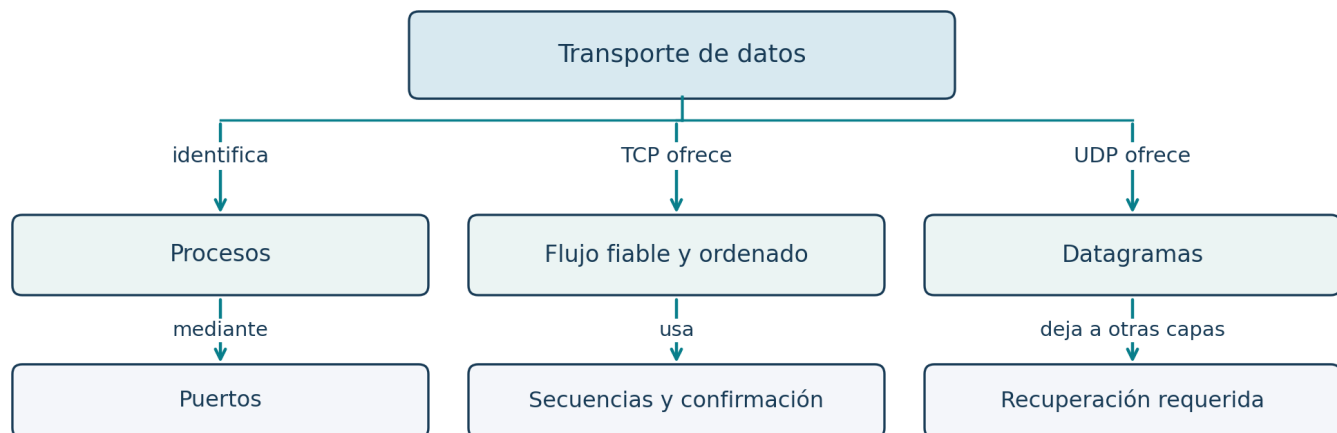
En una llamada en vivo, una muestra de audio muy tardía puede ser poco útil. En una descarga, completar todos los bytes es esencial. La elección depende del diseño, no de una regla universal «video usa UDP» o «TCP siempre es lento». Protocolos modernos pueden combinar UDP con mecanismos superiores complejos.

Diferenciar puerto y dirección

La dirección IP orienta hacia una interfaz; el puerto ayuda a identificar el extremo del proceso. Dos aplicaciones pueden comunicarse desde el mismo equipo usando puertos distintos. Una conexión TCP se distingue por direcciones y puertos de ambos extremos, junto con su protocolo. El número de puerto habitual es una pista de servicio, no una prueba de legitimidad.

Ejemplo ampliado. Una solicitud sobre UDP no recibe respuesta. La aplicación puede esperar un tiempo, registrar la falta y reintentar según su diseño. Sin ese mecanismo, UDP no lo hará automáticamente. El analista debe atribuir la función a la capa que realmente la implementa.

Mapa de relaciones para explicar el tema



Mapa conceptual 37 Transporte de datos

Preguntas y casos del indicador 37

Aplicación del aprendizaje. Comparar fiabilidad, orden, control y uso de puertos según la necesidad de la aplicación.

1 Establecimiento de TCP

Antes de intercambiar datos, se observan SYN, SYN ACK y ACK. ¿Qué función representa esa secuencia habitual?

Explicación. El establecimiento de una conexión TCP. Permite coordinar estado entre extremos. No equivale a autenticar al usuario ni a cifrar automáticamente la comunicación. Esas funciones requieren mecanismos adicionales en las capas y aplicaciones correspondientes.

2 Flujo y congestión

Un receptor necesita limitar lo que recibe; en otro caso la red está congestionada. ¿Son el mismo problema de control?

Explicación. No. Control de flujo atiende capacidad del receptor; control de congestión ajusta comportamiento frente a condiciones de la red. Ambos pueden reducir la tasa, pero por razones diferentes. Identificar la causa evita atribuir toda lentitud al ancho de banda contratado.

3 Orden y retransmisión

Una aplicación necesita recibir un flujo completo y ordenado. ¿Qué mecanismos de TCP apoyan ese requisito?

Explicación. Secuencias, confirmaciones y retransmisiones, dentro de las condiciones de la conexión. No garantizan que una operación de negocio siempre termine: la conexión puede fallar. La aplicación debe tratar errores y estados incompletos propios.

4 UDP y aplicación

Una aplicación utiliza UDP y necesita detectar que no llegó una respuesta. ¿Puede incorporar temporizadores y reintentos?

Explicación. Sí. UDP no aporta por sí solo las mismas garantías de TCP, pero una capa superior puede implementar mecanismos necesarios. Elegir UDP no vuelve imposible toda fiabilidad; obliga a identificar dónde se construye y con qué límites.

5 Puertos y servicios

Un equipo mantiene dos aplicaciones de red. ¿Por qué la IP por sí sola no identifica siempre el proceso destinatario?

Explicación. La comunicación de transporte utiliza puertos y otros datos de la conexión para distinguir extremos. Una IP identifica la interfaz lógicamente, pero puede servir a muchos procesos. Un puerto habitual también es una convención, no prueba de legitimidad de la actividad.

38 Hackeo ético y evaluación autorizada

Operaciones ciberseguras · Nivel 11 · Indicador 13.1 · Tabla página 9

Indicador de logro. Identifica conceptos, tipos, ventajas y desventajas del hackeo ético.

Propósito de aprendizaje. Distinguir propósito, alcance, modalidades y límites de una evaluación de seguridad.

Conceptos fundamentales

El hackeo ético aplica conocimientos y pruebas de seguridad con autorización y dentro de un alcance acordado. Lo que distingue la actividad no es la marca de la herramienta ni que el evaluador tenga buenas intenciones, sino el permiso, las condiciones y su cumplimiento.

El alcance define sistemas, técnicas, horarios, datos, límites de impacto y responsables. Las reglas de trabajo indican cómo reportar hallazgos, proteger evidencia y detener pruebas si aparece un riesgo no previsto. Descubrir un sistema interesante fuera del alcance no autoriza evaluarlo.

Modalidad	Información previa	Consecuencia práctica
Caja negra	Poca o ninguna información interna.	Se aproxima a una perspectiva externa, con cobertura limitada por tiempo.
Caja blanca	Conocimiento interno amplio.	Permite revisar código, arquitectura y configuraciones con mayor contexto.
Caja gris	Conocimiento parcial.	Combina acceso limitado y análisis de ciertos componentes.

Un escaneo de vulnerabilidades identifica indicios y posibles fallas; una prueba de penetración busca verificar caminos de explotación e impacto bajo autorización. Una auditoría compara con criterios. Ninguna garantiza encontrar todo: la cobertura depende de alcance, método, tiempo y cambios del sistema.

Caso resuelto. Se permite evaluar una red, pero se prohíben pruebas que puedan interrumpir el servicio. La herramienta trae una prueba de denegación activada. Debe deshabilitarse o ajustarse la herramienta: el valor predeterminado no amplía la autorización.

Las ventajas incluyen detectar debilidades antes de su abuso y validar controles. Entre los límites están efectos operativos, resultados incompletos y necesidad de interpretar falsos positivos. El informe debe explicar evidencia, impacto y recomendaciones reproducibles de forma autorizada.

La autorización forma parte del método

Una evaluación ética comienza por delimitar sistemas, técnicas, horarios, responsables y límites de impacto. La intención de ayudar no sustituye el permiso. Un sistema encontrado durante la exploración puede pertenecer a un tercero o quedar fuera del acuerdo. El alcance establece qué puede hacerse y qué debe escalarse antes de continuar.

Las reglas de trabajo deben considerar datos sensibles, comunicación de hallazgos y condiciones para detener pruebas. Una herramienta con opciones predeterminadas intensivas no amplía la autorización. El evaluador adapta el método al entorno y registra sus acciones para que puedan interpretarse efectos y resultados.

Diferenciar información previa y profundidad

Caja negra significa poca información interna; caja blanca, conocimiento amplio de componentes; caja gris, información parcial. Ninguna significa trabajar sin permiso. La información disponible influye en cobertura y eficiencia, pero no garantiza encontrar todas las fallas. Una prueba de caja blanca puede revisar código y arquitectura con más contexto, mientras una de caja negra observa una perspectiva externa bajo tiempo y alcance concretos.

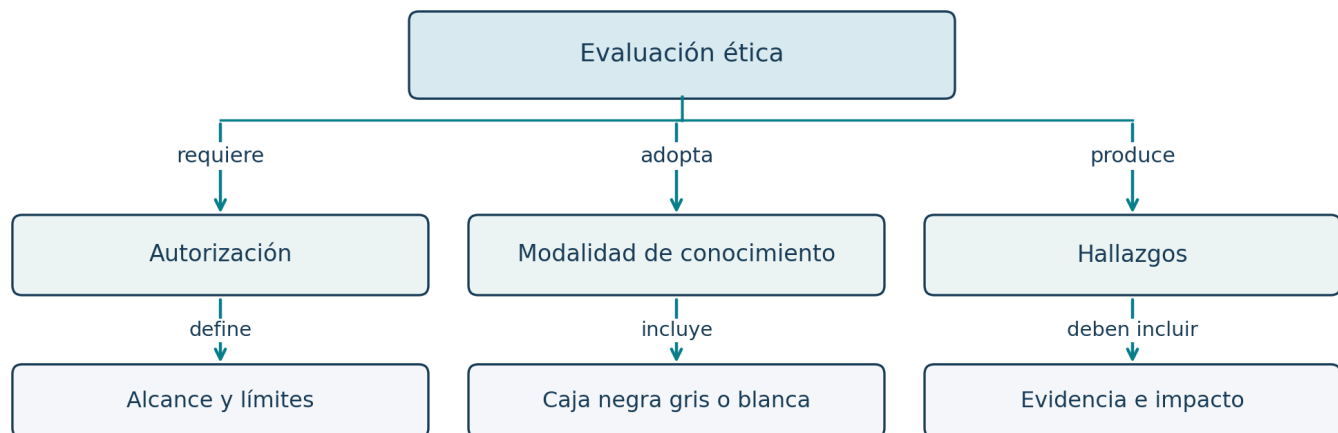
Un escaneo identifica posibles debilidades; una prueba de penetración verifica caminos de explotación e impacto dentro de condiciones autorizadas; una auditoría compara con criterios. Un resultado automatizado requiere validación. También puede haber falsos negativos: no encontrar una falla no prueba que no exista.

Comunicar para que el hallazgo pueda corregirse

Un informe útil describe activo, evidencia, condición observada, impacto posible, límites y recomendación. No basta incluir una captura con una puntuación. La organización necesita saber qué cambio atiende la causa y cómo comprobar que funcionó. La verificación posterior debe considerar que la corrección no haya dañado la operación.

Caso comentado. Se permite revisar una aplicación de prueba, pero se prohíbe interrumpir servicios. Una prueba de saturación queda fuera de esas condiciones aunque la herramienta la ofrezca. La respuesta profesional es ajustar el procedimiento y documentar la limitación. Cumplir alcance es parte de la validez del trabajo, no un obstáculo opcional.

Mapa de relaciones para explicar el tema



Mapa conceptual 38 Evaluación ética

Preguntas y casos del indicador 38

Aplicación del aprendizaje. Distinguir propósito, alcance, modalidades y límites de una evaluación de seguridad.

1 Alcance autorizado

Una prueba autoriza un servidor y el evaluador encuentra otro relacionado. ¿Puede incluirlo automáticamente porque pertenece aparentemente a la misma entidad?

Explicación. No. Debe comprobarse y ampliarse el alcance mediante autorización correspondiente. Una relación técnica no concede permiso. El hackeo ético se distingue por condiciones acordadas, límites y cumplimiento, no solo por la intención de ayudar.

2 Caja negra

El evaluador recibe poca información interna y trabaja desde una perspectiva externa. ¿Qué modalidad representa y qué limita?

Explicación. Caja negra. Describe información previa y puede limitar cobertura por tiempo y acceso. No significa trabajar sin permiso ni demostrar que se encontrarán todas las fallas. La autorización y la modalidad son dimensiones distintas.

3 Caja blanca y gris

En un trabajo se entrega código y arquitectura; en otro, solo una cuenta de usuario y datos parciales. ¿Cómo se distinguen?

Explicación. El primero corresponde a caja blanca y el segundo a caja gris. El conocimiento disponible cambia el análisis posible. No establece automáticamente superioridad absoluta: la modalidad debe seleccionarse según objetivos, tiempo y alcance.

4 Escaneo frente a penetración

Una herramienta informa una posible versión vulnerable. ¿Ese resultado demuestra explotación e impacto confirmado?

Explicación. No. Un escaneo aporta un indicio que puede necesitar validación autorizada. Una prueba de penetración busca verificar caminos de explotación e impacto dentro de

condiciones. Declarar compromiso solo por una alerta omite posibles errores o configuraciones particulares.

5 Informe y verificación de corrección

Se corrige una falla detectada. ¿Qué debe permitir comprobar el informe para cerrar el trabajo?

Explicación. Debe describir evidencia, alcance, riesgo y medida de modo que pueda verificarse la corrección pertinente. También deben constar límites y efectos observados. Una captura sin contexto no demuestra que la causa fue tratada ni que el servicio siga funcionando.

39 Energía sostenibilidad y disposiciones nacionales

Operaciones ciberseguras · Nivel 11 · Indicador 14.1 · Tabla página 10

Indicador de logro. Señala disposiciones nacionales relacionadas con políticas leyes y reglamentos orientados al desarrollo energético sostenible.

Propósito de aprendizaje. Relacionar decisiones tecnológicas con eficiencia energética y normativa costarricense pertinente.

Conceptos fundamentales

La eficiencia energética busca proporcionar un servicio con menor consumo innecesario. Ahorrar energía no significa desactivar indiscriminadamente sistemas críticos. Deben considerarse demanda real, continuidad, seguridad y ciclo de vida de los equipos.

La Ley 7447, Regulación del Uso Racional de la Energía, es una referencia nacional para promover uso eficiente. La Ley Orgánica del Ambiente 7554 establece un marco general de protección ambiental. La Ley 8839, Gestión Integral de Residuos, se relaciona con el tratamiento responsable de residuos, incluidos los tecnológicos según las reglas aplicables. Cumplen objetivos diferentes; no deben intercambiarse sus nombres o atribuciones. [F5]

Una política pública orienta acciones y metas; una ley establece disposiciones con rango legal; un reglamento desarrolla su aplicación. Una estrategia o programa institucional no sustituye automáticamente obligaciones legales. En casos de prueba, identifique cuál instrumento corresponde al tema y no memorice solo un número.

Medidas en tecnología. Medir consumo, activar estados de ahorro cuando la tarea lo permite, dimensionar equipos, consolidar cargas y revisar refrigeración. La virtualización puede mejorar aprovechamiento, pero concentrar servicios sin analizar redundancia puede crear un punto de fallo. Las fuentes renovables y la eficiencia son conceptos complementarios: que la energía sea renovable no justifica desperdiciarla.

Caso resuelto. Una empresa apaga todos sus equipos de respaldo para reducir consumo, sin comprobar continuidad. La medida puede comprometer disponibilidad. Debe comparar alternativas que mantengan el servicio requerido y reduzcan consumo evitable.

Antes de entregar o desechar equipos, deben tratarse dos aspectos: residuos mediante gestores o procedimientos autorizados y datos mediante sanitización apropiada. Reciclar físicamente no demuestra que la información fue eliminada.

Diferenciar consumo potencia y eficiencia

La potencia indica una tasa de uso de energía; la energía consumida depende también del tiempo. Un equipo de menor potencia puede consumir durante más horas para completar una tarea. La eficiencia compara servicio útil y recursos empleados. Por eso no basta elegir el número más pequeño de la etiqueta sin considerar carga de trabajo, duración y rendimiento.

Apagar sistemas innecesarios puede ahorrar, pero desactivar respaldos o refrigeración crítica sin análisis puede comprometer disponibilidad y seguridad. La sostenibilidad requiere equilibrio: reducir desperdicio y mantener el servicio requerido. Medir antes y después permite demostrar resultados en lugar de asumirlos por una configuración.

Reconocer instrumentos nacionales

La Ley 7447 se refiere a regulación del uso racional de la energía. La Ley 7554 establece el marco de la Ley Orgánica del Ambiente. La Ley 8839 trata gestión integral de residuos. En un caso de estudio, debe vincularse cada instrumento con su objeto y no atribuirles funciones intercambiables. Las disposiciones concretas se consultan en el texto vigente y la autoridad correspondiente.

Una política orienta metas y acciones; una ley establece disposiciones de rango legal; un reglamento desarrolla condiciones de aplicación dentro de su competencia. Una iniciativa empresarial o certificación no sustituye cumplir obligaciones. El indicador exige comprender esta relación, además de reconocer nombres.

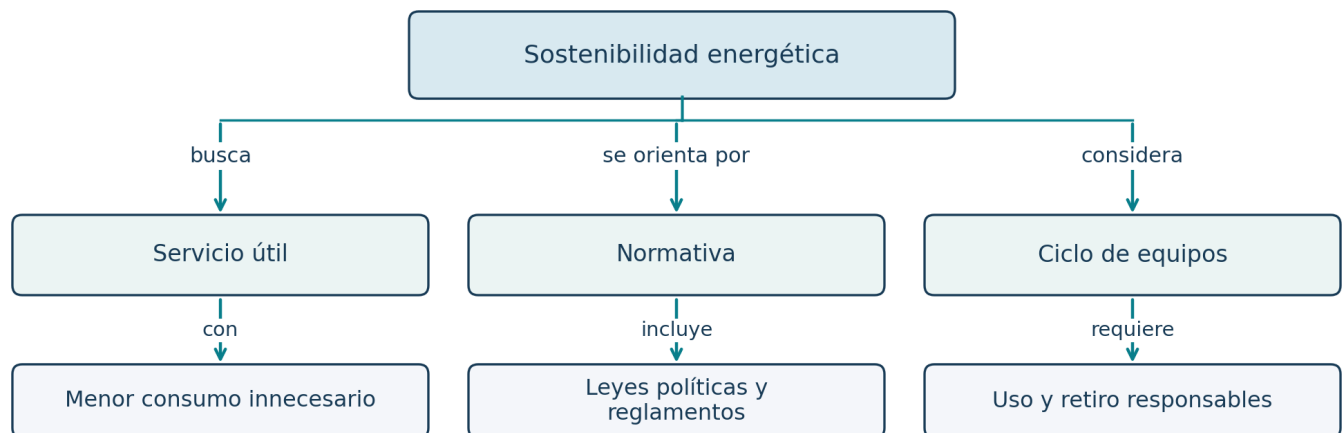
Aplicar el criterio a un laboratorio

Un laboratorio puede programar suspensión de equipos cuando no se usan, dimensionar fuentes, consolidar cargas y revisar ventilación. La virtualización puede mejorar utilización, pero concentrar todo en un único anfitrión aumenta dependencia si no existe continuidad adecuada. Un ahorro de energía debe analizarse junto con capacidad, redundancia y recuperación.

Al retirar equipos se trata el residuo y también la información. Entregar un disco a reciclaje no demuestra que sus datos hayan sido sanitizados. Una donación necesita revisar capacidad de reutilización, datos y obligaciones del proceso. El objetivo es evitar trasladar riesgos ambientales o de privacidad a otra persona.

Caso explicado. Dos servidores poco utilizados se consolidan. Para valorar la decisión, mida consumo y rendimiento, pero también pruebe qué ocurre si falla el anfitrión. La mejora no se demuestra únicamente reduciendo el número de cajas encendidas.

Mapa de relaciones para explicar el tema



Mapa conceptual 39 Sostenibilidad energética

Preguntas y casos del indicador 39

Aplicación del aprendizaje. Relacionar decisiones tecnológicas con eficiencia energética y normativa costarricense pertinente.

1 Potencia y energía

Un equipo consume menos potencia, pero tarda mucho más en completar la tarea. ¿Puede concluirse que siempre utilizará menos energía?

Explicación. No. La energía depende de potencia y tiempo. Debe compararse el trabajo útil bajo condiciones equivalentes. Una cifra menor de potencia nominal no demuestra por sí sola mayor eficiencia para una carga concreta.

2 Uso racional de energía

Un caso pregunta por el instrumento costarricense relacionado con uso racional de la energía. ¿Con cuál ley del manual se vincula?

Explicación. Con la Ley 7447. Su objeto debe distinguirse del marco ambiental general y de la gestión de residuos. Reconocer el número es útil si se entiende qué regula; los requisitos concretos se verifican en el texto vigente aplicable.

3 Marco ambiental y residuos

Se compara protección ambiental general con gestión integral de residuos. ¿Qué diferencia representan las leyes 7554 y 8839?

Explicación. La Ley 7554 corresponde al marco de la Ley Orgánica del Ambiente; la 8839 trata gestión integral de residuos. No son denominaciones intercambiables. Para resolver un caso debe relacionarse la actividad descrita con el objeto de cada instrumento.

4 Ahorro y disponibilidad

Se apaga el respaldo principal de un servicio crítico para reducir consumo sin probar recuperación. ¿Qué conflicto requiere análisis?

Explicación. El ahorro puede debilitar continuidad y disponibilidad. Deben valorarse consumo, criticidad y capacidad alternativa. Una medida sostenible busca reducir desperdicio

manteniendo necesidades del servicio; apagar más equipos no demuestra por sí solo una decisión adecuada.

5 Retiro responsable

Una institución dona computadoras que aún conservan datos personales. ¿Qué dos dimensiones debe atender el proceso?

Explicación. Reutilización o gestión responsable de equipos y protección de información. Deben inventariarse y sanitizarse los medios según corresponda. Entregar un equipo a un destino ambientalmente apropiado no prueba que los datos quedaron inaccesibles.

40 Configuración básica de dispositivos de red

Operaciones ciberseguras · Nivel 11 · Indicador 15.1 · Tabla página 10

Indicador de logro. Reconoce la configuración básica de dispositivos de red con simuladores y equipo físico.

Propósito de aprendizaje. Interpretar modos de administración y comandos fundamentales de Cisco IOS.

Conceptos fundamentales

En Cisco IOS, el modo EXEC de usuario suele mostrar >; el EXEC privilegiado, #; la configuración global, (config)#; y la configuración de interfaz, (config-if)#. El contexto determina qué instrucciones acepta el dispositivo. La sintaxis concreta puede variar por modelo y versión.

Comando	Propósito
enable	Acceder a EXEC privilegiado, con autenticación si está configurada.
configure terminal	Entrar a configuración global.
hostname Sucursal	Asignar el nombre del dispositivo.
interface g0/0	Seleccionar una interfaz, si existe con ese nombre.
ip address 192.168.10.1 255.255.255.0	Asignar dirección y máscara donde corresponda.
no shutdown	Habilitar administrativamente la interfaz.
show ip interface brief	Consultar resumen de direcciones y estado.
show running-config	Ver configuración activa.
copy running-config startup-config	Guardar la configuración activa para el arranque.

La running config es la configuración en uso; la startup config es la guardada para iniciar. Si cambia la primera y no guarda, un reinicio puede recuperar valores anteriores. show consulta; no equivale a modificar ni guardar.

Protección del acceso. Usar credenciales apropiadas, acceso remoto protegido con SSH, cuentas y permisos definidos y restricción de administración. Una contraseña de consola protege ese acceso local; no configura por sí sola todos los accesos remotos. `enable secret` se utiliza para proteger el acceso privilegiado según plataforma.

Caso resuelto. Una interfaz tiene IP correcta, pero aparece administratively down. El estado indica deshabilitación administrativa; revisar shutdown y aplicar `no shutdown` cuando corresponda atiende esa causa. Un estado down por falla física exige revisar otra capa.

Interpretar el contexto de un comando

En Cisco IOS, un comando pertenece a un modo. EXEC de usuario permite determinadas consultas; EXEC privilegiado amplía funciones; configuración global cambia parámetros generales; configuración de interfaz se centra en una interfaz. El indicador del prompt ayuda a reconocer dónde se trabaja. Un comando correcto en un modo equivocado puede no ser aceptado.

`enable` permite acceder al modo privilegiado conforme a autenticación. `configure terminal` entra en configuración global. `hostname` asigna nombre. Seleccionar una interfaz no la configura completamente: deben aplicarse parámetros apropiados y comprobar estado. La sintaxis exacta depende de plataforma y versión, por lo que en el estudio se relaciona comando con función.

Diferenciar configuración y estado operativo

`no shutdown` habilita administrativamente una interfaz, pero no conecta un cable ni corrige la configuración del otro extremo. Una interfaz puede estar habilitada y seguir sin enlace. La dirección IP y máscara deben corresponder al diseño; una dirección escrita correctamente puede ser incorrecta para esa subred.

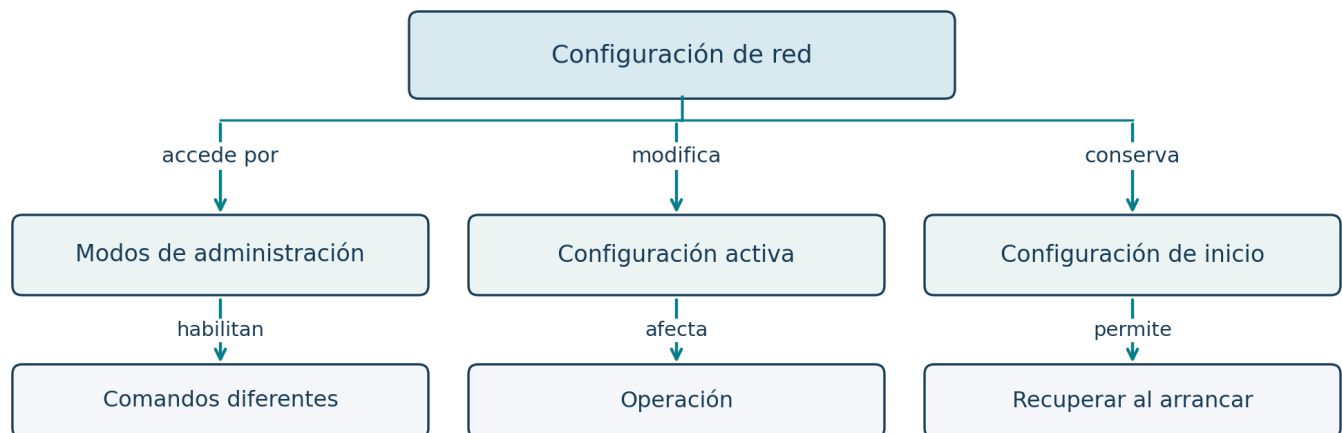
`show ip interface brief` permite observar un resumen, mientras otros comandos ofrecen más detalle. `show running-config` muestra configuración activa. `show startup-config` consulta la guardada para el arranque. Copiar la activa a la de inicio conserva cambios según el funcionamiento de la plataforma; no es lo mismo que guardar un archivo de texto en el equipo del administrador.

Proteger el plano de administración

El acceso remoto debe usar canales protegidos, identidades y permisos. Una contraseña de consola protege ese método de entrada, pero no define por sí sola seguridad de todas las líneas remotas. El secreto de habilitación protege el acceso privilegiado según la configuración. La administración también necesita restricciones de origen, registros y recuperación autorizada.

Caso comentado. El equipo funciona después del cambio, pero vuelve a la configuración anterior al reiniciar. La evidencia orienta a que no se guardó en el lugar de inicio correspondiente. Si la interfaz aparece administratively down, revise deshabilitación administrativa; si aparece down por falta de enlace, investigue el medio. El síntoma determina qué comprobación tiene sentido.

Mapa de relaciones para explicar el tema



Mapa conceptual 40 Configuración de red

Preguntas y casos del indicador 40

Aplicación del aprendizaje. Interpretar modos de administración y comandos fundamentales de Cisco IOS.

1 Modos de comandos

El equipo muestra el modo EXEC de usuario y no acepta un comando de configuración global. ¿Qué debe revisarse?

Explicación. El contexto o modo requerido y la autorización para acceder a él. Un comando válido en otro modo puede ser rechazado. La secuencia habitual utiliza enable para privilegio y configure terminal para configuración global, según plataforma y configuración.

2 Activación administrativa

Una interfaz figura administratively down. ¿Qué función cumple no shutdown y qué no puede corregir?

Explicación. Habilita administrativamente la interfaz. No conecta el cable ni corrige parámetros del extremo remoto. Si después sigue sin enlace, deben revisarse otras condiciones. La palabra down requiere interpretarse dentro del estado completo mostrado.

3 Conservar cambios

Una configuración funciona hasta reiniciar y después vuelve la anterior. ¿Qué diferencia debe comprobarse?

Explicación. La diferencia entre running config y startup config. Debe guardarse la configuración activa en el destino de inicio apropiado, por ejemplo mediante copy running-config startup-config en el entorno correspondiente. Mostrarla en pantalla no equivale a guardarla.

4 Consultas de estado

Se necesita un resumen de direcciones y estado de interfaces. ¿Qué consulta del manual resulta pertinente y qué información complementaria puede requerirse?

Explicación. Show ip interface brief aporta el resumen. Según el síntoma, pueden necesitarse detalles de interfaz, VLAN, rutas o registros. Ningún resumen contiene todas las causas posibles; el comando debe elegirse por la pregunta que permite responder.

5 Acceso de administración

Se protege la consola con contraseña, pero el acceso remoto conserva una configuración débil. ¿Queda asegurada toda la administración?

Explicación. No. Consola y acceso remoto son métodos diferentes. Deben configurarse identidades, canales protegidos, permisos y restricciones pertinentes para cada vía. Proteger un punto de entrada no demuestra protección de los demás.

41 Conceptos de conmutación

Operaciones ciberseguras · Nivel 11 · Indicador 15.2 · Tabla página 10

Indicador de logro. Diferencia los conceptos de conmutación.

Propósito de aprendizaje. Distinguir cómo se reenvían tramas y cómo se separan los dominios de comunicación.

Conceptos fundamentales

La conmutación decide por dónde reenviar tramas dentro de una red de enlace. Un switch aprende MAC y utiliza la tabla correspondiente. Cada puerto conmutado separa el dominio de colisión del enlace; en dúplex completo no se opera mediante colisiones como en Ethernet compartido semidúplex.

Una VLAN crea un dominio de broadcast lógico. Equipos de VLAN diferentes requieren una función de capa 3 para comunicarse entre sus redes. Compartir un mismo switch físico no elimina esa separación. Un switch de capa 2 no enruta únicamente por conocer las MAC.

Método	Comportamiento	Diferencia importante
Store and forward	Recibe toda la trama y verifica FCS antes de reenviar.	Puede descartar tramas con errores detectados.
Cut through	Comienza a reenviar antes de recibir toda la trama.	Reduce espera inicial, pero no dispone aún de la FCS completa.

Un puerto de acceso transporta normalmente tráfico de una VLAN para un dispositivo final. Un troncal puede transportar varias VLAN mediante etiquetado, como IEEE 802.1Q. Las VLAN permitidas y la configuración de ambos extremos deben coincidir con el diseño. La VLAN nativa tiene un tratamiento específico para tráfico no etiquetado, según configuración.

Caso resuelto. Un destino unicast no aparece en la tabla MAC. El switch inunda la trama por otros puertos de la misma VLAN en reenvío. Eso no significa difundirla automáticamente por todas las VLAN ni enviarla siempre a un router.

Dominios distintos. La segmentación por VLAN reduce el alcance de broadcasts, pero no reemplaza autorización, filtros ni protección de endpoints. Un troncal mal configurado puede transportar menos o más VLAN de las previstas.

Comprender qué divide un switch

Cada puerto de un switch separa el dominio de colisión del enlace; en dúplex completo no se utiliza el mecanismo de colisiones del Ethernet compartido. Una VLAN delimita un dominio de broadcast lógico. Un mismo switch puede sostener varias VLAN sin que los broadcasts de una circulen automáticamente por todas las demás.

Los equipos de redes IP diferentes requieren una función de capa 3 para comunicarse entre ellas. Un switch de capa 2 no crea rutas solo por conocer MAC. La tabla MAC permite entrega local dentro de la organización de VLAN. Esta diferencia conecta con los modelos de capas y con la función de la puerta de enlace.

Entender los métodos de reenvío

Store and forward recibe la trama completa y comprueba FCS antes de reenviar. Cut through comienza antes de recibirla completa, cuando dispone de información suficiente para decidir. Esto puede reducir espera inicial, pero no tiene todavía la comprobación final completa. La comparación debe indicar qué beneficio y qué límite se evalúan; no significa que un método sea siempre superior en cualquier red.

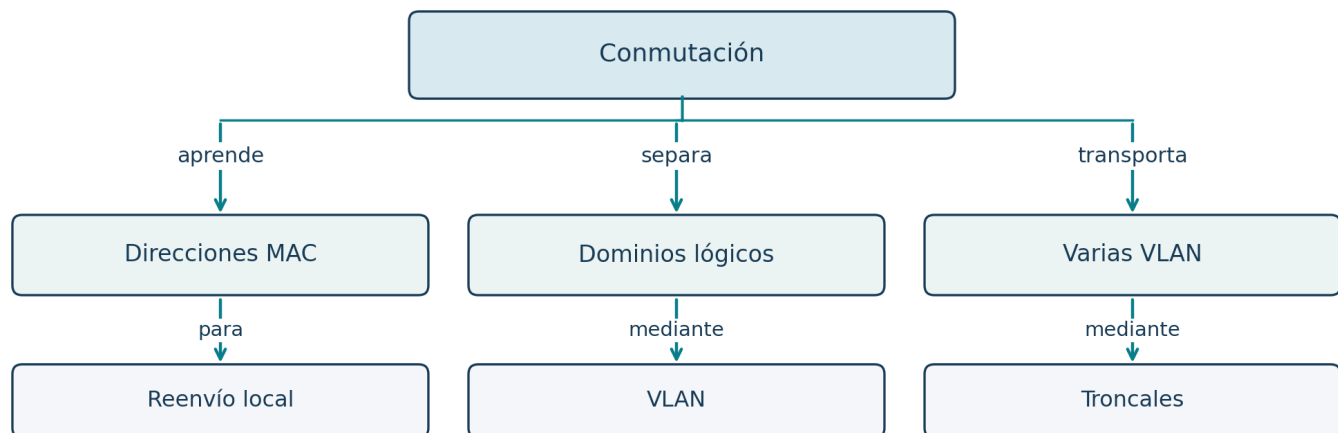
Una trama unicast desconocida suele inundarse por puertos apropiados de su VLAN. La inundación permite intentar alcanzar el destino mientras la tabla aprende, pero debe permanecer limitada por la configuración. Una tormenta causada por bucles es un problema distinto que exige analizar topología y STP.

Acceso y troncal en un escenario

Un puerto de acceso conecta normalmente un dispositivo final con una VLAN. Un troncal transporta varias VLAN mediante etiquetado como IEEE 802.1Q. La lista de VLAN permitidas restringe cuáles pasan. La VLAN nativa recibe un tratamiento específico para tráfico no etiquetado según la configuración; ambos extremos deben ser coherentes.

Caso explicado. Un host de VLAN 20 no llega a otro switch porque el troncal permite solo VLAN 10. Cambiar la dirección MAC no incorpora VLAN 20 a esa lista. Debe revisarse el paso de la VLAN. Si ambas VLAN circulan, pero no hay comunicación entre subredes, la revisión se desplaza a capa 3 y políticas.

Mapa de relaciones para explicar el tema



Mapa conceptual 41 Conmutación

Preguntas y casos del indicador 41

Aplicación del aprendizaje. Distinguir cómo se reenvían tramas y cómo se separan los dominios de comunicación.

1 Dominios de difusión

Dos grupos están en VLAN distintas del mismo switch. ¿Se difunden automáticamente los broadcasts de uno hacia el otro?

Explicación. No. Cada VLAN delimita su dominio lógico de broadcast. El equipo físico compartido no elimina la separación. Si se requiere comunicación entre sus redes, debe existir una función de capa 3 y políticas apropiadas.

2 Store and forward

Un switch recibe la trama completa y verifica FCS antes de reenviarla. ¿Qué método utiliza y qué beneficio aporta?

Explicación. Store and forward. Permite comprobar la trama antes de reenviarla y descartar errores detectados. No equivale a validar el permiso del usuario sobre una aplicación: FCS comprueba transmisión, no autorización de negocio.

3 Cut through

Un switch comienza a reenviar cuando dispone de información suficiente del destino, antes de recibir toda la trama. ¿Qué intercambio entre ventajas y límites aparece?

Explicación. Cut through puede reducir espera inicial, pero aún no dispone de la comprobación final completa. No debe afirmarse superioridad universal: el efecto depende de plataforma, tráfico y requisitos. La diferencia clave es cuándo comienza el reenvío.

4 Puerto de acceso y troncal

Un enlace entre switches debe transportar VLAN 10, 20 y 30. ¿Qué configuración lógica corresponde normalmente?

Explicación. Un enlace troncal que permita esas VLAN, con parámetros coherentes entre extremos. Un puerto de acceso pertenece normalmente a una VLAN para el dispositivo final. Declarar un enlace troncal no garantiza que su lista de VLAN incluya todas las requeridas.

5 Enrutamiento entre VLAN

Dos hosts de distintas redes IP están conectados al mismo switch de capa 2. ¿Conocer ambas MAC basta para comunicarlos entre subredes?

Explicación. No. Se necesita una función de capa 3 y configuración apropiada en hosts y red. La tabla MAC resuelve entrega dentro del ámbito de enlace; no crea rutas IP. La cercanía física no sustituye esa función.

42 VLAN y diagnóstico de switches de capa 3

Operaciones ciberseguras · Nivel 11 · Indicador 16.1 · Tabla página 10

Indicador de logro. Soluciona problemas del conmutador de capa 3.

Propósito de aprendizaje. Localizar la causa de una falla entre VLAN mediante comprobaciones ordenadas.

Conceptos fundamentales

Un switch de capa 3 combina conmutación y enrutamiento. Una SVI es una interfaz virtual asociada a una VLAN y puede funcionar como puerta de enlace de sus hosts. También pueden existir puertos enrutados, según el dispositivo. Habilitar una VLAN y asignar IP a un host no configura automáticamente todo el camino.

Orden de revisión. Compruebe enlace físico; existencia de VLAN; asignación del puerto; paso de VLAN por troncales; estado y dirección de SVI; IP, máscara y puerta de enlace de hosts; enrutamiento; rutas y ACL. Cambiar varios parámetros a la vez dificulta saber cuál causaba la falla.

Herramienta o consulta	Información que aporta
show vlan brief	Existencia de VLAN y puertos de acceso.
show interfaces trunk	Estado y VLAN permitidas en troncales.
show ip interface brief	Direcciones y estados de interfaces.
show ip route	Rutas conocidas y siguientes saltos.
ping	Prueba de alcance según respuesta y política.

Una SVI normalmente necesita VLAN existente, habilitación administrativa y un puerto activo apropiado para esa VLAN en estado útil, según plataforma. Una SVI administrativamente habilitada puede no estar operativa si no se cumplen las condiciones del enlace lógico.

Caso resuelto. VLAN 10 y 20 tienen SVI activas e IP correctas; los hosts usan la puerta de enlace correspondiente, pero el enrutamiento está deshabilitado. En un equipo que lo requiere,

habilitar ip routing atiende esa causa. Si una ACL deniega explícitamente el tráfico, repetir la habilitación de enrutamiento no corrige el filtro.

Máscara y puerta de enlace. Un host de VLAN 20 no debe usar sin diseño especial una puerta de enlace de otra subred. El error puede permitir acceso local y bloquear comunicación remota.

Construir el camino entre dos VLAN

Un host de VLAN 10 necesita una IP y máscara coherentes y una puerta de enlace de su subred. El switch de capa 3 puede ofrecer esa puerta mediante una SVI, interfaz virtual asociada a la VLAN. Para llegar a VLAN 20 se necesita enrutamiento habilitado donde corresponda y una interfaz o ruta apropiada. Crear nombres de VLAN no completa automáticamente ese camino.

Una SVI puede estar configurada pero no operativa si faltan condiciones del enlace lógico: VLAN existente, habilitación y un puerto apropiado activo, según plataforma. También puede existir un puerto enrutado que no funcione como puerto de acceso de una VLAN. Debe identificarse qué diseño se utiliza antes de aplicar comandos.

Diagnosticar en un orden que preserve información

Compruebe primero enlace y estado; después VLAN del puerto y paso por troncales; luego IP, máscara y gateway; finalmente rutas y controles. Si cambia todo simultáneamente, puede recuperar comunicación sin saber qué estaba mal o producir otra falla. Cada comprobación debe responder una hipótesis.

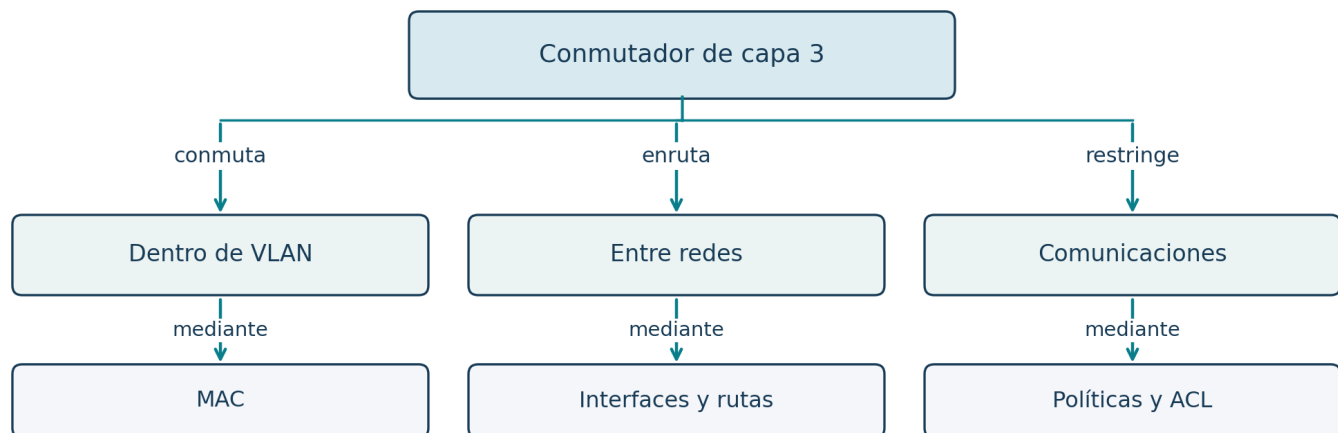
show vlan brief aporta pertenencia de puertos; show interfaces trunk, estado de troncales; show ip interface brief, direcciones y estado resumido; show ip route, rutas. ping prueba respuesta según el protocolo y las políticas, pero una ausencia de respuesta no demuestra por sí sola inexistencia de toda conectividad.

No confundir ruta con autorización

Una ruta indica un camino; una ACL puede permitir o negar tráfico. Si existe una ruta correcta pero una regla prohíbe el servicio, agregar la misma ruta no elimina la restricción. De modo inverso, una ACL permisiva no crea una ruta ausente. Ambos componentes deben corresponder a la necesidad.

Caso ampliado. Dos VLAN tienen SVI e IP válidas; los hosts usan sus gateways, pero está deshabilitado el enrutamiento en un equipo que lo requiere. Habilitar esa función atiende la causa. Si el problema fuera una VLAN omitida del troncal, esa acción sería insuficiente. La respuesta correcta conecta el dato del caso con el componente que falta.

Mapa de relaciones para explicar el tema



Mapa conceptual 42 Conmutador de capa 3

Preguntas y casos del indicador 42

Aplicación del aprendizaje. Localizar la causa de una falla entre VLAN mediante comprobaciones ordenadas.

1 Puerta de enlace en una SVI

Un host de VLAN 20 utiliza como gateway una dirección de otra subred sin diseño especial. ¿Qué debe corregirse?

Explicación. La puerta de enlace debe ser alcanzable en la subred local correspondiente según el diseño. Puede ser la SVI de VLAN 20. Crear una ruta en otro equipo no corrige necesariamente un parámetro inválido del propio host.

2 SVI sin estado operativo

Una SVI tiene IP y está habilitada, pero no está operativa. ¿Qué condiciones de VLAN y puertos deben comprobarse?

Explicación. Existencia de la VLAN y condiciones de activación, como un puerto apropiado activo, según la plataforma. Configuración administrativa y estado operativo son distintos. Escribir una dirección no demuestra que el enlace lógico pueda transportar tráfico.

3 Enrutamiento deshabilitado

Dos VLAN poseen SVI correctas, pero el equipo requiere habilitar enrutamiento y no lo tiene activo. ¿Qué causa explica la falta de comunicación entre ellas?

Explicación. Falta la función de enrutamiento requerida. En plataformas correspondientes se utiliza ip routing. La medida responde a ese dato específico; no solucionaría una VLAN ausente del troncal ni una máscara incorrecta del host.

4 VLAN ausente de la troncal

Una VLAN funciona en un switch, pero no llega al siguiente porque el enlace permite otras VLAN. ¿Qué debe revisarse?

Explicación. La lista de VLAN permitidas y su coherencia en el trayecto. El problema está en el transporte de esa VLAN. Agregar una ruta idéntica a la existente no incorpora automáticamente una VLAN omitida del troncal.

5 Ruta frente a filtro

Existe una ruta válida, pero una ACL niega el servicio solicitado. ¿Por qué agregar nuevamente la ruta no resuelve el acceso?

Explicación. La ruta determina camino y la ACL controla tráfico. Son decisiones distintas. Debe revisarse si el permiso solicitado corresponde al diseño antes de cambiar la regla. Una ACL permisiva tampoco crearía una ruta que no existe.

43 Protocolo de árboles de expansión

Operaciones ciberseguras · Nivel 11 · Indicador 17.1 · Tabla página 10

Indicador de logro. Describe el funcionamiento del protocolo de árboles de expansión.

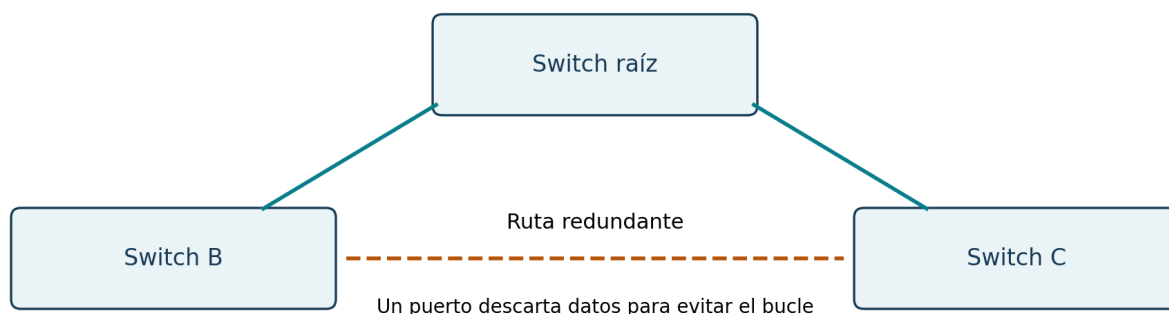
Propósito de aprendizaje. Explicar cómo STP conserva redundancia física sin crear bucles de capa 2.

Conceptos fundamentales

Los enlaces redundantes mejoran posibilidades de recuperación, pero un ciclo de capa 2 puede generar tormentas de broadcast, copias de tramas e inestabilidad de tablas MAC. Las tramas Ethernet no tienen un TTL equivalente al de un paquete IP que solucione ese bucle.

STP intercambia información mediante BPDU y establece una topología lógica sin ciclos. Elige un puente raíz, root bridge, comparando identificadores de puente. Se prefiere el menor identificador: la prioridad influye antes de la MAC; con los demás campos iguales, gana la MAC menor.

Un puerto raíz proporciona el mejor camino de un switch no raíz hacia la raíz. Un puerto designado reenvía en un segmento según la elección correspondiente. Otros caminos pueden mantenerse sin reenviar tráfico de usuario. El costo del camino y reglas de desempate determinan la selección; no basta contar cables visualmente.



Esquema aplicado El camino redundante conserva una alternativa sin crear un bucle

El STP clásico incluye estados como bloqueo, escucha, aprendizaje y reenvío. RSTP acelera convergencia y utiliza estados descarte, aprendizaje y reenvío, con roles adicionales como

alternativo. MST permite asociar grupos de VLAN a instancias; las variantes deben distinguirse por su propósito, no solo por la sigla.

Caso resuelto. En un triángulo de switches, un camino queda sin reenviar datos de usuario. Si falla el camino activo, la reconvergencia puede habilitar una alternativa válida. El enlace bloqueado no implica que esté físicamente averiado.

PortFast o función de puerto de borde acelera el ingreso de puertos destinados a hosts; no elimina el propósito de STP. BPDU Guard puede deshabilitar un puerto de borde al recibir una BPDU inesperada, según configuración.

Por qué la redundancia puede producir un bucle

En una topología triangular, una trama puede circular por caminos redundantes y regresar. Ethernet no utiliza un TTL de trama equivalente al de IP que resuelva ese ciclo. Pueden multiplicarse broadcasts y cambiar repetidamente las asociaciones MAC. La redundancia física necesita una topología lógica que evite circulación indefinida.

STP intercambia BPDU para construir esa topología. Se elige un puente raíz comparando identificadores; se prefiere el menor. La prioridad influye antes que la MAC y, cuando los demás componentes empatan, la MAC permite desempatar. No se elige necesariamente el switch más nuevo ni el ubicado físicamente al centro.

Entender roles y estados

Cada switch no raíz selecciona un puerto raíz como mejor camino hacia la raíz. En cada segmento se determina el puerto designado correspondiente. Otros caminos pueden quedar sin reenviar datos de usuario. El costo de camino y reglas de desempate importan: no basta contar cables visualmente si tienen características diferentes.

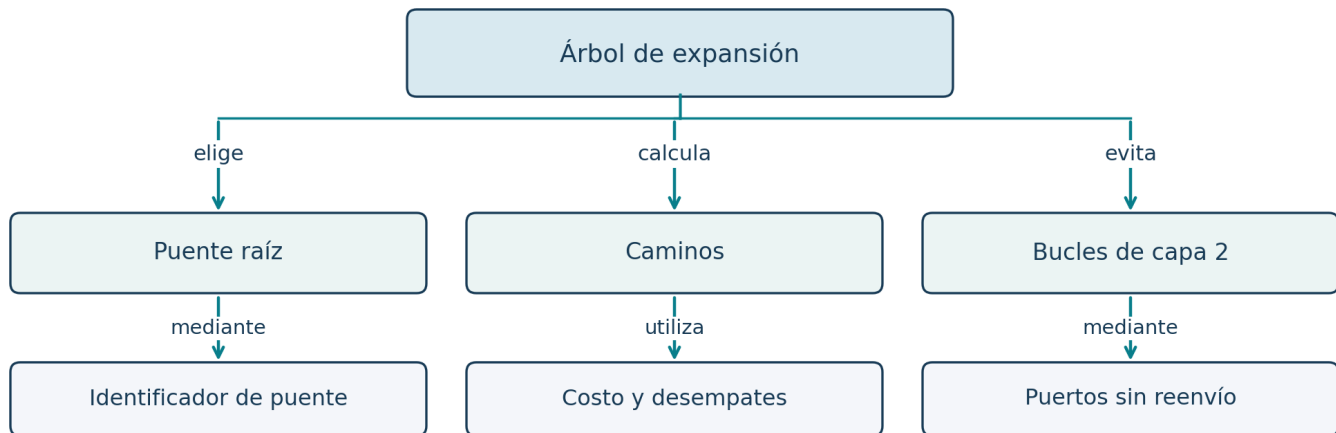
STP clásico utiliza estados como bloqueo, escucha, aprendizaje y reenvío, además de condiciones de deshabilitación. RSTP acelera convergencia y utiliza descarte, aprendizaje y reenvío, con roles adicionales. MST permite asociar VLAN a instancias. La función común es sostener una topología libre de bucles bajo las condiciones del protocolo, no eliminar físicamente todos los enlaces redundantes.

Qué ocurre cuando falla un enlace

Si se pierde un camino activo, el protocolo puede recalcular y permitir una alternativa. El tiempo y comportamiento dependen de versión, topología y configuración. El enlace que no reenviaba datos no estaba necesariamente averiado: conservaba una función de redundancia.

Caso explicado. Desactivar STP para que todos los cables del triángulo transmitan puede crear el problema que se pretendía evitar. PortFast o la función de borde se utiliza en puertos destinados a hosts y no autoriza conectar cualquier switch sin análisis. BPDU Guard puede proteger un puerto de borde ante BPDU inesperada conforme al diseño. La configuración debe respetar la función del puerto.

Mapa de relaciones para explicar el tema



Mapa conceptual 43 Árbol de expansión

Preguntas y casos del indicador 43

Aplicación del aprendizaje. Explicar cómo STP conserva redundancia física sin crear bucles de capa 2.

1 Elección del puente raíz

Dos switches tienen distinta prioridad de puente. ¿Se elige raíz simplemente por ser el más nuevo o tener más puertos?

Explicación. No. Se comparan identificadores de puente y se prefiere el menor conforme al protocolo. La prioridad influye y otros componentes permiten desempatar. La apariencia, antigüedad o posición en un dibujo no determina esa elección.

2 Costo del camino

Un switch no raíz tiene dos caminos hacia la raíz con diferente costo acumulado. ¿Qué característica orienta la selección del puerto raíz?

Explicación. El mejor costo de camino y, si es necesario, las reglas de desempate. No basta contar cables: enlaces con características distintas pueden producir costos distintos. Debe utilizarse la información de protocolo proporcionada por el caso.

3 Puerto sin reenvío

Un enlace redundante tiene un puerto que no reenvía tráfico de usuario. ¿Demuestra que el cable está averiado?

Explicación. No. Puede ser una decisión de STP para evitar bucles mientras conserva una alternativa. El estado lógico debe distinguirse de una falla física. Si cambia la topología, el protocolo puede recalcular y habilitar otro camino.

4 STP y RSTP

Un ejercicio compara bloqueo, escucha, aprendizaje y reenvío con descarte, aprendizaje y reenvío. ¿Qué distinción debe reconocerse?

Explicación. El primer conjunto se relaciona con STP clásico y el segundo con RSTP. También cambian roles y mecanismos de convergencia. No deben mezclarse nombres de estados entre variantes como si describieran exactamente el mismo funcionamiento.

5 Puerto de borde

Un puerto destinado a un host recibe una BPDU inesperada y tiene BPDU Guard. ¿Qué finalidad cumple esa protección?

Explicación. Puede deshabilitar el puerto según configuración para proteger el diseño ante una conexión no prevista. PortFast o función de borde no autoriza conectar switches arbitrariamente. Debe investigarse el origen antes de eliminar una protección para recuperar acceso.

44 DHCPv4

Operaciones ciberseguras · Nivel 11 · Indicador 18.1 · Tabla página 10

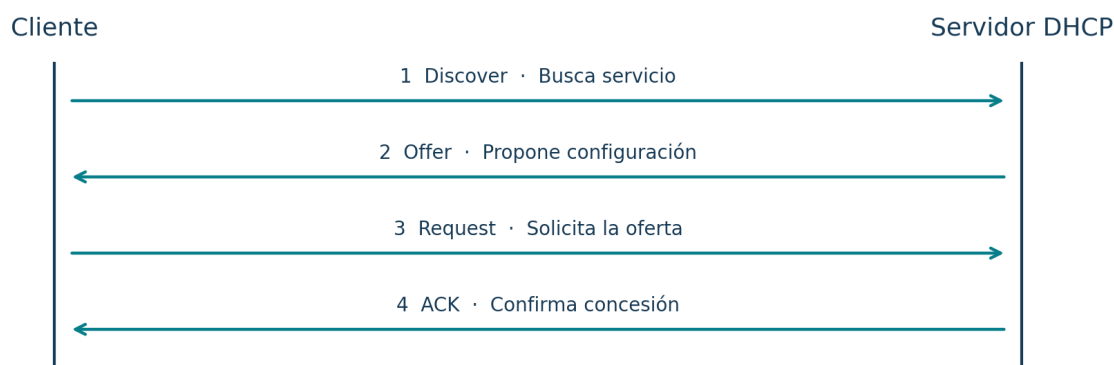
Indicador de logro. Reconoce las características de DHCPv4.

Propósito de aprendizaje. Reconocer asignación dinámica, concesiones y mecanismos para servir a otras subredes.

Conceptos fundamentales

DHCPv4 entrega parámetros como dirección IPv4, máscara, puerta de enlace y DNS. El servidor administra un conjunto o pool; el cliente obtiene una concesión por un tiempo. Una dirección dinámica no debe tratarse como permanente sin revisar reserva y condiciones.

El intercambio inicial habitual se recuerda como DORA: Discover busca servidores; Offer propone parámetros; Request solicita la oferta elegida; Acknowledge confirma la concesión. El cliente utiliza UDP 68 y el servidor UDP 67. Algunos mensajes iniciales usan broadcast porque el cliente todavía no dispone de una configuración utilizable.



Esquema aplicado Negociación habitual de una concesión DHCPv4

Una exclusión retira direcciones del conjunto asignable. Una reserva vincula un cliente a una dirección prevista. Si un equipo tiene una dirección estática que también puede entregar DHCP a otro, existe riesgo de duplicación. Los tiempos de renovación permiten mantener o recuperar la asignación según el protocolo.

Un agente de retransmisión, DHCP relay, permite llegar a un servidor de otra subred, porque los routers no reenvían ordinariamente los broadcasts de clientes. En plataformas Cisco puede configurarse mediante ip helper-address en la interfaz correspondiente, según diseño y versión.

Caso resuelto. Una impresora utiliza .120 estáticamente y el pool entrega .100-.150. Debe excluirse o reservarse adecuadamente .120 para evitar entregarla a otro cliente. Reducir el tiempo de concesión o crear un nombre DNS no elimina el solapamiento.

Diagnóstico. Revisar conectividad, VLAN, servidor, agotamiento del pool, relay, exclusiones y filtros. En ciertos clientes, una dirección 169.254.0.0/16 puede indicar autoconfiguración local por falta de configuración DHCP adecuada; no prueba por sí sola acceso a otras redes.

Una dirección entregada por un tiempo

DHCPv4 puede entregar IP, máscara, puerta de enlace y DNS. La concesión autoriza usar una configuración durante un periodo conforme al protocolo. No debe confundirse con una asignación permanente incondicional. El cliente intenta renovar antes de perder la concesión y sigue reglas para buscar servicio cuando cambian condiciones.

En el intercambio habitual, Discover busca servicio; Offer propone; Request expresa la solicitud del cliente; ACK confirma. El cliente utiliza UDP 68 y el servidor UDP 67. Los mensajes y su forma de envío dependen del estado; no todos son siempre broadcast ni todos necesariamente siguen cuatro pasos en cualquier situación.

Distintuir pool exclusión y reserva

El pool es el conjunto de direcciones disponibles para asignación. Una exclusión retira direcciones de ese conjunto. Una reserva relaciona un cliente con una dirección prevista según el servidor y sus identificadores. Una IP configurada manualmente dentro del rango dinámico puede duplicarse si no se administra la asignación. El tiempo de concesión no corrige por sí solo esa superposición.

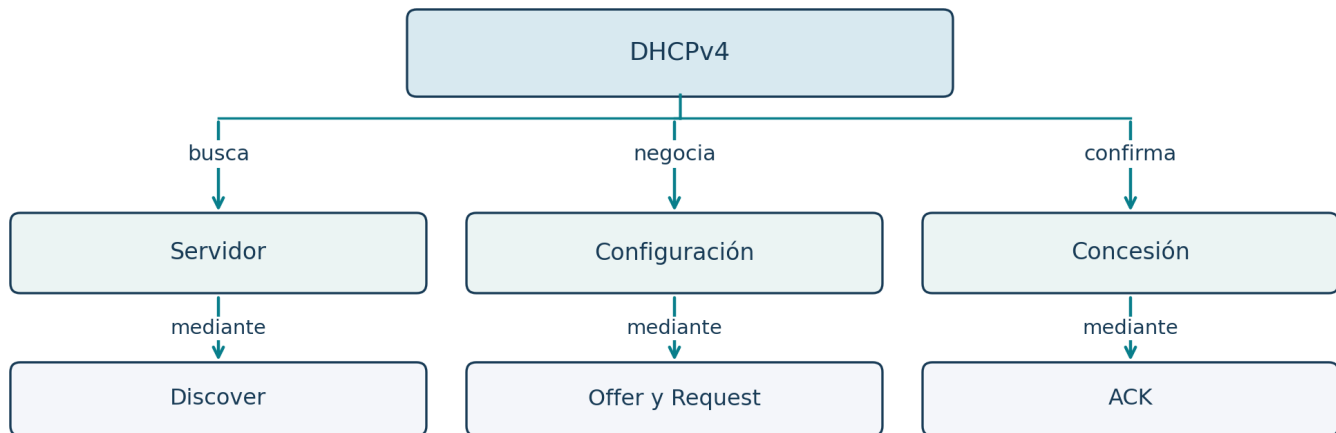
Una reserva facilita previsibilidad, pero debe revisarse cómo identifica el servidor al cliente. No debe asumirse que cualquier cambio de tarjeta o identificador conserva automáticamente la misma asignación. El diseño requiere documentación de direcciones y equipos.

Llegar a clientes de otra subred

Los routers no reenvían ordinariamente broadcasts de clientes entre subredes. Un relay DHCP recibe solicitudes y las transporta al servidor conforme al diseño. En plataformas Cisco puede utilizarse ip helper-address en la interfaz pertinente, pero la sintaxis y funciones concretas deben comprobarse. El servidor necesita conocer el ámbito correspondiente para entregar parámetros adecuados.

Caso comentado. Un cliente obtiene una dirección 169.254.x.x por autoconfiguración local en un sistema que usa ese mecanismo. Es una pista de que no obtuvo la configuración DHCP esperada, no una prueba completa de la causa. Revise enlace, VLAN, relay, servicio, pool y filtros. La solución debe atender la parte del recorrido que falla.

Mapa de relaciones para explicar el tema



Mapa conceptual 44 DHCPv4

Preguntas y casos del indicador 44

Aplicación del aprendizaje. Reconocer asignación dinámica, concesiones y mecanismos para servir a otras subredes.

1 Secuencia inicial

En un intercambio inicial habitual DHCPv4, ¿qué diferencia hay entre Offer y ACK?

Explicación. Offer propone configuración; ACK confirma la concesión correspondiente. Entre ambos, Request expresa la solicitud del cliente. No deben tratarse como nombres equivalentes de una dirección. Existen otras secuencias en renovación y estados diferentes del protocolo.

2 Concesión y renovación

Un cliente recibe una dirección por un periodo definido. ¿Puede considerarla una asignación permanente sin condiciones?

Explicación. No. La concesión tiene vigencia y mecanismos de renovación. Debe seguir las reglas del protocolo y del servidor. Que la dirección permanezca igual durante varios días no demuestra que esté configurada manualmente o garantizada indefinidamente.

3 Exclusiones

Un servidor entrega direcciones .100 a .150 y una impresora utiliza manualmente .120. ¿Qué riesgo debe eliminar el diseño?

Explicación. Una asignación duplicada si .120 sigue disponible para otro cliente. Debe excluirse o administrarse apropiadamente esa dirección. Cambiar el nombre de la impresora no evita la coincidencia de IP ni corrige el rango del servidor.

4 Relay

Los clientes están en otra subred y sus broadcasts no llegan al servidor DHCP. ¿Qué función puede transportar las solicitudes?

Explicación. Un relay DHCP configurado en el lugar pertinente. El servidor también necesita el ámbito correcto. Los routers no reenvían ordinariamente broadcasts de clientes entre subredes; una ruta IP por sí sola no equivale a configurar retransmisión DHCP.

5 Diagnóstico de autoconfiguración local

Un cliente muestra 169.254.x.x en un sistema que utiliza ese mecanismo. ¿Puede concluirse inmediatamente que el servidor está apagado?

Explicación. No. Es una pista de falta de configuración DHCP esperada. También pueden fallar enlace, VLAN, relay, filtros o agotarse el pool. El síntoma orienta un conjunto de comprobaciones, no demuestra una causa única.

45 DHCPv6 SLAAC y anuncios de router

Operaciones ciberseguras · Nivel 11 · Indicador 18.2 · Tabla página 10

Indicador de logro. Distingue las características de DHCPv6.

Propósito de aprendizaje. Distinguir quién proporciona dirección, parámetros adicionales y router predeterminado en IPv6.

Conceptos fundamentales

En IPv6, un host puede formar su dirección mediante SLAAC, recibirla mediante DHCPv6 con estado o utilizar otros métodos permitidos por el diseño. En DHCPv6 sin estado, obtiene información adicional sin que el servidor asigne esa dirección. La diferencia es qué estado de asignación mantiene el servidor.

Los anuncios de router, RA, forman parte de descubrimiento de vecinos con ICMPv6. Pueden proporcionar prefijos y orientar la autoconfiguración. El router predeterminado se descubre normalmente por RA, incluso cuando DHCPv6 entrega dirección y DNS. No debe trasladarse automáticamente el funcionamiento de puerta de enlace de DHCPv4 a DHCPv6.

Mecanismo	Dirección del cliente	Otros parámetros
SLAAC	La genera el host a partir de información recibida.	Según opciones y mecanismos de la red.
DHCPv6 sin estado	No la asigna ese intercambio DHCPv6.	Puede proporcionar DNS y otras opciones.
DHCPv6 con estado	La asigna y registra el servidor.	Puede proporcionar opciones adicionales.

El intercambio habitual con estado puede usar Solicit, Advertise, Request y Reply. Un cliente sin estado puede utilizar Information request y Reply. Los puertos UDP habituales son 546 para cliente y 547 para servidor o relay. El DUID identifica al cliente en el protocolo; no debe asumirse que toda asignación depende únicamente de su MAC. [F6]

Caso resuelto. Un host recibe dirección y DNS por DHCPv6, pero no descubre salida porque los RA legítimos se bloquean. Debe corregirse la política que impide esos anuncios. Renovar indefinidamente la dirección no reemplaza el descubrimiento del router.

La detección de direcciones duplicadas, DAD, ayuda a comprobar unicidad antes de usar una dirección unicast. IPv6 utiliza multicast para funciones que no deben describirse como broadcast IPv6.

Separar tres preguntas de configuración

En IPv6 conviene preguntar por separado quién proporciona la dirección, quién informa DNS u otros parámetros y cómo se descubre el router predeterminado. SLAAC permite que el host forme una dirección con información de anuncios de router y su mecanismo de generación. DHCPv6 con estado entrega direcciones y conserva información de asignación. DHCPv6 sin estado entrega opciones sin asignar la dirección en ese intercambio.

Los RA forman parte del descubrimiento de vecinos mediante ICMPv6. Pueden orientar autoconfiguración y descubrimiento de router. El gateway no se obtiene trasladando sin cambios la lógica de opciones de DHCPv4. Un host puede recibir dirección y DNS por DHCPv6 y aun necesitar RA para descubrir normalmente su router predeterminado.

Comprender los mensajes y los identificadores

El intercambio habitual con estado puede utilizar Solicit, Advertise, Request y Reply. Un cliente que solicita otras opciones sin estado puede usar Information request y Reply. Existen otros intercambios y variantes; la secuencia básica explica la negociación, pero no describe cada caso del protocolo. Los puertos habituales son UDP 546 para cliente y 547 para servidor o relay.

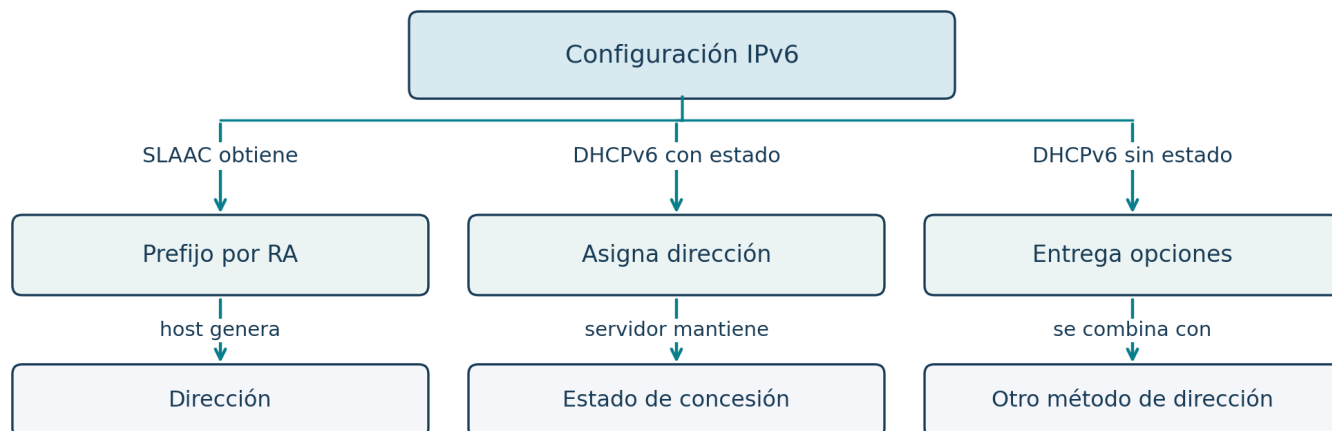
El DUID identifica al cliente en DHCPv6. No se debe reducir toda asignación a la MAC que se observa en una tarjeta. La implementación puede utilizar identificadores y asociaciones específicas. La detección de direcciones duplicadas, DAD, comprueba unicidad antes del uso bajo las reglas correspondientes; no sustituye autenticación de usuarios.

Diagnosticar sin eliminar funciones necesarias

Bloquear indiscriminadamente ICMPv6 puede afectar descubrimiento y funcionamiento de la red. Las políticas deben permitir lo requerido y restringir amenazas de forma específica. IPv6 utiliza multicast para operaciones que no deben describirse como broadcast IPv6, porque ese tipo de entrega no está definido en IPv6.

Caso ampliado. Un host posee dirección global y DNS, pero no tiene salida a otras redes. Revise router predeterminado y recepción de RA, además de rutas y políticas. Renovar repetidamente la dirección no corrige por sí solo anuncios bloqueados. Obtener DNS tampoco demuestra que la dirección se asignó con estado: pudo haberse generado mediante SLAAC.

Mapa de relaciones para explicar el tema



Mapa conceptual 45 Configuración IPv6

Preguntas y casos del indicador 45

Aplicación del aprendizaje. Distinguir quién proporciona dirección, parámetros adicionales y router predeterminado en IPv6.

1 Dirección mediante SLAAC

Un host forma una dirección utilizando el prefijo recibido en un anuncio de router. ¿Qué mecanismo se ilustra?

Explicación. SLAAC. El host genera la dirección conforme a información y reglas pertinentes. Esto no significa que todos los demás parámetros provengan del mismo mecanismo; debe analizarse por separado la obtención de DNS y del router predeterminado.

2 DHCPv6 con estado

El servidor entrega direcciones y conserva su información de asignación. ¿Qué modalidad corresponde?

Explicación. DHCPv6 con estado. La asignación de dirección por el servidor distingue esta modalidad de la obtención únicamente de opciones. El intercambio habitual puede incluir Solicit, Advertise, Request y Reply, con variantes previstas por el protocolo.

3 DHCPv6 sin estado

El host genera su dirección por SLAAC y consulta DNS mediante DHCPv6. ¿Recibir DNS demuestra asignación de dirección con estado?

Explicación. No. DHCPv6 sin estado puede entregar opciones sin asignar la dirección en ese intercambio. Debe observarse quién generó la dirección. La presencia de un servidor DHCPv6 no convierte automáticamente toda la configuración en una única modalidad.

4 Router predeterminado

Un host tiene dirección y DNS, pero no descubre salida a otras redes porque se bloquean anuncios de router. ¿Qué debe revisarse?

Explicación. La recepción de RA y el descubrimiento del router predeterminado, además de rutas y políticas. No debe trasladarse sin cambios la lógica de gateway de DHCPv4. Renovar la dirección no corrige anuncios legítimos que siguen bloqueados.

5 DAD e identidad

Un mecanismo comprueba si una dirección IPv6 ya está en uso. ¿Está autenticando a la persona usuaria?

Explicación. No. DAD comprueba duplicidad bajo las reglas correspondientes. La identidad de usuarios requiere otros mecanismos. También debe distinguirse el identificador DUID de una simple suposición de que toda asignación se basa únicamente en la MAC visible.

46 Controles de seguridad en LAN

Operaciones ciberseguras · Nivel 11 · Indicador 19.1 · Tabla página 10

Indicador de logro. Describe conceptos relacionados con seguridad en redes de área local.

Propósito de aprendizaje. Relacionar ataques de enlace con controles específicos sin atribuirles funciones que no tienen.

Conceptos fundamentales

La LAN necesita control de dispositivos, puertos, identidades y comunicaciones. Una VLAN separa dominios, pero no impide todo acceso indebido si existen reglas permisivas entre redes. Un puerto conectado no equivale a un usuario autorizado.

Control	Problema que atiende	Límite que debe comprender
Port security	Uso de MAC no permitidas en un puerto.	Una MAC no prueba identidad humana y puede suplantarse.
DHCP snooping	Mensajes de servidor DHCP desde puertos no confiables.	Requiere identificar correctamente enlaces confiables.
DAI	Asociaciones ARP falsas o inconsistentes.	Necesita información confiable y tratamiento de hosts estáticos.
BPDU Guard	BPDU inesperada en un puerto de borde.	Debe aplicarse donde el diseño espera un host.
802.1X	Acceso a la red basado en autenticación.	Requiere configuración de cliente, autenticador y servidor.

Una suplantación ARP intenta asociar una IP con una MAC indebida. DAI, inspección dinámica de ARP, puede validar asociaciones usando la tabla de DHCP snooping u otros mecanismos configurados. IP Source Guard limita tráfico según asociaciones IP de origen previstas en puertos, cuando está soportado.

Caso resuelto. Una computadora de usuario entrega ofertas DHCP falsas. DHCP snooping permite rechazar mensajes de servidor que llegan por un puerto no confiable. STP evita bucles; no sustituye ese control de DHCP.

Un host con IP estática puede no aparecer en la tabla aprendida por DHCP. Debe añadirse una asociación o regla confiable específica según equipo y diseño. Marcar todos los puertos como confiables para evitar bloqueos elimina gran parte de la protección.

Medidas complementarias. Deshabilitar puertos sin uso, definir explícitamente acceso o troncal, controlar VLAN permitidas y proteger administración. Una ACL de capa 3 puede restringir tráfico entre redes, pero no corrige por sí sola toda suplantación local.

La conexión física no demuestra autorización

Un puerto activo permite conectividad, pero no prueba identidad de la persona. Port security limita direcciones MAC según configuración; una dirección puede suplantarse. 802.1X incorpora un proceso de autenticación de acceso, con cliente, autenticador y servidor. Son controles diferentes y pueden complementarse. No deben describirse como equivalentes solo porque ambos restringen una entrada.

Una VLAN separa dominios lógicos, pero si el enrutamiento permite cualquier comunicación entre ellas, la separación no impide todo acceso. Deben definirse servicios necesarios y reglas. La segmentación reduce alcance y facilita políticas; no elimina la necesidad de proteger endpoints y aplicaciones.

Entender las validaciones de mensajes

DHCP snooping distingue puertos confiables para recibir determinados mensajes de servidor y puede construir información de asociaciones. Marcar todos los puertos como confiables elimina parte de su valor. DAI, inspección dinámica de ARP, puede validar mensajes con asociaciones confiables. Los hosts estáticos necesitan tratamiento conforme al diseño, porque pueden no aparecer en una tabla aprendida por DHCP.

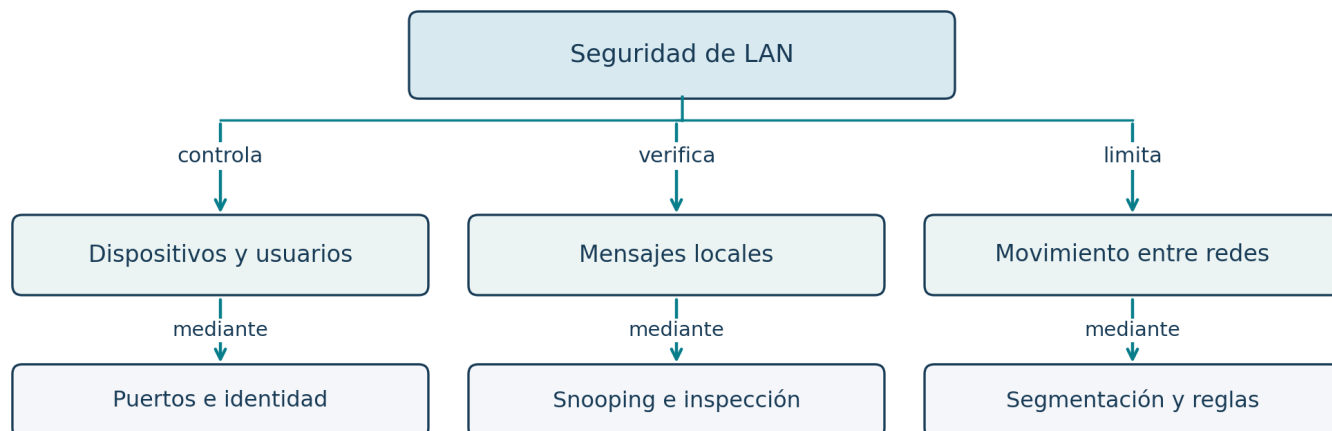
IP Source Guard limita tráfico según asociaciones de origen previstas donde se soporta. BPDU Guard trata BPDU inesperadas en puertos de borde según configuración. Cada control responde a un abuso concreto: uno no sustituye automáticamente a otro. STP evita bucles, pero no impide por sí solo que un servidor DHCP no autorizado entregue parámetros.

Seleccionar a partir del comportamiento observado

Si una computadora de usuario envía ofertas DHCP falsas, revise restricciones de mensajes de servidor y puertos confiables. Si se observan asociaciones ARP inconsistentes, revise validación ARP. Si se necesita identificar al usuario antes del acceso, considere mecanismos de autenticación. Una lista de herramientas sin relación con el ataque no demuestra comprensión.

Caso explicado. Después de habilitar DAI, un host estático pierde acceso. Desactivar toda la protección puede restaurar operación, pero elimina el control. Revise la asociación confiable y el tratamiento previsto para ese host. Una solución segura busca permitir la actividad legítima manteniendo la validación de las demás.

Mapa de relaciones para explicar el tema



Mapa conceptual 46 Seguridad de LAN

Preguntas y casos del indicador 46

Aplicación del aprendizaje. Relacionar ataques de enlace con controles específicos sin atribuirles funciones que no tienen.

1 DHCP no autorizado

Una computadora de usuario envía ofertas DHCP falsas. ¿Qué control local puede restringir mensajes de servidor desde ese puerto?

Explicación. DHCP snooping, con una definición correcta de puertos confiables y no confiables. La señal decisiva es el mensaje de servidor no autorizado. STP evita bucles de capa 2 y no reemplaza esa función de control DHCP.

2 Asociaciones ARP falsas

Se anuncian relaciones indebidas entre IP y MAC. ¿Qué función puede inspeccionarlas con información confiable?

Explicación. DAI puede validar asociaciones ARP mediante la tabla de DHCP snooping u otros mecanismos configurados. Deben contemplarse hosts estáticos. Activarlo sin información adecuada puede bloquear actividad legítima; marcar todo como confiable elimina parte de la protección.

3 MAC e identidad humana

Port security limita MAC en un puerto. ¿Eso equivale a autenticar a la persona que conecta el equipo?

Explicación. No. Restringe identificadores de enlace según configuración y estos pueden suplantarse. 802.1X incorpora un proceso de autenticación con componentes específicos. Los controles pueden complementarse, pero no demuestran exactamente lo mismo.

4 Segmentación y permisos

Dos VLAN están separadas, pero el enrutamiento permite cualquier servicio entre ellas. ¿La separación impide automáticamente movimiento entre redes?

Explicación. No. Deben establecerse reglas coherentes con las comunicaciones necesarias. La VLAN delimita el dominio lógico, mientras filtros y autorizaciones controlan otros accesos. La segmentación necesita políticas; no debe interpretarse como aislamiento absoluto por su nombre.

5 Origen IP permitido

Se necesita limitar tráfico a direcciones IP de origen previstas para ciertos puertos. ¿Qué función se relaciona con esa necesidad?

Explicación. IP Source Guard donde esté soportado y configurado con información adecuada. No sustituye todas las funciones de firewall, autenticación o inspección ARP. La selección debe corresponder al dato que se valida y al lugar donde se aplica el control.

47 Redes inalámbricas

Operaciones ciberseguras · Nivel 11 · Indicador 20.1 · Tabla página 11

Indicador de logro. Identifica conceptos relacionados con redes de área local inalámbricas.

Propósito de aprendizaje. Explicar identificación, acceso al medio, cobertura y autenticación en una WLAN.

Conceptos fundamentales

Una WLAN utiliza radio para conectar dispositivos. El SSID es el nombre de la red; el BSSID identifica una celda básica, habitualmente asociado a la radio del AP. Un AP conecta clientes inalámbricos con la red; varios AP pueden ofrecer movilidad dentro de un diseño coordinado.

Las bandas, canales, ancho de canal, potencia y obstáculos afectan cobertura e interferencia. Una señal intensa no garantiza buena capacidad: muchos clientes comparten el medio. Roaming permite cambiar de punto de acceso manteniendo conectividad según el sistema. En 2,4 GHz debe planificarse el uso de canales y ancho para evitar superposición, conforme a regulación y entorno.

WEP es una protección obsoleta y vulnerable. WPA, WPA2 y WPA3 corresponden a generaciones de protección con capacidades distintas. Debe distinguirse el modo Personal, con credencial compartida o mecanismos asociados al estándar, del Enterprise, que integra autenticación individual mediante 802.1X y un servidor, frecuentemente RADIUS.

Situación	Interpretación o respuesta
Todos usan la misma clave.	Difícil revocar a una sola persona sin cambiarla.
Cada usuario se autentica con su identidad.	Permite controlar accesos individuales según política.
Invitados acceden a servidores internos.	Revisar segmentación y reglas de acceso.
Dos AP interfieren.	Revisar canales, potencia, ubicación y capacidad.

Caso resuelto. Una red de invitados tiene acceso a sistemas administrativos. Cambiar el SSID no corrige el permiso. Deben separarse redes y permitir únicamente servicios necesarios, con pruebas de conectividad autorizada.

Un evil twin imita una red legítima para inducir conexiones. Ocultar el SSID no equivale a cifrar ni autenticar adecuadamente. Una VPN puede proteger parte de una comunicación, pero no vuelve seguro cualquier dispositivo o portal al que se conecte el usuario.

Separar nombre de red identidad y protección

El SSID es el nombre de la red inalámbrica; el BSSID identifica una celda básica, habitualmente asociado a una interfaz de radio. Un nombre familiar no prueba que el punto de acceso sea legítimo. Un evil twin imita una red para inducir conexiones. Ocultar el SSID no proporciona cifrado ni equivale a autenticar dispositivos.

El AP conecta clientes inalámbricos con la red; varios AP pueden sostener movilidad. Roaming permite cambiar de punto manteniendo conectividad según el sistema. La experiencia

depende también de autenticación, diseño de celdas y capacidad. Una señal intensa no demuestra que haya suficiente tiempo de aire para todos los usuarios.

Relacionar canal y capacidad

Las bandas, canales, anchos de canal, potencia y obstáculos influyen en cobertura e interferencia. Aumentar potencia no resuelve toda congestión y puede ampliar solapamiento. El cliente también debe poder transmitir de vuelta. El diseño debe considerar cantidad de dispositivos, aplicaciones y entorno radioeléctrico, además de distancia.

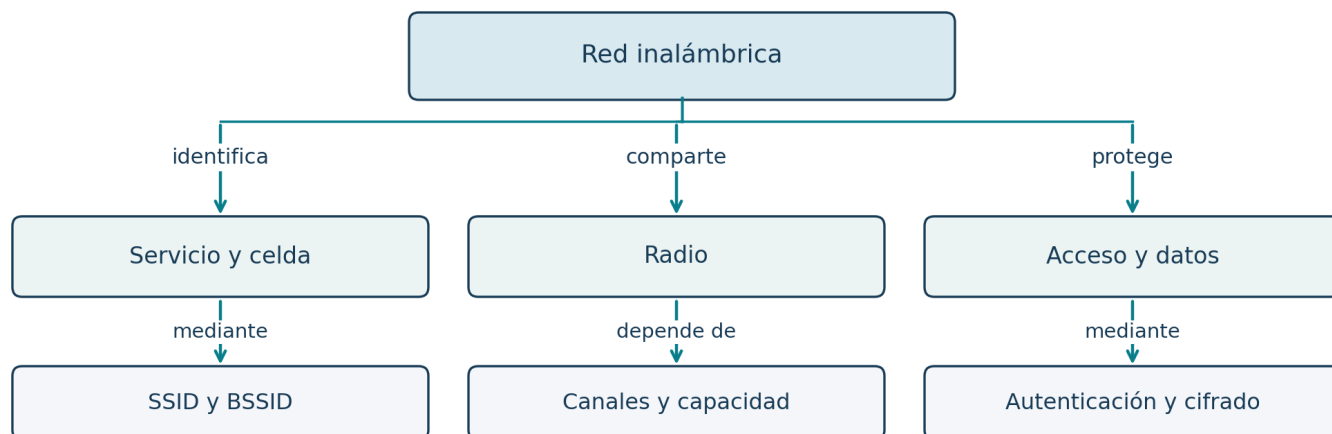
En 2,4 GHz se planifican canales y ancho para reducir solapamiento conforme a regulación local. En otras bandas cambian disponibilidad y condiciones. Las decisiones concretas dependen del país y equipos; no se debe copiar una configuración sin comprobar su pertinencia.

Entender modalidades de seguridad

WEP es obsoleto y vulnerable. WPA, WPA2 y WPA3 representan generaciones con capacidades diferentes. Personal suele usar credencial compartida o mecanismos asociados al estándar; Enterprise incorpora autenticación individual mediante 802.1X y un servidor, frecuentemente RADIUS. Una clave compartida dificulta revocar solo a una persona sin cambiarla para las demás.

Caso comentado. Invitados pueden consultar servidores internos. Cambiar SSID o fortalecer la contraseña de WiFi no necesariamente corrige esa autorización. Deben separarse redes y aplicar reglas de acceso apropiadas. Autenticarse en la WLAN permite entrar a un ámbito; no debería conceder automáticamente permiso sobre cada recurso interno. Esa distinción conecta la seguridad inalámbrica con el control de acceso del apartado 6.

Mapa de relaciones para explicar el tema



Mapa conceptual 47 Red inalámbrica

Preguntas y casos del indicador 47

Aplicación del aprendizaje. Explicar identificación, acceso al medio, cobertura y autenticación en una WLAN.

1 SSID y BSSID

Dos puntos de acceso anuncian el mismo nombre de red. ¿Por qué ese SSID no identifica necesariamente una única celda ni demuestra legitimidad?

Explicación. SSID es el nombre de la red; BSSID identifica una celda básica, habitualmente asociado a una interfaz de radio. Varias celdas pueden compartir nombre. Además, un atacante puede imitarlo, por lo que nombre familiar no basta para confiar.

2 Señal y capacidad

Un teléfono muestra señal intensa, pero la conexión es lenta en un aula llena. ¿Qué otras condiciones deben examinarse?

Explicación. Competencia por el medio, cantidad de clientes, interferencia, canales y capacidad del enlace de salida. Potencia recibida no equivale a rendimiento disponible. Aumentar potencia indiscriminadamente puede ampliar solapamiento sin resolver congestión.

3 Personal y Enterprise

Todos comparten una clave en una WLAN y se necesita revocar acceso a una persona. ¿Qué diferencia puede aportar autenticación individual Enterprise?

Explicación. Permite gestionar identidades y revocación según el sistema, frecuentemente con 802.1X y servidor. Una clave compartida obliga a tratar su conocimiento por todos. Enterprise requiere configuración y validación apropiadas; no es seguridad automática por el nombre.

4 Roaming

Una persona se mueve entre aulas y cambia de punto de acceso manteniendo conectividad según el diseño. ¿Qué función se ilustra?

Explicación. Roaming. La experiencia depende de autenticación, cobertura y coordinación, entre otros factores. No significa que dos AP con igual nombre garanticen continuidad perfecta ni que cambiar de celda elimine toda interrupción.

5 Red de invitados

Los visitantes pueden entrar al servidor de expedientes desde la WLAN de invitados. ¿Por qué cambiar el nombre WiFi no corrige el problema?

Explicación. El nombre no modifica por sí solo rutas y permisos. Deben revisarse segmentación y reglas de acceso a recursos internos. Autenticar una conexión inalámbrica y autorizar lectura de expedientes son decisiones distintas que deben protegerse en sus respectivas capas.

48 Protocolos y servicios de red

Operaciones ciberseguras · Nivel 12 · Indicador 21.1 · Tabla página 11

Indicador de logro. Distingue los protocolos y servicios de red.

Propósito de aprendizaje. Relacionar una necesidad de comunicación con el servicio y protocolo que la resuelve.

Referencia para ampliar los saberes Programa de duodécimo páginas 94 y 95

Conceptos fundamentales

Un servicio debe reconocerse por su función antes de memorizar puertos. Los puertos siguientes son convenciones habituales; pueden cambiarse y un puerto abierto no demuestra por sí solo que el servicio sea legítimo o seguro.

Servicio o protocolo	Función	Puerto o transporte habitual
DNS	Resolver nombres y otros registros.	53 UDP y TCP.
DHCPv4	Asignar parámetros IPv4.	67 y 68 UDP.
DHCPv6	Asignar parámetros IPv6.	547 y 546 UDP.
HTTP y HTTPS	Comunicación web, con TLS en HTTPS.	80 y 443 TCP habitualmente.
SSH y SFTP	Administración y transferencia protegida.	22 TCP.
FTP	Transferencia sin protección de TLS por defecto.	21 TCP para control; datos según modo.
SMTP	Enviar y transferir correo.	25 TCP entre servidores; 587 para envío habitual.
IMAP	Acceder y sincronizar buzones.	143 TCP o 993 con TLS implícito.
POP3	Recuperar correo.	110 TCP o 995 con TLS implícito.
NTP	Sincronizar relojes.	123 UDP.
SNMP	Supervisar y administrar dispositivos.	161 y 162 UDP habituales.
SMB	Compartir archivos y otros recursos.	445 TCP.

DNS utiliza registros A para IPv4, AAAA para IPv6, MX para correo, CNAME para alias y PTR para resolución inversa. ICMP comunica información de control; ping utiliza mensajes eco donde están permitidos. No es un protocolo de puertos TCP o UDP.

Caso resuelto. Un servidor web responde por IP, pero no por nombre. Se revisa resolución DNS. Si el nombre resuelve bien, pero el reloj está años atrasado y falla la validez temporal del certificado, se revisa sincronización horaria. El mismo síntoma general de «no abre» puede tener causas distintas.

Protocolos y versiones. HTTP/3 utiliza QUIC sobre UDP, habitualmente 443; por eso no se afirma que todo tráfico web cifrado use siempre TCP. SNMPv3 incorpora mecanismos de seguridad superiores a configuraciones comunitarias sin protección adecuada.

Seguir la apertura de una página

Una persona escribe un nombre. El cliente puede consultar DNS para obtener una dirección. Después utiliza rutas y mecanismos del enlace para llegar al siguiente salto. El transporte comunica con el servicio y TLS puede proteger el canal antes del intercambio HTTP correspondiente. DNS, IP, TCP o QUIC, TLS y HTTP no compiten por hacer lo mismo: participan en funciones diferentes.

Si el servidor responde por IP pero no por nombre, la resolución merece revisión. Si la resolución funciona y el certificado falla por hora incorrecta, corresponde revisar sincronización. Un mismo mensaje visible de «no abre» puede originarse en causas diferentes. El diagnóstico necesita observar en qué etapa se interrumpe la secuencia.

Leer registros de DNS y funciones de correo

Un registro A relaciona un nombre con IPv4; AAAA, con IPv6; MX identifica servicio de correo del dominio; CNAME establece alias; PTR apoya resolución inversa. DNS no cifra por sí solo toda comunicación posterior ni valida automáticamente que un sitio sea honesto. Sus resultados deben tratarse dentro del contexto de confianza de la red.

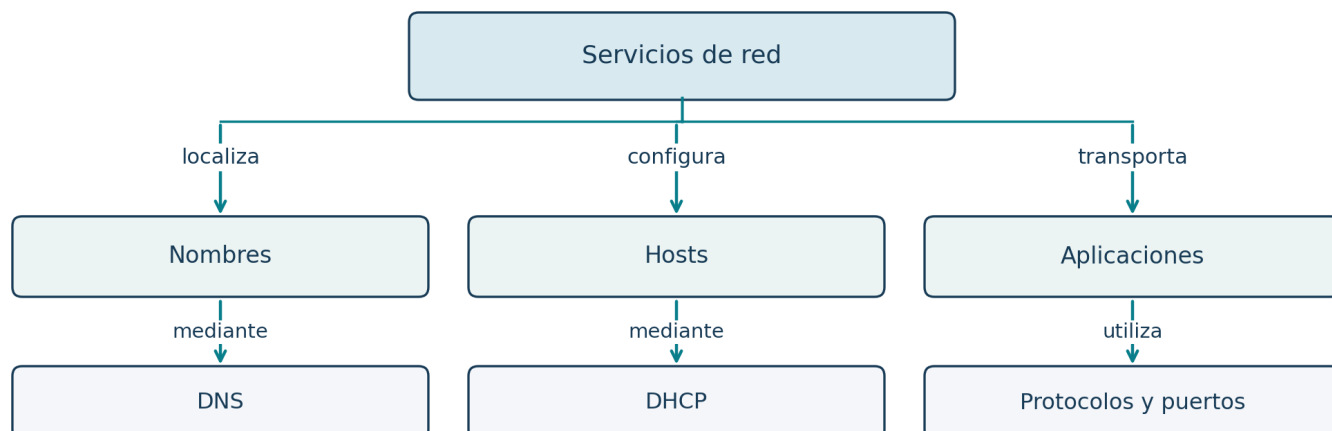
SMTP envía y transfiere correo; IMAP permite acceder y sincronizar buzones; POP3 recupera correo según su funcionamiento. NTP sincroniza tiempo. SNMP permite supervisión y administración conforme a versión y configuración. SMB comparte archivos y otros recursos. Reconocer la función es más sólido que memorizar una cifra de puerto sin contexto.

Qué demuestra un puerto observado

El puerto 443 es habitual para HTTPS, pero un número no prueba qué aplicación lo utiliza ni si su actividad es legítima. HTTP/3 utiliza QUIC sobre UDP, habitualmente en 443, mientras otros usos de HTTPS suelen utilizar TCP. ICMP transmite mensajes de control y no se interpreta como un protocolo con puertos TCP o UDP.

Caso ampliado. Un equipo genera conexiones periódicas por 443 a un destino inusual. El puerto es compatible con tráfico web cifrado, pero no permite declarar normalidad. Revise proceso, identidad, volumen, destino y registros de aplicación. La función esperada y el comportamiento observado deben analizarse conjuntamente.

Mapa de relaciones para explicar el tema



Mapa conceptual 48 Servicios de red

Preguntas y casos del indicador 48

Aplicación del aprendizaje. Relacionar una necesidad de comunicación con el servicio y protocolo que la resuelve.

1 Resolución de nombres

Un servidor responde por IP, pero no por nombre. ¿Qué servicio debe revisarse inicialmente y qué registros pueden ser pertinentes?

Explicación. DNS, según el nombre y tipo de dirección buscados. A relaciona nombres con IPv4 y AAAA con IPv6; otros registros cumplen funciones distintas. Cambiar una contraseña no atiende directamente una resolución de nombres fallida.

2 Envío y consulta de correo

Una aplicación envía mensajes y otra sincroniza un buzón entre dispositivos. ¿Cómo se distinguen SMTP e IMAP?

Explicación. SMTP participa en envío y transferencia; IMAP en acceso y sincronización del buzón. POP3 se relaciona con recuperación según su funcionamiento. Compartir el ámbito de correo no vuelve intercambiables sus funciones ni sus puertos habituales.

3 Tiempo y certificados

La resolución DNS funciona, pero un equipo tiene el reloj muy atrasado y falla la validación temporal de certificados. ¿Qué dependencia requiere atención?

Explicación. La sincronización y configuración horaria, mediante mecanismos como NTP según el entorno. Un certificado se evalúa también por su vigencia. Cambiar DNS no corrige la hora equivocada del cliente si la resolución ya es correcta.

4 Administración y archivos

Se necesita una sesión remota protegida y transferencia de archivos sobre el mismo protocolo seguro. ¿Qué relación existe entre SSH y SFTP?

Explicación. SFTP utiliza SSH para transferencia protegida; SSH proporciona sesión y otras capacidades según configuración. FTP tradicional es otro protocolo y no ofrece por defecto ese resguardo. Coincidir en la tarea «transferir» no significa usar el mismo mecanismo.

5 Puertos y protocolo observado

Se observa tráfico UDP 443. ¿Debe descartarse actividad web porque HTTPS siempre utiliza TCP?

Explicación. No. HTTP/3 utiliza QUIC sobre UDP, habitualmente en 443. El puerto es una pista, no una identificación absoluta de contenido o legitimidad. Deben examinarse protocolo, extremo y contexto sin asumir que todo uso del número es el mismo servicio.

49 Vulnerabilidades de servicios y bases de datos

Operaciones ciberseguras · Nivel 12 · Indicador 22.1 · Tabla página 11

Indicador de logro. Diferencia las vulnerabilidades que pueden darse a las bases y a los servicios.

Propósito de aprendizaje. Diferenciar exposición, debilidad técnica, amenaza y medida correctiva.

Referencia para ampliar los saberes Programa de duodécimo páginas 95 y 96

Conceptos fundamentales

Una vulnerabilidad es una debilidad aprovechable. La exposición describe posibilidad de alcanzar o conocer un activo. Una amenaza puede aprovechar la debilidad y producir un incidente. Un servicio accesible por Internet no es automáticamente vulnerable, pero aumenta su superficie expuesta y exige controles apropiados.

Las causas frecuentes incluyen software sin parches, configuración predeterminada, credenciales débiles, permisos excesivos, secretos expuestos, validación insuficiente y mensajes de error detallados. En bases de datos también deben revisarse restricciones, concurrencia, respaldo y monitoreo de consultas o cambios.

Un identificador CVE permite referirse a una vulnerabilidad publicada. CVSS estima severidad técnica con una metodología; no equivale por sí solo al riesgo real de cada institución. La criticidad del activo, exposición, controles existentes y evidencia de abuso modifican la prioridad.

Hallazgo	Interpretación
Servicio sin parche para una falla conocida.	Debilidad técnica que necesita evaluación y tratamiento.
Credencial de fábrica activa.	Configuración de autenticación inadecuada.
Clave en archivo de lectura pública.	Exposición de secreto por permisos.
Alerta del escáner sin validación.	Indicio que requiere comprobación autorizada.

Caso resuelto. Un formulario concatena entrada en SQL. Ocultar el mensaje de error reduce divulgación de detalles, pero mantiene la causa de inyección. Debe parametrizarse la consulta y limitar permisos, además de revisar registros e impacto.

Un escáner automatiza comprobaciones; un analizador de paquetes observa tráfico capturado; un SIEM correlaciona eventos. Un IDS detecta indicios de intrusión; un IPS puede bloquear tráfico en su ubicación de control. Su eficacia depende de configuración y contexto.

Interpretar las bases de la comunicación como superficie de ataque

Los protocolos fundamentales sostienen servicios empresariales. Una suplantación de origen IP altera la identidad de red declarada; no equivale a demostrar control legítimo de esa dirección. Un abuso de establecimiento TCP puede consumir recursos del servicio; el uso indebido de ciertos servicios UDP puede participar en tráfico reflejado o amplificado. Para estudiarlos, identifique recurso agotado, confianza abusada y control pertinente, sin confundir mecanismo con instrucciones para ejecutarlo.

Los servicios de nombres, autenticación, archivos y bases de datos añaden configuración, permisos y software que mantener. Estar expuesto significa poder ser alcanzado bajo ciertas condiciones; ser vulnerable significa tener una debilidad aprovechable. La exposición aumenta oportunidades de abuso, pero no demuestra por sí sola una falla concreta.

Recoger observaciones desde el lugar adecuado

Un analizador de protocolos examina capturas. Un TAP de red permite observar tráfico en un punto físico mediante el diseño correspondiente; un puerto espejo o SPAN copia tráfico configurado. La ubicación determina qué se ve. Si dos hosts intercambian datos por otro camino, un sensor fuera de ese trayecto puede no observarlos. El monitoreo requiere cobertura, capacidad y conocimiento de la topología.

Los registros de servidores complementan las capturas. Un IDS detecta indicios y un IPS puede actuar sobre tráfico en su posición de control. Ninguno es eficaz solo por estar instalado: reglas, actualizaciones, ubicación y revisión influyen en los resultados.

Priorizar sin depender de una cifra aislada

Un identificador CVE permite referirse a una vulnerabilidad publicada. CVSS describe severidad técnica bajo una metodología. El riesgo del entorno también depende de exposición, criticidad, controles y evidencia de explotación. Dos activos con la misma falla pueden requerir prioridades distintas por el servicio que sostienen.

Caso comentado. Un servicio contiene una falla conocida, pero el escáner no pudo autenticar y solo infirió versión. El hallazgo necesita validación autorizada. Ocultar el banner puede cambiar lo que observa el escáner, pero no necesariamente corrige la falla. El tratamiento debe eliminar o reducir la debilidad y comprobar el resultado, no solo silenciar la detección.

Mapa de relaciones para explicar el tema



Mapa conceptual 49 Exposición y vulnerabilidad

Preguntas y casos del indicador 49

Aplicación del aprendizaje. Diferenciar exposición, debilidad técnica, amenaza y medida correctiva.

1 Exposición y vulnerabilidad

Un servicio es accesible desde Internet. ¿Su accesibilidad demuestra por sí sola una vulnerabilidad explotable?

Explicación. No. Exposición describe alcance; vulnerabilidad, una debilidad aprovechable. La exposición puede aumentar oportunidades de abuso y exige controles, pero debe identificarse la debilidad concreta. Confundir ambos conceptos lleva a conclusiones sin evidencia suficiente.

2 Suplantación de origen IP

Un paquete declara como origen una dirección que no corresponde al emisor real. ¿Qué confianza se está abusando?

Explicación. Se abusa de tomar la dirección declarada como prueba suficiente de origen legítimo. Una IP no autentica por sí sola a una persona o sistema. El análisis debe considerar validación de origen, contexto y controles del trayecto.

3 Consumo de recursos TCP

Numerosos intentos incompletos de conexión consumen recursos de un servicio. ¿Qué relación debe explicarse para reconocer el riesgo?

Explicación. El establecimiento y mantenimiento de estado pueden generar consumo antes de completar una comunicación útil. El caso se analiza por recursos agotados y disponibilidad. No debe confundirse con robo de archivos si no se describe extracción de información.

4 Ubicación del sensor

Un analizador está en un punto que no recibe el tráfico entre dos hosts. ¿Por qué no encontrar paquetes no demuestra ausencia de comunicación?

Explicación. La cobertura depende de topología y ubicación. Un TAP o puerto espejo puede proporcionar tráfico pertinente si se configura adecuadamente. La herramienta solo observa lo que recibe; la ausencia de datos debe interpretarse junto con sus límites de captura.

5 CVE CVSS y prioridad

Dos activos tienen la misma vulnerabilidad y puntuación técnica, pero uno sostiene un servicio crítico expuesto. ¿Deben tratarse necesariamente con igual prioridad?

Explicación. No. CVE identifica la vulnerabilidad y CVSS expresa severidad técnica bajo su metodología. La prioridad incorpora criticidad, exposición, controles y evidencia de explotación. Una cifra común no elimina diferencias de impacto para la organización.

50 Cifrado y monitoreo de seguridad

Operaciones ciberseguras · Nivel 12 · Indicador 23.1 · Tabla página 11

Indicador de logro. Identifica el impacto de la criptografía sobre el monitoreo de la seguridad en las redes.

Propósito de aprendizaje. Explicar qué puede observarse en tráfico cifrado y cómo complementar la investigación.

Referencia para ampliar los saberes Programa de duodécimo páginas 96

Conceptos fundamentales

El cifrado protege contenido frente a observadores sin las claves adecuadas. Un sensor de red puede conservar visibilidad de ciertos metadatos, como IP, puertos, tiempos y volumen, aunque no lea el contenido de la aplicación. Qué otros datos son visibles depende del protocolo, versión y configuración.

Una captura de HTTPS sin descifrado no permite leer automáticamente el cuerpo HTTP. Un túnel VPN puede ocultar detalles de conexiones internas al observador intermedio. Esto reduce exposición, pero también modifica dónde debe ubicarse la observación autorizada.

Fuentes complementarias. Registros de endpoints, servidores, autenticación y aplicaciones; flujos de red; inventarios; alertas de EDR; eventos de donde termina el túnel. La correlación relaciona tiempos, identidades y destinos sin alterar las evidencias originales.

La inspección TLS autorizada puede aportar visibilidad en determinados entornos, pero implica manejo de información sensible, certificados, compatibilidad y reglas institucionales. No es correcto afirmar que todo cifrado debe eliminarse para poder monitorear.

Caso resuelto. Un equipo envía datos periódicamente por TLS a un destino inusual. El cifrado no demuestra que la actividad sea maliciosa ni benigna. Se revisan proceso que genera la conexión, volumen, horario, reputación y registros del endpoint. Una relación temporal es evidencia para analizar, no atribución automática a una persona.

Afirmación	Evaluación
Usa TLS, por tanto es seguro en todo sentido.	Incorrecta: protege el canal, no la intención.
No veo el contenido, por tanto no puedo analizar nada.	Incorrecta: existen metadatos y fuentes complementarias.
Conozco el puerto 443, por tanto puedo leer la contraseña.	Incorrecta: el puerto no descifra el contenido.

Qué puede ver un observador intermedio

El cifrado protege contenido entre extremos, pero determinados metadatos pueden seguir visibles: direcciones, puertos, tiempos y volúmenes, según el protocolo y la configuración. Esos datos permiten observar patrones sin leer el mensaje. No debe afirmarse que siempre se ve cada nombre o campo, porque las tecnologías de protección y sus variantes cambian la visibilidad.

Una captura de HTTPS sin las condiciones de descifrado apropiadas no revela automáticamente el cuerpo HTTP. Una VPN puede ocultar comunicaciones internas al observador del trayecto exterior. El punto donde termina el túnel puede disponer de otra visibilidad. La ubicación del sensor es parte de la interpretación.

Combinar fuentes para responder una pregunta

El flujo de red puede indicar que hubo una conexión; el endpoint puede indicar qué proceso la abrió; la aplicación puede registrar qué operación realizó; el sistema de identidad puede mostrar la cuenta. Correlacionar estas fuentes aporta contexto. Deben sincronizarse y conservarse sus diferencias originales de tiempo y formato de manera documentada.

Una conexión periódica no demuestra por sí sola comando y control: también existen actualizaciones y sincronización legítimas. Del mismo modo, usar TLS no demuestra inocuidad. El analista contrasta comportamiento con función esperada, destino y otras evidencias.

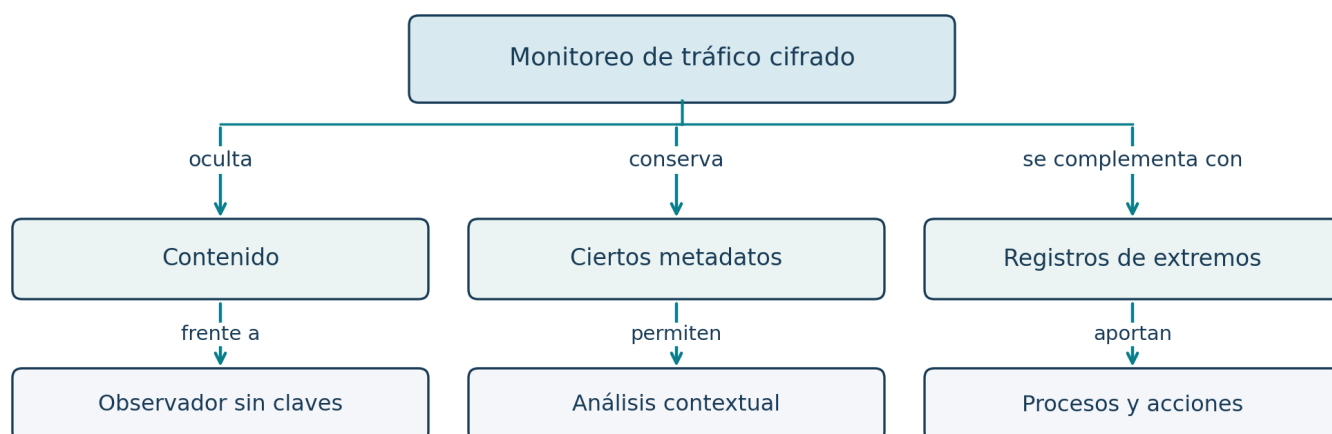
Inspección y sus límites

La inspección TLS autorizada puede proporcionar visibilidad en ciertos entornos, pero modifica la relación de confianza y exige gestión de certificados, privacidad y compatibilidad. No debe suponerse que todo tráfico se puede o se debe descifrar. Algunas aplicaciones o diseños no son compatibles con esa intervención y requieren otras fuentes de observación.

La protección del host añade controles como antimalware, EDR, actualización y restricción de aplicaciones. Un perfil de comportamiento normal de servidor ayuda a detectar diferencias, pero debe actualizarse cuando cambian funciones legítimas.

Caso ampliado. Un servidor envía un volumen inusual a un destino externo. El cifrado impide leer contenido desde la captura, pero los registros de proceso y acceso pueden mostrar qué archivos consultó una cuenta. La investigación combina señales; no necesita inventar el contenido que no puede observar.

Mapa de relaciones para explicar el tema



Mapa conceptual 50 Monitoreo de tráfico cifrado

Preguntas y casos del indicador 50

Aplicación del aprendizaje. Explicar qué puede observarse en tráfico cifrado y cómo complementar la investigación.

1 Contenido y metadatos

Un sensor observa IP, tiempos y volúmenes de una comunicación cifrada, pero no su contenido. ¿Puede aportar información útil?

Explicación. Sí. Los metadatos disponibles permiten estudiar patrones y relaciones, aunque no revelan automáticamente el mensaje. Su visibilidad depende del protocolo y configuración. Deben comunicarse los límites y evitar inventar contenido que no se pudo observar.

2 TLS y actividad maliciosa

Un programa envía datos mediante TLS a un destino inusual. ¿El cifrado demuestra que la actividad es legítima?

Explicación. No. TLS protege el canal, pero puede transportar acciones indebidas. Deben correlacionarse proceso, identidad, destino, volumen y registros pertinentes. La misma protección criptográfica puede estar presente en comunicaciones legítimas o maliciosas.

3 Túnel VPN

Un observador intermedio ve el túnel, pero no las conexiones internas en claro. ¿Dónde puede buscarse evidencia complementaria autorizada?

Explicación. En extremos, registros del servicio y puntos donde termina el túnel según la arquitectura. La ubicación cambia la visibilidad. No debe suponerse que todos los sensores ven la misma información ni que una VPN elimina cualquier posibilidad de investigación.

4 Inspección TLS

Se propone inspeccionar TLS en una red institucional. ¿Por qué no basta activar una opción sin evaluar el entorno?

Explicación. Puede requerir certificados, cambios de confianza y tratamiento de información sensible, además de compatibilidad y reglas institucionales. Algunas aplicaciones no admiten esa intervención. Debe evaluarse necesidad y alcance; descifrar más no equivale automáticamente a observar mejor de manera adecuada.

5 Correlación de fuentes

Una captura muestra una transferencia grande y un registro del endpoint identifica el proceso que la inició. ¿Qué ventaja aporta combinarlos?

Explicación. Vincula comportamiento de red con actividad del equipo y permite formular una hipótesis más precisa. Todavía se necesita contexto para decidir legitimidad. La coincidencia temporal ayuda al análisis, pero no prueba por sí sola intención ni autoría humana.

51 Hardware y firmware de dispositivos IoT

Operaciones ciberseguras · Nivel 12 · Indicador 24.1 · Tabla página 11

Indicador de logro. Identifica las vulnerabilidades y ataques en la capa de hardware.

Propósito de aprendizaje. Reconocer superficies físicas de ataque y controles de autenticidad e integridad.

Conceptos fundamentales

Un dispositivo IoT combina procesador, memoria, sensores, actuadores, interfaces y firmware, software cercano al hardware que controla su operación. El acceso físico puede exponer riesgos distintos a los de una aplicación web.

Interfaces de mantenimiento como UART o JTAG pueden permitir diagnóstico, depuración o acceso a componentes. Si quedan expuestas sin restricciones, pueden facilitar extracción o modificación. Una memoria flash puede conservar firmware y secretos; una clave guardada sin protección puede recuperarse si el atacante obtiene acceso adecuado.

La manipulación física modifica componentes o conexiones. Los ataques de canal lateral infieren información a partir de características como tiempo o consumo; la inyección de fallos altera condiciones para provocar comportamientos no previstos. Se estudian sus objetivos y defensas, sin aplicar pruebas fuera de autorización.

Control	Qué aporta
Verificación de firmware firmado.	Comprueba origen e integridad según una raíz de confianza.
Arranque seguro.	Verifica componentes de la cadena de arranque.
Protección de secretos.	Reduce acceso directo a claves almacenadas.
Restricción de depuración.	Limita interfaces de mantenimiento expuestas.
Controles físicos.	Dificultan manipulación y acceso no autorizado.

Caso resuelto. Un sensor acepta actualizaciones con solo revisar la extensión del archivo. Un atacante puede conservar esa extensión en firmware modificado. Verificar una firma con una clave confiable atiende autenticidad; un checksum que el mismo atacante puede recalcular no ofrece el mismo resguardo.

Cadena de suministro. La procedencia de componentes y actualizaciones importa. Deben existir inventario, soporte, recuperación y una política de fin de vida. Desactivar WiFi no elimina una consola privilegiada accesible por un puerto físico.

Identificar lo que hay dentro de un objeto conectado

Un dispositivo IoT puede integrar microcontrolador o procesador, memoria, sensores, actuadores, alimentación e interfaces. El firmware gobierna funciones cercanas al hardware; una aplicación de gestión configura o consulta. El sistema completo puede incluir pasarela y nube. Una falla física y una falla de aplicación pueden afectar el mismo objeto por caminos diferentes.

La memoria flash puede conservar firmware y secretos. Las interfaces UART o JTAG pueden servir para diagnóstico y depuración. Si quedan expuestas sin restricciones, pueden facilitar acceso no autorizado. Su mera presencia no demuestra vulnerabilidad explotable: importan configuración, permisos y condiciones físicas.

Entender las familias de ataques físicos

La manipulación modifica o sustituye componentes o conexiones. Un canal lateral obtiene información a partir de efectos como tiempo o consumo, sin leer necesariamente el secreto por una interfaz normal. La inyección de fallos altera condiciones de operación para provocar un comportamiento anómalo. Estas categorías se distinguen por el mecanismo; el estudio debe centrarse en reconocerlo y seleccionar mitigación.

Un gabinete protegido puede dificultar acceso, pero una carcasa intacta no prueba que el firmware sea legítimo. Una actualización remota también puede alterar el software. La seguridad debe cubrir fabricación, distribución, actualización y retiro del dispositivo.

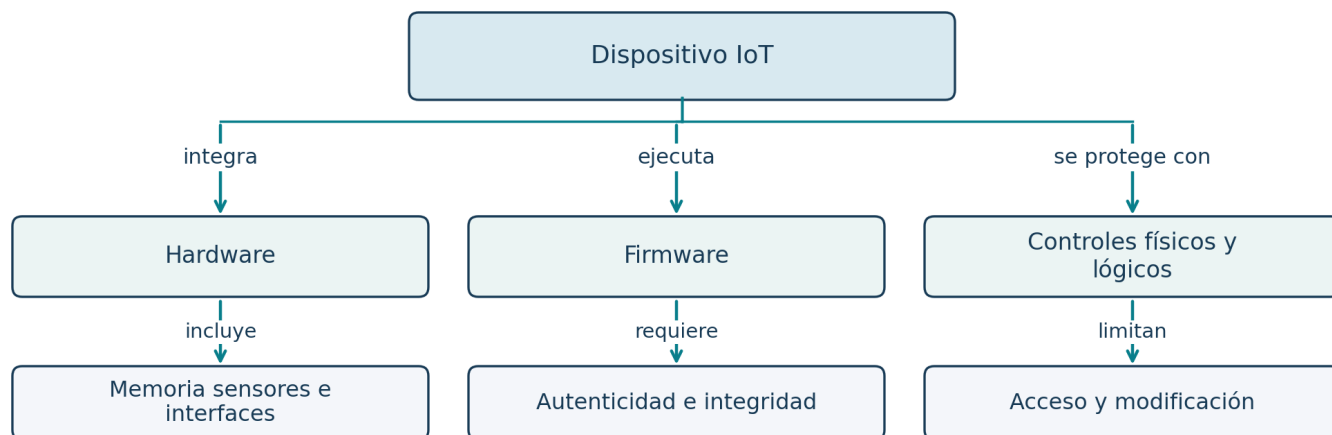
Verificar firmware y arranque

Una firma de firmware permite comprobar procedencia e integridad bajo una raíz de confianza adecuada. Un checksum que cualquier persona puede recalcular no ofrece la misma autenticación. El arranque seguro verifica componentes de la cadena de inicio según el diseño. La protección de claves, restricción de depuración y control de versiones complementan estas verificaciones.

Los dispositivos deben poder actualizarse y tener una política de fin de soporte. Un sensor sin mantenimiento puede permanecer años conectado aunque su fabricante deje de corregir fallas. El inventario permite reconocer esa dependencia.

Caso explicado. Una cerradura acepta cualquier archivo cuya extensión coincida con la esperada. La extensión identifica formato de nombre, no autenticidad. Debe verificarse el paquete y su autorización, junto con un procedimiento que evite dejar el dispositivo inutilizable ante una actualización interrumpida.

Mapa de relaciones para explicar el tema



Mapa conceptual 51 Dispositivo IoT

Preguntas y casos del indicador 51

Aplicación del aprendizaje. Reconocer superficies físicas de ataque y controles de autenticidad e integridad.

1 Hardware y firmware

Un sensor tiene circuito físico correcto, pero una actualización altera sus decisiones. ¿Qué componente lógico cercano al hardware debe examinarse?

Explicación. El firmware, que controla funciones del dispositivo. El estado físico aparente no demuestra integridad de su software. La investigación debe distinguir manipulación de componentes, configuración y cambio de instrucciones para seleccionar la comprobación adecuada.

2 Interfaces de mantenimiento

Una placa expone una interfaz UART o JTAG sin controles apropiados. ¿Qué riesgo puede introducir?

Explicación. Puede facilitar diagnóstico, depuración o acceso no autorizado según el dispositivo. La existencia de la interfaz no demuestra explotación, pero requiere evaluar permisos, exposición y función. Desactivar WiFi no elimina necesariamente una vía física de mantenimiento.

3 Canal lateral

Se intenta inferir información observando variaciones de consumo o tiempo sin leer directamente el secreto. ¿Qué familia de ataques se relaciona?

Explicación. Ataques de canal lateral. Aprovechan efectos observables de la operación. Son distintos de modificar directamente componentes o introducir fallas; el mecanismo preguntado es la inferencia a partir de señales indirectas.

4 Autenticidad de firmware

Un dispositivo acepta una actualización solo por terminar en la extensión esperada. ¿Qué comprobación más sólida se necesita?

Explicación. Verificar autenticidad e integridad mediante mecanismos como firma y una raíz de confianza adecuada. La extensión indica formato o nombre, no procedencia. Un checksum que el atacante también puede recalcular no aporta por sí solo la misma autenticación.

5 Arranque y soporte

Un equipo verifica componentes al arrancar, pero su fabricante dejó de corregir vulnerabilidades. ¿El arranque seguro resuelve toda la situación?

Explicación. No. Comprueba la cadena prevista, pero puede ejecutar componentes auténticos que contengan vulnerabilidades. Se necesitan mantenimiento, inventario y política de fin de vida. Autenticidad de una versión y ausencia de fallas son propiedades diferentes.

52 Funciones del analista y operación del SOC

Operaciones ciberseguras · Nivel 12 · Indicador 25.1 · Tabla página 11

Indicador de logro. Identifica los roles y responsabilidades del analista de ciberseguridad.

Propósito de aprendizaje. Distinguir observación, análisis, escalamiento y respuesta dentro de responsabilidades definidas.

Referencia para ampliar los saberes Programa de duodécimo páginas 102 y 103

Conceptos fundamentales

Un SOC, centro de operaciones de seguridad, coordina personas, procesos y tecnología para vigilar y responder. La distribución de niveles depende de la organización: un primer nivel suele revisar y clasificar alertas; niveles posteriores investigan casos complejos y especialidades. La caza de amenazas, threat hunting, busca indicios de forma proactiva mediante hipótesis.

El triage prioriza según evidencia, impacto y criticidad. Una alerta debe validarse, contextualizarse y documentarse. Un indicador de compromiso, IOC, puede ser un hash, dirección o artefacto asociado a actividad; una táctica, técnica o procedimiento, TTP, describe comportamiento del adversario. Un IOC aislado necesita contexto.

Flujo de actuación. Preparación; detección y análisis; contención; eliminación de la causa o persistencia; recuperación y seguimiento; aprendizaje. La contención limita propagación o daño; erradicación trata la causa; recuperación restablece operación segura. Las actividades pueden superponerse y requieren coordinación.

Caso resuelto. Un analista observa accesos desde un origen inesperado y descarga masiva. Registra hechos, comprueba permisos y actividad habitual, estima impacto y escala conforme al procedimiento. No cambia una sospecha por «confirmado» para acelerar atención ni divulga secretos en un canal general.

La evidencia debe conservar origen, tiempo e integridad. Los reportes distinguen hechos, hipótesis, limitaciones y acciones pendientes. SOAR integra orquestación y automatización de respuesta; no elimina la necesidad de definir permisos, validaciones y condiciones de intervención humana.

Comunicación. El equipo técnico necesita detalle reproducible; la dirección necesita impacto y decisiones; los usuarios necesitan instrucciones claras. La información se comparte según necesidad y autorización. No todo analista puede desconectar por iniciativa propia cualquier servicio crítico.

Distintuir funciones de personas y equipos

Un SOC coordina vigilancia, análisis y respuesta. Los niveles de atención varían entre organizaciones: un primer nivel puede clasificar alertas y otros investigar casos complejos. La capacidad no depende solo del número de pantallas, sino de fuentes, procedimientos, personal y coordinación. Una alerta sin responsable de atención deja incompleto el proceso.

El Blue Team se concentra en defensa; el Red Team evalúa mediante simulación adversaria autorizada; el enfoque Purple Team facilita colaboración y aprendizaje entre ambos. Purple no tiene que ser un tercer equipo permanente. La gestión define prioridades, recursos y aceptación de riesgos; el analista opera dentro de sus responsabilidades. Los colores describen enfoques, no permisos ilimitados.

Seguir una alerta hasta una decisión

El triage revisa relevancia, impacto, urgencia y contexto. Un IOC es un indicador asociado a posible compromiso, como un hash o dominio; una TTP describe táctica, técnica o procedimiento. Un IOC aislado puede caducar o corresponder a actividad compartida, por lo que se contrasta. La caza de amenazas formula hipótesis y busca evidencia de forma proactiva, más allá de esperar una alerta.

La contención limita daño; la erradicación trata causa y persistencia; la recuperación restablece servicio seguro. No son sinónimos. Desconectar un equipo puede contener comunicaciones, pero no demuestra que se eliminó la causa. Volver a conectarlo exige comprobaciones y coordinación.

Comunicar para que otros puedan actuar

Una bitácora útil registra tiempo, activo, identidad, evidencia, acciones y responsables. Debe distinguir observaciones e hipótesis. El personal directivo necesita impacto y decisiones; el equipo técnico necesita detalle reproducible; las personas usuarias necesitan instrucciones claras. Divulgar credenciales o datos completos en un canal general empeora el incidente.

Caso comentado. Se detecta descarga masiva por una cuenta de soporte. El analista verifica función habitual, origen y datos consultados, documenta y escala conforme al procedimiento. No declara robo confirmado sin evidencia ni detiene cualquier servicio por iniciativa propia. El liderazgo se demuestra coordinando una respuesta proporcionada y trazable.

Mapa de relaciones para explicar el tema



Mapa conceptual 52 Operación del SOC

Preguntas y casos del indicador 52

Aplicación del aprendizaje. Distinguir observación, análisis, escalamiento y respuesta dentro de responsabilidades definidas.

1 Triage

Llegan alertas de una impresora de prueba y de un servidor de matrícula con actividad sospechosa. ¿Qué debe orientar la priorización?

Explicación. Evidencia, criticidad, impacto y urgencia, no solo orden de llegada. El triaje clasifica para dirigir atención. Una alerta de un activo crítico puede necesitar respuesta rápida, pero debe verificarse su contexto sin presentar sospechas como hechos confirmados.

2 Equipos defensivos y ofensivos

Un equipo defiende, otro simula adversarios con autorización y ambos comparten resultados para mejorar controles. ¿Qué enfoques aparecen?

Explicación. Blue Team, Red Team y colaboración Purple Team. Los nombres describen funciones o enfoques. Purple no requiere ser siempre un tercer equipo permanente; su valor está en convertir la evaluación en aprendizaje defensivo comprobable.

3 Contención erradicación y recuperación

Se aísla un equipo, se elimina la persistencia y después se restablece el servicio verificado. ¿Por qué deben distinguirse estas acciones?

Explicación. Contención limita daño; erradicación trata causa y persistencia; recuperación restablece operación segura. Aislar no demuestra limpieza y restaurar no demuestra eliminar la vía de entrada. Cada acción responde a una necesidad diferente del incidente.

4 IOC y TTP

Un reporte incluye un hash y describe un método recurrente de acceso. ¿Cómo se distinguen esos datos?

Explicación. El hash puede ser un indicador de compromiso; el método describe comportamiento relacionado con técnicas y procedimientos. Un indicador aislado puede caducar o requerir contexto. Describir comportamiento ayuda a investigar más allá de una coincidencia exacta.

5 Escalamiento y comunicación

Una analista sospecha una descarga indebida, pero no tiene facultad para interrumpir un servicio crítico. ¿Qué actuación corresponde?

Explicación. Documentar evidencia, evaluar urgencia y escalar conforme al procedimiento, con las medidas autorizadas pertinentes. La iniciativa profesional no equivale a permisos ilimitados. El mensaje debe distinguir hechos, hipótesis y decisiones necesarias para que la persona responsable actúe.

53 Arquitecturas y marcos de seguridad

Operaciones ciberseguras · Nivel 12 · Indicador 26.1 · Tabla página 11

Indicador de logro. Describe las arquitecturas y marcos de seguridad de redes.

Propósito de aprendizaje. Relacionar segmentación, confianza, marcos de gestión y modelos de ataque con su función.

Referencia para ampliar los saberes Programa de duodécimo páginas 103

Conceptos fundamentales

Una arquitectura de seguridad organiza componentes y controles. La segmentación separa zonas; una DMZ ubica servicios expuestos entre controles que limitan su relación con redes internas. La defensa en profundidad añade barreras complementarias. Zero Trust, confianza cero, evita conceder confianza permanente por estar dentro de la red y verifica acceso a recursos según identidad, dispositivo y contexto.

Un marco organiza resultados y responsabilidades. NIST CSF 2.0 incluye gobernar, identificar, proteger, detectar, responder y recuperar. ISO/IEC 27001 trata requisitos de gestión de seguridad; no es una lista de comandos para switches. Estos referentes ayudan a ordenar trabajo y riesgo, sin garantizar ausencia de incidentes. [F7]

La Cyber Kill Chain describe una secuencia de ataque: reconocimiento, preparación o armamento, entrega, explotación, instalación, comando y control, y acciones sobre los objetivos. Sirve para pensar dónde detectar o interrumpir un ataque; no todos los incidentes siguen una secuencia lineal visible.

MITRE ATT&CK organiza comportamientos observados mediante tácticas y técnicas. Una táctica expresa el objetivo del adversario y una técnica describe cómo puede alcanzarlo. No es un antivirus ni una cronología obligatoria. El modelo diamante relaciona adversario, infraestructura, capacidad y víctima para analizar una intrusión.

Caso resuelto. Un equipo comprometido contacta un servidor para recibir instrucciones. Esa función corresponde a comando y control; el envío inicial del archivo malicioso corresponde a entrega. Confundir fases impide relacionar la evidencia con el comportamiento correcto.

Diferenciar arquitectura marco norma y herramienta

La arquitectura describe cómo se relacionan componentes y controles para cumplir necesidades. Un marco organiza preguntas, resultados o procesos. Una norma establece requisitos o guías según su naturaleza. Una herramienta implementa funciones concretas. Un firewall no es un marco; instalarlo no equivale a diseñar toda la arquitectura. Un documento de política tampoco conmuta ni filtra paquetes por sí mismo.

SABSA orienta arquitectura de seguridad desde necesidades del negocio, riesgos y trazabilidad de decisiones. TOGAF aborda arquitectura empresarial y su desarrollo, relacionando negocio, datos, aplicaciones y tecnología. Pueden aportar perspectivas complementarias. No son algoritmos de cifrado ni productos de detección. Su utilidad se comprende al relacionar una necesidad organizativa con la estructura que debe sostenerla.

Para comprender SABSA, parta de un servicio de matrícula que debe proteger identidad y continuar disponible. Se identifican necesidades y riesgos, se traducen en servicios de seguridad y se relacionan con controles implementados y mediciones. La trazabilidad permite explicar por qué existe un control y qué necesidad atiende. El punto de partida es el negocio y su riesgo, no una lista de productos.

En TOGAF, una transformación puede analizar cómo cambia el proceso de matrícula, qué datos necesita, qué aplicaciones lo realizan y qué tecnología las sostiene. El método de desarrollo de arquitectura, ADM, organiza el trabajo de arquitectura y sus cambios de manera iterativa. La seguridad debe integrarse en esas decisiones. SABSA aporta una perspectiva especializada de

seguridad; TOGAF una perspectiva de arquitectura empresarial más amplia. No se elige entre ellos como si fueran dos antivirus.

Ubicar ISO y NIST

ISO es una organización que publica diversas normas; decir solo «ISO» no identifica un control específico. ISO/IEC 27001 trata requisitos de un SGSI. ISO/IEC 20000 se relaciona con gestión de servicios. NIST también publica distintos referentes: CSF organiza resultados de ciberseguridad y sus publicaciones técnicas desarrollan temas específicos. No deben considerarse todos equivalentes por aparecer en una lista de estándares.

NIST CSF 2.0 incluye gobernar, identificar, proteger, detectar, responder y recuperar. Gobernar relaciona decisiones y responsabilidades; identificar ayuda a comprender activos y riesgos; las otras funciones orientan protección, observación y tratamiento. No son seis comandos que se ejecutan una vez, sino funciones que se relacionan durante la operación.

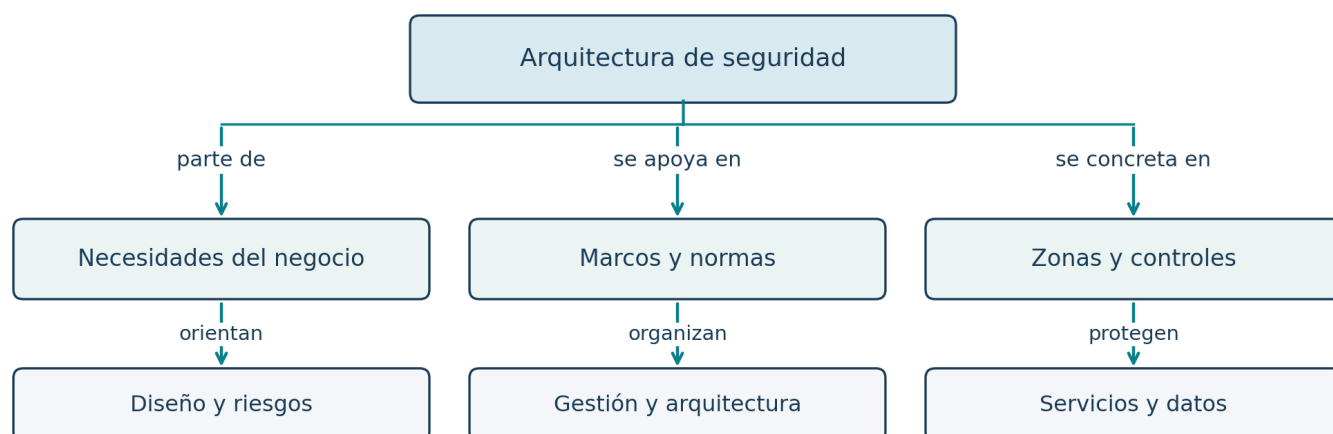
Convertir el diseño en separación verificable

Una DMZ ubica servicios expuestos en una zona con reglas respecto de Internet y de redes internas. La aplicación web puede necesitar una conexión específica hacia una base, no acceso ilimitado. Zero Trust evita otorgar confianza permanente por estar dentro de la red y exige evaluación del acceso según identidad, dispositivo y contexto.

ATT&CK describe comportamientos adversarios mediante tácticas y técnicas. La Cyber Kill Chain representa etapas de un ataque; no todos los incidentes siguen una secuencia lineal visible. Son modelos de análisis distintos de SABSA o TOGAF.

Caso explicado. Una institución quiere justificar por qué sus controles protegen un servicio esencial. Necesita relacionar requisito, riesgo, arquitectura y evidencia. Comprar un SIEM aporta una capacidad, pero el diseño debe determinar fuentes, responsables y respuesta. El marco orienta esa relación y la herramienta ejecuta parte del trabajo.

Mapa de relaciones para explicar el tema



Mapa conceptual 53 Arquitectura de seguridad

Preguntas y casos del indicador 53

Aplicación del aprendizaje. Relacionar segmentación, confianza, marcos de gestión y modelos de ataque con su función.

1 Arquitectura y herramienta

Una institución compra un firewall y afirma que ya tiene diseñada toda su arquitectura de seguridad. ¿Qué falta explicar?

Explicación. Relaciones entre necesidades, zonas, identidades, controles y operación. La herramienta implementa funciones concretas dentro de un diseño. Una compra no define automáticamente qué flujos se permiten, quién responde ni cómo se verifica la protección del servicio.

2 SABSA y TOGAF

Se comparan arquitectura de seguridad orientada a necesidades y riesgos del negocio con arquitectura empresarial más amplia. ¿Qué referentes ayudan a distinguir ambos enfoques?

Explicación. SABSA se centra en arquitectura de seguridad y trazabilidad desde el negocio; TOGAF aborda arquitectura empresarial y su desarrollo. Pueden complementarse. No son algoritmos de cifrado ni dos productos de detección entre los que se elige por marca.

3 ISO y NIST

Se requiere organizar resultados de ciberseguridad y, por otro lado, requisitos de un SGSI. ¿Qué diferencia representa NIST CSF frente a ISO IEC 27001?

Explicación. CSF organiza resultados y funciones de ciberseguridad; ISO IEC 27001 establece requisitos de un sistema de gestión. Son referentes con propósitos distintos. «ISO» o «NIST» por sí solos no identifican un único documento ni un control técnico específico.

4 DMZ y confianza cero

Un portal público debe comunicarse con una base interna. ¿Qué decisiones combinan separación de zonas y evaluación de acceso?

Explicación. Ubicar servicios expuestos en una zona controlada y permitir solo comunicaciones necesarias; evaluar identidades, recursos y contexto sin confianza automática por ubicación. Una DMZ no debe abrir acceso ilimitado a la base. Zero Trust tampoco significa que ninguna comunicación sea posible.

5 Modelos del adversario

Se describe la recepción de instrucciones desde un servidor atacante y se necesita relacionarla con un comportamiento. ¿Qué aportan Kill Chain y ATT&CK?

Explicación. Kill Chain permite ubicar funciones como comando y control dentro de un modelo de etapas; ATT&CK organiza tácticas y técnicas observadas. No son cronologías obligatorias de todos los incidentes ni sustituyen evidencia. El modelo diamante relaciona otros elementos de una intrusión.

54 Herramientas para construir modelos de negocio

Emprendimiento e innovación aplicada a la ciberseguridad · Nivel 11 · Indicador 1.1 · Tabla página 12

Indicador de logro. Compara las herramientas y metodologías vigentes en la construcción de modelos de negocios.

Propósito de aprendizaje. Comparar Canvas Lean Startup y Design Thinking según la decisión que se necesita tomar.

Conceptos fundamentales

Un modelo de negocio explica cómo se crea, entrega y obtiene valor. Una propuesta de valor expresa qué problema se resuelve para qué cliente y por qué la solución resulta pertinente. Un plan de negocio desarrolla operación, mercado y viabilidad; no es idéntico a un lienzo resumido.

Business Model Canvas organiza nueve bloques: segmentos de clientes, propuesta de valor, canales, relaciones con clientes, fuentes de ingresos, recursos clave, actividades clave, socios clave y estructura de costos. Permite observar coherencia, pero completar casillas no valida que los clientes comprarán. [F8]

Lean Startup contrasta hipótesis mediante construir, medir y aprender. Un producto mínimo viable, MVP, permite obtener aprendizaje con una versión suficiente para el experimento. No significa entregar cualquier producto incompleto ni omitir seguridad esencial. Pivotar es cambiar un aspecto significativo del modelo a partir de evidencia.

Design Thinking busca comprender necesidades de las personas mediante empatía, definición del problema, ideación, prototipos y pruebas. El proceso es iterativo. Un prototipo representa una idea para explorarla; no siempre constituye un producto operativo.

Pregunta del equipo	Herramienta que aporta más directamente
¿Qué problema viven los usuarios?	Investigación y empatía en Design Thinking.
¿Cómo se relacionan costos clientes e ingresos?	Canvas.
¿Pagarían realmente por la solución?	Experimento y medición de hipótesis en Lean Startup.

Caso resuelto. Un grupo propone monitoreo para pequeños comercios. Entrevista clientes para comprender sus interrupciones, organiza la propuesta en Canvas y prueba una oferta limitada para medir interés real. Las herramientas se complementan; ninguna garantiza rentabilidad por sí sola.

El FODA examina fortalezas y debilidades internas, oportunidades y amenazas del entorno. Ayuda al análisis, pero no sustituye evidencia de clientes ni un modelo de ingresos. Una ventaja propuesta debe poder explicarse desde la necesidad atendida.

Entender qué significa crear y capturar valor

Un modelo de negocio explica a quién se sirve, qué problema se resuelve, cómo se entrega la solución y cómo se sostiene. Una propuesta de valor no es solo un eslogan: debe indicar un beneficio relevante. «Monitoreo de seguridad» describe una actividad; «detectar incidentes y coordinar atención dentro de un alcance acordado» explica mejor el resultado esperado. Todavía requiere demostrar viabilidad y demanda.

Un plan de negocio desarrolla análisis y operación con más detalle. El Canvas representa relaciones en un lienzo. Confundir el instrumento con el negocio validado lleva a creer que completar nueve casillas demuestra que habrá clientes. El documento ordena hipótesis; la evidencia debe contrastarlas.

Dar significado a los nueve bloques

Los segmentos identifican clientes; la propuesta describe valor; los canales indican cómo se llega y entrega; las relaciones explican atención y vínculo; los ingresos, cómo se recibe valor económico. Recursos, actividades y socios sostienen la operación. La estructura de costos muestra lo que debe financiarse. Cambiar un bloque puede afectar otros: prometer atención continua exige recursos y costos compatibles.

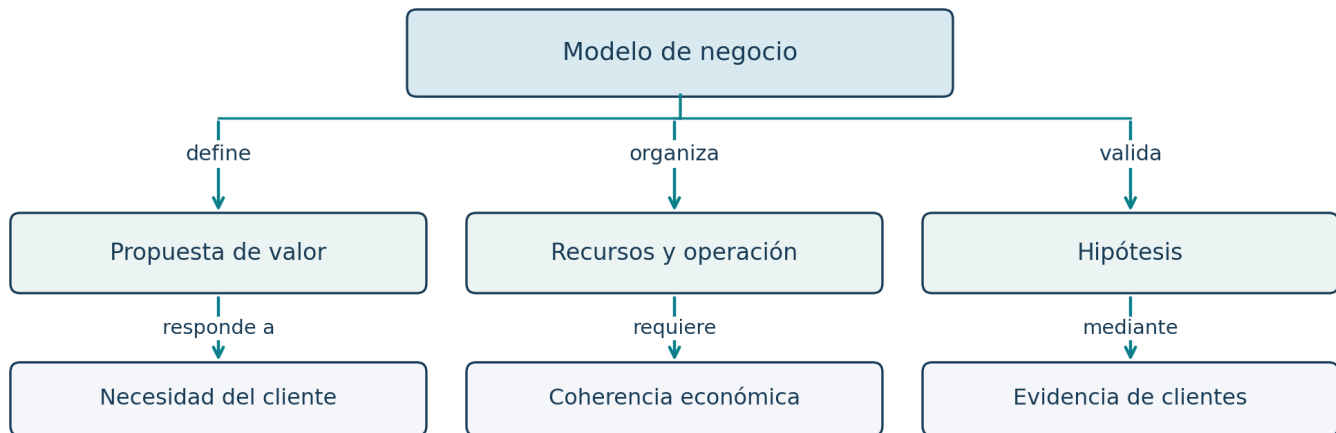
Lean Startup contrasta hipótesis mediante construir, medir y aprender. Un producto mínimo viable permite aprender con una versión suficiente para el experimento; no autoriza omitir seguridad esencial. Pivotar es cambiar un aspecto relevante a partir de evidencia. Design Thinking comienza por comprender necesidades y utiliza definición, ideación, prototipos y pruebas de manera iterativa.

Comparar herramientas con una necesidad real

Para comprender qué dificultad vive un cliente, la investigación y empatía de Design Thinking resultan pertinentes. Para visualizar coherencia de ingresos y recursos, Canvas. Para comprobar si alguien contrataría una oferta, un experimento de validación con criterios observables. FODA identifica fortalezas, oportunidades, debilidades y amenazas, pero no sustituye esas comprobaciones.

Caso comentado. Un equipo ofrece soporte continuo con una sola persona disponible de día. El problema no se resuelve mejorando el logotipo: debe ajustar propuesta, horario, recursos, socios o precio. Un modelo viable conserva coherencia entre lo prometido, lo que puede entregar y lo que el cliente necesita.

Mapa de relaciones para explicar el tema



Mapa conceptual 54 Modelo de negocio

Preguntas y casos del indicador 54

Aplicación del aprendizaje. Comparar Canvas Lean Startup y Design Thinking según la decisión que se necesita tomar.

1 Propuesta de valor

Un negocio se presenta como «empresa de ciberseguridad». ¿Qué debería concretar para expresar su propuesta de valor?

Explicación. Qué problema resuelve, para qué cliente y con qué beneficio pertinente. La especialidad describe un ámbito, pero no demuestra necesidad atendida. «Detectar y coordinar respuesta a incidentes de pequeños comercios» expresa mejor un resultado que luego debe validarse.

2 Coherencia del Canvas

Se promete monitoreo continuo, pero no se incluyen personal nocturno, socios ni costos correspondientes. ¿Qué relación del modelo debe revisarse?

Explicación. La propuesta debe corresponder a actividades, recursos, socios y estructura de costos. Los bloques del Canvas se afectan entre sí. Completar casillas no demuestra viabilidad si lo prometido no puede sostenerse con la operación descrita.

3 Design Thinking

El equipo desconoce qué dificultad viven los usuarios y quiere diseñar pantallas inmediatamente. ¿Qué enfoque inicial resulta pertinente?

Explicación. Investigación y empatía para comprender necesidades, seguida de definición del problema. Design Thinking relaciona comprensión, ideación, prototipos y pruebas. Diseñar una pantalla atractiva antes de conocer la necesidad puede producir una solución a un problema equivocado.

4 Lean Startup

Se desea comprobar si comercios pagarían por un servicio antes de desarrollarlo completo. ¿Qué debe definir un experimento útil?

Explicación. Una hipótesis y evidencia observable que permita aceptarla provisionalmente, ajustarla o rechazarla. Un producto mínimo viable facilita aprendizaje con alcance suficiente. Muchas visitas no prueban compra; debe medirse una señal coherente con la hipótesis comercial.

5 FODA y evidencia

El equipo identifica fortalezas y amenazas, pero no entrevista clientes ni prueba demanda. ¿El FODA demuestra que el negocio tendrá compradores?

Explicación. No. FODA organiza factores internos y externos para analizar, pero no sustituye validación del cliente ni del modelo de ingresos. Cada herramienta responde a preguntas distintas; un buen análisis estratégico debe conectarse con evidencia de comportamiento real.

55 Atención y servicio al cliente

Emprendimiento e innovación aplicada a la ciberseguridad · Nivel 11 · Indicador 2.1 · Tabla página 12

Indicador de logro. Explica la diferencia entre atención y servicio al cliente.

Propósito de aprendizaje. Diferenciar el trato interpersonal del cumplimiento de la solución y analizar ambos en un caso.

Conceptos fundamentales

La atención al cliente comprende escucha, comunicación, trato, orientación y manejo de la interacción. El servicio al cliente abarca el conjunto de acciones que satisface una necesidad antes, durante y después de la prestación. Incluye solución, cumplimiento, seguimiento y experiencia. Una atención amable puede coexistir con un servicio incumplido.

La escucha activa verifica comprensión mediante preguntas y reformulación. La empatía reconoce la situación de la persona sin inventar promesas. La asertividad comunica límites y acuerdos de manera clara y respetuosa. Debe utilizarse lenguaje comprensible y evitar culpar a la persona sin analizar hechos.

Un SLA establece compromisos de servicio, como disponibilidad y tiempos de atención o recuperación. El tiempo de primera respuesta mide cuándo se atiende el contacto; el tiempo de resolución mide cuándo se soluciona el caso según su definición. Son métricas distintas y deben interpretarse con el alcance contratado.

Situación	Valoración
Respuesta cordial y rápida, pero solución fuera del plazo.	Buena dimensión de atención; revisar cumplimiento del servicio.
Solución técnica a tiempo con trato hostil.	Cumplimiento técnico con atención inadecuada.
Solución verificada y seguimiento del usuario.	Servicio que comprueba satisfacción de la necesidad.

Caso resuelto. Un comercio reporta caída de facturación. Soporte responde en cinco minutos, pero restaura al día siguiente pese a un compromiso menor. La rapidez del saludo no

demuestra cumplimiento de recuperación. Deben explicarse estado, acciones y alternativas autorizadas sin prometer una hora sin fundamento.

Confidencialidad. Para dar soporte no se debe pedir publicar contraseñas ni divulgar datos de otros clientes. Escalar un caso significa transferirlo al responsable o nivel adecuado conservando información necesaria y trazabilidad.

Separar la interacción del resultado

La atención se manifiesta en cómo se escucha, orienta y comunica. El servicio incluye lo que se entrega y si resuelve la necesidad bajo las condiciones acordadas. Una respuesta amable que nunca soluciona la falla no demuestra buen cumplimiento; una solución técnica con trato hostil tampoco ofrece una experiencia adecuada. Ambas dimensiones deben analizarse.

La escucha activa verifica comprensión mediante preguntas y reformulación. La empatía reconoce la situación de la persona sin prometer algo imposible. La asertividad comunica límites y alternativas de forma clara y respetuosa. En soporte, atribuir culpa antes de investigar puede impedir que la persona comparta información necesaria para diagnosticar.

Definir tiempos que no se confundan

El tiempo de primera respuesta mide cuánto tarda en atenderse el contacto. El tiempo de resolución mide hasta completar la solución según la definición acordada. Un SLA establece compromisos y condiciones, incluidos alcance, horario, prioridades y escalamiento. Responder en cinco minutos no compensa necesariamente incumplir una recuperación comprometida; son medidas diferentes.

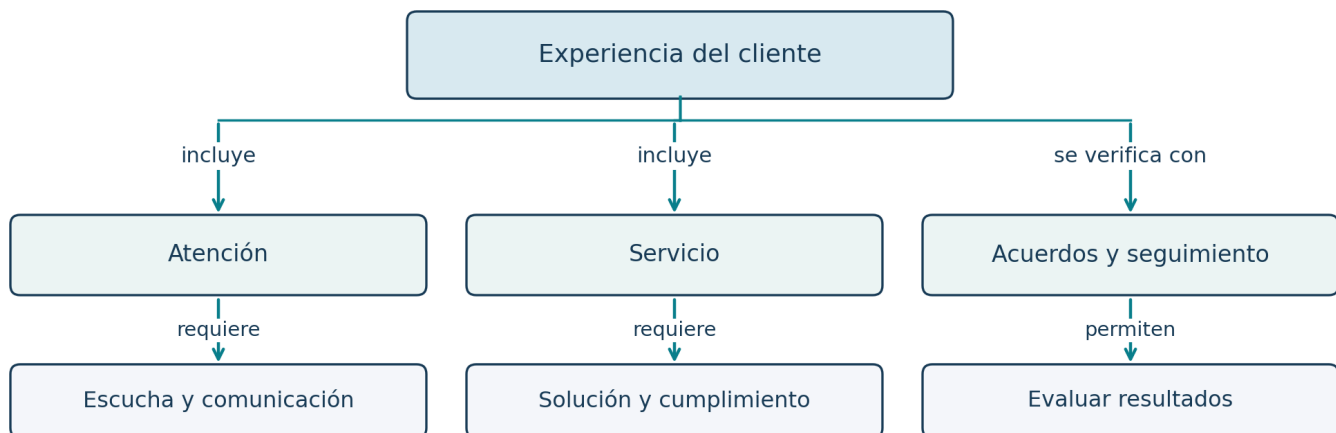
Un ticket registra la necesidad, contexto, acciones y estado. Escalar significa trasladar al nivel o responsable adecuado con información pertinente. No equivale a abandonar el caso. El seguimiento permite verificar que la solución funciona para la persona, no solo que desapareció una alerta técnica.

Proteger información durante la atención

No debe pedirse publicar contraseñas ni compartir expedientes completos en canales abiertos. La identidad y autorización se verifican mediante el procedimiento institucional. El soporte debe conservar la información necesaria y limitar acceso. Una solicitud urgente no elimina esos controles.

Caso explicado. Una persona no puede facturar. El técnico restablece el servicio y cierra el ticket sin comprobar que se registró una venta de prueba autorizada. Puede haber resuelto conectividad, pero no toda la función. Confirmar el resultado con el usuario permite descubrir dependencias pendientes. El servicio se evalúa por necesidad atendida y condiciones acordadas, además de la calidad del trato.

Mapa de relaciones para explicar el tema



Mapa conceptual 55 Experiencia del cliente

Preguntas y casos del indicador 55

Aplicación del aprendizaje. Diferenciar el trato interpersonal del cumplimiento de la solución y analizar ambos en un caso.

1 Atención y solución

Soporte responde con amabilidad en cinco minutos, pero no resuelve la falla durante el plazo acordado. ¿Qué dimensiones deben evaluarse por separado?

Explicación. Calidad de atención interpersonal y cumplimiento del servicio. La rapidez y cordialidad son valiosas, pero no demuestran restauración. También puede existir solución técnica a tiempo con trato inadecuado; ambas dimensiones contribuyen a la experiencia.

2 Escucha activa

El usuario dice que «no puede trabajar» y el técnico concluye inmediatamente que falla Internet. ¿Qué conducta permite precisar la necesidad?

Explicación. Preguntar, escuchar y reformular qué tarea intenta realizar, qué observa y desde cuándo. La escucha activa verifica comprensión antes de imponer una causa. Una hipótesis técnica debe comprobarse; la descripción general del usuario puede tener varias explicaciones.

3 Respuesta y resolución

El primer contacto se atiende a las 8:05 y el servicio se restablece a las 11:00. ¿Por qué no debe informarse un único tiempo sin definirlo?

Explicación. Tiempo de primera respuesta y de resolución miden hitos diferentes. Debe conocerse el inicio, el alcance y las condiciones acordadas. Responder rápido no significa haber recuperado la operación; resolver tampoco acredita que el contacto inicial fue oportuno.

4 Escalamiento

Un caso supera las facultades de la persona de soporte. ¿Escalarlo significa abandonarlo?

Explicación. No. Debe trasladarse con contexto, evidencias, acciones realizadas y seguimiento al nivel responsable. El usuario necesita saber cómo continúa la atención. Transferir sin información puede repetir preguntas y retrasar la solución.

5 Confidencialidad durante soporte

Para diagnosticar, se pide al usuario publicar su contraseña y expediente en un chat general. ¿Qué alternativa respeta el servicio y la protección de datos?

Explicación. Verificar identidad y utilizar un procedimiento seguro que limite información compartida a la necesaria. La urgencia no justifica divulgar secretos. La atención correcta debe resolver la necesidad sin crear una exposición adicional de datos propios o ajenos.

56 Formalización del emprendimiento en Costa Rica

Emprendimiento e innovación aplicada a la ciberseguridad · Nivel 11 · Indicador 3.1 · Tabla página 12

Indicador de logro. Identifica los procesos requeridos para la formalización del emprendimiento en las instituciones de apoyo.

Propósito de aprendizaje. Relacionar cada trámite con la institución y obligación que le corresponde.

Conceptos fundamentales

La formalización organiza la actividad económica para cumplir obligaciones aplicables. Un emprendimiento puede operar mediante persona física o una forma jurídica según el caso. Constituir una sociedad, registrar una marca y obtener permisos de operación son trámites distintos.

La actividad, ubicación, contratación de personal y características del servicio determinan requisitos concretos. No existe un único trámite que sustituya a todos. Debe distinguirse apoyo al emprendimiento de una autorización legal para operar.

Institución o ámbito	Función que debe reconocer
Ministerio de Hacienda	Inscripción y obligaciones tributarias y de comprobación correspondientes.
Municipalidad	Licencia o patente y requisitos locales de operación.
CCSS	Aseguramiento como patrono o trabajador independiente según situación.
INS	Seguro de riesgos del trabajo cuando corresponde.
Ministerio de Salud	Permiso sanitario de funcionamiento según actividad y regulación.
Registro Nacional	Constitución e inscripción jurídica o derechos registrables según trámite.
MEIC y entidades de apoyo	Orientación y programas de desarrollo empresarial según requisitos.

Una marca distingue productos o servicios; su registro no concede por sí solo licencia municipal. Un dominio de Internet es una dirección o nombre en el entorno digital; no equivale

a inscripción tributaria ni aseguramiento social. Una póliza de equipo protege un riesgo patrimonial distinto al de trabajadores.

Caso resuelto. Una empresa de soporte obtiene patente y después contrata personal. Debe atender obligaciones patronales y aseguramiento pertinentes; no puede asumir que la patente afilió automáticamente a las personas. Debe verificar requisitos vigentes en la institución competente. [F9]

Protección de datos y contratos. Un emprendimiento de ciberseguridad también necesita definir alcance del servicio, autorización para pruebas, manejo confidencial de datos, responsabilidades y conservación de evidencia. La formalización administrativa no autoriza a intervenir sistemas de terceros sin acuerdo.

Entender la formalización como varias obligaciones

Un emprendimiento puede operar mediante persona física o una forma jurídica según su situación. Constituir una sociedad no equivale a completar todos los permisos. La actividad, ubicación, contratación de personal y condiciones del servicio determinan requisitos. Por eso no existe una única casilla que convierta cualquier actividad en formal.

La inscripción tributaria corresponde al ámbito de Hacienda. La licencia o patente y requisitos locales corresponden a la municipalidad según actividad. La CCSS atiende aseguramiento en las condiciones de patrono o trabajador independiente aplicables. El INS se relaciona, entre otros ámbitos, con seguro de riesgos del trabajo cuando corresponde. El Ministerio de Salud atiende permisos sanitarios según actividad y regulación. Cada trámite debe comprobarse en su institución competente.

Diferenciar identidad comercial y autorización

Registrar una marca protege una identificación conforme al régimen correspondiente; no concede por sí solo licencia municipal ni afiliación social. Un dominio de Internet identifica una ubicación o nombre digital y tampoco sustituye trámites. El Registro Nacional interviene en inscripciones jurídicas y derechos registrables según el caso. Tener un sitio web operativo no demuestra cumplimiento administrativo.

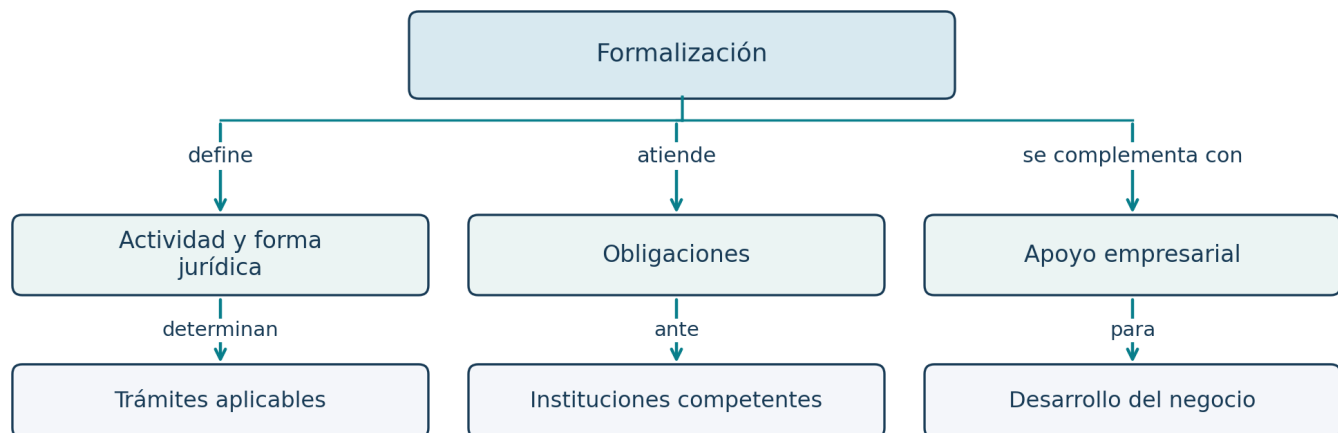
MEIC y otras entidades pueden ofrecer orientación y programas de apoyo, sujetos a requisitos. Recibir capacitación o apoyo empresarial no reemplaza obligaciones tributarias, laborales o locales. El indicador exige reconocer la función de cada institución y distinguir apoyo de autorización.

Aplicarlo a servicios de ciberseguridad

Un servicio debe definir alcance, responsabilidades, tratamiento de datos y autorización de pruebas. Estar formalizado no concede permiso para examinar sistemas de cualquier cliente sin acuerdo. Los contratos deben corresponder a lo que se ejecutará y a las condiciones de confidencialidad y conservación de evidencia.

Caso comentado. Un negocio con patente contrata personal por primera vez. Debe atender las obligaciones patronales y de aseguramiento pertinentes; no puede asumir que la patente inscribió a esas personas automáticamente. Para resolver una pregunta, identifique el hecho que cambia —contratar, abrir local, registrar marca— y relacione ese hecho con la institución, sin mezclar funciones.

Mapa de relaciones para explicar el tema



Mapa conceptual 56 Formalización

Preguntas y casos del indicador 56

Aplicación del aprendizaje. Relacionar cada trámite con la institución y obligación que le corresponde.

1 Forma de operación

Una persona inicia un servicio técnico y considera constituir una sociedad. ¿Esa inscripción completa automáticamente todos los requisitos de operación?

Explicación. No. Forma jurídica, actividad, ubicación y contratación de personal determinan obligaciones distintas. Constituir una sociedad atiende una dimensión; pueden existir requisitos tributarios, locales, laborales y otros aplicables que deben revisarse por separado.

2 Obligaciones tributarias y locales

Se comparan inscripción tributaria y patente municipal. ¿Qué instituciones y funciones debe diferenciar el estudiante?

Explicación. Hacienda atiende obligaciones tributarias; la municipalidad, licencia o patente y requisitos locales pertinentes. Un registro no sustituye automáticamente al otro. El caso debe resolverse según la actividad y norma aplicable, sin inventar que existe un único trámite universal.

3 Contratación de personal

Un negocio ya tiene patente y contrata por primera vez. ¿Qué obligaciones adicionales deben analizarse?

Explicación. Aseguramiento y obligaciones patronales pertinentes, incluyendo funciones de CCSS e INS según corresponda. La patente no afilia automáticamente trabajadores ni sustituye cobertura de riesgos del trabajo. Deben verificarse condiciones ante cada institución competente.

4 Marca y autorización

Una empresa registra su marca y compra un dominio. ¿Eso demuestra que puede operar legalmente en cualquier local?

Explicación. No. Marca y dominio identifican aspectos comerciales o digitales; permisos de operación dependen de otros requisitos. La formalización requiere distinguir protección de identidad, inscripción jurídica y autorización para la actividad concreta.

5 Apoyo empresarial

Un emprendimiento recibe capacitación de una institución de apoyo y desea evaluar redes de clientes. ¿La capacitación sustituye formalización y autorización técnica?

Explicación. No. El apoyo fortalece capacidades, pero no reemplaza obligaciones aplicables ni acuerdos de alcance para intervenir sistemas. Deben diferenciarse orientación empresarial, permisos administrativos y autorización contractual del trabajo de ciberseguridad.

57 Herramientas y preservación en peritajes forenses

Seguridad de la información y gestión administrativa en ciberseguridad · Nivel 12 · Indicador 1.1 · Tabla página 13

Indicador de logro. Identifica herramientas requeridas en peritajes forenses.

Propósito de aprendizaje. Seleccionar herramientas según la evidencia y explicar integridad y cadena de custodia.

Referencia para ampliar los saberes Programa de duodécimo páginas 75 y 76

Conceptos fundamentales

El análisis forense digital utiliza métodos documentados para identificar, recolectar, preservar, examinar, analizar y comunicar evidencia. Su objetivo es responder preguntas sobre hechos, no modificar datos para que coincidan con una hipótesis. La autorización, alcance y procedimientos aplicables condicionan la actuación.

La cadena de custodia documenta quién recibió, trasladó, examinó o resguardó evidencia, cuándo y bajo qué condiciones. Un hash criptográfico permite comparar integridad de una copia respecto de un valor de referencia. El hash no demuestra por sí solo autoría del incidente ni que lo escrito dentro de un archivo sea verdadero.

Herramienta o técnica	Función
Bloqueador de escritura	Impide modificaciones al medio desde el acceso de análisis compatible.
Generador de imagen forense	Adquiere una copia con alcance y procedimiento documentados.
Autopsy u otra suite forense	Examina archivos y artefactos en imágenes.
Herramienta de adquisición y análisis de memoria	Obtiene o estudia información volátil.
Analizador de tráfico como Wireshark	Examina capturas de comunicación.
Función hash como SHA 256	Calcula huellas para comprobar integridad.

Una imagen física puede incluir áreas que una copia de archivos no captura; una adquisición lógica recoge información según el alcance de la herramienta. Archivos borrados pueden dejar rastros, pero su recuperación no está garantizada. La memoria y conexiones activas pueden perderse al apagar el equipo.

Caso resuelto. Se recibe un disco y se necesita examinarlo preservando el original. Se documenta recepción, se aplica el procedimiento de adquisición con controles de escritura y se verifica la copia. Desfragmentar primero el original cambia datos y puede perjudicar evidencia.

Un informe debe distinguir observaciones, interpretaciones y limitaciones. Las horas pueden requerir considerar zona horaria y desfases documentados. Corregir manualmente los logs originales para que coincidan destruye su valor como registro original.

Diferenciar contenido metadatos y contexto

El contenido es lo que un archivo representa, como texto o imagen. Los metadatos describen propiedades: tamaño, fechas, autor declarado, dispositivo o ubicación cuando existan. Los del sistema de archivos, de una aplicación y de una fotografía pueden provenir de fuentes distintas. Una fecha no demuestra automáticamente cuándo ocurrió un hecho real: puede depender de copia, configuración horaria o modificación. Debe interpretarse junto con otras evidencias.

Un rastro digital es una huella de actividad. Para utilizarlo como evidencia se requiere examinar procedencia, integridad y relación con la pregunta. Un consultor técnico y una persona perita pueden tener funciones distintas según el proceso; no se presume autoridad judicial por poseer una herramienta. La actuación exige alcance y autorización aplicables.

Elegir el método de adquisición

Una extracción manual registra lo visible mediante interacción documentada; puede ser limitada y alterar estado. Una adquisición lógica obtiene datos expuestos por mecanismos del sistema o aplicación. Una adquisición del sistema de archivos recoge estructura y contenido accesibles según herramienta. Una adquisición física intenta obtener un alcance más cercano al medio completo, pero cifrado, tecnología y método condicionan qué se obtiene.

Las herramientas pueden operar por hardware o software. En sentido general, una obtención directa trabaja con la fuente o dispositivo; una indirecta recibe datos mediante intermediarios, exportaciones o copias disponibles. La terminología concreta debe precisarse en el procedimiento, porque no constituye una clasificación universal idéntica en todas las herramientas. Ninguna de esas etiquetas garantiza por sí sola completitud. En nube, puede requerirse exportación o colaboración del proveedor y no existir acceso al disco físico. Deben registrarse alcance, formatos, límites y referencias de tiempo.

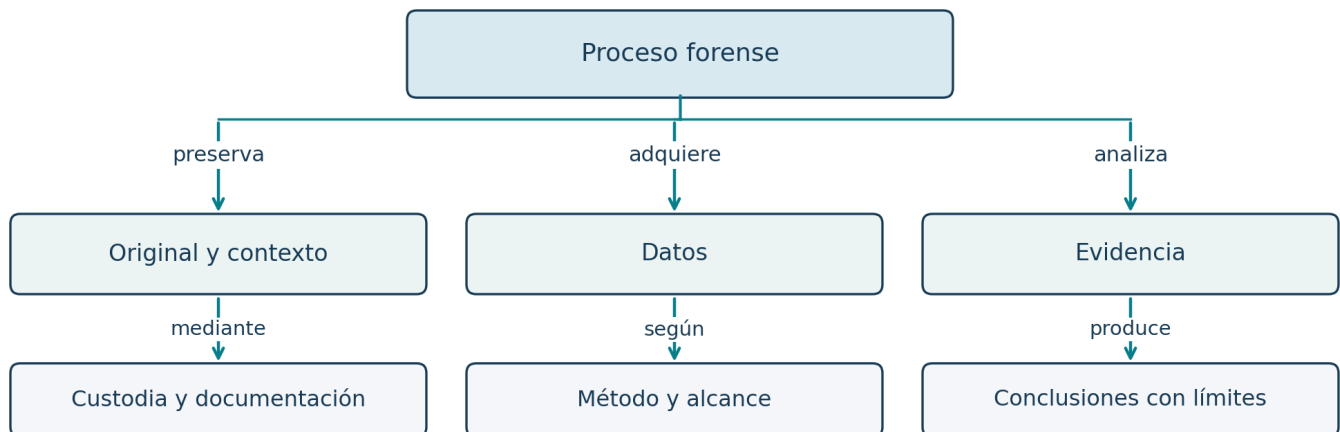
Preservar y demostrar integridad

Un bloqueador de escritura busca evitar modificaciones al medio desde el acceso de análisis compatible. Una imagen permite trabajar sobre copia. Los hashes comparan integridad respecto de una referencia; la cadena de custodia documenta quién recibió, transfirió o examinó y en qué condiciones. Ninguno demuestra por sí solo autoría del incidente.

Patrón, PIN, contraseña, huella, rostro y cifrado pueden limitar adquisición. Su presencia no autoriza eludirlos sin procedimiento. La memoria y las conexiones son volátiles y pueden perderse al apagar. Las decisiones deben coordinar preservación y seguridad operativa.

Caso comentado. Un teléfono contiene una conversación relevante. Fotografiar una pantalla ofrece una observación limitada; no equivale a adquirir todo el dispositivo. El informe debe indicar qué se obtuvo, cómo y qué no puede concluirse. La calidad forense se apoya en esa precisión y en preservar la fuente.

Mapa de relaciones para explicar el tema



Mapa conceptual 57 Proceso forense

Preguntas y casos del indicador 57

Aplicación del aprendizaje. Seleccionar herramientas según la evidencia y explicar integridad y cadena de custodia.

1 Elegir una herramienta

Se requiere examinar archivos y artefactos de una imagen de disco, y en otro caso analizar tráfico capturado. ¿Qué herramientas del manual cumplen esas funciones?

Explicación. Una suite como Autopsy ayuda a examinar imágenes y artefactos; un analizador como Wireshark examina tráfico capturado. La elección depende de la evidencia. Instalar una herramienta no autoriza adquisición ni demuestra que la captura esté completa.

2 Cadena de custodia

Una unidad cambia de responsable sin registrar entrega, fecha ni condición. ¿Qué aspecto del proceso forense se debilita?

Explicación. La cadena de custodia y trazabilidad de manejo. Debe documentarse quién recibió, trasladó, examinó o resguardó la evidencia y bajo qué condiciones. Un hash coincidente no reemplaza todos esos registros ni prueba por sí solo autoría del hecho investigado.

3 Integridad mediante hash

La copia y la referencia tienen el mismo hash criptográfico apropiado. ¿Qué respalda esa comparación y qué no demuestra?

Explicación. Respalda coincidencia de integridad de los bytes respecto de esa referencia bajo el procedimiento. No prueba que el contenido sea verdadero ni quién lo creó. La conclusión debe limitarse a la propiedad que realmente se comprobó.

4 Tipos de adquisición

Fotografiar una conversación visible se compara con adquirir datos lógicos o una imagen física. ¿Por qué no deben presentarse como alcances equivalentes?

Explicación. La observación manual registra lo visible; adquisiciones lógicas y físicas obtienen otros conjuntos según método, herramienta y dispositivo. Ninguna etiqueta garantiza completitud. Debe informarse qué se obtuvo, qué pudo alterarse y qué quedó fuera del alcance.

5 Metadatos y tiempo

Un archivo muestra una fecha reciente después de copiarlo, aunque su contenido sea anterior. ¿Por qué debe interpretarse el significado de esa fecha?

Explicación. Los metadatos dependen del sistema, operación y campo observado. Una fecha puede representar copia o modificación, no el hecho investigado. Deben correlacionarse fuentes y documentar zona horaria y limitaciones sin reescribir originales para sostener una hipótesis.

58 Clasificación funcional del software malicioso

Seguridad de la información y gestión administrativa en ciberseguridad · Nivel 12 · Indicador 2.1 · Tabla página 13

Indicador de logro. Identifica conceptos y la clasificación de software maliciosos.

Propósito de aprendizaje. Interpretar persistencia, ocultamiento, control remoto y mecanismos de activación.

Referencia para ampliar los saberes Programa de duodécimo páginas 76 y 77

Conceptos fundamentales

La clasificación del malware puede basarse en propagación, propósito o técnicas. Conviene describir el comportamiento observado antes de elegir un nombre. Un troyano puede instalar un rootkit y usar comando y control; varias etiquetas pueden ser válidas si responden a dimensiones distintas.

Persistencia es la capacidad de mantener acceso o ejecución después de ciertos cambios, como reinicios. Ocultamiento busca evitar observación. Una puerta trasera permite acceso que evade el mecanismo normal previsto; puede ser instalada por otro malware. Un dropper deposita o instala una carga maliciosa y un downloader la obtiene de otra ubicación.

Concepto	Rasgo que debe distinguir
Rootkit	Oculto actividad o mantiene acceso alterando o abusando de componentes.

Concepto	Rasgo que debe distinguir
RAT	Permite control remoto malicioso del equipo.
Bomba lógica	Se activa ante una condición, como fecha o evento.
Keylogger	Captura pulsaciones.
Bot	Dispositivo o agente comprometido que recibe tareas de control.
Malware sin archivos	Utiliza memoria o herramientas del sistema y puede reducir rastros en archivos.

El código polimórfico cambia ciertas representaciones para dificultar detección; no implica que su objetivo sea diferente en cada ejecución. Comando y control, C2, coordina instrucciones o intercambio con infraestructura del atacante. Un programa que se comunica por HTTPS no se vuelve legítimo solo por usar cifrado.

Caso resuelto. Un programa oculta procesos privilegiados y altera funciones para evitar detección. La capacidad descrita corresponde a rootkit. Si la pregunta se refiere a copiarse por red, esa evidencia sería necesaria para clasificarlo como gusano: no se infiere de su ocultamiento.

La misma herramienta de acceso remoto puede servir a soporte legítimo o ser utilizada abusivamente. Contexto, autorización, instalación y comportamiento distinguen un uso permitido de una intrusión.

Describir la función antes de asignar una etiqueta

Una puerta trasera permite un acceso que evade el mecanismo normal previsto. Un rootkit oculta actividad o mantiene acceso mediante alteración o abuso de componentes. Un RAT permite control remoto malicioso en el contexto descrito. Un keylogger registra pulsaciones. Estas funciones pueden convivir en una infección y no son sinónimos de cómo llegó el código.

Un dropper deposita o instala una carga; un downloader descarga componentes. La persistencia busca que una capacidad sobreviva a reinicios u otros cambios; el ocultamiento busca que no sea observada. Un mecanismo puede cumplir ambas, pero hay que identificar qué comportamiento menciona el caso.

Incluir las categorías del programa de estudio

Un dialer malicioso utiliza o altera marcación para conexiones o cargos indebidos, especialmente en entornos históricos de módem. El malware de boot o arranque afecta componentes del inicio. Rogueware simula protección o diagnósticos para engañar y obtener pagos o instalaciones. Crimeware agrupa software orientado a actividades delictivas. Ransomware bloquea o cifra y exige rescate; la extorsión también puede involucrar amenaza de divulgar información extraída.

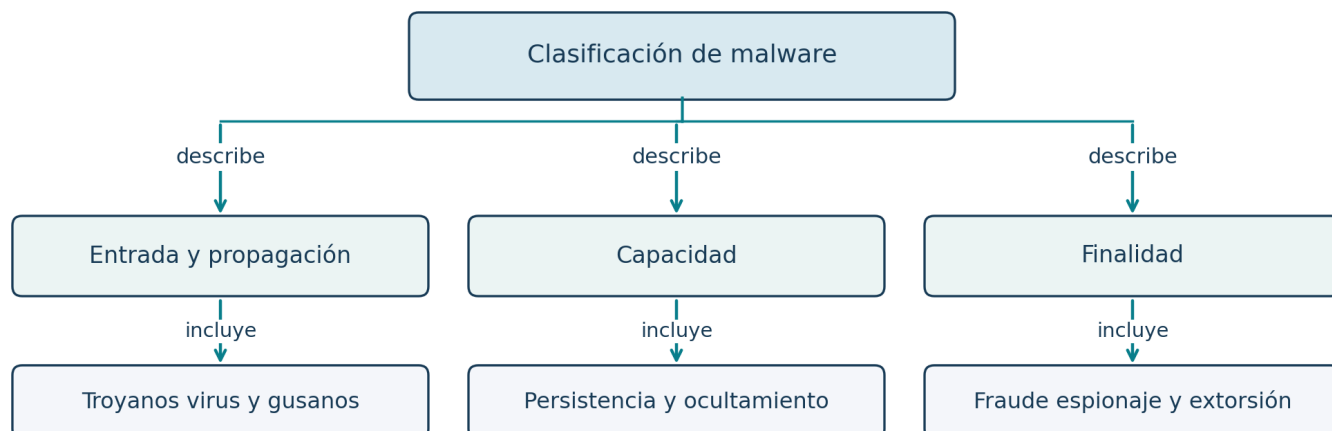
Una bomba lógica se activa por una condición, que puede ser fecha, evento o cambio de estado. No necesita ser siempre un temporizador. Un bot recibe tareas de control; varios equipos coordinados forman una botnet. La comunicación C2 coordina instrucciones o intercambio con infraestructura adversaria.

Entender evolución y límites de la clasificación

El código polimórfico modifica representaciones para dificultar detección. Malware sin archivos puede abusar de memoria y herramientas legítimas, pero no significa ausencia absoluta de rastros. Una aplicación de administración remota puede ser legítima o utilizada indebidamente; se revisan autorización, instalación y comportamiento.

Caso explicado. Un programa muestra alertas falsas y exige pagar para eliminar amenazas inventadas. El rasgo central corresponde a rogware. Si además registra teclas, incorpora una función de keylogger. En selección única, el enunciado debe precisar el rasgo que se pide; el estudiante no debe añadir una forma de propagación que no se observó.

Mapa de relaciones para explicar el tema



Mapa conceptual 58 Clasificación de malware

Preguntas y casos del indicador 58

Aplicación del aprendizaje. Interpretar persistencia, ocultamiento, control remoto y mecanismos de activación.

1 Rootkit y backdoor

Un componente oculta procesos; otro permite acceso que evade el mecanismo normal. ¿Qué funciones corresponden?

Explicación. Ocultamiento mediante rootkit y acceso mediante backdoor, según el comportamiento descrito. Pueden coexistir. Una categoría no permite inventar otra: ocultar un proceso no demuestra por sí solo cómo se propagó el código.

2 Bomba lógica

Un código se activa cuando se elimina una cuenta concreta. ¿Necesita una fecha programada para ser una bomba lógica?

Explicación. No. La condición puede ser un evento o cambio de estado, no solo una fecha. El rasgo decisivo es activarse al cumplirse una condición. Una acción programada legítima no es maliciosa únicamente por utilizar esa misma lógica de ejecución.

3 Bot y control remoto

Muchos equipos comprometidos reciben instrucciones coordinadas. ¿Cómo se relacionan bot, botnet y comando y control?

Explicación. Un bot es un agente o equipo comprometido bajo control; una botnet reúne varios; comando y control coordina instrucciones y comunicación. El canal puede usar protocolos comunes, incluso cifrados. El protocolo por sí solo no demuestra legitimidad.

4 Dropper y downloader

Un programa deposita una carga incluida y otro descarga componentes adicionales. ¿Qué diferencia funcional permite reconocerlos?

Explicación. Dropper deposita o instala una carga; downloader la obtiene mediante descarga. Ambos pueden participar en una infección, pero realizan operaciones distintas. El análisis debe describir comportamiento observado y no clasificar exclusivamente por extensión o nombre.

5 Otras categorías del programa

Se comparan falsa protección, marcación indebida, alteración del arranque y herramientas para actividades delictivas. ¿Qué términos se relacionan?

Explicación. Rogueware, dialer malicioso, malware de arranque y crimeware, respectivamente. Los criterios difieren: engaño, acción de marcación, zona afectada o finalidad. No son categorías necesariamente excluyentes ni equivalentes a todos los virus, troyanos o programas de publicidad.

59 Infección prevención y herramientas antimalware

Seguridad de la información y gestión administrativa en ciberseguridad · Nivel 12 · Indicador 2.2 · Tabla página 13

Indicador de logro. Compara métodos de infección, medidas preventivas y herramientas anti malware.

Propósito de aprendizaje. Comparar medidas según el vector de entrada y comprender los límites de la detección.

Referencia para ampliar los saberes Programa de duodécimo páginas 76 y 77

Conceptos fundamentales

Un vector de infección es una vía de ingreso o ejecución: adjuntos, macros, descargas falsas, medios extraíbles, vulnerabilidades de servicios o actualizaciones comprometidas. Detectar el vector permite seleccionar medidas concretas; un consejo genérico como «tener cuidado» no explica el control requerido.

La detección por firmas compara patrones conocidos. La heurística aplica reglas para reconocer características sospechosas. El análisis de comportamiento observa acciones; una sandbox permite ejecución controlada. Un EDR recopila actividad de endpoints y facilita detección, investigación y respuesta. Ninguna técnica detecta todas las amenazas por sí sola.

Vector o situación	Medida pertinente
Documento que pide macros no confiables.	Restringir macros y verificar el origen por un canal seguro.

Vector o situación	Medida pertinente
Instalador de sitio que imita al proveedor.	Usar fuente oficial y verificar firma o integridad confiable.
Explotación de una falla conocida.	Evaluar y aplicar corrección, reduciendo exposición.
Equipo que ejecuta programas innecesarios.	Mínimos privilegios y control de aplicaciones.
Malware que cifra archivos.	Detección, contención y respaldos separados y probados.

Caso resuelto. Un archivo no coincide con firmas conocidas, pero solicita desactivar protecciones. La ausencia de alerta no garantiza inocuidad. Debe mantenerse la protección y seguir revisión autorizada antes de ejecutarlo. La extensión y un logotipo no sustituyen esa verificación.

La cuarentena aísla un archivo detectado; no significa automáticamente que todo el incidente fue resuelto. Deben analizarse alcance, persistencia y credenciales potencialmente afectadas. Si hay necesidad forense, las acciones de limpieza deben coordinarse con preservación de evidencia.

Actualizar herramientas y sistemas, formar a usuarios, controlar ejecución y mantener copias son medidas complementarias. Un respaldo reduce consecuencias de ciertas pérdidas, pero no evita que se extraiga información antes de cifrarla.

Comprender por qué llega el código

Un vector es la vía de ingreso o ejecución: adjunto, descarga, vulnerabilidad de servicio, medio extraíble o actualización comprometida. La ingeniería social induce a ejecutar o permitir; la explotación aprovecha una debilidad técnica. Un incidente puede combinar ambas. Por eso formar usuarios y actualizar sistemas son medidas complementarias.

La procedencia debe verificarse mediante fuentes y mecanismos apropiados. Un nombre de archivo conocido, extensión o logotipo puede falsificarse. Una firma válida aporta verificación bajo su cadena de confianza, pero no garantiza ausencia de vulnerabilidades. Las ventanas emergentes que presionan para desactivar protección requieren especial análisis de legitimidad.

Comparar métodos de detección

Las firmas reconocen patrones conocidos. La heurística utiliza reglas para identificar características sospechosas. El análisis de comportamiento observa acciones, como modificaciones masivas o acceso anómalo a procesos. Una sandbox permite ejecución controlada con límites. EDR agrega visibilidad de endpoints e investigación y respuesta según sus capacidades. No todas las herramientas ofrecen lo mismo por utilizar la etiqueta antimalware.

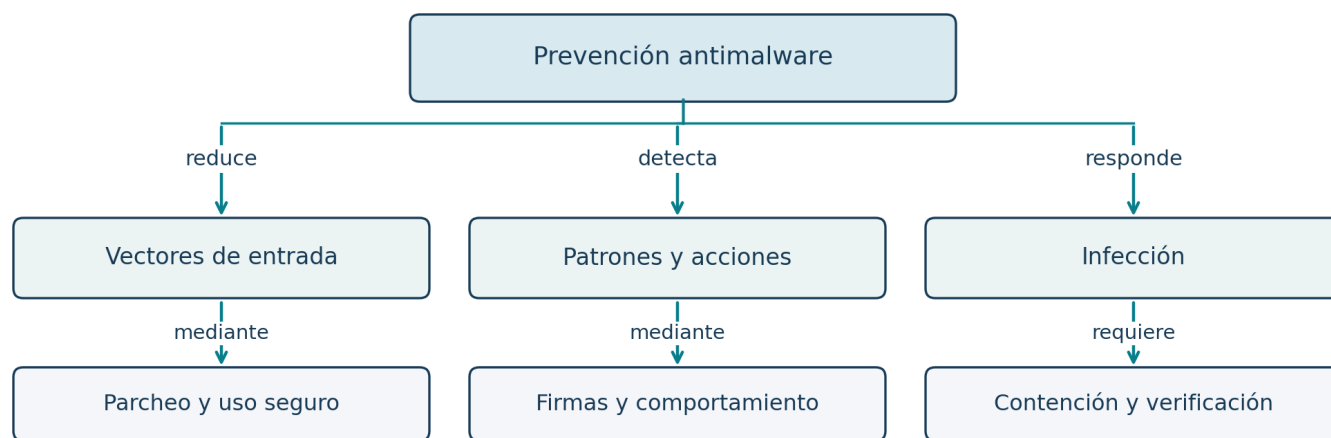
Los falsos positivos y negativos obligan a revisar resultados. Un archivo no detectado no queda certificado como seguro. Una alerta tampoco justifica borrar sin analizar si contiene evidencia o si afecta una operación legítima. La decisión debe corresponder al procedimiento y criticidad.

Recuperar sin perder el contexto del incidente

La cuarentena aísla un archivo, pero puede quedar persistencia, otra carga o una credencial comprometida. Debe revisarse alcance y causa. Si se requiere análisis forense, limpieza y preservación deben coordinarse. Restaurar desde una copia sin corregir la vía de entrada puede repetir la infección.

Caso comentado. Un ransomware cifra archivos y la carpeta sincronizada replica el daño. El respaldo independiente puede permitir recuperación, mientras el cifrado de datos robados sigue siendo un problema distinto. La respuesta debe considerar contención, evidencia, accesos y recuperación comprobada. No existe una única herramienta que sustituya todas esas funciones.

Mapa de relaciones para explicar el tema



Mapa conceptual 59 Prevención antimalware

Preguntas y casos del indicador 59

Aplicación del aprendizaje. Comparar medidas según el vector de entrada y comprender los límites de la detección.

1 Vector de infección

Un documento solicita habilitar macros no confiables para ver su contenido. ¿Qué decisión preventiva atiende directamente ese vector?

Explicación. Restringir ejecución de macros y verificar origen mediante un canal apropiado conforme a la política. El archivo recibido es una posible vía de ejecución. Tener respaldo facilita recuperación, pero no impide automáticamente ejecutar el código.

2 Firma de malware y heurística

Una herramienta reconoce una secuencia conocida y otra señala rasgos sospechosos sin coincidencia exacta. ¿Qué enfoques representan?

Explicación. Detección por firmas y heurística. La primera reconoce patrones conocidos; la segunda aplica reglas de características. Ambas tienen límites. Una alerta requiere análisis y la falta de coincidencia no demuestra inocuidad de un archivo nuevo.

3 Comportamiento y EDR

Se investigan modificaciones masivas de archivos y el proceso que las provoca. ¿Qué aporta observación de comportamiento en el endpoint?

Explicación. Permite relacionar acciones y procesos para detectar e investigar actividad, con capacidades de respuesta según la herramienta. No depende solo de una etiqueta de archivo. EDR requiere configuración, cobertura y análisis; instalarlo no elimina toda posibilidad de infección.

4 Cuarentena

Se aísla un archivo detectado, pero permanece una credencial robada y otro componente activo. ¿Terminó la respuesta?

Explicación. No. La cuarentena atiende ese archivo, no necesariamente todo el incidente. Deben examinarse alcance, persistencia, accesos y recuperación. Eliminar la alerta visible puede dejar la causa o vías de entrada todavía operativas.

5 Recuperación tras ransomware

Una carpeta sincronizada replica el cifrado malicioso hacia su copia remota. ¿Qué capacidad de respaldo debe verificarse?

Explicación. Una recuperación independiente y protegida frente a esa modificación, con versiones o copias adecuadas y restauración probada. Sincronización no equivale a respaldo seguro. Además, recuperar datos no elimina automáticamente credenciales comprometidas ni una filtración ya ocurrida.

60 Gobernanza clasificación y protección de datos

Seguridad de la información y gestión administrativa en ciberseguridad · Nivel 12 · Indicador 3.1 · Tabla página 13

Indicador de logro. Reconoce estrategias de aseguramiento de protección de datos.

Propósito de aprendizaje. Relacionar responsabilidades, sensibilidad, conservación y recuperación con el aseguramiento de información.

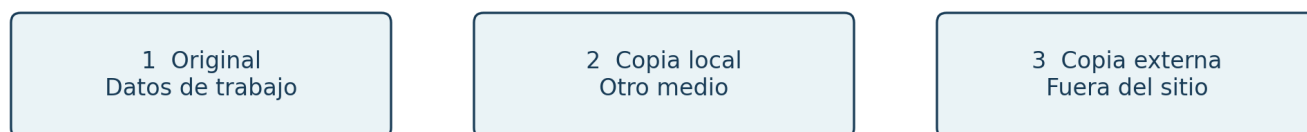
Referencia para ampliar los saberes Programa de duodécimo páginas 78 a 80

Conceptos fundamentales

La gobernanza de datos define quién decide, quién responde y qué reglas se aplican. El propietario determina necesidades y autorizaciones del negocio; el custodio implementa resguardo técnico; responsables de calidad o administración de datos pueden coordinar definiciones y uso. Los nombres de los roles varían, pero sus responsabilidades deben estar claras.

La clasificación de información asigna categorías según sensibilidad e impacto, por ejemplo pública, interna, confidencial y restringida, conforme a la política. Las etiquetas orientan acceso, almacenamiento, transmisión y eliminación. Clasificar no equivale a cifrar: establece qué protección se necesita; cifrar es una medida posible.

El ciclo incluye inventario, finalidad, calidad, acceso, uso, conservación y eliminación. La minimización evita conservar datos innecesarios. DLP, prevención de pérdida de datos, ayuda a detectar o controlar ciertas salidas de información; no reemplaza autorización ni formación.



Tres copias totales · Dos tipos de medio · Una copia fuera del sitio

Esquema aplicado Tres copias totales en una estrategia de respaldo

La regla 3 2 1 plantea tres copias en total, en dos tipos de medio y una fuera del sitio. Debe complementarse con aislamiento o inmutabilidad cuando corresponda y restauración probada. La inmutabilidad impide modificar o borrar una copia durante condiciones definidas; no es sinónimo de conservar para siempre.

RPO expresa cuánta información reciente se admite perder; RTO, cuánto tiempo se busca tardar en recuperar el servicio. Si solo se respalda al final del día, una falla antes del siguiente respaldo puede perder cambios recientes. Si el negocio necesita recuperar durante la misma mañana, también debe probar el tiempo de restauración; son dos preguntas diferentes.

Caso resuelto. Todos los documentos reciben el mismo acceso, aunque algunos contienen datos sensibles. Clasificar y definir responsables permite aplicar controles proporcionados. Crear más copias públicas aumenta exposición, no gobernanza.

La protección comienza por decisiones compartidas

Gobernar datos significa decidir quién responde, qué finalidades se permiten, cómo se clasifican y qué reglas rigen su ciclo. El propietario determina necesidades y autorizaciones del negocio; el custodio aplica resguardo técnico; otros responsables coordinan calidad y uso. Los nombres pueden variar, pero las funciones deben quedar claras. Una herramienta DLP o de cifrado no reemplaza esas decisiones.

El programa de estudio relaciona aseguramiento con seguridad de la información, seguridad jurídica, responsabilidad, transparencia, reputación, rentabilidad y ética. La seguridad jurídica exige conocer obligaciones y actuar conforme a ellas; la transparencia permite explicar tratamiento; la responsabilidad identifica quién decide y rinde cuentas. La reputación y sostenibilidad económica pueden verse afectadas por incidentes, pero no justifican tratar datos de cualquier manera.

Construir un programa de cumplimiento

Se establecen objetivos, inventario, riesgos, reglas y grupos de trabajo. Un equipo de protección puede reunir liderazgo de privacidad, área legal, seguridad, ingeniería, análisis de datos y dirección. El rol DPO o líder de privacidad aparece como referencia organizativa; su exigencia legal y configuración concreta dependen del marco aplicable. No debe presentarse como una obligación universal para cualquier negocio sin revisar la norma.

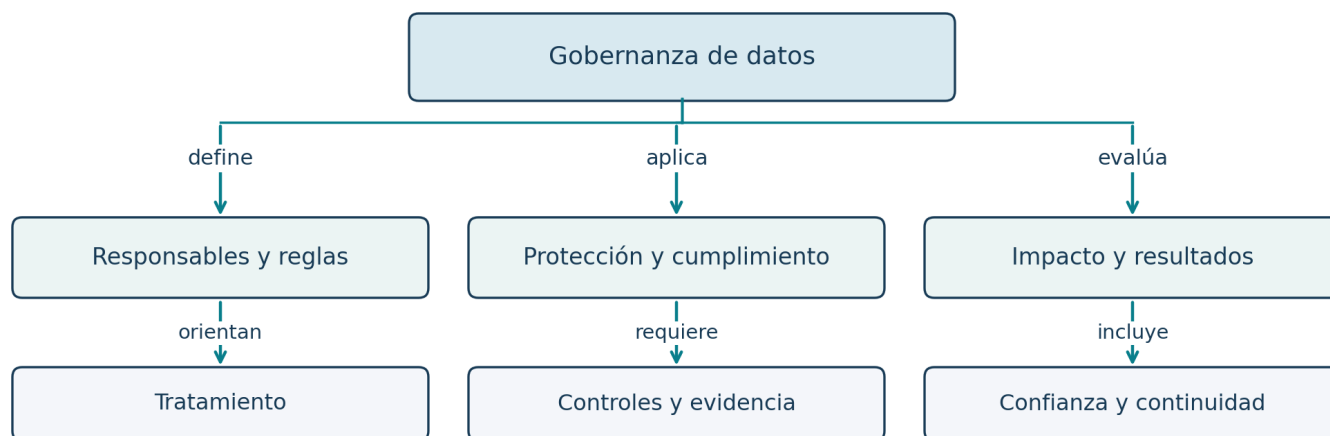
La privacidad desde el diseño incorpora prevención, configuración protectora, integración al sistema, seguridad durante el ciclo, transparencia y respeto por las personas. Una evaluación de impacto analiza datos, finalidad, riesgos y medidas antes de decisiones relevantes. Obtener consentimiento no elimina la necesidad de seguridad ni convierte cualquier recopilación en necesaria.

Relacionar clasificación conservación y recuperación

La clasificación orienta controles según sensibilidad e impacto. La retención define cuánto conservar por necesidad y obligación; la eliminación trata copias y soportes. La regla 3 2 1 organiza copias, pero requiere protección y pruebas. RPO expresa pérdida de información reciente tolerable; RTO, tiempo objetivo de recuperación. Se deben explicar con necesidades del proceso, sin convertirlos en cifras arbitrarias.

Caso integrado. Una empresa limita acceso, pero conserva datos indefinidamente y no informa su uso. Existen controles técnicos, aunque faltan decisiones de finalidad, conservación y transparencia. El programa de gobernanza debe corregir esas condiciones, asignar responsables y verificar resultados. Proteger datos significa gestionar su uso legítimo y su seguridad durante toda su existencia.

Mapa de relaciones para explicar el tema



Mapa conceptual 60 Gobernanza de datos

Preguntas y casos del indicador 60

Aplicación del aprendizaje. Relacionar responsabilidades, sensibilidad, conservación y recuperación con el aseguramiento de información.

1 Gobierno y custodia

El área de negocio define quién debe acceder a datos y el equipo técnico implementa permisos. ¿Por qué no son la misma responsabilidad?

Explicación. La decisión de uso y autorización pertenece al gobierno correspondiente; la custodia implementa resguardo técnico. Los roles deben coordinarse y estar definidos. Una herramienta no puede decidir por sí sola qué finalidad está permitida en toda la organización.

2 Clasificación

Un informe público se combina con información que identifica personas. ¿Debe conservarse automáticamente su clasificación original?

Explicación. No. La combinación puede cambiar sensibilidad e impacto. Debe revisarse la clasificación y los controles de acceso, uso y conservación. Clasificar orienta protección; no equivale a cifrar ni garantiza por sí solo tratamiento legítimo.

3 Estrategia de respaldo

Una organización tiene tres copias en el mismo equipo. ¿Cumple completamente la lógica 3 2 1?

Explicación. No. La regla contempla tres copias totales, dos tipos de medio y una fuera del sitio. Compartir un equipo concentra fallas. Además, deben comprobarse restauración y protección frente a alteraciones; contar archivos no demuestra resiliencia.

4 RPO y RTO

Un negocio define cuántos datos recientes podría perder y cuánto puede tardar en recuperar el servicio. ¿Cómo se distinguen ambos objetivos?

Explicación. RPO se relaciona con el punto de recuperación y la pérdida reciente tolerable; RTO con el tiempo objetivo para restablecer. Son necesidades distintas. Un respaldo frecuente puede reducir pérdida de datos sin asegurar una restauración rápida.

5 Programa de protección

Una institución compra DLP, pero nadie define conservación, responsables ni atención de derechos. ¿Qué falta en su aseguramiento de datos?

Explicación. Gobierno, reglas, responsabilidades y evidencia de cumplimiento durante el ciclo de vida. DLP puede controlar determinadas salidas, pero no sustituye decisiones jurídicas, éticas y organizativas. Un programa requiere coordinar privacidad, seguridad, negocio y funciones pertinentes, no solo adquirir tecnología.

Índice de conceptos

AAA · apartado 06	20
ACID · apartado 23	71
ACL · apartado 06	20
Actuador · apartado 11	35
Adware · apartado 05	17
Anycast · apartado 36	109
Análisis forense · apartado 57	172
ARP · apartado 35	106
Arquitectura de seguridad · apartado 53	159
Atención al cliente · apartado 55	166
Autenticación · apartado 06	20
Automatización robotizada · apartado 11	35
Autorización · apartado 06	20
Backdoor · apartado 58	175
Base de datos · apartado 23	71
Big data · apartado 22	68

Blue Team · apartado 52	156
Botnet · apartado 58	175
BPDU · apartado 43	130
Broadcast · apartado 36	109
Cadena de custodia · apartado 57	172
Canvas · apartado 54	163
Certificado digital · apartado 25	77
Ciclo de vida del software · apartado 14	44
Cifrado en nube · apartado 18	56
Cifrado · apartado 25	77
Clave foránea · apartado 23	71
Clave primaria · apartado 23	71
Cliente ligero · apartado 29	88
Concesión DHCP · apartado 44	133
Confidencialidad · apartado 03	11
Conmutación · apartado 41	124
Contenedor · apartado 13	41
Control de acceso · apartado 06	20
Control de flujo · apartado 37	112
Controlador de dispositivo · apartado 12	38
Credential stuffing · apartado 24	74
Crimeware · apartado 58	175
CSMA CA y CSMA CD · apartado 34	103
CSRF · apartado 20	62
CVE y CVSS · apartado 49	148
Código abierto · apartado 12	38
DAC · apartado 06	20
DAI · apartado 46	139
DAST · apartado 19	59
Data mart · apartado 22	68
Defensa activa · apartado 24	74
Defensa en profundidad · apartado 15	47
Design Thinking · apartado 54	163
DHCPv4 · apartado 44	133
DHCPv6 · apartado 45	136
Dialer · apartado 58	175
Diccionario · apartado 09	29
Disponibilidad · apartado 03	11
DLP · apartado 60	181
DMZ · apartado 53	159
DNS · apartado 48	144
DPO · apartado 60	181
EDR · apartado 59	178
Elasticidad · apartado 16	50
Emulación · apartado 13	41

Encapsulación en objetos · apartado 07	23
Encapsulación · apartado 33	100
Escalabilidad · apartado 30	91
ETL y ELT · apartado 22	68
Excepción · apartado 10	32
FCS · apartado 34	103
Firma digital · apartado 25	77
Firmware · apartado 51	153
Formalización · apartado 56	169
Función · apartado 07	23
Gobernanza de datos · apartado 60	181
Gusano · apartado 05	17
Hackeo ético · apartado 38	115
Hash · apartado 25	77
Hilo · apartado 12	38
Hipervisor · apartado 13	41
Honeypot · apartado 24	74
HTTP y HTTPS · apartado 48	144
IaaS · apartado 17	53
Idempotencia · apartado 11	35
Imagen forense · apartado 57	172
Integridad referencial · apartado 23	71
Integridad · apartado 03	11
Internet de todo · apartado 02	8
IoT · apartado 02	8
IP Source Guard · apartado 46	139
IPv4 e IPv6 · apartado 36	109
ISO IEC 27001 · apartado 08	26
Jitter · apartado 30	91
Kernel · apartado 12	38
Keylogger · apartado 58	175
Latencia · apartado 30	91
Lean Startup · apartado 54	163
Lista · apartado 09	29
MAC de acceso obligatorio · apartado 06	20
MAC de enlace · apartado 35	106
Malware · apartado 05	17
Memoria virtual · apartado 12	38
Metadatos · apartado 57	172
MFA · apartado 06	20
Minería de datos · apartado 22	68
Modelo OSI · apartado 33	100
Modelo TCP IP · apartado 33	100
Mínimo privilegio · apartado 06	20
NAT · apartado 36	109

NIST CSF · apartado 53	159
Nube híbrida · apartado 16	50
Objetos · apartado 07	23
OWASP · apartado 20	62
PaaS · apartado 17	53
Parametrización SQL · apartado 23	71
Password spraying · apartado 24	74
Permisos Linux · apartado 26	80
Persistencia · apartado 58	175
Phishing · apartado 21	65
Port security · apartado 46	139
Privacidad desde el diseño · apartado 19	59
Proceso · apartado 12	38
Purple Team · apartado 52	156
QoS · apartado 30	91
RA de IPv6 · apartado 45	136
Ransomware · apartado 05	17
RBAC y ABAC · apartado 06	20
Red Team · apartado 52	156
Regla de respaldo 3 2 1 · apartado 60	181
Reserva DHCP · apartado 44	133
Riesgo residual · apartado 08	26
Rogueware · apartado 58	175
Rootkit · apartado 58	175
RPO y RTO · apartado 60	181
RSTP · apartado 43	130
SaaS · apartado 17	53
SABSA · apartado 53	159
Sal de contraseña · apartado 24	74
Sandbox · apartado 28	86
Sanitización · apartado 04	14
SAST y SCA · apartado 19	59
Secuestro de sesión · apartado 19	59
Sensor · apartado 02	8
SGSI · apartado 08	26
SIEM · apartado 27	83
SLA · apartado 55	166
SLAAC · apartado 45	136
SNMP · apartado 48	144
SOAR · apartado 52	156
SOC · apartado 52	156
SSH y SFTP · apartado 26	80
SSID y BSSID · apartado 47	142
STP · apartado 43	130
SVI · apartado 42	127

Tabla MAC · apartado 35	106
TCP y UDP · apartado 37	112
TLS · apartado 25	77
TOGAF · apartado 53	159
Transacción · apartado 23	71
Troncal · apartado 41	124
Troyano · apartado 05	17
Tupla · apartado 09	29
VLAN · apartado 42	127
VPN · apartado 50	151
WiFi · apartado 47	142
XSS · apartado 20	62
Zero Trust · apartado 53	159

Casos integradores con explicación

Una matrícula en nube

Una plataforma exige contraseña y código temporal, pero cambiar el número del expediente permite leer a otra persona. El proveedor informa que la infraestructura funciona. ¿Qué control falla?

Explicación. La autenticación no sustituye autorización por objeto. El servidor debe verificar permiso en cada solicitud. Se afecta confidencialidad y la responsabilidad sobre la aplicación no desaparece por contratar nube. Revise los apartados 6, 17, 19 y 20.

Una redundancia que interrumpe la red

Un segundo enlace entre switches provoca tramas repetidas y cambios continuos de ubicación MAC. ¿Qué mecanismo debe investigarse?

Explicación. La evidencia es compatible con un bucle de capa 2. Deben revisarse topología, STP y estado de puertos. DNS no elimina ese bucle. La redundancia física requiere una organización lógica que evite circulación indefinida. Revise 35, 41 y 43.

Una recuperación incompleta

Después de una infección se restauran archivos, pero la cuenta de servicio conserva una credencial comprometida. ¿Se ha completado la recuperación segura?

Explicación. Restaurar información no elimina todas las vías de acceso. Deben tratarse causa, persistencia, sesiones y credenciales pertinentes, y verificar la operación. El respaldo es una capacidad dentro de la respuesta. Revise 24, 52, 59 y 60.

Aplicar lo aprendido a una situación nueva

Un servicio que debe sostener su promesa

Un emprendimiento ofrece monitoreo continuo, pero solo tiene personal de día. La publicidad promete que ningún incidente ocurrirá. Analice modelo de negocio, atención, servicio y responsabilidades.

Explicación. La propuesta debe corresponder a recursos, actividades, socios y costos. El acuerdo define alcance, horarios, prioridades y escalamiento verificables. La atención cordial no reemplaza disponibilidad del servicio. Ninguna oferta puede demostrar ausencia absoluta de incidentes. Relacione los apartados 52, 54, 55 y 56.

Una evidencia que debe conservarse

Una persona propone cambiar las fechas de archivos originales para ordenar una investigación. Otra propone conservarlos, adquirir datos mediante un procedimiento y documentar diferencias temporales. ¿Qué actuación es coherente con preservación?

Explicación. Deben preservarse originales y documentarse interpretaciones. El hash compara integridad de bytes, no prueba autoría ni veracidad del contenido. Una adquisición parcial debe presentarse como tal. Relacione los apartados 25, 28 y 57.

Cómo reconocer comprensión suficiente

Una explicación sólida define el concepto, lo vincula con la evidencia del caso y distingue una alternativa plausible. Una explicación más avanzada identifica condiciones y límites. Si solo se recuerda una palabra, vuelva al ejemplo y reconstruya por qué se aplica. Si puede cambiar el escenario y justificar el nuevo resultado, está transfiriendo el aprendizaje.

Fuentes curriculares y técnicas

Base curricular. Ministerio de Educación Pública de Costa Rica. 2026. Tabla de especificaciones para la Prueba Nacional Escrita Estandarizada Comprensiva de Especialidades Técnicas 2026 Ciberseguridad. DGEC. Archivo 3006-Ciberseguridad-VP-1.pdf. Distribución e indicadores en páginas 3 a 13; orientaciones de uso en página 2.

Programa de duodécimo. Ministerio de Educación Pública. 2020. Programa de estudio Ciberseguridad Duodécimo. Aprobación CSE sesión 60-2020, acuerdo 03-60-2020 del 09 de noviembre de 2020. Saberes consultados en páginas 74 a 104, especialmente 75 y 76, 80, 84 a 86, 89 a 91, 94 a 96, 99, 102 y 103.

Referencia de programas por nivel

<https://detce.mep.go.cr/ciberseguridad>

Los indicadores conservan correspondencia con la tabla. Los propósitos de aprendizaje, ejemplos, explicaciones y mapas son elaboración didáctica. Los referentes técnicos ayudan a interpretar funcionamiento; la tabla y los programas establecen el marco curricular.

F2 Ley 8968 Protección de la persona frente al tratamiento de sus datos personales

<https://www.tse.go.cr/pdf/normativa/leydeprotecciondelapersona.pdf>

F3 ISO IEC 27001 Sistemas de gestión de seguridad de la información

<https://www.iso.org/standard/27001>

F4 NIST SP 800 145 Definición de computación en nube

<https://csrc.nist.gov/pubs/sp/800/145/final>

F5 Sistema Nacional de Legislación Vigente Normativa costarricense

<https://sinalevi.go.cr/>

F6 RFC 9915 Protocolo DHCPv6

<https://www.rfc-editor.org/rfc/rfc9915.html>

F7 NIST Cybersecurity Framework

<https://www.nist.gov/cyberframework>

Referencias para ampliar el estudio

F8 Strategyzer Business Model Canvas

<https://www.strategyzer.com/library/the-business-model-canvas>

F9 Caja Costarricense de Seguro Social

<https://www.ccss.sa.cr/>

Python Clases y objetos

<https://docs.python.org/3/tutorial/classes.html>

Python Control de flujo

<https://docs.python.org/3/tutorial/controlflow.html>

Python Errores y excepciones

<https://docs.python.org/3/tutorial/errors.html>

OWASP Prevención de inyección SQL

https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

NIST SP 800 86 Técnicas forenses y respuesta a incidentes

<https://csrc.nist.gov/pubs/sp/800/86/final>

SABSA Institute Descripción de la metodología

<https://sabsa.org/sabsa-executive-summary/>

The Open Group TOGAF

<https://www.opengroup.org/togaf>

MITRE ATT&CK

<https://attack.mitre.org/>

RFC 4291 Arquitectura de direcciones IPv6

<https://www.rfc-editor.org/rfc/rfc4291.html>

Las configuraciones, trámites y versiones deben contrastarse con documentación vigente al utilizarlos en un entorno real. Los procedimientos de laboratorio requieren autorización y condiciones de trabajo apropiadas. Las referencias del cuerpo se identifican como F2 a F9 y se complementan con estas fuentes por tema.